

Segurança da Informação Gestão e Governança (Conformidade

Unknown

**PARA
CONFORMIDADE
COM A LEI GERAL
DE PROTEÇÃO DE
DADOS PESSOAIS
LGPD**

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA

Inclusive para Empresas Startups

EDISON FONTES, CISM, CISA, CRISC, MS.

SÃO PAULO, SP, BRASIL



**SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes)**

Segurança da Informação:

Gestão e Governança

(Inclusive para Startups)

Para Conformidade com a Lei Geral de Proteção de Dados Pessoais

LGPD – Artigos 46 a 50.

Prof. Ms. Edison Fontes, CISM, CISA, CRISC

São Paulo/SP - Brasil, 2020

F683 Fontes, Edison Luiz Gonçalves.
Segurança da Informação: Gestão e Governança /
Edison Luiz Gonçalves Fontes. – São Paulo, 2020. Autor.
Livro Eletrônico.272f-A4

ISBN: 978-65-00-02212-4

1. Centro de processamento de dados – Medidas de
segurança. 2. Computadores – Medidas de segurança. 3.
Informação – Sistemas de armazenagem e recuperação –
Medidas de segurança 4. Informática – Medidas de
segurança 5. Sistemas de informação gerencial – Medidas
de segurança. 6. Tecnologia da informação. I. Título.

16-00001

CDD - 658:472

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

Copyright © 2020 por Edison Luiz Gonçalves Fontes

Todos os direitos reservados. Nenhuma parte deste livro poderá ser reproduzido sob qualquer meio sem a permissão prévia e formal de Edison Luiz Gonçalves Fontes

edison@pobox.com

Edição do Autor. 2020. 1ª. Edição. São Paulo – SP - Brasil

Técnica e muito cuidado foram utilizados na elaboração deste livro, Porém erros podem acontecer, tipo digitação ou reprodução. Qualquer erro encontrado, qualquer dúvida de interpretação solicitamos que seja enviada uma mensagem para edison@pobox.com para a devida verificação e resposta. O Autor não assume qualquer responsabilidade por eventuais danos ou perdas a pessoas, organizações ou bens, originados do uso deste livro. Os conceitos declarados neste livro são decorrentes da experiência profissional do autor que compartilha com os leitores.

Dados Internacionais de Catalogação na Publicação (CIP)

(Câmara Brasileira do Livro, SP, Brasil)

Índices para catálogo sistemático:

1. Ambiente de informações: Segurança: Administração empresas 658.472
2. Informações: Ambientes: Segurança: Administração empresas 658.472
3. Segurança de informações: Administração de empresas
658.472

Edison Fontes

edison@pobox.com

Núcleo Consultoria em Segurança

Alameda Santos, 1293 – Conj. 84

Tel. 55-11-3266-6468

Cel. 55-11-99132-5526

01419-001 0 São Paulo – SP – Brasil

3

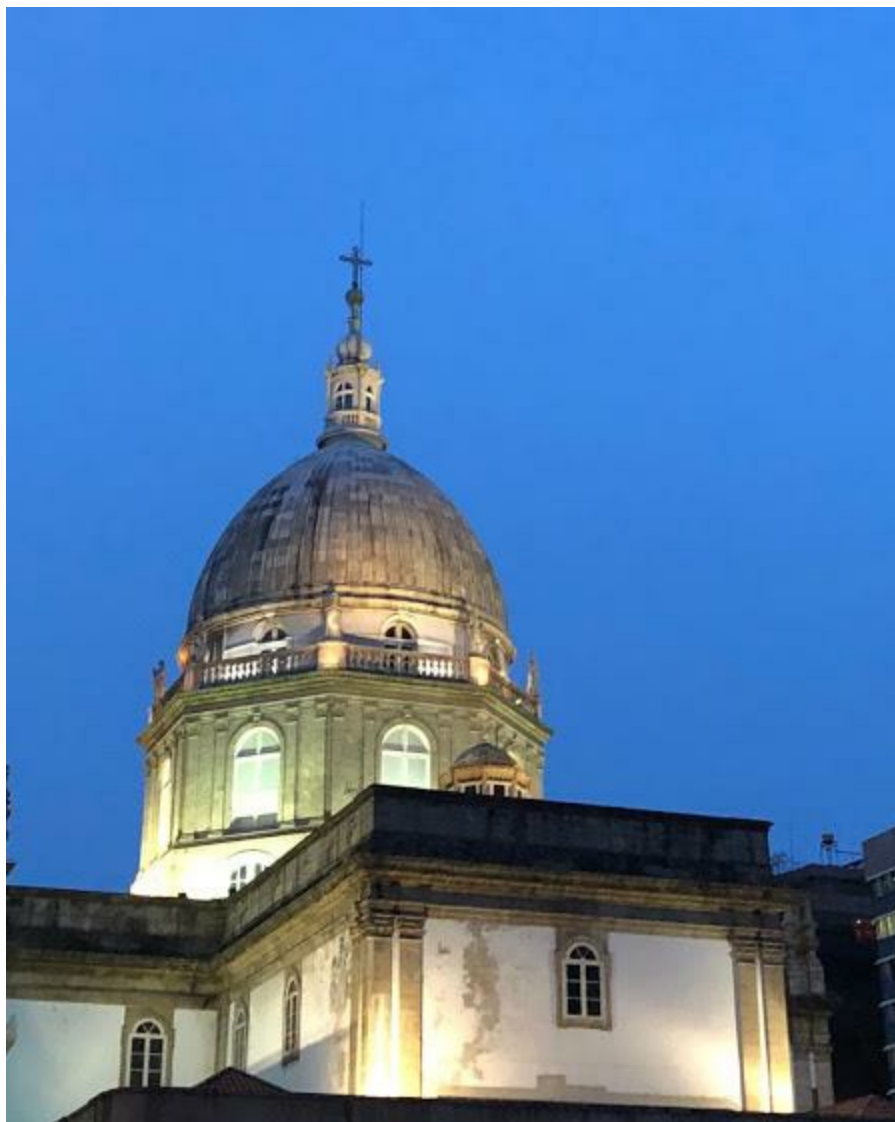
***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***



SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

Aos meus netos Mateus e Sofia.

Foto: Edison Fontes, Arte de Mateus e Sofia



SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA **(Edison Fontes)**

APRESENTAÇÃO

Foto: Edison Fontes, Rio de Janeiro, Brasil

Este livro disponibiliza para o leitor a estrutura do Programa Organizacional de Segurança da Informação, considerando a sua Gestão e os aspectos de Governança. Também para empresas *Startups*. Mesmo que uma empresa *Startup* tenha um porte menor, ela deve considerar todos estes controles.

Evidentemente a implementação dos mesmos em uma Empresa Startup deve ser compatível com o momento da organização. Lembro que existem empresas *Startups* que prestam serviços para grandes organizações e desta maneira passam a fazer parte da cadeia de confiança da informação das mesmas. Enfim, independentemente do tamanho da empresa, a informação sob sua responsabilidade é fator crítico para o sucesso do negócio.

5

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) O objetivo do autor é auxiliar o profissional de segurança da informação e os demais profissionais que se relacionam com o tema, compartilhando um conhecimento estruturado dos controles que devem ser seguidos para o desenvolvimento, implementação, implantação e sustentabilidade das ações de proteção de informação.

Todos os controles e orientações aqui apresentadas estão baseadas em estruturas teóricas descritas na bibliografia, porém, com a formatação e facilitação do autor, baseadas na sua experiência como gestor ou como consultor em segurança da informação.

Este livro também é leitura obrigatória para todos que estão desenvolvendo ou mantendo projetos para a conformidade com a Lei Geral de Proteção de Dados Pessoais, LGPD, Brasil que exige a existência de ações organizacionais de segurança da informação. Conforme os artigos 46, 47, 48, 49 e 50 da LGPD.

Art. 47. Os agentes de tratamento ou qualquer outra pessoa que intervenha em uma das fases do tratamento obriga-se a garantir a segurança da informação prevista nesta Lei em relação aos

dados pessoais, mesmo após o seu término.

Sem um Programa Organizacional de Segurança da Informação efetivo, a organização não tem sustentabilidade para a conformidade com a Lei Geral de Proteção de Dados Pessoais – LGPD. Evidentemente esta lei tem outros controles legais que não diz respeito diretamente com a segurança da informação.

Como sempre faço nos livros que escrevi, compartilho exemplos práticos de elementos que o leitor pode utilizar na sua vida profissional, no seu dia a dia.

Seja na organização implementando estes controles, seja em atividades acadêmicas. Neste livro disponibilizo Documentos e Estruturas de Apoio que utilizo e utilizei na minha prática profissional. São disponibilizados 07 (sete) Documentos e 15 (quinze) Estruturas de Apoio, totalizando 22 (vinte e dois)

6

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes) elementos validados na prática. Em um dos deles, Documento Base para Avaliação dos Controles de Segurança da Informação, são apresentados 214

(duzentos e quatorze) controles para uma avaliação prática. Todos estes documentos e estruturas podem ser utilizados pelo leitor, desde que devidamente citados a fonte e o autor. Nas Estruturas de Apoio já coloquei esta liberação, para facilitar o seu uso.

Alguns controles específicos, como políticas e normas podem e devem ser complementados com a leitura de outros livros de minha autoria. Neste exemplo de regulamentos, o livro “Políticas e Normas para a Segurança da Informação”, Editora Brasport, detalha o assunto e apresenta 30 (trinta) exemplos de políticas e normas de proteção da informação.

Evidentemente este livro não esgota o tema segurança da informação. Aqui apresento uma consequência teórica e prática, de maneira estruturada, como parte do conhecimento que que aprimoro a cada dia, enquanto o bondoso Deus, me permitir. Tudo para que o leitor, principalmente aquele que começa a estudar o tema, trilhe um caminho mais rápido no seu desenvolvimento profissional e desenvolva ações efetivas para a proteção das informações sob responsabilidade das organizações.

Lembro e recomendo uma leitura e estudo básico: todas as normas ISO relacionadas à segurança e proteção da informação e todas as estruturas conceituais relacionadas ao ambiente de informação. Não se pode implementar controles sem conhecer profundamente os conceitos e referências.

Sugestões, críticas, elogios e observações serão muito bem vindas.

Prof. Ms. Edison Fontes, CISM, CISA, CRISC

São Paulo, SP, Brasil, 2020

edison@pobox.com

AGRADECIMENTOS

Ao nosso bom Deus pelo dom da vida, sem o qual nada disso seria possível, sem o qual não existiria o eterno sopro divino em cada um de nós.

A minha esposa, amiga e companheira de sempre, Fatima Fontes. Você é uma inspiração para minha vida. Eu te amo.

Aos meus filhos, Edison Filho e Vinícius, que sempre me inspiraram a continuar a trabalhar e a compartilhar conhecimento.

A você leitor pela confiança em estudar este livro. Prometo que, o que você lerá, é verdadeiro e praticável. É o caminho que recomendo. Com todo respeito a outras abordagens.

Aos meus cuidadores mais recentes, que com profissionalismo e amizade me ajudaram na saúde e no espírito: Dr. Savério Agrisani Neto, Dr. Jou Eel Jia, Mestre de Tai Chi Jerusha Chang e a Nutricionista Virgínia Sgorion.

Evidentemente extensivo às suas equipes.

Aos mestres de conhecimento, alguns como professores formais, outros como companheiros de jornada, mas que sempre tiveram a humildade de compartilhar e permitir o crescimento das outras pessoas.

1989.

Possui Mestrado em Tecnologia pelo Centro Paula Souza do Governo do Estado de São Paulo, Especialização pelo Mestrado Ciência da Computação UFPE, Pós Graduação em Gestão Empresarial pela FIA-USP e Bacharelado em Informática UFPE (Aluno laureado, Prêmio Universitário BANORTE).

Em termos profissionais possui as certificações internacionais: CISA -

Certified Information Systems Auditor, CISM - *Certified Information Security Manager* e CRISC – *Certified in Risk and Information System Control* pela ISACA - *Information System Audit and Control Association / USA*.

É professor de MBAs em disciplinas relacionada à Gestão da Segurança da Informação, Políticas e Normas, Planos de Continuidade de Negócio, Gestão de Riscos de Segurança da Informação, Combate à Fraude de Informação e outros temas relacionados à proteção da informação.

Atuou como Coordenador de Segurança da Informação no Banco

BANORTE e posteriormente fez trabalhos de consultoria em diversas organizações. Foi Gerente na área de GRMS - *Global Risk Management Solutions* da PricewaterhouseCoopers e posteriormente exerceu a função de *Security Officer and Software Quality Assurance Manager* da GTECH Brasil.

Foi Gerente Sênior da Prática da Segurança da Informação da CPM Braxis.

Seu trabalho de políticas de segurança da informação desenvolvido para o NOSI – Núcleo Operacional para a Sociedade da Informação do Governo da República de Cabo Verde, foi base para o Decreto Lei 19/2010, aprovado pelo

(Edison Fontes) Conselho de Ministros, promulgado pelo Presidente da República e referendado pelo Primeiro Ministro. O referido decreto estabelece as políticas, normas e regras de segurança da informação para Rede Tecnológica Privativa do Estado (RTPE).

Desenvolveu suas atividades profissionais em segurança da informação e temas relacionados como Gestor ou como Consultor, onde atendeu uma grande variedade de empresas no Brasil, de diferentes tipos de negócio e de diferentes portes como organização.

É autor dos livros:

- Vivendo a segurança da informação, Editora Sicurezza;
- Segurança da informação: o usuário faz a diferença! Editora

Saraiva;

- Praticando a segurança da informação, Editora Brasport;
- Clicando com segurança, Editora Brasport,
- Políticas e Normas para a Segurança da Informação, Editora

Brasport

- Segurança da Informação: orientações práticas, Edição autor,

Amazon;

- Política de Segurança da Informação, Rede Nacional de Pesquisa (RNP)

É coautor dos livros:

- Banco Eletrônico, PricewaterhouseCoopers, FEBRABAN
- Porque GESITI – Segurança, Inovação e Tecnologia”,

CENPRA/MCT, Editora Komedi,

- Innovations and Advanced Techniques in Computer and

Information Sciences and Engineering, Editora Springer

Netherlands.

Foi premiado pela apresentação de trabalhos nas Conferências 12 e 13 da GUIDE LATIN AMERICA e em Congresso Nacional da SUCESU. Foi eleito

através de voto da comunidade de profissionais e usuários, Profissional do Ano em Segurança da Informação, recebendo o Prêmio SECMASTER, promovido



SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

pela ISSA-Information Systems Security Association - Capítulo São Paulo e VIAFORUM.

Atualmente é Sócio da Núcleo Consultoria em Segurança.

É natural de Recife, Pernambuco. Está há mais de 20 anos em São Paulo.

Sempre que possível, fica descalço na Ilha de Itamaracá, litoral norte de Pernambuco, terra da ciranda.

Foto: Álbum Família, Edison Fontes

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) PREFÁCIO

Conheci o Edison Fontes quando a Internet era novidade no nosso país. A maior sensação da época era receber e-mails! Até competíamos para saber qual caixa de entrada tinha mais mensagens que a outra. Falar de Segurança das Informações, naquela época, era algo como ciência astrofísica e mesmo assim havia um visionário, o Edison, que sabia como as ferramentas, processos e estratégias para garantir a segurança dos dados processados era e é importante.

Não sei se ele vislumbrava, naquela época, toda a importância que as informações teriam em nossa sociedade atual, mas acho que sim. Hoje, informação é, literalmente, poder. O Google, Facebook, Microsoft, Amazon estão aí para confirmar isso. Todas essas empresas e muitas outras comercializam ou armazenam informações e fazem todo tipo de tratamento. Toda a nossa vida resume-se a uma porção de dados que são comercializados entre as empresas para nos vender mais e melhor.

É por isso que, de repente, ao navegar na internet você começa a ver anúncios de coisas que expressou desejar vez ou outra. Os algoritmos de navegação parecem nos conhecer melhor que nós mesmos. Gustavo Reis, Head de Marketing & Digital na Tecnisa, em uma palestra sobre Inovação, afirmou recentemente que os algoritmos do Facebook sabem antes dos próprios casais se eles vão se divorciar ou não com base no padrão de navegação de cada um. Sim, as “máquinas” conseguem tratar uma enorme quantidade de informação que permite fazer prognósticos melhores que nós. E esse é um processo sem volta.

Cada vez mais seremos escrutinados por sistemas que armazenarão, analisarão e preverão nossos comportamentos, atitudes e escolhas, porque somos seres de hábitos e esses padrões nos definem, sendo possível saber o

que faremos num futuro próximo.

Mas nem tudo é negativo. Com esses sistemas cada vez mais eficientes, a vida fica mais confortável. Não perdemos tempo com notícias que em nada nos interessariam, somos mais assertivos na hora de consumir produtos e serviços, contamos com serviços de armazenamento de fotos, vídeos, músicas e experiências que fazem parte e documentam nossa vida, preservando momentos que fazem nossa história.

12

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA

(Edison Fontes) Tudo isso é muito bonito, quando tudo o que é coletado de informação a nosso respeito acontece com o nosso consentimento e em conformidade com a legislação. Quando não é, sentimo-nos invadidos. A Lei Geral de Proteção de Dados Pessoais vem garantir que os dados informados por nós, ao preencher uma ficha de solicitação de emprego ou crédito, por exemplo, não sejam usados para outros fins, comerciais ou políticos. É nosso direito decidir se vamos alimentar o banco de dados de uma determinada instituição ou não, pois são informações privadas e merecem ser tratadas como tal.

Ter segurança dessa informação é um passo fundamental para a defesa dos direitos civis e as empresas deverão comprovar seu compromisso com a incolumidade desse direito, sob pena de multa e sanções. Para entender como essa adequação acontecerá, nada melhor do que a obra que o leitor tem nas mãos.

A segurança da informação é a base para a conformidade com a Lei Geral de Proteção de Dados Pessoais - LGPD e necessária para a garantia do alcance dos objetivos corporativos.

Edison Fontes conseguiu esmiuçar o assunto com maestria, transformando seu conhecimento em um roteiro prático de segurança da informação para

empresas e instituições seguirem se quiserem cumprir a LGPD. O texto explica desde o reconhecimento da informação, seu tratamento, coleta, armazenamento, infraestrutura crítica, processos, equipamentos, gestão de mudança, conscientização dos usuários, plano de continuidade de negócios, até abordar a Governança da Segurança da Informação com seus princípios, diretrizes, processos e objetivos. Um verdadeiro manual!

Não há como pensar em gerenciar a adequação de uma instituição à segurança da informação como base para a LGPD sem ler esse livro e seguir os ensinamentos do mestre Edison Fontes que já era certificado pelas maiores instituições mundiais de Segurança antes de muitos saberem que sequer existiam certificações a serem obtidas. Em nosso meio, Fontes é reconhecido como precursor do cuidado e proteção às informações, explicando essa intrincada rede de processos, estratégias e sistemas para leigos como eu e a imensa maioria dos empresários do país.

A LGPD é um avanço legal, técnico, mas também moral de respeito à privacidade de cada um de nós. Nossas informações precisam da seriedade que Fontes propõe nessa obra, fruto de uma carreira e estudos intensamente dedicados ao assunto

13

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

**SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes)** Querido amigo, companheiro da ABSEG, obrigado por mais esse presente.

Lê-lo e implementar seu conteúdo é nossa obrigação!

Marco Antônio Lopes

**Diretor da SEFRA Segurança e Vigilância Privada e Presidente da
ABSEG**

*Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com*



**SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes)**

ÍNDICE DO CONTEÚDO

Sumário

Foto: Edison Fontes, Varsóvia, Polônia

1. INTRODUÇÃO 19

1.1 – A Informação 19

1.2 – Segurança da Informação - Definição 23

1.3. Elementos do Programa Organizacional de Segurança da Informação 26

1.4 – Ambiente da Informação 27

1.5 – Objetivo da Segurança da Informação 31

1.6 – Direcionadores da Segurança da Informação Família NBR ISO/IEC 27000, COBIT, ITIL

..... 33

2. IMPLANTANDO A SEGURANÇA DA INFORMAÇÃO 36

2.1 – Considere o ambiente existente e considere as limitações 37

2.2 - Fatores críticos de sucesso 40

<u>2.3 – Programa Organizacional Segurança da Informação</u>	
<u>..... 44</u>	

3. PROGRAMA ORGANIZACIONAL DE SEGURANÇA DA INFORMAÇÃO 47

<u>3.1 – Dimensão Política da Segurança da Informação</u>	
<u>..... 48</u>	

<u>3.2 – Dimensão Gestão de Riscos de Segurança da Informação</u>	
<u>..... 49</u>	

<u>3.3 – Dimensão Acesso Lógico à Informação</u>	
<u>..... 49</u>	

15

*Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com*

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

<u>3.4 – Dimensão Classificação da Informação</u>	
<u>..... 50</u>	

<u>3.5 – Dimensão Proteção Técnica de Recursos de Tecnologia</u>	
<u>..... 51</u>	

<u>3.6 – Dimensão Flexibilidade Operacional</u>	
<u>..... 51</u>	

<u>3.7 – Dimensão Ambiente Físico</u>	
<u>..... 52</u>	

<u>3.8 – Dimensão Infraestrutura</u>	
<u>..... 52</u>	

<u>3.9 – Dimensão Desenvolvimento Aplicativo ou Aquisição de Produto</u>	
<u>..... 52</u>	

<u>3.10 – Dimensão Modelo Operativo da Segurança da Informação</u>	
<u>..... 53</u>	

<u>3.11 – Dimensão Conscientização e Treinamento do Usuário</u>	
<u>..... 53</u>	

<u>3.12 – Dimensão Continuidade de Negócio</u>	
<u>..... 53</u>	

<u>4. DIMENSÃO POLÍTICA DA SEGURANÇA DA INFORMAÇÃO</u>	
<u>..... 54</u>	

<u>4.1. Objetivo da Dimensão Política de Segurança da Informação</u>	
<u>..... 56</u>	

<u>4.2. Arquitetura da Política de Segurança da Informação</u>	
<u>..... 59</u>	

<u>4.3. Desenvolvendo os Regulamentos</u>	
<u>..... 64</u>	

<u>5. DIMENSÃO GESTÃO DE RISCOS DE SEGURANÇA DA INFORMAÇÃO</u>	
<u>..... 92</u>	

<u>5.1. Objetivo da Dimensão Gestão de Riscos de Segurança da Informação</u>	
<u>..... 94</u>	

<u>5.2. Elementos de para o Gerenciamento de Riscos</u>	
<u>..... 97</u>	

<u>5.3. Como realizar a Gestão de Riscos de Segurança da Informação</u>	
<u>..... 106</u>	

<u>6. DIMENSÃO ACESSO A INFORMAÇÃO</u>	
<u>..... 114</u>	

<u>6.1 – Objetivo da Dimensão Controle de Acesso à Informação</u>	<u>115</u>
<u>6.2 – Identificação – Gestão de Identidade</u>	<u>118</u>
<u>6.3 – Autenticação</u>	<u>120</u>
<u>6.4. Autorização – Gestor da Informação</u>	<u>124</u>
<u>7. DIMENSÃO CLASSIFICAÇÃO INFORMAÇÃO</u>	<u>126</u>
<u>7.1 – Níveis de Classificação</u>	<u>129</u>
<u>7.2 – Implementando a Classificação da Informação</u>	<u>129</u>
<u>7.3. Conclusão</u>	<u>132</u>
<u>8. DIMENSÃO RECURSOS DE TECNOLOGIA DA INFORMAÇÃO</u>	<u>133</u>
<u>8.1 – Objetivo da Dimensão Recursos de Tecnologia da Informação</u>	<u>134</u>
<u>8.2 – Proteção Técnica</u>	<u>135</u>

Edison Fontes, edison@pobox.com

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

8.3 – Equipamentos

.....
142

9. DIMENSÃO FLEXIBILIDADE OPERACIONAL

..... 143

9.1. Gestão de Mudanças

..... 145

9.2. Gestão de Capacidade (Gestão de Recursos)

..... 148

10. DIMENSÃO AMBIENTE FÍSICO

..... 150

10.1 – OBJETIVO DIMENSÃO AMBIENTE FÍSICO

..... 151

10.2 – Requisitos de segurança para o ambiente físico

..... 152

11. DIMENSÃO INFRAESTRUTURA

..... 158

11.1 – Objetivo da Dimensão Infraestrutura

..... 159

11.2 – Requisitos de segurança para a infraestrutura

..... 160

12. DIMENSÃO DESENVOLVIMENTO E MANUTENÇÃO DE SISTEMAS

APLICATIVOS

..... 164

12.1 – Objetivo da Dimensão Desenvolvimento e manutenção de sistemas aplicativos 165

12.2 – Requisitos de segurança para o desenvolvimento e manutenção de sistemas aplicativos

.....
166

13. DIMENSÃO MODELO OPERATIVO DA SEGURANÇA DA INFORMAÇÃO ... 171

13.1 – Objetivo da Dimensão Modelo Operativo da Segurança da Informação 172

13.2 – Requisitos de segurança para o modelo operativo da segurança da informação. 174

14. DIMENSÃO CONSCIENTIZAÇÃO E TREINAMENTO
..... 178

14.1 – Objetivo da Dimensão Conscientização e Treinamento de Usuários 178

14.2 – Requisitos de segurança para a Dimensão Conscientização e Treinamento de Usuários

.....
181

15. DIMENSÃO CONTINUIDADE DE NEGÓCIO
..... 184

15.1 – Objetivo da Dimensão Continuidade de Negocio
..... 185

15.2 – Etapas de um Plano de Continuidade de Negócio

..... 187

16. GOVERNANÇA DE SEGURANÇA DA INFORMAÇÃO..... 199

16.1. INTRODUÇÃO

.....
199

16.2. GOVERNANÇA CORPORATIVA

..... 201

16.3. GOVERNANÇA DA SEGURANÇA DA INFORMAÇÃO

..... 203

16.4. PRATICANDO OS PRINCÍPIOS DA GOVERNANÇA DA SEGURANÇA DA

INFORMAÇÃO

.....
213

17

*Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com*

**SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes)**

16.5. CONCLUSÃO

.....
216

BIBLIOGRAFIA

..... 219

ANEXO 1 - Os controles da segurança da informação – Norma ISO/IEC 27002..... 228

**ANEXO 2 - Exemplos de Documentos e Estruturas de Apoio
..... 257**

**Documento Programa Organizacional Segurança da Informação
..... 258**

**Documento Base para Avaliação Controles de Segurança da Informação
(214 Controles) 279**

**Documento Base para Planejamento Inicial Segurança da Informação
..... 303**

**Documento Gerenciamento de Risco de Segurança da Informação
..... 317**

**Documento Termo de Uso de Informação
..... 325**

**Documento Carta de Risco em Segurança da informação
..... 327**

**Documento Planejamento para Teste de Continuidade de Negócio
..... 330**

**Estrutura Segurança da Informação Abrangência e Responsabilidades
..... 337**

**Estrutura Risco Corporativo
..... 338**

**Estrutura Governança – Princípios
..... 339**

**Estrutura Governança, Gestão, Controles de Proteção e Segurança
..... 340**

Estrutura Governança Corporativa – Princípios

..... 341

Estrutura Governança da Tecnologia da Informação – Princípios

..... 342

Estrutura Governança da Segurança da Informação – Princípios

..... 343

Estrutura Governança da Segurança da Informação – Prática

..... 344

Estrutura Arquitetura de Segurança da Informação e Proteção de Dados

..... 346

Estrutura Ambiente de Informação

..... 347

**Estrutura Segurança da Informação – Dados sob responsabilidade da
organização 348**

Estrutura Acesso à Informação – Estrutura Básica

..... 349

Estrutura Controles Corporativos

..... 351

Estrutura Classificação da Informação – Abordagens

..... 352

Estrutura Proteção e Tratamento do Recurso Informação

..... 353

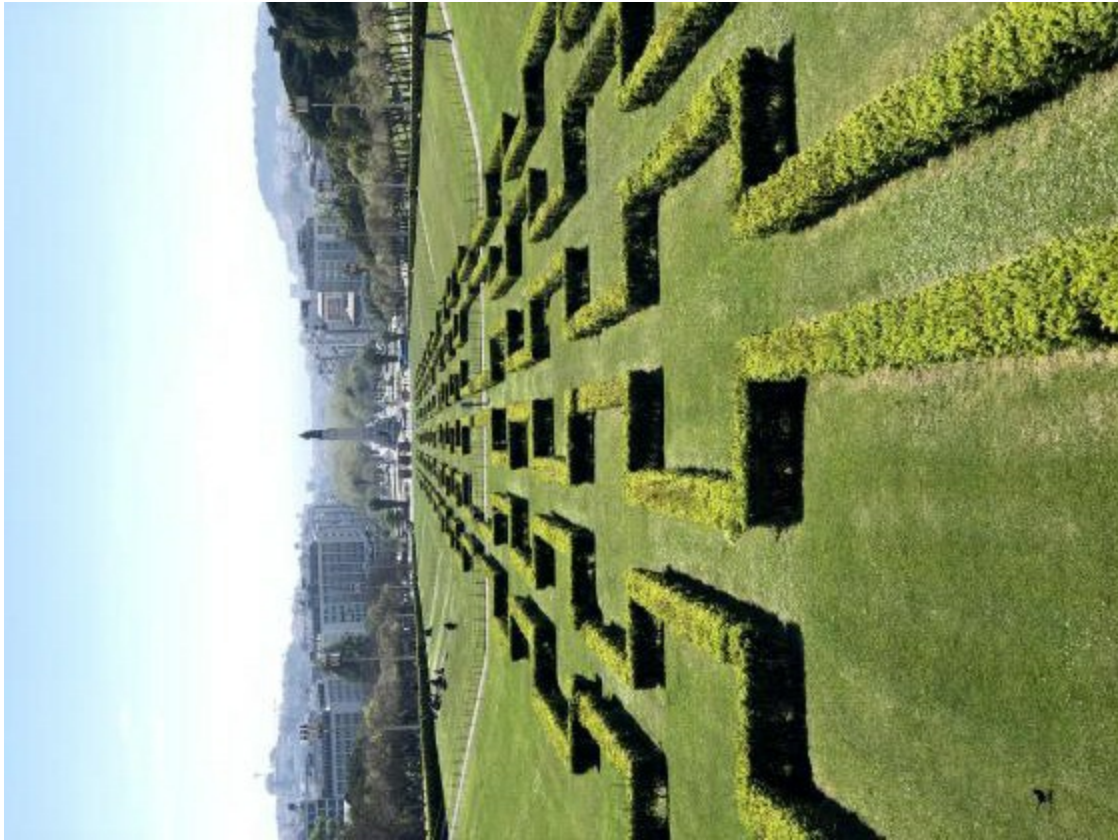
Estrutura Segurança da Informação e Controles LGPD

..... 354

LIVROS PUBLICADOS PELO AUTOR

..... 355

*Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com*



SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

1. INTRODUÇÃO

Foto: Edison Fontes, Lisboa, Portugal

1.1 – A Informação

A vida é o sopro do Eterno, do Divino. A informação é a vida transformada

em símbolos, códigos e representações que permitem a comunicação entre os seres vivos. Sejam seres simples ou seres complexos que possuem inteligência, da forma como entendemos este termo. Seres que podem se comunicar de uma maneira mais estruturada e ao mesmo tempo mais livre.

Mas, para a sobrevivência de qualquer forma de vida a informação precisa existir. E os seres precisam reconhecer e entender a informação.

O desenvolvimento da humanidade dependeu e depende até os dias de hoje da informação e dos recursos de informação. É um fato e independe da nossa vontade. A informação possibilita o conhecimento e a consequente possibilidade de aprimoramento da maneira de como vivemos no planeta Terra. Infelizmente a

19

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes) existência da informação não garante uma maneira feliz e inteligente de viver. O

ser humano tem o livre arbítrio de tratar e usar a informação da maneira como generosamente ou egoisticamente ele deseja. O conjunto de informações e comandos que faz um avião levar rapidamente órgãos humanos para salvar vidas em um transplante, é o mesmo que permite que este avião seja usado para destruir vidas e sonhos. A mesma Internet que utiliza informação para aproximar quem está distante, é a mesma Internet que com informação afasta aqueles que estão próximos.

Muitas vezes ainda não estamos atentos qual valiosa é a informação para cada um de nós.

A informação é um bem universal.

A UNESCO considera o acesso à informação um direito da sociedade e desenvolve ações para que este direito seja disponibilizado para todos os

cidadãos do mundo. O artigo 19 da Declaração dos Direitos Humanos define que

“Todo o ser humano tem direito à liberdade de opinião e de expressão; este direito inclui a liberdade de, sem interferência, ter opiniões e de procurar, receber e transmitir informações e ideias por quaisquer meios e independente de fronteiras.”(UNESCO, 1998).

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes) A mudança do século XX para o século XXI foi fortemente caracterizada pelo uso, armazenamento e disponibilização da informação. Nunca se teve acesso à tanta informação utilizando as mais diversas tecnologias e as mais poderosas formas de comunicação.

No ambiente corporativo a informação é um recurso essencial para qualquer tipo de organização independente do tipo do seu mercado de atuação ou do seu porte econômico. Nenhuma organização funciona sem a informação. Ela é um recurso utilizado por todos os níveis organizacionais: estratégico, tático e operacional.

A informação permite e possibilita que a organização alcance os seus objetivos corporativos. Isto é, com a informação, a organização pode realizar a sua missão, melhorar a sua competitividade em relação aos seus concorrentes, agregar valor aos resultados planejados e garantir a sua sustentabilidade (continuidade adequada ao longo do tempo).

Dependendo das suas características de realização do negócio, as organizações necessitam utilizar a informação de duas maneiras:

- a) Quando o seu produto principal é a própria informação.
- b) Quando o seu produto principal é um bem material, porém em paralelo, a

organização utiliza a informação para construir esse bem material.

O primeiro caso se aplica, por exemplo, às empresas de notícias, de comércio eletrônico, de banco eletrônico, de transmissão de conhecimento e similares. O segundo caso, temos como exemplo uma empresa montadora de automóvel. O produto principal é o automóvel. Mas, para construir um

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes) automóvel esta empresa precisa utilizar a informação de como se faz sua construção, seja nos manuais para os empregados, seja no código dos programas que são utilizados pelos robôs.

Na prática, a maioria das as organizações se encontram nos dois casos.

Elas entregam informação e também disponibilizam um bem material. Em qualquer situação, a informação é fundamental para cada organização. No ambiente corporativo nada funciona sem um conjunto de informações.

**Sem informação, a organização não realizará suas
atividades de negócio nem atenderá aos objetivos**

corporativos.

Esta informação permite o conhecimento estruturado e a inteligência competitiva nas organizações. Domeneghetti e Meir (2009) pesquisaram profundamente o assunto e como conclusão de seus estudos declaram:

A globalização da economia, impulsionada pela Tecnologia da Informação e pela malha intermitente, multiformato e multicanal das comunicações, é uma realidade da qual não se pode escapar. A informação tornou-se a fonte de aproximadamente três quartos do valor agregado nas indústrias. É neste contexto que o conhecimento, ou melhor, que a gestão do conhecimento e a inteligência competitiva se transformam em valiosos recursos estratégicos para a vida das pessoas e das empresas (DOMENEGHETTI; MEIR, 2009, p.176).

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) Sendo a informação um recurso essencial para a realização dos negócios da organização ela precisa ser protegida adequadamente de maneira a garantir a sua confidencialidade, integridade e disponibilidade. É necessário que cada organização implemente um processo de segurança para a sua informação. Caso não implemente esta proteção a organização pode sofrer indisponibilidades, roubos e uso indevido da informação que inviabilizarão a sua permanência no mercado em que atua e consequentemente não atingirá os objetivos corporativos.

1.2 – Segurança da Informação - Definição

Existem várias definições para a segurança da informação. Baseado na nossa experiência de gestor e em alinhamento com os referenciais teóricos sobre o assunto, defino para o leitor o que é segurança da informação:

Segurança da Informação é um programa organizacional que tem por objetivo permitir e possibilitar que a Organização alcance seus objetivos no que depende da informação e dos recursos de informação.

Edison Fontes.

Vamos refletir nos pontos importantes desta definição:

23

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

a) Segurança da Informação é um programa organizacional

A segurança da informação é um conjunto de ações, um programa de ações, que tem por objetivo atender requisitos da organização. Ela não existe por si só. O Programa Organizacional de Segurança da Informação não existe para atender a Área de Segurança da Informação nem a Área de Tecnologia da Informação. Tão pouco este processo existe por causa de pontos indicados pela Auditoria.

O Programa Organizacional de Segurança da Informação é de

responsabilidade do Corpo Diretivo da Organização. Isto é, os executivos que representam os acionistas e conduzem a organização, devem estabelecer e garantir a existência contínua da segurança da informação.

b) O Programa Organizacional de Segurança da Informação tem por

objetivo permitir e possibilitar que a organização alcance os seus objetivos: O Programa Organizacional de Segurança da Informação existe para que a organização alcance os seus objetivos estratégicos, táticos e operacionais e conseqüentemente, para que a organização continue existindo. O mais importante de tudo é: a organização e o negócio que esta organização realiza.

Peltier afirma ainda que a segurança da informação está ligada fortemente aos objetivos de negócio e não deve existir para ela mesma e sim para atender à organização e aos seus objetivos de negócio: “Para garantir que os objetivos de negócio são alcançados no tempo previsto e de uma maneira eficiente, padrões e políticas eficazes devem existir na organização” (PELTIER, 2004, p. 14).

Segurança pela própria segurança, não possui valor. A criação de políticas, padrões, e procedimentos deve ser benéfica para a organização. Nenhuma política deve ser criada para garantir que a

Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes) *organização está em conformidade com os requerimentos de auditoria.*

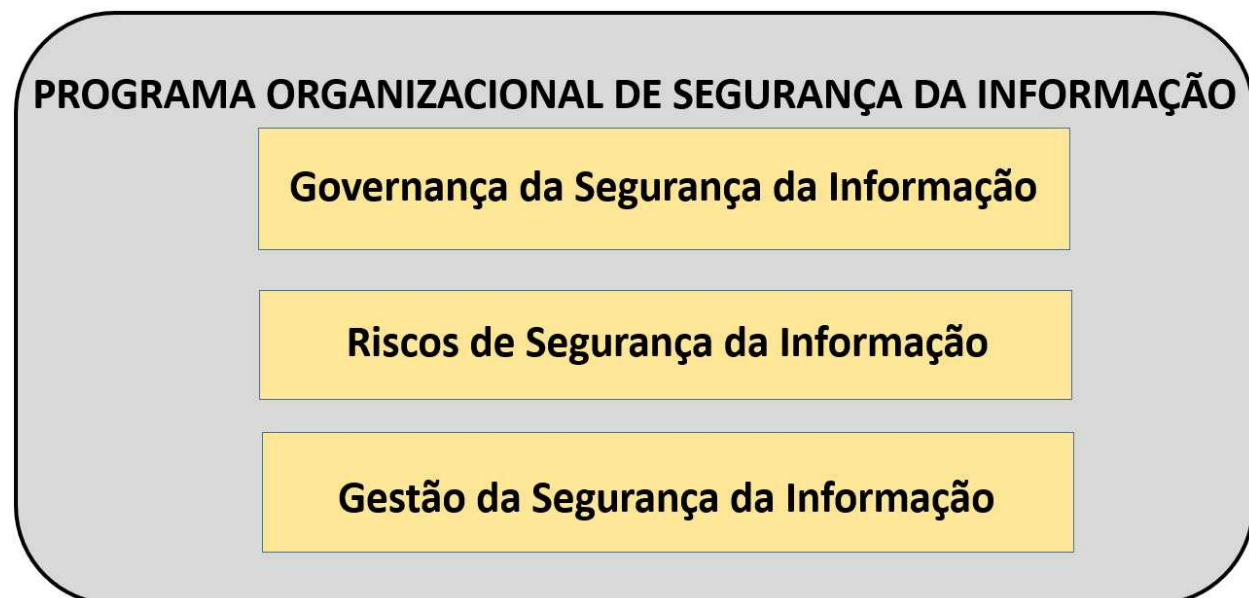
Políticas, padrões e procedimentos são criados para garantir que a organização atende aos requisitos legais e obrigações contratuais para seus clientes, acionistas e funcionários (PELTIER, 2004, p. 14).

Boas regras de segurança da informação não são definidas para satisfazer a própria segurança, elas são implantadas para proteger recursos de informação utilizados no funcionamento da organização e conseqüentemente protegem os objetivos da organização (PELTIER, 2005, p. XV).

c) No que depende da informação e dos recursos de informação:

O escopo do Programa Organizacional de Segurança da Informação está limitado à informação e aos recursos de informação. Se a organização não vai bem porque o produto da organização não é bom, este fato não é problema da segurança da informação. Agora se o produto não tem sido bom, porque o acesso à informação impede a melhoria do produto, aí sim, este fato tem e deve ser relacionado com a segurança da informação. Desta maneira, podemos afirmar que a abrangência de atuação da segurança da informação é bastante ampla.

Todas as organizações podem desenvolver e implementar um processo de segurança da informação. Porém, este é um tema que no Brasil, com exceção das instituições financeiras e empresas com ações em Bolsas de Valores no exterior, não tem tido a importância devida. Infelizmente, na maioria das organizações: muito se fala, mas pouco se pratica.

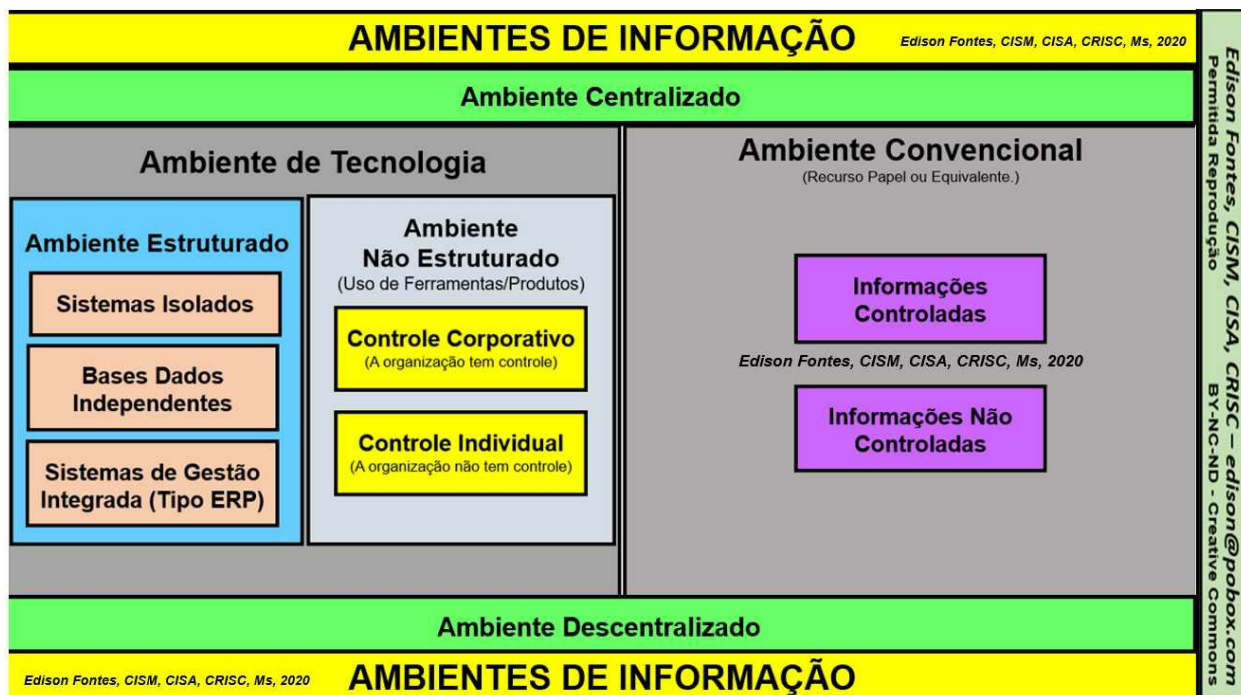


1.3. Elementos do Programa Organizacional de Segurança da Informação

A figura abaixo representa os elementos estratégicos que o Programa Organizacional de Segurança da Informação deve considerar.

Figura 1.1 – Elementos do Programa Organizacional de Segurança da Informação. Fonte: Autor.

O Programa Organizacional de Segurança da Informação deve atender estes elementos estratégicos. A Governança da Segurança da Informação garante o alinhamento das ações e o direcionamento da segurança da informação com a Governança Corporativa que zela pelo funcionamento e sustentabilidade da organização. O elemento Riscos de Segurança da Informação garante que o Programa Organizacional de Segurança da Informação se mantém vivo e atento às ameaças que podem inviabilizar o uso da informação ou podem acarretar grandes impactos negativos na organização. O terceiro elemento, Gestão da Segurança da Informação garante que o funcionamento da segurança da informação será realizado de uma maneira eficiente e eficaz.



SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

1.4 – Ambiente da Informação

Para protegermos adequadamente a informação, precisamos entender o ambiente onde ela está inserida. Precisamos conhecer qual é o ambiente da informação e identificar quais são os elementos que interagem com a informação.

A figura abaixo apresenta o ambiente da informação identificando os itens que influenciam a informação. São os elementos do Ambiente da Informação que devemos considerar quando do desenvolvimento e implantação da Segurança da Informação.

Figura 1.2 – Ambientes da informação, Fonte: Autor.

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) a) Ambiente de Tecnologia ou Ambiente Digital

Atualmente, este é o ambiente que mais possui informação. A maioria das informações do mundo está em formato digital e armazenada no ambiente de tecnologia. Este ambiente tem características que influenciam a maneira de se fazer segurança da informação, destacamos:

- **Atualização e modernização:** este ambiente é continuamente atualizado e em cada momento surgem novos tratamentos

tecnológicos para a informação. A organização precisa garantir o acompanhamento destas novas tecnologias e a proteção adequada.

- **Popularização:** o conhecimento da tecnologia ficou mais amigável e tornou-se facilmente acessível e em alguns casos tornou-se produto

pronto para consumo, isto é, produto de prateleira. Qualquer pessoa

compra e utiliza pacotes e serviços de tecnologia. Isto facilita tanto nas ações para melhorar o desempenho dos processos

organizacionais como facilita as ações de má-fé, ações criminosas, executadas por pessoas que não precisam mais ser especialistas em

tecnologia.

- **Diminuição do custo:** cada dia que passa o custo da tecnologia diminui permitindo que pessoas ou organizações que não possuíam

condições anteriores de utilizar a tecnologia, agora podem. Isto vale tanto para as pessoas bem intencionadas, como para os criminosos.

- **Mais serviços neste ambiente:** a variedade de serviços que atendem ao usuário é crescente e muito grande. Desta maneira o usuário é conquistado para utilizar o Ambiente de Tecnologia.

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes) O Ambiente de Tecnologia tem as seguintes possibilidades de existência da informação:

Ambiente Estruturado: ambiente onde as informações são tratadas de maneira concatenadas e em um relacionamento organizado. As

informações podem estar em sistemas isolados, bases de dados

independentes ou sistemas de gestão integrada.

Ambiente Não Estruturado: ambiente onde as informações estão

independentes, estão isoladas. Elas podem estar sob um controle organizacional como pastas de arquivos ou sob o controle individual, sem controle organizacional. Neste último caso são, por exemplo as

planilhas eletrônicas que os usuários possuem nos mais diversos locais e equipamentos.

b) Ambiente Convencional

O Ambiente Convencional se refere ao mundo concreto, ao espaço físico não digital em que vivemos. Neste ambiente, a informação aparece em folha de papel, nas conversas entre as pessoas e nos demais meios convencionais. Se desejamos realizar a segurança da informação da organização, precisamos contemplar este ambiente convencional com a mesma rigidez do ambiente digital, de tecnologia. A segurança da informação será de pouca eficiência se protegermos com grande rigidez a informação no ambiente digital e não protegermos adequadamente um relatório em papel que vai para o lixo sem ser devidamente destruído

No Ambiente Convencional as informações podem estar sob controle da organização, por exemplo fichários controlados. Ou podem não estar sob controle

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes) da organização, e estão sob controle do usuário que utiliza e guarda esta informação em papel nos mais diversos lugares.

Outra questão que é muito explorada no ambiente convencional é a comunicação entre as pessoas. Um criminoso com uma boa aparência e uma boa conversa, consegue recuperar informações confidenciais de pessoas apenas em um contato, muitas vezes aparentemente por acaso. Além do que, este método é menos dispendioso do que um projeto para se quebrar arquivos criptografados.

Quando de uma ação para obter informação de uma determinada organização neste ambiente convencional, são empregados meios falsos de:

- mensagens de correio eletrônico,
- pesquisas técnicas,
- eventos profissionais. e
- outros criativos métodos.

Portanto a informação pode estar no ambiente digital mas o acesso à informação acontece utilizando pessoas do mundo convencional, do mundo físico. A efetividade do controle (tipo senha), controle de tecnologia depende muito do usuário, pessoa no ambiente convencional.

c) Ambiente Centralizado ou Ambiente Descentralizado

Tanto no Ambiente de Tecnologia ou no Ambiente Convencional, a informação pode estar localizada e tratada de forma:

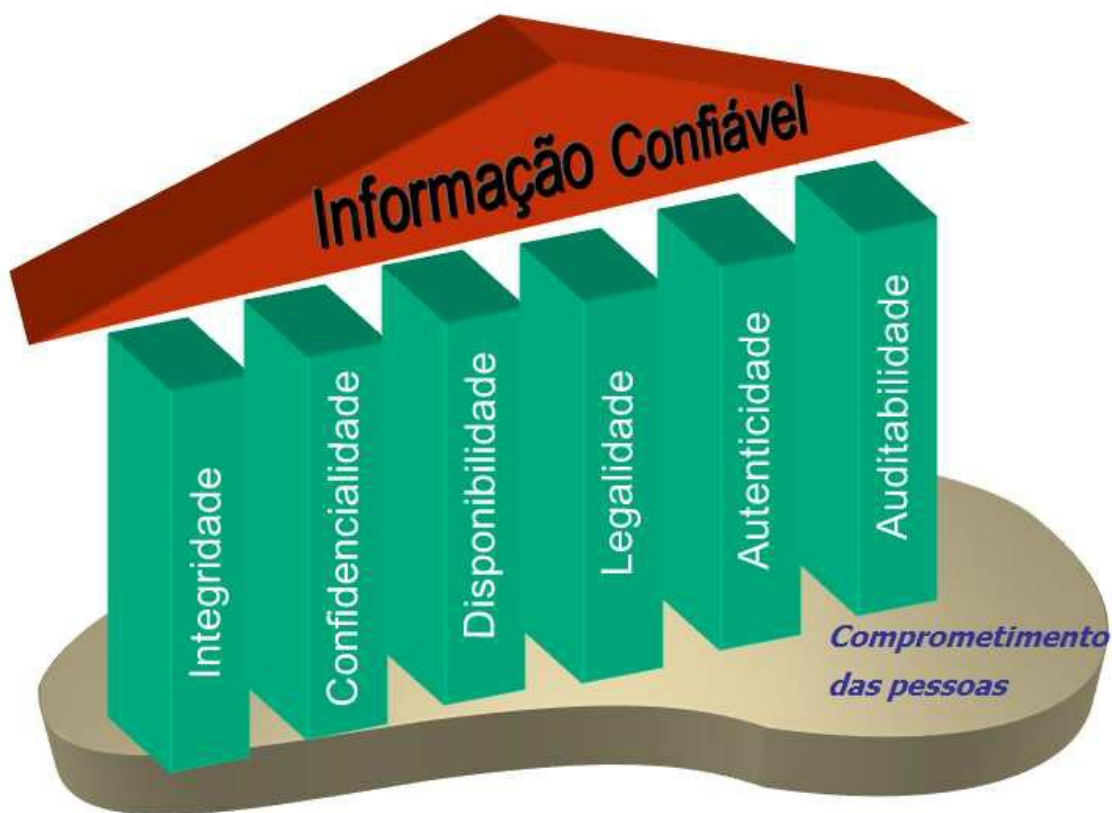
Centralizada: sob controle da organização nos seus departamentos juntos à

administração principal.

Descentralizada: sob controle de unidades regionais que tem grande autonomia sobre a informação.

30

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***



SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

1.5 – Objetivo da Segurança da Informação

A segurança da informação tem como objetivo

garantir uma informação confiável.

A informação torna-se confiável quando garantimos a confidencialidade, integridade, disponibilidade, autenticidade, legalidade e auditabilidade da informação. A figura abaixo apresenta estes objetivos, tendo como base, o comprometimento das pessoas.

Figura 1.3 – Objetivos da segurança da informação

Fonte: Autor, baseado na ABNT Normas da Família 27000.

31

*Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com*

**SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes)** Detalhamos, a seguir, cada um destes objetivos:

a) Confidencialidade

A informação deve ser acessada apenas por usuários previamente autorizados e que necessitam da informação para desempenharem suas funções profissionais para a organização.

b) Integridade

A informação deve manter o seu valor original e não deve permitir que a informação tenha a sua representação corrompida.

c) Disponibilidade

A informação deve estar disponível para ser utilizada pelos usuários e pelos processos organizacionais para atendimento às necessidades do seu negócio e objetivos corporativos.

d) Autenticidade

A informação deve ter a sua origem comprovada garantindo a identificação do emissor ou o gerador da informação.

e) Legalidade

A informação deve estar de acordo com a legislação em vigor, em atendimento aos normativos que a organização está submetida e deve estar adequada aos contratos e compromissos assumidos pela organização.

32

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) f) Auditabilidade

O uso da informação deve permitir o rastreamento do uso desta informação, garantindo a possibilidade de realizar auditorias ou outras ações que identifique o que aconteceu com a representação da informação durante um período de tempo.

1.6 – Direcionadores da Segurança da Informação Família NBR

ISO/IEC 27000, COBIT, ITIL

A família de normas NBR ISO/IEC 27000 é o conjunto de normativos básicos para uma organização que deseje implementar e manter a segurança para a sua informação ou para informações sob sua responsabilidade.

Deste conjunto, a Norma ABNT, NBR ISO/IEC 27002 - Tecnologia da informação – técnicas de segurança - código de prática para a gestão da segurança da informação. Rio de Janeiro: Associação Brasileira de Normas Técnicas é o documento base para todas as ações.

Não devemos esquecer que o COBIT – *Control Objectives for Information*

and related Technology e o ITIL - *Information Technology Infrastructure Library*, são estruturas que também contemplam os controles de Segurança da Informação. Porém, com ênfases diferentes. O COBIT tem como foco a gestão e a governança da tecnologia da informação e contempla como um dos seus elementos a segurança da informação. O ITIL tem como objetivo a qualidade e a entrega dos serviços de tecnologia da informação. Nessa abordagem, também considera a Segurança da Informação.

Como profissionais e estudiosos devemos contemplar todas as estruturas que considerem a Segurança da Informação. Porém, a diretriz básica é a Norma NBR ISO/IEC 27002. Como base deve-se tomar como base a Norma NBR

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA

(Edison Fontes) ISO/IEC 27002 e considerar de maneira complementar as demais normas da família 27000, o ITIL, o COBIT e os aspectos de governança corporativa com a sua interligação com a governança da segurança da informação. Estes elementos são válidos para qualquer organização e possuem controles que devem ser considerados sempre. Existe um outro grupo de controles que pertencem a elementos que devem ser considerados, considerando as características específicas da organização. Descrevemos abaixo os principais elementos deste tipo, porém você pode identificar outros elementos específicos para a organização. Estes elementos complementares são:

- Regulamentos setoriais

São regulamentos específicos de um setor no qual a organização está subordinada. Por exemplo uma Instituição Financeira está subordinada aos regulamentos do Banco Central. Uma organização que negocia ações na Bolsa de Nova Iorque deve seguir a SOX (Lei Sarbanes-Oxley)

- Exigências do Mercado.

Dependendo do tipo de negócio da organização, podem existir exigências de clientes específicos, ou exigências para este tipo de mercado. Por exemplo, uma organização que atua no seguimento de tratamento de cartão de pagamento deve seguir o Padrão PCI DSS (Padrão de Segurança de Dados da Indústria de Cartões de Pagamento).

34

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***



46

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

- Legislação.

Evidentemente a Legislação é um elemento válido para todas as organizações. No Brasil o tratamento específico da segurança e a proteção da informação é um tema novo. Cada organização deve analisar detalhadamente a legislação existente, identificar o que lhe afeta diretamente e garantir o cumprimento da mesma.

- Acionistas.

Muitas organizações possuem como acionistas outras organizações que por motivo próprio ou por estar submetida a controles específicos, exige da organização controlada o cumprimento de controles que rigorosamente ela não precisa.

Figura 1.4 – Estruturas direcionadoras para a segurança da informação
Fonte: Autor.



SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes)

2. IMPLANTANDO A SEGURANÇA **DA INFORMAÇÃO**

Foto: Edison Fontes, Porto, Portugal.

Desenvolver e implantar os controles são dois grandes desafios da gestão da segurança da informação. No mundo teórico não existem restrições de recursos, a cultura organizacional é perfeita e as pessoas são iguais aos seus perfis nas redes sociais: simpáticas, abertas a mudanças, sem preconceitos, honestas, trabalhadoras, adora desafios e entende que a segurança é muito importante. Porém, no mundo real das nossas organizações existem limitações de orçamento, restrições de tempo, objetivos que aparentemente são opostos à segurança, disputa pelo poder pelas pessoas, concorrentes desleais, colaboradores não comprometidos com a organização (estão mais preocupados com os comentários nas redes sociais), planejamento não realizado fazendo com que a organização sofra surpresas que poderiam ser previstas, e outras situações que

36

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) influenciam e impactam a implantação e manutenção da segurança da informação.

Para uma efetiva implantação da segurança da informação, recomendamos que você siga às seguintes orientações.

2.1 – Considere o ambiente existente e considere as limitações

Para implantar um processo de segurança da informação eficiente e eficaz ao longo do tempo precisamos considerar os seguintes pontos:

a) Atingir 100% é muito caro

A empresa precisa saber que, quanto mais controles de segurança, maior é o custo da implantação e da manutenção desta proteção. Este custo pode ser financeiro, de tempo ou operacional. Portanto é a organização, materializada pelos seus gestores, que tem a obrigação de definir qual será o a rigidez dos controles de segurança. Este é um dos grandes desafios na gestão da segurança da informação. No mundo da teoria não existem restrições,

questões culturais e pessoas.

Porém, chamo a atenção para o risco de transformarmos esta afirmação em “É impossível termos 100% de segurança” e depois vai se transformando em “Não disse, não podemos ter 100% de segurança”. Estas afirmações fazem com que nos acomodemos no aperfeiçoamento da segurança da informação.

Eu acredito que é possível termos 100% de segurança. Porém, para isto, precisamos ter muito bem identificadas premissas, escopo e controles considerados. Por exemplo, quando viajamos em uma avião em um voo comercial, é inconcebível ocorrer um desastre por falta de combustível. Para este escopo devemos implantar e garantir controles que verifiquem a quantidade adequada de combustível para aquele trecho de viagem. E estes controles devem

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes) ter outros controles que verificam se os primeiros controles realmente foram implementados. Queremos e exigimos uma segurança 100%. O objetivo é 100%.

Portanto ter segurança 100% é possível, tem seu custo e exige definições claras de escopo, controles e premissas.

b) É obrigatório ter um responsável por fazer acontecer

A segurança da informação é uma responsabilidade de todos. Porém, é necessário que exista um gestor específico e dedicado que tenha a responsabilidade de implantar, manter o programa de segurança e planejar o caminho a seguir. Ele será o Gestor do Programa Organizacional de Segurança da Informação, descrito mais adiante. Tem que ser uma pessoa com nome, sobrenome e deve ser formalizado na estrutura organizacional. O

sucesso da segurança da informação será proporcional ao tempo de dedicação, conhecimento e experiência deste gestor.

c) Identifique e busque alcançar o nível adequado

A segurança da informação precisa definir a rigidez para cada um dos seus controles. Mais rigidez em controles de segurança significa maior quantidade de controles. Significa mais segurança, porém gera um maior impacto operacional.

Cada novo controle exige a existência de outros novos controles para garantir a efetividade do primeiro controle. Porém estes controles que controlam o controle original, como ficam? Precisam ser controlados. Na teoria esta cadeia de garantia de controles nunca termina. Na prática, temos que identificar qual o ponto de equilíbrio. Qual deve ser o nível adequado? Sua organização tem que responder!

E a Área de Negócio precisa ser envolvida nesta definição.

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) Neste ponto é importante destacar que na maioria das vezes esta rigidez dos controles será validado pela área de negócio, ou outras áreas que não são a Área de Segurança. Porém o Gestor do Programa Organizacional da Segurança da Informação têm a responsabilidade de estruturar, realizar um estudo prévio e recomendar uma solução ou apresentar as diversas possibilidades de soluções para os demais gestores da organização. Mais especificamente, aos gestores das áreas de negócio. Por exemplo, qual o nível de indisponibilidade de informação que a organização suporta? Esta resposta deve ser dada pelo gestor de cada área de negócio ou área de suporte ao negócio. Porém, este pedido de definição deve ser levado de maneira inteligente que facilite a tomada de decisões pelas áreas de negócio ou áreas de suporte ao negócio.

d) Considere a segurança versus facilidade

A segurança da informação é inversamente proporcional à facilidade operacional. Pura e cruel verdade! Quanto mais segurança, menos facilidade.

Quanto mais facilidade, menos segurança. Esta verdade precisa ser de conhecimento de todos. Não adianta nos iludirmos. A segurança exige um preço que não significa apenas valor em dinheiro. Desta maneira, as pessoas precisam entender que é necessário a decisão do ponto de equilíbrio adequado específico para a organização: considerando segurança x facilidade operacional.

As pessoas devem ser esclarecidas que não existe uma solução milagrosa: maior segurança sem impactos operacionais. Isto não existe. Evidentemente que a organização deve buscar estes elementos, mas terá que se contentar com uma situação adequada às características e às necessidades da organização. Cada organização é peculiar e precisa de uma solução desenvolvida especificamente para a ela.

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) e) Considere a boa cultura da organização

A segurança da informação acontece dentro de uma organização. E neste caso, cada organização tem uma cultura que afeta a segurança da informação.

Com o passar do tempo, a segurança deve afetar mais a cultura da organização, do que ser afetada por esta cultura. O Gestor Corporativo da Segurança da Informação deverá ter sabedoria suficiente para garantir que o programa de segurança tem uma efetividade crescente com a implantação e o funcionamento dos controles. O Gestor da Segurança da Informação também deve analisar os pontos positivos da cultura organizacional e trabalhar para tirar proveito dos mesmos.

2.2 - Fatores críticos de sucesso

Considere os fatores que influenciam diretamente no sucesso da segurança da informação na organização. Abaixo definimos os principais fatores que valem para qualquer empresa. Porém, não se acomode e identifique fatores críticos de sucesso específicos da sua organização e trabalhe fortemente nos mesmos.

Abaixo os fatores críticos de sucesso que são válidos para qualquer organização: **a) Apoio explícito da Alta Direção**

A segurança da informação define novas regras e responsabilidades. Com isso é alterado, em sua maioria, a relação de poder dentro de uma organização.

Para o sucesso da segurança da informação é obrigatório o apoio e a explicitação deste apoio pela Alta Direção. Se isto não acontecer, algo está errado e existe uma alta probabilidade do fracasso dessa área.

Muitos profissionais se queixam que os executivos não dão importância à segurança da informação e por isso a segurança não tem força nem prioridade.

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA

(Edison Fontes) Esta afirmação tem um pouco de razão porém, entendo que na maioria das vezes o Gestor da Segurança da Informação não se prepara e nem gera um material de bom nível, sucinto, em uma linguagem sem termos técnicos para ser apresentado. Este Gestor não propõe um plano de ações para a segurança, explicitando os perigos para a organização e para o executivo principal. Duvido que qualquer executivo, diretoria ou comitê fique passivo com a apresentação destes fatos. O presidente da organização não precisa conhecer profundamente a segurança da informação. Ele precisa conhecer os

riscos de ameaças se concretizarem e o impacto desta cristalização da ameaça. Ele deve ter o Gestor Corporativo de Segurança da Informação para tratar deste assunto e trazer alternativas para ele tomar decisão.

A minha experiência me faz acreditar que quando planejamos,

estruturamos e realizamos ações que facilitam o entendimento e a tomada de decisão, o Corpo Diretivo da organização retorna com atenção e com recursos.

Chamo atenção que este aspecto não é uma tarefa fácil. Muitas vezes eu tive reuniões, com executivos da organização, adiadas porque uma necessidade de negócio que imediatamente dará resultado positivo para a organização precisou fazer uma reunião com os executivos. Foram postergadas, mas não canceladas. Procure planejar, planejar e planejar como será a sua abordagem como Gestor Corporativo de Segurança da Informação para com o Corpo Diretivo. Tenha certeza, vamos colher proporcionalmente à nossa dedicação inteligente. Chamo de dedicação inteligente o conjunto de ações planejadas e posteriormente implementadas focadas no Plano de Ações da organização.

Muitas pessoas pensam que somente porque elas estão trabalhando, muitas vezes trabalhando até demais, estão dedicadas de maneira inteligente. É

necessário trabalhar certo e com foco no plano de ações de segurança da informação.

b) Conscientização e treinamento de usuários

Todos os usuários precisam ser treinados em segurança da informação.

Sem exceção, cada usuário precisa saber quais são as regras da organização, quais são suas responsabilidades e quais são as consequências do não cumprimento destas regras da organização. Evidentemente, este treinamento pode e deve ser diferente para cada tipo de grupo de usuários e neste treinamento deve-se destacar os itens fortemente relacionados às características de cada tipo de grupo de usuário.

Um ponto em comum nas organizações: principalmente no primeiro ano, a organização indica que não tem verba para gastar com segurança da informação.

Pode até ser verdade. Neste caso podemos ter soluções de baixo custo. Por exemplo, no primeiro ano, o próprio Gestor Corporativo de Segurança da Informação pode realizar as palestras de conscientização e de geração de evidência da participação dos colaboradores.

Com o passar do tempo podemos ter soluções com uso de tecnologia que facilita e melhor controla o treinamento de conscientização em segurança da informação para as pessoas.

c) Disponibilização de recursos para a segurança da informação

A implantação e manutenção da segurança da informação exigem recursos.

Muitas vezes, pensamos que estes recursos são apenas financeiros. Também são.

Mas não são os únicos. O recurso financeiro viabiliza concretamente a realização de várias ações. Mas, precisamos de recursos como tempo, planejamento, espaço nas reuniões da direção para validação de diretrizes de segurança e outros similares. Entendo que toda e qualquer organização tem condições e recursos necessários para implementar e manter um processo de segurança da informação.

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA

(Edison Fontes) Mesmo com pouco recurso financeiro é possível implantar uma boa segurança para a informação da organização.

É semelhante à nossa vida particular. Muitas pessoas possuem um notebook possante de alto valor, mas não possuem um *pendriver* para realizar cópia de segurança dos seus principais arquivos. Um pendriver custa um por cento do valor de um notebook. Ninguém pode alegar que não realiza cópias de segurança por limitação financeira.

d) Continuidade das ações

Muitas organizações erram porque exercem a segurança da informação em momentos de crise ou em momentos para um marketing interno ou externo. É a segurança por demanda de medo. A segurança da organização deve existir enquanto essa organização existe. Sendo assim, deve existir sempre! Na prática, as ações de segurança da informação continuam, inclusive, após a empresa deixar de existir para o mercado. Uma organização quando vai deixar de existir precisa pensar o que fará com as informações. E dependendo do tipo de negócio, ela pode até “aparentemente” estar fechada, mas na realidade ela está fechada para o mercado, mas legalmente ainda existe ainda tem uma série de obrigações a cumprir, sob pena dos executivos serem legalmente punidos ou a matriz em outro país sofrer consequências. Faço uma observação que ter uma experiência deste tipo é triste, mas é um aprendizado muito grande para o profissional de segurança da informação. Imagine como está o clima organizacional e a motivação dos colaboradores? Este é um dos momentos que fortemente fica evidenciado a importância da existência de políticas e normas de segurança da informação definindo responsabilidades. É importantíssimo para enfrentar estas situações, que anteriormente a organização tenha alcançado um bom nível de maturidade em segurança da informação. Também nestas ocasiões identificamos controles

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes) que não foram definidos porque só pensávamos em situação “céu de brigadeiro”

e não imaginávamos uma situação deste tipo.

e) Existência de profissionais capacitados em segurança da informação.

A proteção da informação somente acontecerá com a existência de um

Programa Organizacional de Segurança da Informação sob a responsabilidade de um profissional capacitado e com experiência em gestão da segurança. A grande diferença de um profissional experiente em gestão da segurança e um

profissional que apenas entende de segurança é que este segundo começa a realizar uma série de ações de segurança da informação sem considerar as prioridades e sem estabelecer um plano de ação. Um profissional maduro e com experiência busca antes de tudo ter uma visão da floresta das ameaças e riscos que rondam a informação. Procura estruturar critérios que permitam priorizar as principais ameaças e somente depois, com o plano organizado dá andamento as atividades de implementação e implantação dos controles.

O conhecimento teórico permite que o profissional de segurança da

informação respalde as suas ações práticas em conceitos aceitos mundialmente.

Vamos gastar esforço em como fazer e como priorizar. Não precisaremos discutir o que será feito.

2.3 – Programa Organizacional Segurança da Informação

É necessário que para segurança da informação seja elaborado um programa organizacional. Este programa é necessário porque a organização precisa alcançar objetivos de negócio. Para alcançar estes objetivos é necessário o uso de informações que precisam ser protegidas. A Pesquisa Global de Segurança da Informação da *PricewaterhouseCoopers* do ano de 2013 (PwC, 2013), apontou a grande dificuldade que os executivos têm para definir uma

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) estratégia para a segurança da informação. Esta dificuldade surge porque a segurança da informação deve considerar vários aspectos e diversos tipos de controles. Estes executivos estão corretos: é necessário estabelecer uma estrutura inteligente para fazer acontecer a segurança da informação.

Definimos controle de segurança como qualquer ação que aumente a proteção da informação. Sendo assim, são inúmeros os controles que precisam ser definidos, implantados e mantidos. A dificuldade está em como coordenar estes controles

Inicialmente é necessário definir uma estrutura para a segurança da informação. Vamos tomar por base a Norma NBR ISO/IEC 27002 - Tecnologia da informação – Técnicas de segurança - Código de prática para a gestão da segurança da informação. Baseado nesta norma, definimos o Programa Organizacional de Segurança da Informação que é composto pelas Dimensões de Segurança da Informação. O próximo capítulo detalha este processo e considera as seguintes Dimensões:

- a. Política da Segurança da Informação
- b. Gestão de Riscos de Segurança da Informação
- c. Acesso Lógico à Informação
- d. Classificação da Informação
- e. Proteção Técnica de Recursos de Tecnologia
- f. Flexibilidade Operacional
- g. Ambiente Físico

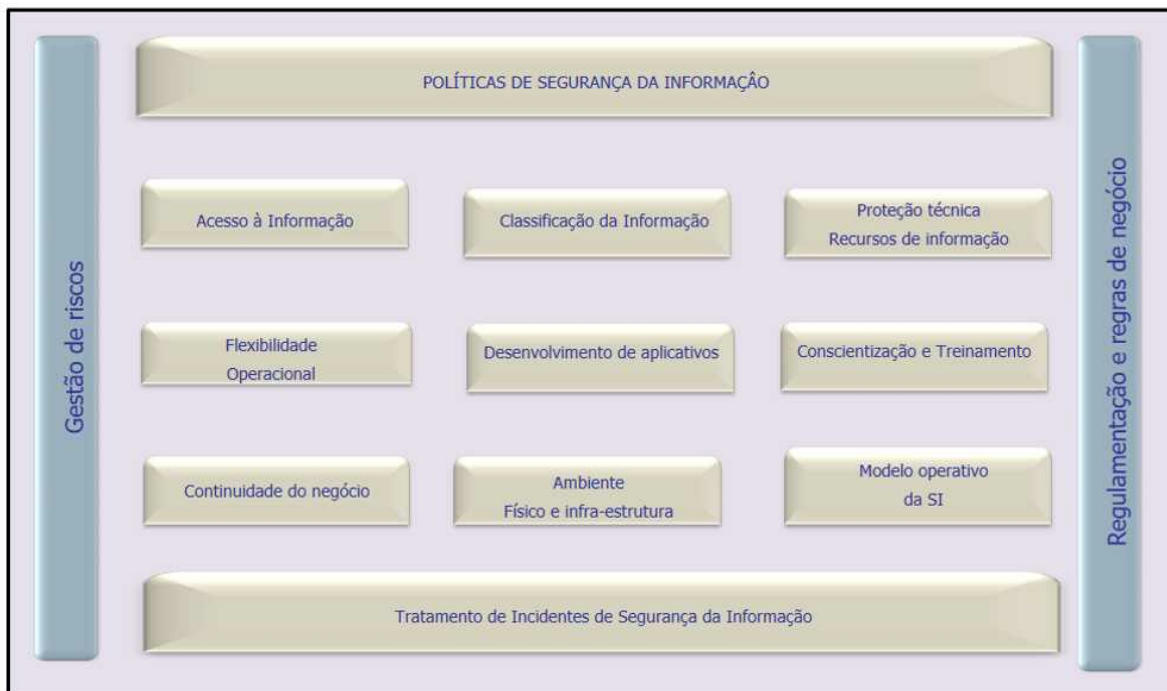
- h. Infraestrutura
- i. Desenvolvimento Aplicativo ou Aquisição de Produto
- j. Modelo Operativo da Segurança da Informação
- k. Conscientização e Treinamento do Usuário
- l. Continuidade de Negócio

45

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

Programa Organizacional de Segurança da Informação

nte: Livro Praticando a Segurança da Informação, Edison Fontes, Editora BRASPORT.
Estrutura baseada na Norma Internacional ISO/IEC 27002



**SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes)**

Figura 2.1 -Programa Organizacional de Segurança da Informação.
Fonte: Autor, baseado em Normas ISO



SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA

(Edison Fontes)

3. PROGRAMA

ORGANIZACIONAL DE

SEGURANÇA DA INFORMAÇÃO

Foto: Edison Fontes, Brasília, Brasil.

O Programa Organizacional de Segurança da Informação tem como objetivo principal estruturar a proteção da informação e como consequência garantir que os controles de segurança existem, são eficientes e são eficazes ao longo do tempo. Isto é, os controles são efetivos. Desta maneira a segurança da informação vai existir na organização de uma maneira adequada ao seu tipo de negócio e ao seu porte, na medida em que todas as dimensões (temas) consideradas para a segurança da informação são criadas, desenvolvidas, implementadas e mantidas. Estas dimensões não possuem uma hierarquia de maior ou menor importância entre si. Todas as dimensões precisam ser contempladas. Porém, precisamos estar atentos para o fato de que dependendo do



SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

tipo de negócio da organização algumas dimensões precisam ser implementadas prioritariamente para permitir o crescimento mais efetivo da proteção da informação. A figura abaixo apresenta este conjunto de dimensões.

Figura 3.1 – Dimensões da Segurança da Informação

Fonte: Livro “Praticando a Segurança da Informação” (FONTES, 2008, p. 48).

A seguir, descrevemos as principais objetivos e características de cada uma destas dimensões. Desta maneira você terá uma visão gerencial e completa da abordagem da proteção da informação que deverá ser desenvolvida e implantada.

Nos capítulos seguintes detalhamos cada uma destas dimensões.

3.1 – Dimensão Política da Segurança da Informação

A Dimensão Política de Segurança da Informação define as regras de como o Programa Organizacional de segurança da informação irá funcionar, define as responsabilidades e permite a conexão da Governança da Segurança da

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) Informação com a Governança Corporativa. Ela é um elemento estrutural para o Programa Organizacional da Segurança da Informação.

Esta Dimensão explicita como a organização deseja que a informação seja utilizada, controlada e responsabilizada quando do seu uso. Sem a existência da Política de Segurança da Informação a organização fica sem um direcionamento, sem definição de responsabilidade e com alto o risco de fracasso em curto prazo do Programa Organizacional da Segurança da Informação.

3.2 – Dimensão Gestão de Riscos de Segurança da Informação

A Dimensão de Gestão de Riscos de Segurança da Informação

implanta e operacionaliza as regras e controles para a existência da gestão de riscos de específica para o escopo da segurança da informação da organização.

Esta Dimensão facilita a priorização das ações e a continuidade do Programa Organizacional da segurança da informação e,

consequentemente, ajuda o seu alinhamento com a governança

corporativa na medida que a priorização de ações deve ser validada com a presidência da organização e/ou com um Comitê Executivo com

poder de decisão.

3.3 – Dimensão Acesso Lógico à Informação

A Dimensão de Acesso à Informação implanta e operacionaliza as regras e os controles necessários para um acesso seguro à informação, tanto no ambiente de tecnologia (ambiente digital), como no ambiente convencional.

Nesta Dimensão são considerados os seguintes tipos de controles:

49

*Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com*

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

- Gestão de identidade do usuário;
- Gestão de autenticidade do usuário;
- Gestão de autorização do acesso à informação pelo usuário, e
- Auditabilidade dos acessos realizados à informação.

Para a efetividade desta Dimensão é necessário a existência do Gestor da Informação para cada informação existente que pertence à organização ou está sob a sua responsabilidade. Este Gestor da Informação é responsável para autorizar ou negar o acesso da informação sob sua responsabilidade, para qualquer pessoa ou perfil de acesso. Ele também tem a responsabilidade de indicar o tempo máximo de indisponibilidade da informação quando da ocorrência de um impedimento de uso da informação, considerando impactos financeiros, impactos de imagem e impactos operacionais.

Também são utilizados nesta Dimensão, os conceitos de Gestor de Usuário e Custodiante da Informação.

3.4 – Dimensão Classificação da Informação

A Dimensão Classificação da Informação implanta e operacionaliza as regras e os controles para a existência e para a utilização de níveis de classificação da informação no que diz respeito ao seu sigilo. Os controles definidos para cada nível da classificação da informação indicam como deve ser o tratamento dos recursos que suportam a informação.

Nesta Dimensão são definidos os níveis de sigilo que são utilizados para as informações da organização ou sob responsabilidade da organização.

*Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com*

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) 3.5 – Dimensão Proteção Técnica de Recursos de Tecnologia

A Dimensão Proteção Técnica e Recursos de Tecnologia é responsável pela proteção do ambiente de tecnologia da informação, tipo proteção da periferia de rede contra invasões criminosas. Muitas vezes, se pensa que segurança da informação é apenas esta dimensão pois o noticiário dá muita ênfase neste tipo de ação, ou supostamente este tipo de ação. Devemos considerar nesta Dimensão:

3.5.1 – Ambiente de Tecnologia da Informação

Este aspecto considera a implantação e a garantia da existência de controles que protegem o ambiente digital da organização contra invasões maliciosas, ataques buscando vulnerabilidades técnicas e outras ações de criminosos.

3.5.2 – Recursos de Tecnologia utilizados pelos usuários

A Dimensão de Recursos de Tecnologia define como os recursos e facilidades de tecnologia, tipo correio eletrônico, Internet, Redes Sociais e similares, devem ser utilizados pelos usuários e quais devem ser os controles e a sua rigidez.

3.6 – Dimensão Flexibilidade Operacional

A Dimensão Flexibilidade Operacional considera como a organização vai desenvolver controles paralelos à segurança da informação, mas que influenciam fortemente a proteção da informação.

São consideradas as ações para:

- Gestão de Mudanças no Ambiente da Informação.
- Gestão de Problemas no Ambiente da Informação.
- Gestão de Recursos de Informação.

51

*Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com*

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) 3.7 – Dimensão Ambiente Físico

A Dimensão Ambiente Físico define, implanta e operacionaliza as regras e os controles necessários para o acesso do usuário no ambiente físico que possui recursos de informação.

Para cada ambiente físico deve existir um Gestor de Ambiente Físico.

3.8 – Dimensão Infraestrutura

A Dimensão Infraestrutura define, implanta e operacionaliza as regras e os controles necessários para que a infraestrutura que suporta o ambiente físico esteja adequada e atenda aos requerimentos exigidos pelo Programa Organizacional de Segurança da Informação.

3.9 – Dimensão Desenvolvimento Aplicativo ou Aquisição de

Produto

A Dimensão Desenvolvimento Aplicativo ou Aquisição de Produto define, implanta e operacionaliza as regras e os controles de segurança (obrigatórios ou desejáveis) em relação ao desenvolvimento de sistemas aplicativos ou a aquisição de programa produto.

Sobre o desenvolvimento ou aquisição, são definidos os requisitos de segurança da informação que devem ser formalmente atendidos, após a especificação do produto/Sistema e antes da especificação técnica.

Na prática, quando essa Dimensão não é contemplada adequadamente, esses requisitos de segurança serão analisados após a implantação do sistema ou produto, gerando um maior custo e um impacto de maior gravidade.

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) 3.10 – Dimensão Modelo Operativo da Segurança da Informação

A Dimensão Modelo Operativo da Segurança da Informação define a estrutura, implanta e mantém a operacionalização da área de segurança da informação da organização. Indica como esta área funcionará, a sua posição no organograma da organização, as suas responsabilidades e as suas limitações de atuação.

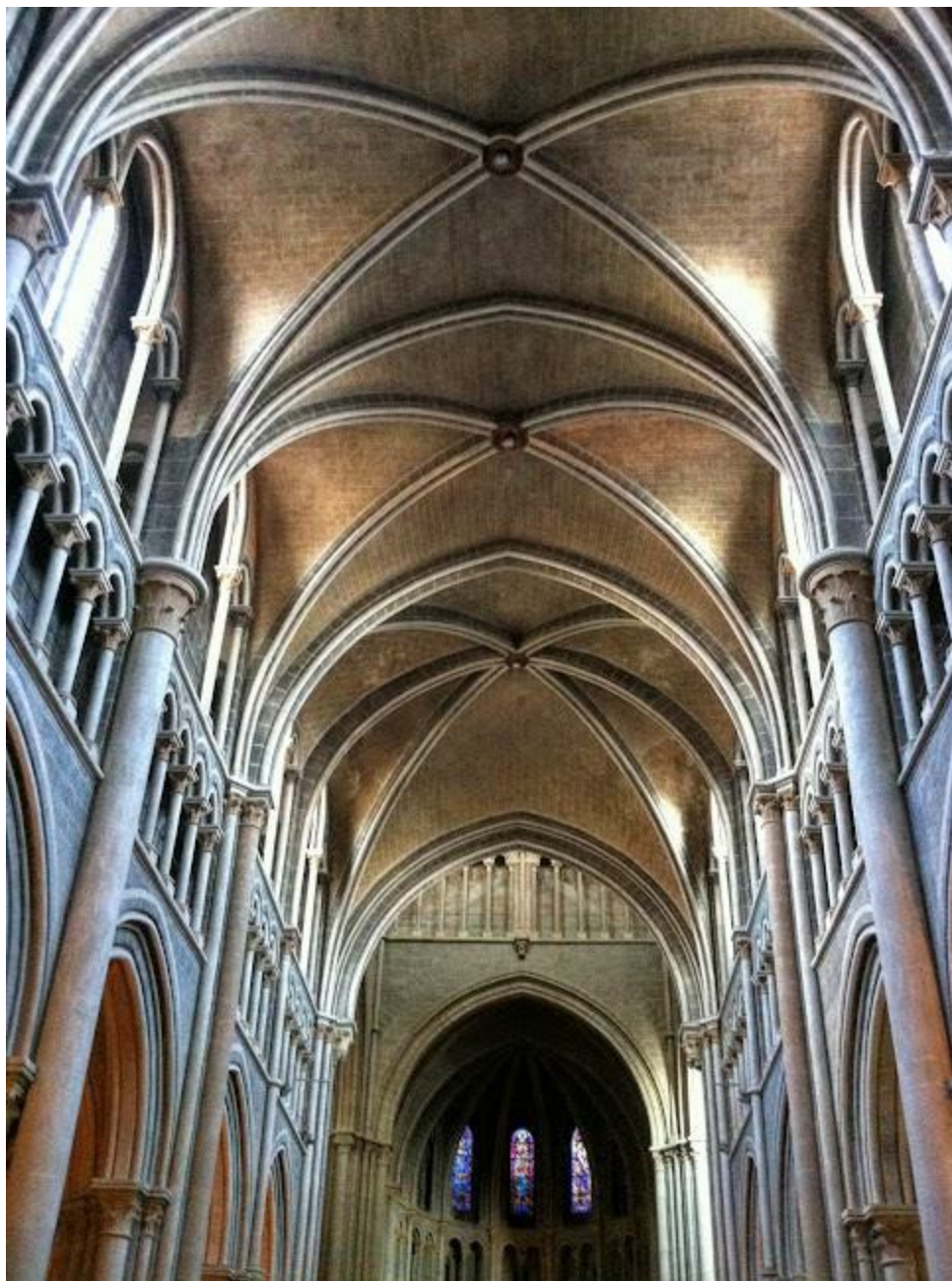
3.11 – Dimensão Conscientização e Treinamento do Usuário

A Dimensão Conscientização e Treinamento do Usuário, define, implanta e operacionaliza as regras e os controles para que exista de maneira efetiva o treinamento contínuo do usuário em segurança da informação.

O judiciário tem aplicado a jurisprudência de que para as regras definidas pela organização, em assuntos que ainda não estão definidos por lei, é necessário a existência de regulamentos organizacionais e que o usuário seja treinado em segurança da informação. É fundamental que a organização gere as evidências da realização destes treinamentos.

3.12 – Dimensão Continuidade de Negócio

A Dimensão Continuidade de Negócio define, implanta e operacionaliza as regras e os controles para garantir que a organização continuará funcionando em condições mínimas aceitáveis, mesmo quando da ocorrência de uma indisponibilidade da informação. Seja esta indisponibilidade causada por erros de pessoas, ações de má-fé, fenômenos da natureza ou similar.



SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

4. DIMENSÃO POLÍTICA DA SEGURANÇA DA INFORMAÇÃO

Foto: Edison Fontes, Lausanne, Suíça.

Neste capítulo apresentamos a Dimensão Política de Segurança da Informação e a sua aplicação no Programa Organizacional de Segurança da Informação.

A Política de Segurança da Informação é um elemento estrutural para que uma organização implemente a proteção da informação e dos recursos de informação. Ser um elemento estrutural significa que a sua existência permitirá que, mais facilmente e de maneira ordenada, outras dimensões e/ou outros controles sejam desenvolvidos e implantados. É recomendado que a Dimensão Política de Segurança da Informação seja a primeira dimensão a ser desenvolvida ou a ser revisada no Programa Organizacional de Segurança da Informação.

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes) Evidentemente, considerando as características e o momento de cada organização.

As organizações precisam ter as seus regulamentos para garantir a existência e a manutenção da segurança da informação, conforme afirmam Albertin e Pinochet (2010) “no âmbito das organizações, a manutenção da segurança depende da adequada formulação e implantação de políticas corporativas” (p.10).

A Norma NBR ISO/IEC 27002:2013 é taxativa em relação à necessidade da existência de políticas e normas de segurança da informação quando explicita: *A segurança da informação é alcançada pela implementação de um conjunto adequado de controles, incluindo políticas, processos, procedimentos, estrutura organizacional e funções de software e hardware.* (ABNT, 2013, p.x).

A necessidade da política de segurança da informação é tão crítica que o

primeiro controle da Norma NBR ISO/IEC 27002:2013 declara:

Convém que um conjunto de políticas de segurança da informação seja definido, aprovado pela direção, publicado e comunicado a todos os funcionários e partes externas relevantes. (ABNT, 2013, p.2).

A elaboração dos regulamentos que compõem a Política de Segurança da Informação não é uma tarefa simples. Muitas organizações ainda não possuem suas políticas de segurança da informação apesar de seus colaboradores entenderem a importância de regulamentos de segurança da informação. Em sua pesquisa “Ciclo contínuo de acompanhamento para desenvolvimento de uma política de segurança da informação em organizações hospitalares”, Albertin e Pinochet (2010) descrevem o levantamento em cinco unidades hospitalares no Estado de São Paulo, e em todas elas, de uma maneira direta ou indireta, seus

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) gestores declaram a importância da segurança da informação, porém nenhuma delas possui uma política adequada para a segurança da informação.

O hospital possui deficiência em desenvolver uma política de segurança da informação. (ALBERTIN; PINOCHET, 2010, p.275).

Os gestores na sua maioria consideram que falta conhecimento de como mapear as necessidades para se desenvolver uma política de segurança da informação formal. (ALBERTIN; PINOCHET, 2010, p.275).

O hospital possui claras deficiências em desenvolver uma política de segurança da informação devido à falta de orientação da Secretaria (de Estado) e do conselho de saúde. (ALBERTIN; PINOCHET, 2010, p.275).

Para implantação de um Programa Organizacional de Segurança da

Informação é preciso desenvolver as políticas e normas que possibilitarão a existência e a sustentabilidade deste processo.

4.1. Objetivo da Dimensão Política de Segurança da Informação

O objetivo principal da Dimensão Política de Segurança da Informação é formalizar e explicitar como a Organização deseja que obrigatoriamente o seu recurso informação seja tratado, protegido e responsabilizado.

Como objetivos complementares, a Dimensão Política de Segurança da Informação deve:

- a) Declarar, explicitar e registrar as regras;
- b) Definir obrigações, responsabilidades e autoridades;
- c) Definir e formalizar padrões e procedimentos;
- d) Fornecer informações aos usuários;
- e) Ajudar a educar e treinar as pessoas.

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA

(Edison Fontes) Esta dimensão é formada por um conjunto de regulamentos organizados, estruturados, com escopos específicos, de maneira a facilitar o desenvolvimento, implantação, leitura e facilidade de manutenção dos controles de segurança da informação.

Com a existência dos diversos regulamentos (diretrizes, normas e procedimentos), de segurança da informação, todos os usuários tomarão conhecimento de como deve ser o seu comportamento perante a informação. Para que este conhecimento do usuário aconteça de maneira efetiva é necessário que um processo de conscientização e treinamento em segurança

da informação exista na Organização que faz parte da Dimensão Conscientização e Treinamento de Usuário.

A Política de Segurança da Informação é uma Dimensão do Programa Organizacional de Segurança da Informação conforme apresenta a figura abaixo, porém ela tem uma característica única: ela se relaciona com todas as demais dimensões. Isto significa que deve existir um conjunto de regulamentos relacionados a cada Dimensão.

57

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***



SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

Figura 4.1 – Dimensões da Segurança da Informação

Fonte: Livro “Praticando a Segurança da Informação” (FONTES, 2008,

p. 48).

Peltier (2004) considera a política como a declaração que a Organização acredita e quer que exista em todas as suas áreas. A política é uma diretiva da direção executiva para criar um programa de segurança da informação, estabelecer seus objetivos e definir responsabilidades.

Outros autores colaboram nesta linha de definição:

Uma política é um guia genérico para a ação. Ela delimita uma ação, mas não especifica o tempo. É uma definição de propósitos de uma empresa e estabelece linhas de orientação e limites para a ação dos indivíduos responsáveis pela implantação. As políticas são princípios que estabelecem regras para a ação e contribuem para o alcance bem-sucedido dos objetivos (CHIAVENATTO, 2010, p.173).

58

Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes) *Política de segurança é um conjunto de diretrizes gerais destinadas a governar a proteção que será dada aos ativos de informação.*

(CARUSO; STEFFEN, 1999, p.49).

Política de segurança é um conjunto de regras e padrões sobre o que deve ser feito para assegurar que as informações recebam a proteção conveniente que possibilite garantir a sua confidencialidade, integridade e disponibilidade. (BARMAN, 2002, p.4).

As políticas são as linhas mestras que indicam os limites ou restrições sobre aquilo que se quer conseguir. (ALBERTIN; PINOCHET, 2010, p.34).

A existência de políticas internas é um dos cinco fatores direcionadores mais

importantes para a disponibilização de recursos para a implantação da Segurança da Informação, conforme estudo conduzido pela Consultoria *PricewaterhouseCoopers*, CIO Magazine e CSO Magazine, com a participação de 12.800 (500 do Brasil) executivos, entre CEOs, CFOs, CIOs e CSOs, vice-presidentes e diretores de TI e segurança da informação de empresas médias, grandes e gigantes de 135 países e de todos os setores (PwC, 2010).

4.2. Arquitetura da Política de Segurança da Informação

Uma grande dificuldade que o profissional de segurança da informação encontra ao ser responsável pelo desenvolvimento, implantação e manutenção da Política de Segurança da Informação é: como deve-se estruturar esta política? É

um documento único? São vários documentos? Qual o critério para o agrupamento de assuntos? Existem regras com detalhamento diferente?



SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

As estruturas que abordam o tema Política de Segurança da Informação, mais especificamente as Normas da Família 27000, não especificam como construir um documento ou documentos que compõem a Política de Segurança da Informação. Elas apenas declaram o que deve ser feito.

No desenvolvimento e implantação da Política de Segurança da Informação também devem ser considerados os aspectos: manutenção dos documentos, agrupamento dos assuntos, hierarquia dos profissionais para a assinatura de aprovação de cada documento e comunicação com os usuários.

Para atender estas questões e estruturar a ação de construção dos regulamentos, Fontes (2012) definiu uma Arquitetura da Política de Segurança da Informação, baseada na Norma NBR ISO/IEC 27002:2013 que considera as Dimensões da Segurança da Informação (FONTES, 2006).

A Figura abaixo apresenta a Arquitetura da Política de Segurança da Informação:

Figura 4.2 – Arquitetura da Política de Segurança da Informação. Fonte:

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) Esta arquitetura está alinhada com a Norma NBR ISO/IEC 27002 que indica que podemos ter diferentes tipos de controles como políticas, procedimentos, processos, estruturas organizacionais e funções de software e hardware. Estruturamos esta arquitetura em três níveis de detalhamento de controles, descritos nos itens seguintes.

4.2.1 Política principal da segurança da informação

No primeiro nível, o Nível 1, encontra-se o Documento Política Principal da Segurança da Informação. Este documento define as diretrizes para a existência e sustentabilidade do Programa Organizacional de Segurança da Informação e apresenta as regras que a Organização define para o tratamento da informação em relação à segurança. Ela transmite a filosofia da Organização em relação ao assunto Segurança da Informação.

O regulamento do Nível 1 define macro controles que estão alinhados à Governança da Segurança da Informação e, conseqüentemente, alinhada à Governança Corporativa. O ITGI considera que a estrutura básica para a Governança da Segurança da Informação deve conter Políticas de Segurança da Informação que direcione cada aspecto da estratégia e dos requisitos definidos em regulamentação aplicável à Organização (ITGI, 2006, p.18).

Considerando esta abordagem estratégica, o Documento Política de Segurança Principal deve ser aprovado pelo presidente ou pelo Conselho de Administração da Organização. Os demais controles, orientações e regras descritas nos demais documentos de regulamentos estarão conectadas a uma diretriz definida nesta Política Principal. As declarações deste documento são estratégicas e, portanto, a expectativa é que este regulamento não será

alterado nos próximos cinco anos.

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) Com base no assunto de acesso lógico à informação e descrevendo um exemplo, teremos neste documento de Política Principal, as seguintes diretrizes: a) É obrigatório que cada usuário do ambiente de informação da organização possua uma identificação e seja autenticado.

b) A identificação e a autenticação do usuário é pessoal e intransferível.

c) A autenticação do usuário é pessoal.

d) O acesso do usuário utilizando recursos da organização é monitorado, registrado e o usuário não deve ter expectativa de privacidade.

4.2.2 Políticas das Dimensões de Segurança da Informação

O Nível 2 da Arquitetura de Políticas e Normas para a Segurança da informação, é composto pelas Políticas das Dimensões da Segurança da Informação que, por sua vez, indicam as diretrizes e as regras para cada Dimensão específica. Neste nível, o documento indica o que se quer e começa a definir como se quer implementar o controle.

Sendo assim, seguindo as dimensões de segurança da informação, teremos os documentos:

- Política Dimensão do Acesso Lógico;
- Política Dimensão do Ambiente Físico;
- Política Dimensão Classificação da Informação;
- Política Dimensão Cópias de Segurança;

- Política Dimensão Conscientização e Treinamento;
- Política Dimensão Continuidade de Negócio;
- Política Dimensão Proteção Técnica;
- Política Dimensão Uso do Correio eletrônico;
- Política Dimensão Uso da Internet;

62

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

- Política Dimensão Uso de Redes Sociais;
- Política Dimensão Equipamentos;
- Política Dimensão Desenvolvimento de Aplicativos e Aquisição de Programas Produto.

Cada organização define exatamente quais são os documentos que serão elaborados para este nível 2. É permitido que se agreguem documentos em um único documento, por exemplo: as políticas das dimensões do uso de internet, correio eletrônico e redes sociais podem ser consideradas uma dimensão. O

importante é que todos os controles considerados na Norma ISO/IEC 27002 sejam contemplados.

Continuando o exemplo do item 2.1, tomando por base o assunto controle de acesso à informação, neste nível 2, teremos as seguintes regras:

- a) Quando a senha for utilizada para a autenticação do usuário, obrigatoriamente ela deve ser formada por uma sequência de caracteres contendo números, letras e pelo menos um caractere especial.
- b) A senha deve ser modificada em cada período máximo de noventa dias.
- c) O arquivo de senhas tem a classificação máxima de rigor em relação ao sigilo da informação.

4.2.3 Procedimentos e outros documentos

O nível 3 é composto por documentos de normas, procedimentos, documentação, fluxos e similar. Neste nível 3 o documento já define como deve ser implementado o controle de segurança.

Continuando o exemplo do item 2.1, tomando por base o assunto controle da informação, neste nível 3, teremos documentos como:

63

*Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com*

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

- Recuperação de senha (usuário esqueceu a senha);
- Lista dos programas produtos homologados pela Organização;
- Lista dos gestores de informação, gestores de ambiente físico.

Havendo necessidade, pode-se ter outros níveis com maior detalhamento.

O importante é que esta arquitetura, estruture os regulamentos e permita que cada organização tenha a solução adequada a sua realidade.

4.3. Desenvolvendo os Regulamentos

Os regulamentos de segurança da informação são específicos para cada organização. Existem conceitos e controles que devem ser considerados por todas as organizações, porém, a forma de implantação, a rigidez dos controles, a abrangência do público que será atingido e a granularidade das regras são específicos de cada organização. A política de segurança da informação deve ser uma consequência de como a organização deseja proteger a sua informação.

Uma organização que tenha uma política fraca de segurança da informação é uma organização, que pelas mais diversas razões, (cultura, ambiente interno, integridade dos executivos, momento, exigência de legislação) não quer proteger adequadamente a sua informação. Todas as organizações, sem exceção, podem proteger adequadamente o recurso informação.

Para desenvolver documentos de políticas e normas de segurança da informação recomendamos que o profissional que recebeu esta missão considere os seguintes temas descritos abaixo. Eles ajudarão para que a criação dos regulamentos aconteça de forma organizada, com consciência, verdadeira, adequada à organização e sustentável ao longo do tempo.

**SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes) 4.3.1. Motivações para a existência da política de
segurança da informação** Para melhor entender a organização que definiu
que deve ter políticas e normas de segurança da informação é conveniente
que seja identificada qual foi a motivação para a existência da Política de
Segurança da Informação.

Conhecendo este motivador teremos mais chances de melhor implementar estes regulamentos, atender mais adequadamente à direção da Organização e também melhor entender o comportamento das pessoas durante o desenvolvimento, implantação e manutenção deste processo.

Uma organização autoriza o desenvolvimento e implantação de políticas e normas de segurança da informação, por algumas destas razões descritas abaixo: **a) Legislação**

A Organização realiza um tipo de negócio que está submetido a leis e/ou que possui um órgão regulamentador que tem poder de sobre todas as

organizações desse segmento de negócio. É mandatório que a Organização siga estas regras (leis, regulamentos) existentes.

b) Exigência do mercado e/ou dos clientes.

Neste caso a Organização não necessita obrigatoriamente atender a uma lei ou um regulamento, porém o próprio mercado começa a ficar mais exigente e começa a considerar como um diferencial as organizações que possuem um processo de segurança da informação que necessita ter um conjunto de políticas, normas e procedimentos. Em muitos casos a demanda por um processo formal de segurança da informação e consequentemente a existência da política de segurança da informação começa com a solicitação de um cliente específico. É a indicação de que o mercado, em que a Organização atua, começa a exigir o processo de segurança da informação nos seus fornecedores.

informação porque as melhores práticas de gestão da informação consideram este fato, e também as diretivas aceitas globalmente, como COBIT, ITIL, Normas internacionais da família ISO 27000 exigem uma política de segurança da informação para cada Organização. Então, esta Organização precisa estar adequada a estas normas e diretivas para que apareça como seguidora das melhores práticas.

d) Avanço tecnológico

A rapidez do avanço tecnológico pode levar a organização a sentir a necessidade de regulamentar o uso de novas tecnologias. Daí a necessidade de se escrever políticas e normas para que se controle o uso destas novas tecnologias que tratam a informação da Organização.

e) Necessidade do negócio

Na essência, esta deveria ser a única motivação para que uma organização desenvolva seus regulamentos de segurança da informação. Evidentemente para considerar esta motivação todas as motivações anteriores devem ser considerados. Eles seriam sub itens desta motivação principal.

4.3.2. O Projeto de Política de Segurança da Informação

Ao desenvolver uma política ou um conjunto de regulamentos de segurança da informação é necessário tratar este assunto como um projeto.

- criar documentação,
- ter acompanhamento das etapas,
- concluir o projeto, e
- compartilhar as lições aprendidas.

Devemos separar bem os conceitos do projeto de regulamentos e os conceitos do processo de segurança da informação. O projeto de elaboração de regulamentos (políticas e normas) tem início, meio e fim, com a característica de termos vários projetos ao longo do tempo. O processo de segurança da informação é único e deve existir durante toda a vida da Organização e até após a vida operacional dela, pois as informações disponibilizadas para o mundo virtual existirão para sempre.

Para elaborar uma política de segurança e seus regulamentos complementares, devemos considerar as seguintes etapas:

a) Inicialização do projeto

a.1 – Objetivo

Nesta etapa devemos descrever o projeto, justificá-lo e declarar o seu objetivo. Estas são as informações básicas para começar um projeto.

a.2 – Escopo

Em seguida, o escopo do projeto deve ser definido. Como estamos tratando de políticas de segurança da informação, a limitação do escopo pode ser referente à abrangência dos documentos que serão gerados e/ou em relação ao

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA

(Edison Fontes) detalhamento do texto destes documentos. Para o primeiro caso, podemos por exemplo, definir que este projeto irá desenvolver a política principal e os regulamentos da Dimensão Acesso à Informação e a Dimensão Continuidade de Negócio. Para a segunda questão devemos esclarecer se os documentos gerados serão políticas, normas e procedimentos, inclusive procedimentos ou padrões técnicos.

a.3 – Restrições

Nesta etapa de Inicialização do projeto é importante que sejam registrados as restrições, isto é, os fatores que podem impactar o projeto e impedir a construção do produto final. Por exemplo podemos registrar sobre este tema o fato de que a participação de gestores das Áreas de Negócio, Jurídica e de Recursos Humanos, é crítica para a construção das políticas e demais regulamentos. Com isto estamos declarando que se estes gestores não

participarem adequadamente, o projeto não terá sucesso no seu objetivo.

Consequentemente, a organização não terá a segurança da informação desejada.

a.4 - Premissas

Também é necessário a definição das premissas que este projeto assume.

Premissas são fatos, situações ou compromissos que são tomados como

existentes. Isto é, existem ou vão acontecer no momento previsto. Por exemplo, uma premissa é que tendo se definido o cronograma de ações, todos os envolvidos no projeto cumprirão os prazos estabelecidos. Outra premissa é que, caso alguma pessoa necessite se afastar do projeto, um outro profissional com o

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA

(Edison Fontes) mesmo grau de conhecimento do anterior, será agregado ao projeto de maneira planejada sem impacto para o cronograma pré-estabelecido.

a.5 – Produto a ser entregue

Finalmente é preciso definir o produto a ser entregue. Esta definição deve ser a mais detalhada possível, no que diz respeito ao produto. Por exemplo, um produto final pode ser o conjunto de dez normas definidas e aprovadas em papel, e outro produto final pode ser dez regulamentos aprovados e divulgados na rede interna da empresa em conjunto com um treinamento dos usuários sobre estes regulamentos.

b) Desenvolvimento do projeto

Para a realização de um projeto de políticas e normas de segurança da informação devemos realizar um levantamento do que existe na Organização ou no grupo de organizações em relação ao tema que estaremos trabalhando para a definição dos regulamentos. Mesmo organizações do mesmo grupo empresarial podem ter políticas e normas de segurança da informação diferentes. Por isso é necessário analisar o que existe e quais são as necessidades. Este conjunto de regulamentos existentes será um orientador para este projeto. É importante que seja identificado se estes regulamentos são de fato seguidos ou são apenas exemplares de documentos que registram regras e neste caso nenhum usuário levará a sério estas recomendações.

O Gestor da Segurança precisa conhecer fortemente as normas de

segurança da informação, especialmente as normas internacionais divulgadas pela ISO/IEC. Baseado nos controles destas normas este profissional irá com a

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA

(Edison Fontes) ajuda das área de negócio, de recursos humanos, de tecnologia da informação, da jurídica e da alta administração definir as políticas e as normas de segurança da informação. Para tanto será necessário fazer um mapeamento para identificar com quais áreas da organização será feita a discussão sobre controles de segurança. Um mesmo controle de segurança da informação é implantado de maneira diferente em organizações distintas. Não existe certo ou errado. Existem implantações coerentes com o que a Organização decide para as suas

informações e seus usuários. Um exemplo simples é o uso de *email* corporativo pelos estagiários. Algumas empresas não permitem, outras permitem mas limitam apenas para uso interno e outras empresa liberam sem restrições. No caso deste controle, as áreas de recursos humanos e jurídica têm forte participação. A área de negócio também deve participar desta definição, pois podemos ter o caso em que a função do estagiário seria comunicar com pessoas internas e externas da empresas, informando o retorno de uma determinada solicitação. Por tudo isto, é necessário planejar e estruturar as reuniões de trabalho deste projeto.

O Gestor da Segurança da Informação deve identificar, considerando as regras da Organização, quais serão as pessoas que assinarão (autorizarão) cada regulamento. Dependendo do porte da organização, eu sugiro que a definição de quem vai aprovar o regulamento (uma pessoa ou duas pessoas) seja validada com o Presidente da Organização ou o Comitê de Segurança, caso este exista. É

possível inclusive gerar um regulamento que formalize os autorizadores para cada documento ou para cada tipo de documento.

Evidentemente, assinar o documento pressupõe que esta pessoa fará a

revisão final. Cada documento a ser gerado precisa ter definido quem será o seu autorizador.

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) Baseado nos levantamentos e nas reuniões de trabalho o Gestor da

Segurança da Informação precisa desenvolver os regulamentos. Após a escrita do texto inicial é necessário e conveniente que este texto seja revisado pelos participantes das reuniões de trabalho referente a cada documento. Esta etapa poderá significar não apenas uma revisão, mas várias revisões e novas reuniões de trabalho. Para esta atividade sugerimos que sejam previstas no cronograma pelo menos duas rodadas de revisões para cada documento, e evidentemente as suas validações. É um parâmetro. Você vai ter que descobrir como será o esforço destas revisões e validações na organização que você atua. Mas, é fundamental, imprescindível e obrigatório que este esforço seja colocado no cronograma do projeto. Após estas revisões ainda resta a revisão do aprovador que também deve ser considerado no esforço e cronograma do projeto. Lembre-se da diferença de horas de esforço (homens/hora) e o tempo de realização para a atividade (datas do calendário).

Todos os documentos gerados devem estar em conformidade com o padrão dos documentos de regulamentação da Organização. Caso a Organização não tenha um padrão, você deve contemplar no esforço e cronograma deste projeto a atividade de definir um padrão para as políticas e normas de segurança da informação.

c) Entrega, comunicação e treinamento do produto final

Após a conclusão da elaboração dos regulamentos e sua aprovação o trabalho ainda não está terminado. Isto é, o projeto ainda não terminou. É

necessário realizar formalmente a entrega, pois para regras que vão legislar internamente a organização é importante a data da implantação de cada um

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes) regulamentos. A partir daquela data as regras valerão para todos os usuários da informação da organização. Todos! Sem exceção!

Mas, se queremos que as políticas e normas de segurança da informação sejam eficazes na organização é necessário realizar uma comunicação formal e efetiva. Todos precisam saber das novas regras. E mais do que isto, todas as pessoas que são consideradas nestes regulamentos precisam ser treinadas nestas novas ou atualizadas regras. Esta comunicação pode ser um simples comunicado enviado pelo correio eletrônico ou um treinamento presencial específico para o tema do regulamento.

Uma organização responsável e que deseja verdadeiramente que as pessoas sigam adequadamente seus regulamentos, precisa planejar o tempo das pessoas para o treinamento, o entendimento, a compreensão e a internalização das políticas e normas de segurança da informação.

d) Definição dos processos de manutenção e atualização

Esta etapa define como acontecerá a manutenção e atualização das políticas e normas de segurança da informação. Na realidade deve existir uma política específica para a manutenção e atualização de regulamentos. Mas, também são necessários documentos mais detalhados indicando, por exemplo, quem é o responsável pela atualização e em que situações específicas deve acontecer uma manutenção.

Tendo definido os processos de manutenção e atualização das políticas e das normas de segurança da informação, este projeto pode se encerrar.

Evidentemente neste momento, um novo projeto contínuo começará: o de

atualização e manutenção destes regulamentos.

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

4.3.3 – Alinhamento aos objetivos da Organização, objetivos do negócio.

A política e demais regulamentos de segurança da informação devem refletir o que a Organização deseja como proteção da informação. Algumas vezes a proteção da informação existe, porém sem o respaldo de políticas e normas.

Neste caso os regulamentos irão documentar a boa cultura da organização em relação à segurança da informação. Porém, em outros casos a organização está completamente sem rumo em termos de proteção da informação e as políticas e normas serão os direcionadores como deve ser a proteção da informação.

O Gestor de Segurança da Informação é o especialista que irá levantar as questões, recomendar controles e identificar os riscos referentes à proteção da informação para a Organização específica. Ele é responsável pela Gestão do Processo de Segurança da Informação. Porém, é a direção e a área de negócio que devem definir o grau de rigor (rigidez) que devem ter os controles de segurança da informação. Por exemplo, o Gestor da Segurança da Informação deve levantar a questão do controle referente a guarda de informação (registros de acesso e cópias de informação). O Gestor da Informação (que deve ser da área de negócio) é quem deve indicar o tempo de armazenamento. Ele tem a responsabilidade de saber qual legislação e regulamentos internos da organização que são obrigatórios de serem cumpridos. Inclusive porque esta definição exigirá que os custos para o desenvolvimento e implantação desses controles sejam de responsabilidade da área de negócio. A partir desta definição a Área de Segurança da Informação e no caso de informação no ambiente computacional, a Área de Tecnologia da Informação serão

responsáveis pela gestão desses controles e da existência da informação durante o tempo definido. Se o Gestor da Informação determinou que uma informação precisa permanecer utilizável por 50

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) anos, a Área de Tecnologia da Informação irá buscar a melhor solução para este armazenamento, inclusive considerando a necessidade da troca do tipo de mídia em função do fato da mídia original deixar de existir.

Para construir a política considerando este alinhamento, o Gestor da Segurança da Informação conta com a Norma NBR ISO/IEC 27002 que define controles que precisam e devem ter a participação das direções da Organização e das áreas de negócio.

No Anexo 1 são descritos os controles da Norma 27002 que devem ser a base dos controles de segurança da informação da Organização. Estes controles deverão ser considerados para a elaboração dos regulamentos (políticas e normas) de proteção da informação Organização.

Os controles que existirão definidos na política e normas de segurança da informação devem ser resultados do desejo de proteção da Organização para a sua informação. A figura abaixo indica esta situação. Primeiramente o mais importante é o conjunto de objetivos da organização. Deve ser o início de tudo.

Em seguida devemos definir os objetivos da segurança da informação que deverão atender os objetivos da organização e se materializam pela definição dos requisitos de segurança. Sabendo que requisitos de segurança da informação são necessários para a Organização, podemos desenvolver e implantar os diversos tipos de regulamentos, cada um com sua característica de conter mais políticas (diretrizes) ou conter mais ações detalhadas (normas,

procedimentos).

Existindo todo este conjunto de regulamentos, os serviços, produtos e demais atividades da organização serão realizados alinhados à segurança e aos objetivos de negócio da organização. Além do que a segurança acontecerá pela ação do usuário. Estes dois últimos blocos, Desenvolvimento de serviços e

74

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***



SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

usuário, precisam ser submetidos a controles constantes, de gradação adequada ao negócio e objetivos da Organização.

Figura 4.3– Sequencia para a segurança ser realizada pelo usuário

Fonte: Livro Políticas e Normas para a Segurança da Informação, Fontes (

2012)

4.3.4. Desenvolvendo a Política e as Normas de Segurança da Informação

O desenvolvimento de políticas e normas de segurança da informação possui os seguintes objetivos:

a) Declarar, explicitar e registrar as regras

A organização precisa formalizar as regras que deseja que sejam seguidas por todos que utilizam a sua informação ou os seus recursos de informação.

Somente escrevendo e publicando o que deseja que seja realizado quando do acesso e uso da informação, é que a organização terá chances de conseguir que estas regras serão cumpridas.

75

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA

(Edison Fontes) Em muitas organizações de porte pequeno e médio, existem regras que não estão escritas e que (às vezes) funcionam bem. Nestes casos, a organização tem uma cultura forte, os funcionários trabalham na organização há muitos anos e praticamente não há rotatividade de pessoal. Mas, esta não é uma maneira profissional de tratar o assunto de proteção da informação.

Mesmo empresas de menor porte devem ter suas políticas e normas de segurança da informação definidas. Evidentemente a sofisticação técnica da implementação dos controles deve ser diferente em relação a uma grande organização. Além do que, pequenas e médias empresas crescem e, mais do que nunca, precisam ser profissionais para atender e continuar no mercado, que cada vez é mais exigente e submetido a regulamentações.

b) Definir obrigações, responsabilidades e autoridades

Ao definir os controles e regras a organização indica como quer que a informação seja tratada. Mas, é necessário indicar quem vai ser responsável

pelo que. O que é obrigação de determinada pessoa, cargo ou área. Também é necessário definir quem tem autoridade para aprovar as políticas, as normas e os procedimentos.

Os regulamentos de segurança da informação devem explicitar as obrigações, responsabilidades e o poder de autorização.

c) Definir e formalizar padrões e procedimentos

A construção de regulamentos de segurança da informação define padrões e procedimentos que devem ser seguidos por todos. Seja uma questão estrutural, como por exemplo a definição de que a identificação do usuário será individual, como uma definição de procedimento de atividades, como por exemplo o que

76

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) deve ser feito quando um usuário esquecer a sua senha utilizada para sua autenticação para acesso à informação da organização.

Padrões e procedimentos permitem que todos os usuários seguirão da mesma forma o que deve ser feito para atender os controles definidos para a segurança da informação.

Ao se definir estes padrões e procedimentos devemos ter em mente que alguma situação de exceção poderá não ser prevista, porém acontecerá. É

praticamente certo que este fato acontecerá. Mas, não vamos conseguir ao definir padrões e procedimentos, considerar todas as situações possíveis e coloca-las no normativo. Desta maneira sugiro que você considere o que for possível e razoável de definir e implantar, e considere no regulamento o que deve ser feito se uma situação de exceção acontecer. Quem se deve procurar, o que deve ser feito, o que deve ser registrado e outras definições.

Em resumo, com a definição de padrões e procedimentos que todos devem seguir, acabamos com a situação de utilizar o “achômetro”, onde cada pessoa pode definir o que deve fazer e como fazer em determinada situação, simplesmente porque ela assim “achava”.

d) Fornecer informações para os usuários

Os regulamentos de segurança da informação formalizados e publicados permitem que o usuário consulte como ele deve agir em determinadas situações quando estiver tratando com a informação ou com os recursos de informação. A situação contrária acontece quando não existem regulamentos escritos e o usuário tem que perguntar a outro usuário (chefe, colega, subordinado, o guarda da esquina), como deve proceder em determinada situação.

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA

(Edison Fontes) As políticas e normas de segurança da informação ao serem publicadas precisam estar em local (físico ou virtual) de fácil acesso. Pouco adianta uma Organização ter regulamentos de segurança da informação se os usuários (funcionários, prestadores de serviço, estagiários, diretores, conselheiros, outros) não souberem achar estas regras e recomendações. Um erro que muitas organizações cometem é acreditarem que somente porque o regulamento está no portal (ambiente de tecnologia) da empresa tudo está resolvido. Ela precisa estar no mundo virtual, seja no portal da empresa, no portal de segurança ou em outro local virtual, mas, o mais importante é que o conjunto de políticas e normas de segurança da informação seja de fácil acesso. Caso contrário todo o esforço de desenvolvimento e implantação terá sido desprezado e a organização será equivalente a uma organização que não possui estes regulamentos. Não basta ter os regulamentos, é preciso que os usuários saibam da sua existência, acessem, leiam, entendam e cumpram. Você conhece os regulamentos da sua organização?

e) Ajudar a educar e treinar as pessoas

O treinamento, educação e conscientização das pessoas em segurança da informação é uma dimensão importante no programa de proteção da informação.

Ela tem que ser planejada, executada e ter continuidade de ações (sustentabilidade). Porém, é fator crítico de sucesso para a educação do usuário em segurança da informação, a existência de políticas e normas sobre o assunto.

Quando se realiza um treinamento de segurança da informação com o usuário, deve-se explicar ao usuário o porquê das medidas e controles que a organização está implantando. Mas, isto significa que estas políticas e normas precisam existir previamente na organização, estarem publicadas e serem de conhecimento dos usuários.

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes) 4.3.5. Premissas para uma existência efetiva de políticas e normas Existem alguns simples, mas importantíssimos pré requisitos para que as políticas e normas funcionem adequadamente e cumpram sua missão na organização.

a) Apoio verdadeiro e patrocínio explícito da direção

A direção da organização, cristalizando-se pelos seus executivos precisa querer, acreditar e apoiar verdadeiramente o processo de segurança da informação. As políticas e normas serão uma maneira de explicitar que a direção deseja que a informação seja adequadamente protegida. As ações da Alta Direção devem ser explícitas e devem ser divulgadas com todas as pessoas da organização. Evidentemente o exemplo verdadeiro e transparente de cada executivo está implícito neste apoio ao processo de segurança da

informação.

b) As políticas e normas devem representar a verdade da Organização

Os regulamentos de segurança da informação são documentos que indicam como a organização deseja que este recurso seja tratado. Os regulamentos não devem ser documentos que serão armazenados e esquecidos em um portal ou em uma pasta de uma estante qualquer. Os regulamentos devem conter o que verdadeiramente a organização deseja para os seus recursos de informação. Fazer de conta que existe proteção porque está escrito é um tratamento que levará a organização a uma fragilidade, a uma existência crescente de vulnerabilidades e a um caos organizacional.

c) As políticas e normas devem definir controles possíveis de serem desenvolvidos e implantados.

Objetivo / Porque

Escopo

Definições / Glossário

Regras

Responsabilidade

Cumprimento

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

As regras e controles descritos nos regulamentos de segurança da informação devem ser possíveis de serem implantados na organização. Não podemos definir regulamentos, controles que nunca serão implantados.

Evidentemente haverá ocasiões que controles e regras podem estar definidos mas a organização ainda não os têm funcionando. Mas esta situação deve ser tomada como um caminho a ser seguido e deve-se ter como objetivo, o desenvolvimento de projetos para atender estes controles e estas regras.

4.3.6. Desenvolvendo políticas e normas de segurança da informação

Com certeza você já leu algum documento que teve muita dificuldade para entendê-lo. Você começa a ler, termina e fica com muitas dúvidas.

Com o objetivo de melhorar o seu entendimento, cada documento deve ter alguns blocos de informação. Descrevemos na figura abaixo os blocos mínimos que todo documento de regulamento de segurança da informação deva possuir.

Figura 4.4.– Estrutura documento *Fonte: Livro Políticas e Normas para a S.I., Fontes (2012)*

80

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) a) Objetivo do documento

Neste bloco é indicado o objetivo do documento, o que é o documento, o que a organização deseja comunicar com este documento. Neste ponto quando o usuário ler o documento deve ficar sabendo o assunto tratado no documento e o seu grau de detalhamento (granularidade das ações)

Também neste bloco deve ser indicado a aderência ou alinhamento deste documento com outros regulamentos, legislação, normas e estruturas de tratamento de informações e projetos.

Pode-se neste ponto indicar as razões da existência da política ou da norma.

Não se deve descrever uma aula sobre o tema, no caso segurança da informação. Políticas e normas têm como objetivo comunicar para os usuários o que a organização deseja para o tratamento do recursos de informação. Pela política ou norma a organização indicará o que é obrigatório, o que é proibido e o que é desejável ser feito. Explicar em demasia sobre segurança da informação deve ser feito em um outro documento, tipo cartilha e também nos treinamentos e conscientização dos

usuários. Não é na política ou na norma que o usuário deverá aprender sobre a teoria da segurança da informação.

b) Escopo do documento

Aqui deve-se indicar os ambientes físicos, os ambientes lógicos, os tipos de usuários, as regiões geográficas ou outras definições que indicam os limites da aplicação do documento e das regras.

Este bloco indica para quem e para quais ambientes organizacionais as regras serão aplicadas e serão exigidas.

Cada vez mais a linha de separação entre a vida profissional e a vida pessoal do usuário fica mais tênue. Neste bloco pode ser indicado se as

81

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes) recomendações escritas no documento também valem para a vida pessoal do usuário.

Outras limitações tipo tempo de validade do regulamento pode ser indicado neste bloco. Alguns padrões de documentos possuem esta informação no seu padrão de documento. Neste caso deve-se seguir o padrão de documentos da organização. As políticas e normas de segurança da informação devem ser documentos como os demais regulamentos sobre os vários assuntos e ambientes da organização.

c) Definições ou Glossário

Neste bloco estrutural do documento deverão estar definidos os termos específicos, as abreviaturas, os termos técnicos, os nomes-siglas de entidades, os nomes-siglas de áreas organizacionais, as palavras, as siglas não comuns para os usuários e outros termos utilizados no documento, mas que precisam de uma explicação porque não é de conhecimento comum para todos os

leitores.

Quando escrevemos políticas e normas, sempre nos vêm uma dúvida, principalmente após termos escritos alguns documentos: Estas definições devem compor todos os documentos ou deveria compor um documento específico e comum para todos os demais documentos?

Ter estas definições em cada documento tem a vantagem de facilitar a consulta. Por outro lado, tem a desvantagem de ficar repetido em vários documentos e com o passar do tempo, ao ser necessário uma melhoria ou correção da definição podemos cometer o erro de alterar apenas em alguns documentos. Teremos uma não integridade da informação.

Colocar todas as definições em um único documento de glossário, tem a vantagem de termos a definição de cada termo em um mesmo local dando maior

82

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes) garantia de integridade dessas definições. A desvantagem desta opção seria a maior dificuldade em realizar consultas.

A utilização de documentos eletrônicos e o uso de *hiperlinks* facilitam estas consultas pelos usuários. Mas, na maioria das vezes teremos que ter obrigatoriamente o regulamento em papel, em função de auditorias externas ou certificações corporativas.

Recomendo, então, que você comece a desenvolver as políticas e normas e coloque as definições em cada documento. Na medida em que a organização for criando os novos regulamentos, caso a quantidade de termos necessários de definições seja crescente e muito grande, sugiro que seja criado um documento de glossário que fará parte dos conjunto de regulamentos de segurança da informação.

d) Regras

Este bloco contém as orientações, as regras que a Organização deseja que todos os usuários cumpram. Este bloco é a essência do documento.

Neste bloco a Organização indicará:

- O que deve ser feito
- O que é obrigatório a ser feito
- O que não se pode fazer
- Os princípios que se deseja que sejam seguidos.

As regras não podem deixar dúvidas para os usuários. Se precisar ser redundante para ser melhor compreendido, seja redundante.

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) e) Responsabilidades

Neste bloco devem ser definidas as responsabilidades referentes ao documento. Não se trata das responsabilidades em relação às regras. Isto deve estar definido no bloco das regras. Neste ponto deve-se indicar o responsável:

- pela atualização, revisão e manutenção do texto do regulamento,
- pelo treinamento necessário para que os usuários tenham capacidade de cumprir o regulamento,
- pela divulgação do texto para os usuários, e
- por outras ações necessárias para garantir que o documento será

sempre verdadeiro, atualizado, possível de ser cumprido e de conhecimento de todos.

Recomendamos que ao definir responsabilidades seja indicado cargos ou áreas. Indicar nomes é válido, porém, poderá gerar uma necessidade de atualização constante sempre que acontecer alteração de pessoas. Analise a situação da sua organização, suas características e sua rotatividade de pessoal.

Depois, decida como entende que é a melhor maneira de se declarar na política ou norma. Minha recomendação básica é pelo uso do cargo ou da área organizacional.

f) Cumprimento

Neste bloco devem estar explícitas as possíveis penalidades (gerais ou específicas) caso o usuário não cumpra adequadamente as regras descritas no regulamento. Deve-se indicar o comportamento que será inaceitável para a organização.

Neste bloco também deve ser indicado o procedimento do usuário em caso de erro, em caso de dúvidas ou em situações que não estejam previstas no documento.

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) 4.3.7. Escrevendo o texto do documento

O texto a ser escrito nas políticas e normas de segurança da informação deve ser agradável e de fácil entendimento. Ninguém gosta de ler um documento complicado e que é necessário reler várias vezes um parágrafo para compreendê-

lo. Não deve ser neste texto que você ou seja lá quem for que estiver

elaborando as políticas e normas de segurança da informação devem colocar um vocabulário sofisticado. Não é hora de demonstrar seu conhecimento da linguagem sofisticada. O texto destes regulamentos deve ser simples, sem ser simplório.

Deve ser como uma boa conversa respeitosa, porém amigável e de boa comunicação.

O texto desenvolvido deve ser capaz de ser entendido por todos na organização. Uma questão prática é a utilização de termos em língua estrangeira, normalmente o inglês. Termos como *backup*, *signon*, *sigoff*, *boot*, *mouse screen saver* e outros fazem parte do dia a dia de muitas pessoas. Devemos ser inteligentes quando da solução desta questão. Considere a organização e o público alvo que lerá estes regulamentos.

Inicialmente é bom lembrar que todo documento de regra e procedimento em empresas brasileiras deve ser escrito em português. Pode até ser uma simples tradução do texto original em inglês. Em muitas situações existem questões legais que obrigam o texto em português.

Considerando que em segurança da informação queremos comunicar ao usuário as regras da Organização em relação à informação e aos recursos de informação recomendamos que escreva tudo em português. Alguns termos em inglês já fazem parte do cotidiano e ficam estranhos à tradução. Por exemplo, *mouse*, traduzir por rato não faz o menor sentido. Mas, o termo *backup*, podemos muito bem traduzir para cópia de segurança sem nenhum problema.

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes) Desta maneira segue uma recomendação que possibilitará o sucesso dos regulamentos de segurança da informação: escreva para o seu público. Considere os usuários que irão ler o documento. Qualquer pessoa que for destinatária do regulamento de ter condições de ler o regulamento e

não deve ter dúvidas após a leitura. Seguindo esta linha, caso você esteja escrevendo ou ajudando a escrever um documento técnico, pode utilizar muito mais palavras originais em inglês do que o procedimento de solicitação de nova senha que será utilizado por todos os usuários. Neste regulamento técnico seria muito estranho traduzir *Firewall*, *IDS*

ou outro termo usado pelos técnicos e que ficará restrito a este grupo técnico.

Ao escrever, sendo possível tenha uma mensagem mais positiva do que negativa. Porém eu chamo atenção aqui para a situação em que ao não quisermos colocar um “não”, escrevemos muitas linhas, damos muitas voltas e no final não comunicamos claramente. Neste caso é melhor dizer um “não” explicitamente.

Tipo, “O Operador de máquina industrial não pode acessar a Internet durante o expediente. Poderá fazê-lo nos intervalos de descanso ou na hora do almoço”. Ou podemos usar a opção: “É proibido o Operador de máquina industrial ...”

O texto da norma não deve ser grosseiro nem desrespeitoso. Deve ser firme e obrigatoriamente deve indicar o que é proibido e o que não é proibido. Em muitos textos usa-se o “deve” ou “não deve” e fica-se na dúvida. No exemplo acima, se o texto fosse “O operador de máquina não deve acessar a Internet durante o expediente. Poderá fazê-lo nos intervalos de descanso ou na hora do almoço.”. Ficarà uma dúvida: não deve, mas se acessar não estará cometendo nenhuma infração. Então não deve, mas pode.

Este tema acima nos leva a um outro cuidado: se o texto tiver a possibilidade de ser mal interpretado, será mal interpretado. Tenha certeza disto.

Algumas vezes por uma verdadeira não compreensão. Outras vezes por pura má fé e por interesses criminosos. Isto significa que devemos escrever

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA

(Edison Fontes) explicitamente, mesmo que isto nos leve a ser repetitivos. Ou aparentemente repetitivo. Um exemplo este tipo de problema é o jornalista que vai colocar a manchete no jornal e indica: “Policial prendeu o ladrão na casa dele!” Parabéns ao policial, mas tenho pena do leitor. Ficará sem saber se o ladrão foi pego na casa do policial ou na casa do próprio ladrão. Se fosse a primeira situação a manchete teria que ser “Policial prende o ladrão na casa do próprio policial”.

Muito policial para pouca frase? Concordo! Faça um exercício e tente escrever melhor mas sem deixar dúvidas. Devemos sempre que possível escrever pouco.

Mas, não devemos temer em escrever muito se isto vai facilitar a leitura do usuário sobre as regras de segurança da informação.

Não esqueça de utilizar frase curtas. Mas, evidentemente que passem a mensagem corretamente. Utilize o estilo conversação. Se você for o Gestor da Segurança da Informação, seria como o usuário estivesse ouvindo você falar de segurança da informação para ele em uma conversa em reunião de trabalho.

Tendo esta compreensão, os documentos de políticas e normas garantem (ou tentam garantir) que todos os usuários vão ter o mesmo comportamento quando diante de uma mesma situação ou problema.

Ao escrever regras não esqueça de citar o que o usuário deve fazer caso ele tenha uma determinada situação que não foi considerada no documento específico ou nos demais documentos. É uma situação de exceção e o usuário precisa saber o que fazer. Neste caso o usuário sabendo o que fazer, mesmo que seja ligue para determinada área e peça instruções, a possibilidade de fazer de uma maneira desastrosa diminui. Além do que, ninguém é perfeito e realmente o documento pode ter deixado de considerar uma determinada situação. Neste caso tendo uma comunicação do usuário, o responsável pela política ou norma saberá desta situação e poderá gerar uma nova versão do documento já considerando a

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) situação de exceção identificada, que se tornará uma situação prevista no regulamento.

A texto de um política norma deve dizer o que deve ou não deve ser feito.

A teoria sobre segurança da informação deve ser deixada para outros documentos.

Não se acanhe e diga no regulamento o que é preciso dizer. Porém diga corretamente em espírito da mensagem e no texto da mensagem. Exija uma revisão de português por um especialista.

Cada documento deve tratar de um assunto com um determinado escopo.

Uma dúvida para quem está escrevendo políticas e normas de segurança da informação é se o que está escrevendo é uma política ou uma norma e (se sendo o que for) como deve juntar ou separar assuntos. Exemplo: devo construir uma norma para correio eletrônico e outra norma para Internet? Esses dois assuntos vão ter recomendações bem parecidas.

Minha sugestão é que na medida em que os controles e recomendações serão os mesmo, podemos agrupar em um mesmo documento esses assuntos e ambientes. Quando são bem diferentes convém construirmos dois documentos.

Um mesmo assunto em um mesmo nível de detalhamento pode exigir documentos diferentes. Se considerarmos a questão do acesso físico da empresa que possui dois ambientes: um bem antigo e outro com a melhor sofisticação técnica. Provavelmente neste caso as normas de acesso físico de cada ambiente devam ser diferentes.

Buscar um texto simples deve ser o seu direcionamento quando estiver escrevendo políticas e normas de segurança da informação. Tenha certeza: se o texto ficar complicado vai gerar mais treinamento e a possibilidade de erros

crece pois o usuário não saberá o que fazer em certas ocasiões,

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA

(Edison Fontes) Os documentos gerados devem ser tão curtos como possíveis. Por isto sugerimos neste capítulo 11 uma arquitetura para as políticas, normas e procedimentos de segurança da informação. Nesta estrutura quanto mais alto o nível, mas simples e curto deve ser o documento. A política principal deve dizer a filosofia da organização para o uso e tratamento da informação.

Escrever o texto de uma política ou norma de segurança da informação não é a primeira etapa deste trabalho de construção de regulamentos de segurança da informação. Ele vai espelhar o que a Organização deseja, e para que isto aconteça a Organização deve ter sido questionada e deve ter respondido questões sobre controles de segurança da informação.

Desta maneira ao iniciar o processo de escrita, reúna todo o material de levantamento, organize este material e crie um comitê de revisão. Se este nome estiver pomposo demais para a sua organização crie um grupo para a revisão do regulamento. Neste grupo inclua o RH, o Jurídico, a Área de Negócio e outra área que você julgar necessária para o sucesso das políticas e normas de segurança da informação.

4.3.8. A definição dos controles a serem considerados

A construção das políticas e normas de segurança da informação deve ser conduzida pelo Gestor da Segurança da Informação ou por um Consultor. Muitas pessoas, inclusive alguns gestores, pensam que o Gestor de Segurança da Informação ou o Consultor, trarão um conjunto de políticas e normas prontas.

Afinal de contas eles já fizeram isto em outras organizações.

Os controles a serem exigidos e considerados nos regulamentos de segurança da informação da organização, bem como a rigidez que será considerada, depende de como a organização, de como a Alta Direção, de como as áreas de negócio desejam a proteção da informação da sua organização. O

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA

(Edison Fontes) Gestor de Segurança ou o Consultor encarregado do projeto de construção das políticas e normas farão questionamentos sobre controles ou a maneira de controlar. Por exemplo: estagiário terá conta de correio corporativo da organização? E os prestadores de serviço? Estas respostas obrigatoriamente devem ser dadas pelos gestores da organização.

O Grupo de Construção das Políticas e Normas de Segurança da Informação será coordenado pelo Gestor de Segurança da Informação ou por um Consultor e deverá ter participantes principais que serão os profissionais da organização ligados ao tema, considerando o nível de granularidade dos controles ou diretrizes. A política principal de segurança da informação que deve ser assinada pelo presidente da organização ou aprovada pelo Conselho de Administração, deve ter seus assuntos definidos com os executivos da Organização.

Em praticamente na revisão de todas as políticas e normas, os gestores (ou seus representantes) da Área de Recursos Humanos e da Área Jurídica devem participar. Recursos Humanos deve participar porque muitas questões que aparentemente são de segurança, são realmente de pessoas, de criação de cultura e de clima organizacional. Ter acesso pessoal à Internet não é um problema da Área de Segurança da Informação. É uma questão de facilidade e benefício que a organização disponibiliza para os seus funcionários, prestadores de serviço e demais colaboradores. É uma questão da maneira da pessoa trabalhar na organização. É uma questão sobre pessoas e requer definições da Área de Recursos Humanos.

A Área Jurídica obrigatoriamente deve participar da construção das políticas e normas de segurança da informação, porque alguns controles, ou a falta de determinados controles, ou a maneira de escrita do texto pode trazer risco jurídico para a Organização. Neste caso, o posicionamento da Área Jurídica é

90

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) fundamental para que as políticas e normas de segurança da informação sejam criadas e publicadas de maneira proveitosa para a organização e sem risco de desrespeitar a legislação em vigor.

Este processo de construção de políticas e normas de segurança da informação deve chegar a uma primeira versão do normativo.

Com esta primeira versão deve-se fazer um Painel de Revisão. Algumas organizações já possuem uma estrutura tipo Comitê de Gerentes, onde todos os normativos que serão publicados, passam por este comitê, pois os gerentes formam o conjunto de colaboradores que mais influenciaram os demais funcionários e prestadores de serviço a colocarem em prática os regulamentos.

Um Comitê deste tipo pode levantar questões que na teoria estão completamente corretas mas que terão dificuldades práticas de serem implantadas ou mantidas.

Neste Painel de Revisão podemos ter a participação de áreas que serão afetadas pelos regulamentos ou que considerando a estrutura organizacional são importantes serem envolvidas. A formação deste Painel de Controle é uma implementação específica para cada organização, inclusive para cada momento da organização. Em momentos diferentes, seus participantes podem ser diferentes.

Após esta revisão é que os documentos de políticas e normas de segurança da informação devem ser submetidas à pessoa ou ao órgão, tipo Comitê de

Segurança da Informação para ser aprovado. Mas, nem todos os regulamentos precisam ser aprovados por este comitê. Por exemplo, normativos técnicos podem ser assinados pelo Gestor da Tecnologia da Informação. Estas regras de poder para assinar determinados documentos deve seguir o padrão utilizado pela organização em relação aos seus demais regulamentos.

Lembrando que o padrão do documento de política ou de norma deve seguir o padrão que a Organização utiliza para os seus demais regulamentos.



SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes)

**5. DIMENSÃO GESTÃO DE
RISCOS DE SEGURANÇA DA
INFORMAÇÃO**

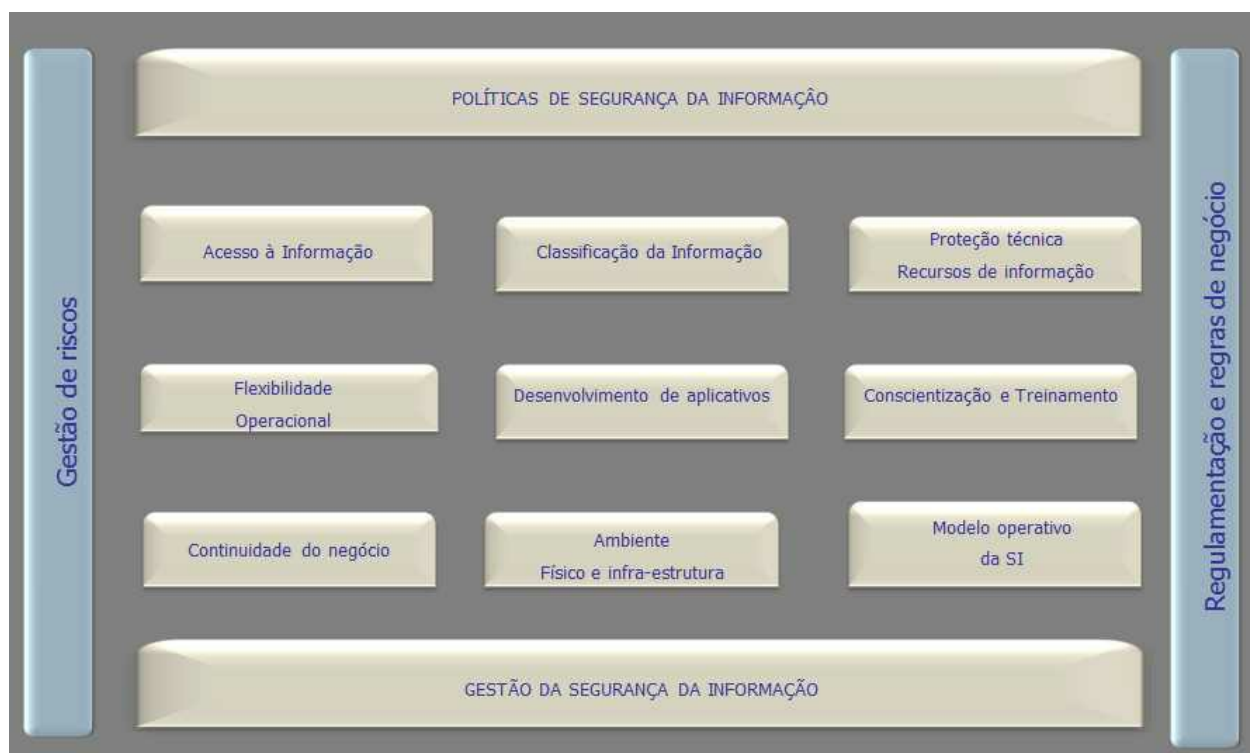
Foto: Edison Fontes. Escultura e Pintura. Ilha de Itamaracá, Brasil

Neste Capítulo apresentaremos a Dimensão Gestão de Riscos em Segurança da Informação e a sua participação no Programa Organizacional de Segurança da Informação.

Após a definição do conjunto de regulamentos que formam a Política de Segurança da Informação é necessário a implementação dos controles das Dimensões da Segurança da Informação. A Dimensão Gestão de Riscos em Segurança da Informação é uma destas dimensões. Recomendamos que após a implantação das políticas e normas de segurança da informação seja realizada uma avaliação da efetividade dos controles definidos nos regulamentos. A figura abaixo apresenta as Dimensões de Segurança da Informação.

92

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***



SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

Figura 5.1 – Dimensões da Segurança da Informação

Fonte: Livro “Praticando a Segurança da Informação” (FONTES, 2008, p. 48).

A Norma ABNT NBR ISO/IEC 27005 – Tecnologia de segurança –

Técnicas de segurança – Gestão de riscos em segurança da informação indica claramente que a Gestão de Riscos faz parte da Gestão da Segurança da Informação:

Convém que a gestão de riscos de segurança da informação seja parte integrante das atividades de gestão da segurança da informação e aplicada tanto à implementação quanto à operação cotidiana de um SGSI (Sistema de Gestão de Segurança da Informação).

[..] Convém que a gestão de riscos de segurança da informação seja um processo contínuo (ABNT, 2008, p.3).

93

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

[..] Convém que a organização e as responsabilidades para o processo de gestão de riscos de segurança da informação sejam estabelecidas e mantidas (ABNT, 2008, p.9).

A seguir apresentamos os objetivos da Dimensão Gestão de Riscos da Segurança da Informação, em seguida descreveremos os principais conceitos e suas definições e, na sequência, comentaremos a atividade de Gerenciamento de Riscos que considera a Análise e a Avaliação de Risco.

Neste último tópico apresentaremos um exemplo utilizando estes conceitos.

5.1. Objetivo da Dimensão Gestão de Riscos de Segurança da

Informação

Gestão de Riscos é o Conjunto de “atividades coordenadas para dirigir e controlar uma organização no que se refere a riscos” (ABNT, 2009, p.2).

A Gestão de Riscos em Segurança da Informação é uma Dimensão do Programa Organizacional de Segurança da Informação e considera os controles relacionados à informação ou aos recursos de informação.

O objetivo principal da Gestão de Riscos de Segurança da Informação é minimizar os riscos que permitem que ameaças interfiram na utilização, pelos usuários, da informação ou dos recursos de informação para o atendimento aos objetivos corporativos.

Os objetivos complementares da Gestão de Riscos de Segurança da Informação são:

a. Facilitar o planejamento baseado na priorização das ações necessárias para a segurança da informação.

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA

(Edison Fontes) b. Alinhar o planejamento de segurança da informação com as diretrizes da organização.

c. Explicitar o apetite de risco para a segurança da informação e a responsabilidade por parte da direção da organização ao definir: minimizar, assumir, transferir ou evitar os riscos.

d. Formalizar e gerar justificativas estruturadas para a priorização das ações

de segurança.

- e. Formalizar as ameaças que são consideradas na avaliação de riscos.
- f. Definir as responsabilidades dos envolvidos.
- g. Comunicar mais facilmente aos envolvidos, como a organização trata seus riscos de segurança da informação.
- h. Possibilitar a participação de um maior número de pessoas na análise e avaliação de riscos.
- i. Possibilitar um acompanhamento do estado de risco dos recursos relacionados à segurança da informação ao longo do tempo.
- j. Possibilitar a implantação gradual da Gestão de Riscos de Segurança da Informação na organização.

A Gestão de Riscos deve ser um processo e deve ter um escopo definido, como recomenda as Normas NBR ISO/IEC:

Convém que a gestão de riscos de segurança da informação seja um processo contínuo (ABNT, 2008, p.3).

Convém que a análise/avaliação de riscos de segurança da informação tenha um escopo claramente definido para ser eficaz (ABNT, 2005, p.6).

Ao realizar a Gestão de Riscos em Segurança da Informação, deve-se garantir que os principais recursos (ativos) de informação estão sendo considerados, conforme exige a Norma NBR ABNT ISO/IEC 27001:2013:

O escopo do processo de gestão de riscos de segurança da informação precisa ser definido para assegurar que todos os ativos relevantes sejam considerados na análise/avaliação de riscos. Além disso, os limites precisam ser identificados para permitir o reconhecimento dos riscos que possam transpor esses limites (ABNT, 2013, p.8).

Peltier (2001, p.17) sintetiza que “o gerenciamento de risco permite a organização colocar foco nos seus objetivos e na segurança da informação”. Ele complementa:

Um importante fator para o sucesso na implantação de um processo de segurança da informação é implantar uma completa arquitetura de gerenciamento de risco. Esta arquitetura deve estar conectada as políticas e padrões de segurança da informação e deve direcionar o risco para o negócio em um ambiente automático e continuo (PELTIER, 2001, p.17).

Para executar a Gestão de Riscos é necessário definir um conjunto de ameaças que podem impedir que os controles considerados protejam adequadamente a informação.

Desta maneira as organizações devem primeiramente considerar para o seu processo de segurança da informação, os controles

Uma tendência que muitas vezes acontece, é considerar um conjunto muito grande e diversificado de ameaças. É uma ação de boa intenção, mas não é profissionalmente recomendada, não é realisticamente adequada.

Evidentemente ao longo do tempo deveremos considerar todas as ameaças possíveis. Porém, para cada avaliação de riscos este conjunto deve ser bem limitado de maneira a tornar possível a avaliação e a realização de ações para minimizar os riscos.

Considere a ameaça ou as ameaças que possuem uma maior probabilidade de acontecer.

5.2. Elementos de para o Gerenciamento de Riscos

Ameaças, Riscos e Contramedidas são os elementos básicos para o Gerenciamento de Riscos (análise e avaliação de riscos) de Segurança da Informação. É muito importante que você entenda o conceito de cada um deles.

O Anexo 2 contém uma lista mais completa de definições,

5.2.1. Ameaça

Ameaça é um evento que “tem o potencial de comprometer ativos (tais como informações, processos, sistemas) e, por isso, também as organizações.

Ameaças podem ser de origem natural ou humana e podem ser acidentais ou intencionais” (ABNT 27005, 2008, p.11).

As ameaças podem ser identificadas de maneira discreta e individual, ou também por classe. Dependendo do esforço disponibilizado, o tratamento das ameaças terá uma maior ou menor granularidade.

(Edison Fontes) É necessário compreender que a Ameaça existe, independente de considerarmos ela no escopo do nosso trabalho ou não. Ela pode ter uma pequena possibilidade de acontecer e podemos definir que ela estará fora do escopo, mas, mesmo assim, ela existe.

O primeiro passo no Gerenciamento de Riscos em Segurança da Informação é a identificação e definição das ameaças que serão consideradas.

Experiências internas de incidentes e avaliações anteriores de ameaças são uma boa base para o começo da análise e avaliação de riscos (ABNT 27005, 2008).

Não se deve esquecer que as ameaças relevantes estão sempre mudando, sendo assim, trabalhos anteriores ou catálogos de ameaças ajudam no trabalho, porém precisam ser sempre revalidadas e atualizados constantemente.

Exemplo de ameaças:

- Roubo de informação.
- Perda de *pen drive* contendo informação confidencial.
- Acesso de usuário não autorizado.
- Indisponibilidade das pessoas chegarem ao trabalho por causa de chuva e alagamentos.
- Falta de energia da concessionária para o ambiente físico dos servidores.

Para facilitar, podemos agrupar as ameaças por assuntos/tipos correlatos, por exemplo, a ameaça da indisponibilidade do ambiente computacional provocada por desastres naturais. Podemos não detalhar chuva, alagamento, enchentes, descarga elétrica ou similar.

Edison Fontes, edison@pobox.com

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA

(Edison Fontes) 5.2.2. Risco

Risco é a “probabilidade ou possibilidade de uma determinada ameaça explorar vulnerabilidades de um ativo (recurso), desta maneira prejudicando a organização” (ABNT 27005, 2008, p.1). Simplificando, risco é a probabilidade de uma ameaça se concretizar. Na maioria das vezes em conversa coloquial, chamamos de risco o resultado final da probabilidade com o impacto, que veremos mais adiante.

A identificação desta probabilidade (risco) pode ser realizada por duas metodologias: estimativa qualitativa ou estimativa quantitativa.

A estimativa qualitativa utiliza uma escala com atributos qualificadores que descrevem a magnitude das consequências potenciais (por exemplo Média, Pequena e Grande) e a probabilidade destas consequências ocorrerem (ABNT, 27005, 2008, p.14) [...]

A estimativa quantitativa utiliza uma escala com valores numéricos tanto para as consequências quanto para a probabilidade (ABNT, 27005, 2008, p.14).

Como exemplo, vamos considerar a estimativa qualitativa.

a. Probabilidade Alta

- Grande probabilidade de acontecer.
- Já aconteceu.
- Se não aconteceu, foi sorte.

b. Probabilidade Média

- Em condições normais pode acontecer.
- Acontece com baixa frequência. Já aconteceu.
- Provável de acontecer.

c. Probabilidade Baixa

- Nunca aconteceu.
- Muito raramente acontece.
- Pouco provável de acontecer.
- Se acontecer, ocorreram muitas coincidências.

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) 5.2.3. Controles/Contramedidas existentes

Controles são ações ou procedimentos que minimizam a concretização da ameaça. Controles minimizam a exploração de vulnerabilidades (fraquezas) que existem nas barreiras de defesa da informação ou dos recursos de informação.

A identificação dos controles existentes é necessária para evitar custos e trabalhos desnecessários, por exemplo, a duplicação de controles.

Para os controles considerados será avaliada a efetividade destes controles.

Como consequência desta efetividade, quanto mais efetivo (eficiente e eficaz) for o controle mais baixo será o risco (probabilidade de uma ameaça acontecer).

Na figura abaixo apresentamos um exemplo de escala considerando a

vulnerabilidade do controle de segurança. Chamamos atenção para o fato de que, quanto mais frágil estiver o controle, maior é o risco. Isto é, se o controle

é menos efetivo, ele está mais vulnerável e a probabilidade de concretização da ameaça é maior. O risco é maior. De maneira inversa, quanto melhor a efetividade do controle, menor é o risco da ameaça se concretizar.

Na tabela abaixo apresentamos um exemplo do Nível de Maturidade (ou efetividade) do Controle. Normalmente uma tabela deste tipo têm cerca de 5 a 10

níveis de classificação. Neste exemplo temos 10 níveis agrupados em 3 grupos.

100

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

Maturidade N/A - Não se Aplica	
Maturidade 1 a 4 – CONTROLE NÃO EXISTE	
Se for auditado, será Ponto de Auditoria	
Precisa ser implantado	
1. Não é considerado.	Menos Efetividade => Maior o Risco
2. Em planejamento inicial. Sem compromisso formal.	
3. Está planejado. Com data, responsáveis e aprovação (quase) formal.	
4. Início de implantação. Não atende aos requisitos básicos. Muito frágil.	
Maturidade 5 a 7 – CONTROLE EXISTE COM LIMITAÇÕES/PRECARIEDADES	
Se for auditado: podem ser encontrados algumas situações não adequadas.	
Em funcionamento com requisitos mínimos	
5. Atende minimamente aos requisitos básicos.	
6. Identificadas melhorias necessárias e já planejadas.	
7. Quase totalmente implementado. Com pendência: documentação, outra.	
Maturidade 8 a 10 – CONTROLE EXISTE DE MANEIRA ADEQUADA.	
Se for auditado: não será Ponto de Auditoria. Exceto se falha em atividades por erro, ação de má fé ou outras situações não contempladas no processo.	
Em funcionamento com atendimento adequado	Mais Efetividade => Menor o Risco
8. Está funcionando bem. Pode ter melhorias.	
9. Totalmente implementado. Atende adequadamente à organização.	
10. É ou pode ser considerado: referência de mercado. (Melhor da Classe)	

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA

(Edison Fontes)

Figura 5.2 – Nível de Maturidade do Controle de Segurança da Informação.

Fonte: Autor.

É importante que esta classificação proposta seja validada no início do projeto de Gestão de Riscos em Segurança da Informação e eventualmente aprimorada por um grupo de profissionais da organização. Quando do início das atividades de avaliação de riscos, os conceitos de maturidade que serão tomados como base deverão obrigatoriamente estar validados e formalmente aprovados. À

princípio não devemos alterar as definições consideradas. Porém, nada impede que estas definições sejam aprimoradas ao longo do tempo. Caso aconteça esta melhoria é necessário avaliar se existe algum impacto em relação à avaliações já realizadas.

Existe uma relação direta da ameaça e os controles identificados. Para facilitar a realização da Gestão de Riscos em Segurança da Informação tanto a ameaça quanto qualquer controle precisam ser muito bem definidos. Ao

101

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes) identificar um controle precisamos garantir que este controle rigorosamente minimiza a ameaça se concretizar. É muito fácil cometermos o erro de considerar controles que não evitam a ameaça acontecer. Ou pensamos em uma situação e escrevemos outra situação. Um erro deste tipo gerará uma avaliação com grande margem de erro e a organização poderá gastar recursos desnecessários ou ficar em uma situação de maior risco sem que isto esteja explícito.

Por exemplo, identificamos a ameaça “Queda do link principal de

comunicação.” Como contramedida (controle) identificamos que a organização possui um link alternativo de comunicação. Rigorosamente ter um segundo link de comunicação não impede a queda do link principal de comunicação. Neste caso, a ameaça está mal definida. O que se quer considerar como ameaça é “Falta de comunicação”. Neste caso, ter um segundo link de comunicação minimiza o risco da organização ficar sem comunicação, caso o link principal esteja indisponível. Revise muito bem as ameaças e as respectivas contramedidas (controles).

Existem 6 tipos de controles considerando o seu objetivo.

Sendo assim, temos controles de prevenção, detecção, contenção, desmotivação, correção e garantia de continuidade. Como segue:

a. Controles Tipo Prevenção:

Objetivo: Evitar, impedir danos aos recursos de informação.

b. Controles Tipo Detecção.

Objetivo: Identificar o mais rápido possível os danos aos recursos de informação.

Quando os controles de detecção são acionados, significa que os controles de prevenção não foram suficientes para impedir a ocorrência da ameaça. A ameaça se concretizou.

**SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes) c. Controles Tipo Contenção.**

Objetivo: Evitar a propagação dos danos aos recursos de informação. Quando os controles de contenção são acionados, significa que os controles de prevenção não foram suficientes para impedir a ocorrência da ameaça. A

ameaça se concretizou.

d. Controles Tipo Desmotivação.

Objetivo: Desestimular a geração de problemas ou a concretização de ameaças.

Normalmente são controles focados na pessoa humana.

e. Controles Tipo Correção.

Objetivo: Buscar a normalidade do serviço/recurso de informação após um dano a este serviço/recurso.

f. Controles Tipo Garantia de Continuidade

Objetivo: garantir que os controles continuarão existindo de maneira adequada após uma ocorrência que impacte na disponibilidade da informação. Podemos afirmar que este controle é o controle do controle.

Como exemplo de controles, temos os 114 controles da Norma NBR

ISO/IEC 27002:2013 que estão descritos no Anexo 1. Baseados nestes controles devemos definir controles mais específicos, considerando o conjunto de ameaças que estamos tratando e considerando as características da organização.

Para um melhor entendimento, seguem abaixo alguns exemplos de contramedidas:

- Controle de acesso lógico com identificação e autenticação individuais.

(Edison Fontes)

- Cópias de segurança de informações.
- Sistema de *Nobreak* e Gerador Alternativo de energia elétrica.
- Recursos alternativos, tipos *links* de comunicação alternativos.

5.2.4. Impacto no Negócio

O valor do Impacto no Negócio pode ser indicado tanto por uma Estimativa Quantitativa quanto por uma Estimativa Qualitativa. Porém é necessário que seja utilizada apenas um tipo de estimativa. O tipo de estimativa escolhido será utilizado para todo o Gerenciamento do Risco em Segurança da Informação realizado pela organização.

A valorização do Impacto do Negócio deve ser considerada independente da probabilidade da Ameaça se concretizar. Para entender melhor este impacto, podemos fazer a pergunta: Se esta ameaça acontecer, qual será o impacto no recurso de informação?

Vamos tomar por exemplo a estimativa Qualitativa. A ocorrência da ameaça gera nos recursos de informação do negócio um impacto: alto, médio ou baixo. Abaixo, descrevemos, em exemplo, do que significa cada um destes tipos: Quando da avaliação do impacto no negócio, devemos considerar quais os aspectos serão considerados. A figura abaixo apresenta um exemplo de avaliação qualitativa do impacto, considerando os seguintes aspectos:

- Continuidade.
- Financeiro.
- Imagem.
- Legal.
- Combate à fraude.
- Prevenção de vazamento de dados.

- Geração de pontos de auditoria.

IMPACTO			
	ALTO	MÉDIO	BAIXO
	Gera ou tem alto potencial de gerar situações que a Organização não quer e não aceita que ocorra. Este tipo de ocorrência impede ou tem grande potencial de impedir o atendimento aos objetivos corporativos.	Gera ou tem alto potencial de gerar situações não desejadas pela Organização, mas que caso ocorram podem ser absorvidas em tempo médio pelas atividades operacionais.	Gera ou tem alto potencial de gerar situações não desejadas pela Organização, mas que caso ocorram são facilmente absorvidas pelas atividades operacionais. Este tipo de ocorrência reflete mais fortemente em área interna da Organização.
ASPECTOS			
Continuidade (CT)	Impede o funcionamento normal do negócio. Impacta fortemente o negócio com o Cliente.	Impacta realização do negócio, mas suportável. Pouco impacto para todos os Clientes	Pequeno impacto no funcionamento do negócio. Cliente não perceberá.
Financeiro (FI)	Forte prejuízo financeiro. Necessário justificar perante Direção ORGANIZACAO.	Prejuízo financeiro suportável, possível de ser aceitável.	Prejuízo financeiro facilmente absorvido pela própria área.
Imagem (IM)	Forte impacto de imagem. Tem que se justificar perante a mídia (público, mercado, clientes).	Impacto de imagem não atinge fortemente todos os clientes. É específico.	Pequeno impacto de imagem. Pouco perceptível.
Legal (LG)	Possível impacto Legal. Não atende a legislação ou órgãos reguladores.	Não fica aderente às boas práticas. Não cumpre controle definido em regulamentos da Organização. Está aderente à legislação.	Não fica aderente às boas práticas. Está aderente à legislação.
Combate a Fraude (CF)	Facilita a ocorrência de fraude. Impede a identificação do usuário. Organização pode ser acusada de não implementar ações para evitar atos ilícitos. Impede a rastreabilidade.	Pequena possibilidade de ocorrência de fraude. Rastreabilidade mínima.	Gera maior vulnerabilidade no futuro Possibilidade de ocorrência de fraude se combinado com outras falhas de controle.
Prevenção Vazamento de Dados (PV)	Facilita o vazamento de dados de clientes e/ou do negócio.	Facilita o vazamento de dados gerais.	Gera maior vulnerabilidade no futuro
Auditoria	Ponto Severo (High) em Relatório de Auditoria. Exigirá correção em curto prazo.	Ponto Comum em Relatório de Auditoria. Possível ser programado no planejamento.	Ponto de Atenção em Relatório de Auditoria.

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

Figura 5.3 – Impacto (Aspectos e Nível) - Fonte: Autor.

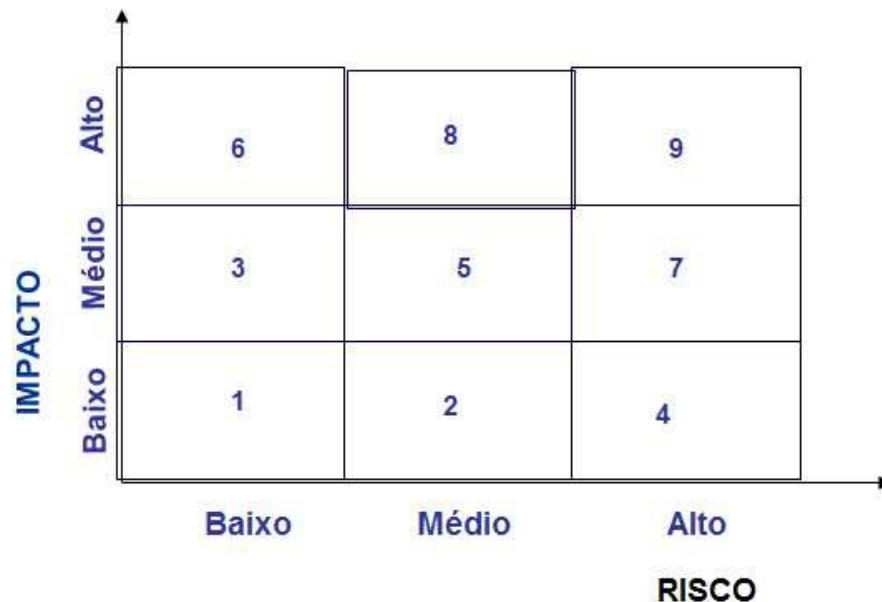
5.2.5. Nível de Proteção

A estimativa do Nível de Proteção designa valores para o risco (probabilidade) e para as consequências de uma ameaça se concretizar. O Nível de Proteção estimado é uma combinação entre o risco (probabilidade) de um cenário de incidente e as suas consequências. Desta maneira podemos ter uma matriz: probabilidade *versus* impacto.

A figura 5.4 apresenta um exemplo de uma matriz que aponta o Nível de Proteção:

105

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***



**SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes)**

Figura 5.4 – Matriz Nível de Proteção (probabilidade/risco versus impacto) Fonte: Norma NBR ABNT ISO/IEC 2005:2008 – Exemplo Simplificado (ABNT, 2008, p.50).

5.3. Como realizar a Gestão de Riscos de Segurança da Informação

Nos capítulos anteriores detalhamos os conceitos da Gestão de Riscos em Segurança da Informação. Agora vamos orientar como deve ser feita a Gestão de Riscos de Segurança da Informação.

Os conceitos aqui apresentados são baseados na Norma NBR ISO/IEC

27005 – Tecnologia da Informação – Técnicas de segurança – Gestão de riscos de segurança da informação. Porém, chamamos atenção para o fato de que estes conceitos existem há muitos anos e são utilizados por diversos profissionais antes da norma existir. A norma trouxe uma organização estruturada e uma consolidação destes conceitos. Por ser uma norma internacional ela buscou equalizar os conceitos, definição e aplicação da Gestão de Riscos de Segurança da Informação.

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) 5.3.1. Definição do Processo de Gestão de Riscos

Conforme indicamos no Capítulo 4 – Dimensão Política de Segurança da Informação, no item 4.2 – Arquitetura da Política de Segurança da Informação, a organização deve ter uma Política Dimensão Gestão de Riscos de Segurança da Informação. Nesta política deve estar definido o Contexto que deve considerar:

- o objetivo principal,
- os objetivos complementares,
- o escopo (abrangência, limitação),
- a área organizacional responsável pela Dimensão,

- o comprometimento do Corpo Diretivo com a Dimensão.

5.3.2. Execução do Processo de Gerenciamento de Riscos

A execução das atividades do Processo de Gerenciamento de Riscos de Segurança da Informação deve seguir as seguintes etapas:

5.3.2.1. Definição da abordagem para a análise e avaliação de riscos.

a. Escopo

=> Devem ser definidos os recursos de informação que serão considerados.

b. Objetivo

=> Deve ser explicitado o objetivo da ação de análise e avaliação de riscos.

c. Método

=> Deve ser indicado qual o método escolhido para a análise e avaliação de riscos.

d. Critérios

=> Devem ser divulgados os critérios para possibilitar a análise e a avaliação de riscos. Estes critérios se materializam em tabelas e classificações de níveis de riscos, de impactos e efetividade das vulnerabilidades.

107

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) 5.3.2.2. Identificação das ameaças.

Nesta etapa devem ser consideradas as ameaças consideradas para a análise e avaliação dos riscos de segurança da informação.

Não existe uma regra de como considerar estas ameaças. Pode ser considerada uma única ameaça ou um conjunto de ameaças. Minha sugestão é que ao fazer uma análise e avaliação de riscos, tente concentrar a energia em uma única ameaça significativa. Seguem abaixo dois exemplos:

a. Indisponibilidade total da informação existente no Ambiente Principal de Tecnologia da Informação por um período superior a quatro horas. Neste exemplo não estamos preocupados se a indisponibilidade foi causada por incêndio, enchente ou falta de energia elétrica.

b. Não implementação dos controles de segurança da informação definidos nas políticas e normas.

Para facilitar o entendimento de todos, principalmente no futuro, recomendamos a justificativa do porquê da escolha desta ameaça ou deste conjunto de ameaças.

A definição de uma ameaça pode ser simplificada com a utilização da frase: “Eu tenho medo de...” Este complemento é uma ameaça.

5.3.2.3. Definição das premissas.

Cada análise e avaliação de riscos de segurança da informação precisa junto com a definição de ameaças, ter explicitado as premissas consideradas.

Considerando o exemplo do item anterior da ameaça de indisponibilidade total da informação existente no Ambiente Principal de Tecnologia da

108

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

**SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes)** Informação por um período superior a quatro horas, podemos ter como premissas:

- Todos os colaboradores (funcionários, prestadores de serviço e fornecedores de insumos), continuam ativos e exercendo suas funções profissionais.

- O Ambiente Alternativo de Tecnologia da Informação estará disponível e funcionando normalmente durante a indisponibilidade do Ambiente

Principal de Tecnologia da Informação.

5.3.2.4. Análise dos riscos

Considerando cada um dos recursos de informação, nesta etapa serão identificados:

- a. Os eventos (relacionados às ameaças) que podem causar perdas à organização.
- b. As contramedidas existentes

5.3.2.5. Avaliação dos riscos

Nesta etapa são avaliadas:

a. Os impactos

As consequências de impactos para a organização, caso a ameaça se concretize. Podemos ter consequências do tipo: social, ambiental, operacional, financeiro, imagem institucional, reputação, oportunidade de negócio, cumprimento de prazo, legal, respeito ao cliente ou outro que a organização defina que deve ser considerado. O impacto causado pela concretização da ameaça independe da maior ou menor efetividade dos controles existentes. O

impacto avaliado é “se a ameaça se concretizar”. Se esta concretização é muito

b. O risco existente

O risco existente, isto é, a probabilidade da ameaça se concretizar em função da efetividade dos controles de segurança existentes.

c. Nível de proteção

A identificação do Nível de Proteção, considerando os padrões adotados e a situação vigente. (Ver item 5.2.5)

5.3.2.6. Tratamento do risco

Para cada elemento considerado no gerenciamento de riscos teremos um resultante e devemos considerar qual será o tratamento do risco residual. Mesmo que os controles de segurança da informação sejam muito efetivos e o resultado do Nível de Proteção seja excelente, isto é, o risco de uma ameaça se concretizar é muito baixo, é necessário que a organização defina como tratará este risco.

Inicialmente esta avaliação deve ser feita pelo grupo responsável pela Gestão de Riscos, porém precisa ser validado pelo Corpo Diretivo da organização.

Para o tratamento de risco podem ser tomadas as seguintes atitudes:

a. Minimizar o risco

=> Neste caso será definida o desenvolvimento e implantação de novos controles de segurança da informação ou aprimoramento dos controles existentes.

b. Aceitar o risco

=> A organização aceita o risco ainda existente da ameaça se concretizar, considerando os controles de segurança da informação implantados. Isto significa

110

*Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com*

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes) que no momento a organização entende que não vale à pena investir em ter mais controles para esta ameaça.

c. Evitar o risco

=> Para tomar esta decisão a organização deverá desconsiderar alguma opção que hoje utiliza. O risco somente poderá ser evitado se não existir mais a ameaça.

Muitas vezes a organização não pode assumir esta opção porque não pode descartar a ameaça.

d. Transferir o risco

=> A organização pode transferir o risco para um prestador de serviço, para uma seguradora ou alguma outra situação equivalente.

5.3.2.7. Obtenção da aprovação pelo Corpo Diretivo

O Corpo Diretivo da organização precisa validar periodicamente o Tratamento de Riscos definidos para a segurança da informação, considerando os riscos residuais identificados. Esta validação deve contemplar também a priorização de ações em relação ao desenvolvimento de novos controles, ao aprimoramento de controles existentes ou apenas a confirmação de implantação de controles já definidos porém ainda não implementados.

5.3.2.8. Comunicação dos Riscos de Segurança da Informação

O Processo de Gestão de Riscos de Segurança da Informação, incluindo o tratamento de riscos, deve ser divulgado com as pessoas envolvidas no Programa Organizacional

de

Segurança

da

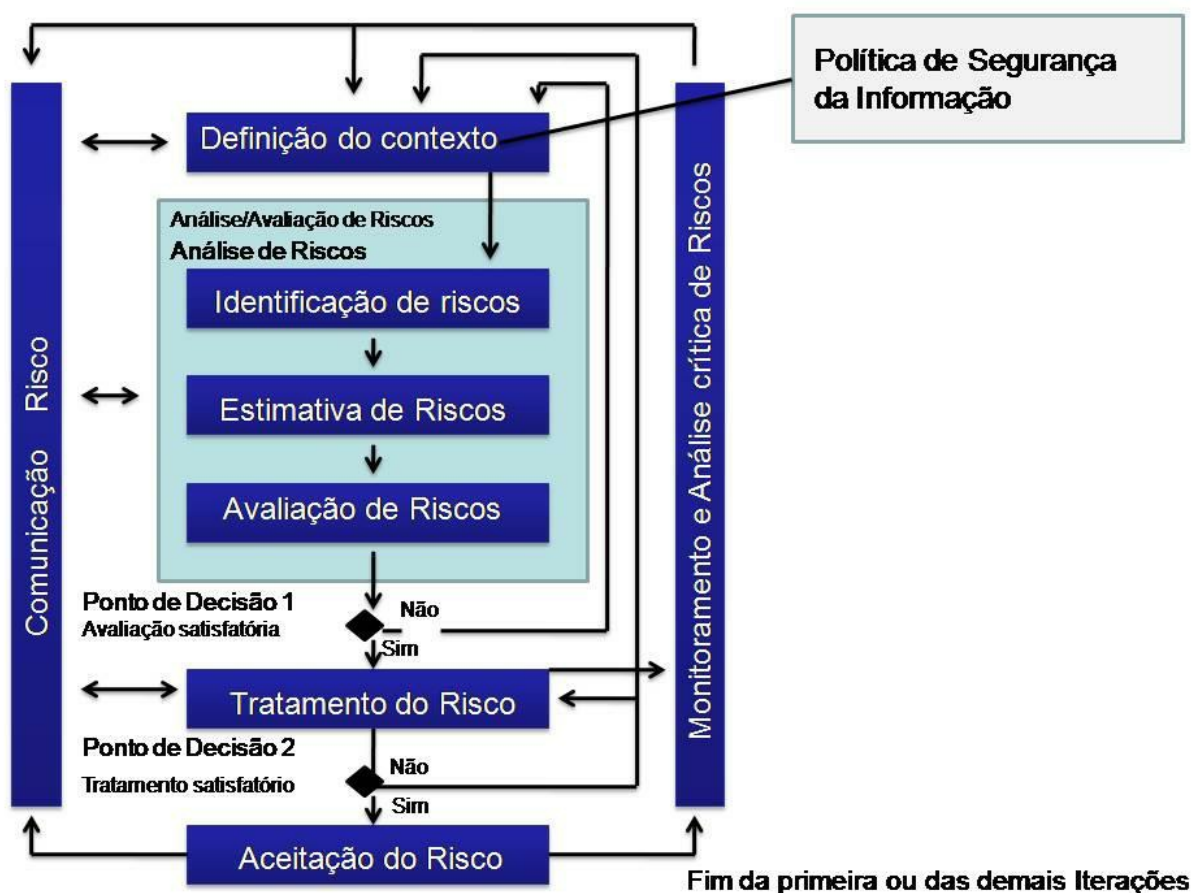
Informação,

considerando

a

confidencialidade/sigilo da informação.

A existência de uma Gestão de Riscos de Segurança da Informação e a sua possível comunicação com as pessoas ou áreas envolvidas é um fator de



SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

facilidade para o alcance do patamar desejado de segurança da informação. Este fato facilita quando de uma auditoria interna ou auditoria externa. Caso a organização já tenha várias necessidades de segurança da informação mapeadas pela gestão de risco, a conversa com a auditoria será mais efetiva e mais estruturada. Os pontos que a auditoria apresentará já estarão no mapa de ações de segurança da informação. Entendo que será mais fácil a definição, em conjunto com a auditoria, da manutenção do estado atual ou se será

solicitado uma priorização pela auditoria para algum controle ou conjunto de controles de segurança da informação.

A figura abaixo apresenta os componentes do Processo de Gestão de Riscos em Segurança da informação.

Figura 5.5 – Processo de gestão de risco de segurança da informação
Fonte: NBR ISO/IEC 27005:2008

112

Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA **(Edison Fontes)**

É fundamental que ao realizar a Gestão de Riscos em Segurança da Informação sigamos uma estrutura que apresente de maneira completa e com direcionamento de etapas a serem cumpridas. Recomendamos seguir a estrutura apresentada pela Norma ISO/IEC 27005.

113

Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com



SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

6. DIMENSÃO ACESSO A INFORMAÇÃO

Foto: Edison Fontes. Forte Orange. Ilha de Itamaracá, Brasil.

Neste capítulo apresentaremos a Dimensão Controle de Acesso à Informação e sua participação no Programa Organizacional de Segurança da Informação.

Após a definição do conjunto de regulamentos que formam a política de segurança da informação é necessário a implementação dos controles das dimensões da segurança da informação. A Dimensão Controle de Acesso à Informação é uma destas dimensões.

A Norma ABNT NBR ISO/IEC 27002 – Tecnologia de segurança –

Técnicas de segurança – Código de prática controles de segurança da informação indica a necessidade do controle de acesso à informação:

Convém que os proprietários dos ativos determinem regras

apropriadas de controles de acesso, direitos de acesso e restrições

114

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes) para papéis específicos dos usuários acessarem seus ativos, com o nível de detalhe e o rigor dos controles que reflitam os riscos de segurança da informação associados (ABNT, 2013, p. 23).

6.1 – Objetivo da Dimensão Controle de Acesso à Informação

O objetivo principal da Dimensão Controle de Acesso à Informação é

“assegurar acesso de usuário autorizado e prevenir acesso não autorizado a sistemas e serviços” (ABNT, 2013, pp. 24-25). Em resumo: somente usuários previamente autorizados devem acessar a informação.

Existem duas abordagens que direcionam a Dimensão de Controle de Acesso à Informação:

a) Necessidade de conhecer:

=> O usuário somente deve ter permissão para acessar a
informação que necessita para desempenhar suas tarefas;

b) Necessidade de uso:

=> O usuário somente deve ter permissão para acessar os
recursos de processamento da informação que necessita

para desempenhar a sua tarefa profissional na Organização.

O controle de acesso à informação é uma Dimensão do Programa Organizacional de Segurança da Informação e considera os controles relacionados à informação ou aos recursos de informação. A Figura abaixo apresenta as Dimensões que compõem o Programa Organizacional da segurança da informação.

115

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***



SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

Figura 6.1 – Dimensões da Segurança da Informação

Fonte: Livro “Praticando a Segurança da Informação” (FONTES, 2008, p. 48).

Para que esta Dimensão aconteça, a Norma ABNT NBR ISO/IEC 27002 –

Tecnologia de segurança – Técnicas de segurança – Código de prática controles de segurança da informação indica controles e objetivos complementares ao objetivo principal descrito acima:

Convém que uma política de controle de acesso seja estabelecida, documentada e analisada criticamente baseada nos requisitos de segurança da informação e dos negócios (ABNT, 2013, p. 23).

Convém que as regras de controle de acesso sejam apoiadas em procedimentos formais e responsabilidades claramente definidas (ABNT, 2013, p. 23).

Convém que os usuários recebam acesso às redes e aos serviços de rede que tenham sido especificamente autorizados a usar (ABNT, 2013, p. 25).

116

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes) *Convém que um processo formal de registro e cancelamento de usuário seja implementado para permitir atribuição aos direitos de acesso (ABNT, 2013, p. 25).*

Convém que um processo formal de provisionamento de acesso do usuário seja implementado para conceder ou revogar os direitos de acesso do usuário para todos os tipos de usuários em todos os tipos de sistemas ou serviços (ABNT, 2013, p. 26).

Convém que a concessão e o uso de direitos de acesso privilegiado sejam restritos e controlados (ABNT, 2013, p. 27).

Convém que a concessão de informação de autenticação secreta seja controlada por meio de um processo de gerenciamento formal (ABNT, 2013,

p. 28).

Convém que os proprietários de ativos analisem criticamente os direitos de acesso dos usuários a intervalos regulares (ABNT, 2013, p.

28).

Convém que os direitos de acesso de todos os funcionários e partes externas às informações e aos recursos de processamento da informação sejam retirados logo após o encerramento de suas atividades, contratos ou acordos, ou ajustados após a mudança destas atividades (ABNT, 2013, p. 29).

Convém que o acesso à informação e às funções dos sistemas de aplicações seja restrito, de acordo com a política de controle de acesso (ABNT, 2013, p. 31).

117

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes) A Dimensão de Controle de Acesso à Informação possui os seguintes elementos descritos a seguir.

6.2 – Identificação – Gestão de Identidade

Um dos grandes desafios da segurança da informação é garantir que o usuário que está se apresentando para o ambiente como uma determinada pessoa, é realmente esta pessoa. A garantia de que o usuário é realmente quem se diz ser, acontecerá com a utilização de duas informações: a identificação do usuário e a autenticação do usuário.

A identificação tem como propósito informar para o ambiente da informação quem é a pessoa que deseja acessar o ambiente. A identificação é a informação única referente ao usuário e ficará armazenada para registrar as

ações deste usuário. Ela permite que o sistema de controle de acesso faça o relacionamento da pessoa com o método de autenticação.

Pode-se utilizar para a identificação do usuário a matrícula funcional, matrícula contratual, CPF, nome/sobrenome ou outra informação que possa estar relacionada de maneira única à pessoa do usuário. É importante o uso de uma identificação única por usuário que permita relacioná-los às suas responsabilidades e ações (ABNT, 2013).

Recomendamos os seguintes controles para a identificação do usuário: 1. A identificação deve ser individual e não deve ser reutilizada por um outro usuário, mesmo em momentos diferentes.

118

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA

(Edison Fontes) 2. A identificação deve poder ser reutilizada pelo mesmo usuário, caso este usuário se desligue profissionalmente da organização e no futuro retorne a manter vínculo profissional com a mesma..

3. A identificação deve ser atrelada ao usuário como pessoa que acessa o ambiente da informação, independentemente deste usuário ser funcionário, prestador de serviço ou outro tipo de relacionamento.

4. O usuário deve ter a mesma identificação em todas as plataformas de tecnologia da informação ou ambientes da Organização.

5. A identificação do usuário deve estar conectada a um sistema de controle que realize o seu gerenciamento.

6. Os dados cadastrais do usuário devem estar sempre atualizados.

7. A identificação não deve ser composta por elementos que perdem ou dificultam a identificação do usuário ao longo do tempo.

8. A identificação deve ser representada por uma informação que tenha uma ligação direta e individual com o usuário.
9. A identificação pode ser arquivada e retirada do sistema em uso, mas nunca deve ser removida do ambiente de tecnologia da informação. A qualquer momento a organização pode necessitar conhecer informações sobre aquela identificação.

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) 10. Quando não existir mais relacionamento profissional do usuário com a organização, a identificação do usuário deve ser bloqueada de uso. Qualquer tentativa de uso desta identificação deve ser tratada como um incidente de segurança da informação.

A gestão de identidade consiste em um processo estruturado que garante a efetividade (eficácia e eficiência) dos controles descritos acima. Este processo deve garantir que somente identificações de usuários em pleno desempenho de suas funções profissionais com a Organização devem existir, devem estar válidas e poderão acessar a informação. Assim que um usuário sair da Organização, ele deve ter o seu acesso eliminado, impedindo desta maneira de acessar a informação.

6.3 – Autenticação

A autenticação “é o procedimento pelo qual o ambiente da informação garante que o usuário que está se apresentando para o sistema é realmente este usuário” (FONTES, 2000, p. 123).

A autenticação acontece com a utilização dos controles:

- *Algo que o usuário tem conhecimento: como sua senha;*

- *Algo que o usuário possui: como seu cartão digital ou token;*
- *Algo que o usuário é: como a biometria do dedo da mão.*

Por questões de custo e facilidade, a senha é o controle de autenticação mais utilizado. Ela possui um bom nível de segurança, porém necessita ter controles complementares:

120

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA

(Edison Fontes) 1. Toda vez que um responsável pelo controle de acesso atribuir uma senha para um usuário, ela deve ser descartável, isto é, o usuário é obrigado a mudá-la na primeira vez que acessar a informação.

2. No ambiente computacional, a atribuição de senha para o usuário somente deve ser feita pelo sistema de controle de acesso e deve registrar a data, hora/minuto/segundo, identificação do responsável, identificação do usuário, numeração sequencial de senha permanente e terminal/local de onde está sendo realizado este controle.

3. Deve-se exigir que o usuário faça mudança periódica de senha. Sugestão de tempo máximo: 60 dias.

4. Deve ser exigido um tamanho mínimo para o texto da senha. Sugestão: mínimo de seis caracteres.

5. O arquivo de senhas deve ser criptografado sem possibilidade de reversão ao valor original.

6. O transporte da senha no ambiente interno ou externo da Organização deve ser sempre criptografado.

7. Não devem existir recursos técnicos que permita que uma pessoa tenha acesso à senha de outra pessoa.

8. O usuário deve ter o poder de alterar sua própria senha quando assim o desejar.
9. O usuário deve ser conscientizado sobre o uso da senha e de seus controles necessários.

121

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

**SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes)** 10. Todos os acessos e tentativas de acesso devem ser registrados permitindo a rastreabilidade destas ações e geração de evidências.

11. Deve haver um número máximo de tentativa incorreta de senha. Após este número de tentativas a entrada do usuário deve ser bloqueada.

Quando do uso de senha para a autenticação de usuário, em muitas situações a Organização precisa seguir algum normativo externo. Por exemplo, o PCI DSS (Padrão de Segurança de da Indústria de Cartões de Pagamento, desenvolvido pelo PCI Security Standards Council, define nos seus requisitos e procedimentos as seguintes regras para a utilização do controle senha, no ambiente que precisa seguir o padrão PCI, descrito nos requisitos e procedimentos da avaliação de segurança (PCI, 2013).

Para o ambiente que está submetido às regras do PCI, quando da autenticação de usuário utilizando senha, é obrigatório o atendimento às seguintes regras abaixo:

Tipo de

Tamanho

Complexidade

Troca de Senha

Tentativas

Histórico

Mínimo de

Número

Senhas

Usuário

Caracteres

Tipos de Caracteres

Mínimo/Máximo

Máximo

Anteriores

Mínimo: 24hs

Comum

8

3 Tipos de 4 Tipos

10

9

Máximo: 90 dias

Mínimo: 24hs

Administrador

12

3 Tipos de 4 Tipos

5

9

Máximo: 90 dias

Não pessoal

Mínimo: não exigido

(Processo

16

4 Tipos

5

9

Máximo: 1 ano

automatizado)

Figura 20– Critérios para Senha - Fonte: Padrão PCI.

122

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

a) Tipos de Usuário

a.1. Comum: é o usuário que representa diretamente uma pessoa. Ele acessa a informação para o desempenho das suas funções profissionais na STELO.

a.2. Administrador: é o usuário, que representa uma pessoa porém tem um grande poder de ação. É uma identificação que os fraudadores buscam roubar, pois o seu poder de ação é total. Este usuário exerce a função de administrador de sistema, administrador de aplicação ou administrador de ferramenta. Este tipo de usuário realiza transações críticas que tem grande poder na administração e no suporte do recurso de informação.

a.3. Não Pessoal: é o usuário relacionado a programas ou algum processo automatizado. Este usuário não está diretamente relacionado à pessoa.

b) Tipos de Caracteres:

- Tipo Letras Maiúsculas

- Tipo Letras Minúsculas.
- Tipo Números.
- Tipo Caracteres Especiais (@#\$%¨&*() _+::?.)

c) Tempo para Troca de Senha

Indica o tempo mínimo e o tempo máximo que um usuário pode realizar a troca de senha.

d) Tentativas

Indica o número máximo de tentativas erradas de autenticação por senha que o usuário pode executar, antes que sua conta seja bloqueada. Após uma tentativa com a senha correta, este contador é zerado.

123

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

**SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes)**

e) Histórico

Indica o número de senhas que o usuário não pode reutilizar.

6.4. Autorização – Gestor da Informação

O terceiro elemento para que aconteça o uso da informação pelo usuário, é a autorização para que este usuário acesse a informação. Alguém com poder deve autorizar o usuário a ter este acesso. Esta pessoa é o Gestor da Informação ou em alguns casos chamados de proprietário da informação (FONTES, 2000).

Seguindo a orientação de Fontes (2008) utilizaremos o termo Gestor da

Informação, considerando que rigorosamente a proprietária da informação é da Organização.

A Norma ABNT NBR ISO/IEC 27002 – Tecnologia de segurança –

Técnicas de segurança – Código de prática controles de segurança da informação explicita a necessidade desta autorização:

Convém que um processo formal de provisionamento de acesso do usuário seja implementado para conceder ou revogar os direitos de acesso do usuário para todos os tipos de usuários em todos os tipos de sistemas ou serviços (ABNT, 2013, p. 26).

Alguns controles básicos devem ser considerados para a efetividade da autorização de acesso à informação pelo Gestor da Informação. Segue abaixo uma lista de orientações baseadas nestes controles:

a) Cada informação deve ter o seu Gestor da Informação.

124

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) b) O Gestor da Informação tem a autoridade de liberar ou negar o acesso à informação pelo usuário.

c) Devem existir critérios formais que devem ser considerados para a avaliação pelo Gestor da Informação quando da avaliação da liberação (ou não) do acesso à informação.

d) A informação somente deve ser liberada para o usuário que necessita dela para o desempenho das suas funções profissionais para a Organização.

e) A relação de usuários que acessam a informação deve estar sempre disponível e atualizada.

f) O Gestor da Informação deve revisar periodicamente os usuários que estão autorizados a acessar a informação.

g) Deve sempre existir pelo menos uma pessoa alternativa ao gestor principal da informação.

h) A negação de acesso à informação deve sempre ser explicitada para o usuário solicitante.

Uma ação importante que deve acontecer de maneira concorrente com a implantação do conceito de Gestor da Informação é o treinamento destes gestores e treinamento dos usuários em geral. Um usuário que recebe a responsabilidade como Gestor da Informação precisa receber um treinamento específico sobre estas suas novas funções.



SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes)

7. DIMENSÃO CLASSIFICAÇÃO

INFORMAÇÃO

Foto: Edison Fontes. Lisboa, Portugal.

O objetivo principal da Dimensão Classificação da Informação é “assegurar que a informação receba um nível adequado de proteção, de acordo com a sua importância para a organização” (ABNT, 2013, p. 18).

Existem dois controles básicos que direcionam a Dimensão Classificação da Informação:

Convém que a informação seja classificada em termos de seu valor, requisitos legais, sensibilidade e criticidade para evitar modificação ou divulgação não autorizada.

Convém que um conjunto apropriado de procedimentos para rotular e tratar a informação seja desenvolvido e implementado de acordo com

126

Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com



SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes)

o esquema de classificação da informação adotado pela organização (ABNT, 2013, pp. 18-20).

A classificação da informação é uma Dimensão do Programa

Organizacional de Segurança da Informação e considera o grau de sigilo para a informação ou para os recursos de informação. A figura 04 apresenta as dimensões que compõem o Programa Organizacional da segurança da informação.

Figura 7.1 – Dimensões da Segurança da Informação

Fonte: Livro “Praticando a Segurança da Informação” (FONTES, 2008, p. 48).

Para que essa Dimensão aconteça, a Norma ABNT NBR ISO/IEC 27002 –

Tecnologia de segurança – Técnicas de segurança – Código de prática controles de segurança da informação indica controles e objetivos complementares ao objetivo principal descrito acima:

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes) *Convém que a classificação e os controles de proteção, associados à informação, levem em consideração as necessidades do negócio para compartilhar ou restringir a informação bem como os requisitos legais.*

Convém que os proprietários de ativos de informação sejam responsáveis pela sua classificação.

Convém que o esquema de classificação inclua convenções para a classificação e critérios para análise crítica de classificação ao longo do tempo. Convém que o nível de proteção seja avaliado por meio da análise de confidencialidade, integridade e disponibilidade, e quaisquer requisitos

considerados para a informação.

Convém que a cada nível seja dado um nome que faça sentido no contexto do esquema de classificação.

Convém que o esquema seja consistente em toda a organização de forma que cada pessoa possa classificar a informação e os ativos relacionados da mesma forma, e tenha um entendimento comum dos requisitos de proteção e aplique a proteção apropriada (ABNT, 2013, p. 19).

A classificação fornece às pessoas que lidam com informações uma indicação concisa de como tratar e proteger os recursos que suportam a informação.

Para acontecer a classificação de informação é necessária a definição de níveis de classificação que detalhamos a seguir.

128

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) 7.1 – Níveis de Classificação

Classificação da informação é a definição do nível de confidencialidade ou sigilo da informação, considerando:

** Quais grupos de pessoas, áreas organizacionais e/ou*

organizações que deverão ter acesso à informação; e

** Que procedimentos de proteção da informação devem ser*

seguidos com o objetivo de preservar a

confidencialidade/sigilo da informação.

Os níveis de classificação indicam a sensibilidade e a rigidez de sigilo da

informação para a organização. Em função desta sensibilidade de sigilo será definida a rigidez dos controles de tratamento da informação.

Não existe um padrão rígido para os níveis de classificação da informação: cada organização deve definir os padrões de sigilo e o tratamento dos recursos de informação para cada um deles.

Considerando as informações do Estado brasileiro, foi aprovado o Decreto nº 4.554 de 2002 define no seu Art. 5º que os dados ou informações sigilosas serão classificados em ultrassecretos, secretos, confidenciais e reservados, em razão do seu teor ou dos seus elementos intrínsecos.

Para um ambiente organizacional, Fontes (2012) exemplifica uma classificação da informação e sua aplicação nos diversos meios de utilização da informação. Vamos conferir um exemplo?

7.2 – Implementando a Classificação da Informação

Para a implantação da Classificação da Informação aconteça de maneira efetiva na organização devemos considerar alguns aspectos.

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) 7.2.1. Toda a informação deverá ser classificada.

O maior esforço no controle Classificação da Informação é a implantação do conceito em toda informação. Exige um planejamento Para este planejamento é recomendado começar com a classificação da informação dos novos sistemas ou projetos. A partir do momento em que a Política de Classificação da Informação for publicada, toda informação de novos sistemas, projetos e ferramentas deverão ser classificadas antes da implantação dos mesmos.

7.2.2. Informação em Sistemas Legados

Em relação aos sistemas legados, enfrentaremos uma dificuldade: dificilmente encontraremos uma janela de tempo para fazer uma manutenção exclusivamente para a classificação da informação. Desta maneira a opção mais adequada é aproveitar a manutenção dos Sistemas Legados e realizar (parcialmente) a classificação das informação.

7.2.3. Considere o ambiente convencional

A Classificação da Informação deve acontecer no ambiente de tecnologia como no ambiente convencional. Evidentemente este ambiente têm as suas dificuldades e características e será necessário fazer um planejamento para as informações a partir de agora e para as informações já existentes.

7.2.4 – Responsabilidade por classificar a informação

O Gestor da Informação tem a responsabilidade pela classificação da

130

*Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com*

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes) informação sob a sua responsabilidade. Para definir o nível de classificação da informação, o Gestor deverá considerar:

- a. A necessidade de sigilo da informação.
- b. Os controles exigidos para cada um dos níveis de classificação.
- c. O impacto para os objetivos da ORGANIZAÇÃO e a possibilidade de prejuízo, caso a informação seja classificada em um nível indevido e consequentemente ocorra um vazamento da informação.
- d) O nível de classificação ao longo do tempo ou a necessidade de mudança de classificação durante o ciclo de vida da informação.

7.2.5 – O Custodiante da informação – Responsabilidade

O Custodiante da Informação tem a responsabilidade, considerando o ambiente sob sua custódia, de garantir que os controles exigidos pelo nível de sigilo definido para cada informação, estão implantados, são cumpridos e

estão bem gerenciados.

7.2.6 – O Usuário da informação - Responsabilidade

É obrigatório que o usuário siga as regras definidas para a informação classificada em qualquer um dos níveis de sigilo adotados pela Organização.

7.2.7 – Informação não classificada

A Organização precisa definir como deve ser o tratamento da informação ainda não classificada. Organizações que precisam de um rígido sigilo podem

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) considerar que as informações sem classificação serão consideradas informações de mais alto sigilo. Para organizações que não necessitam de um extremo nível de confidencialidade, pode definir uma regra para esta situação que se espera que seja temporária, ou pode considerar como informação de proteção interna.

7.3. Conclusão

Não existe um padrão obrigatório de classificação da informação para Organizações não governamentais. Porém, ao se elaborar seu controle de classificação da informação e treinamento dos usuários neste tema, o Gestor de Segurança da Informação deve contemplar o ambiente externo com o qual a sua Organização de relaciona. Dependendo do tipo de negócio, os usuários precisam ser treinados com os níveis de sigilo da informação das organizações-clientes.

Como as demais Dimensões de Segurança da Informação, a implementação desta dimensão deve considerar as características da organização e do mundo em que habita e se relaciona.



SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

8. DIMENSÃO RECURSOS DE TECNOLOGIA DA INFORMAÇÃO

Foto: Edison Fontes. Barco Viking. Oslo, Noruega.

Neste capítulo apresentaremos a Dimensão Recursos de Tecnologia da Informação, considerando a participação da mesma no Programa Organizacional de Segurança da Informação.

Após a definição do conjunto de regulamentos que formam a política de segurança da informação é necessário a implementação dos controles das dimensões da segurança da informação. As dimensões recursos de tecnologia da informação é uma destas dimensões (FONTES, 2008).

Consideramos nesta dimensão a proteção técnica do ambiente e a utilização de recursos deste ambiente.

A Norma ABNT NBR ISO/IEC 27002 – Tecnologia de segurança –

Técnicas de segurança – Código de prática controles de segurança da informação

133

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) indica a necessidade do controle de recursos de tecnologia da informação considerando a proteção técnica:

Convém que informações sobre vulnerabilidades técnicas dos sistemas de informação em uso sejam obtidas em tempo hábil; convém que a exposição da organização a estas vulnerabilidades seja avaliada e sejam tomadas as medidas apropriadas para lidar com os riscos associados (ABNT, 2013, p.58).

Iniciamos esse capítulo apresentando os objetivos da Dimensão Recursos de Tecnologia da Informação, em seguida descreveremos os principais conceitos/definições, identificaremos os elementos que compõem essa Dimensão.

Vamos apresentar também a Dimensão flexibilidade operacional descrevendo seus objetivos, seus elementos e um exemplo de níveis de classificação da informação.

8.1 – Objetivo da Dimensão Recursos de Tecnologia da Informação

O objetivo principal da Dimensão Recursos de Tecnologia da Informação é garantir que os usuários utilizem recursos e serviços de maneira protegida e alinhada com os objetivos de negócio (FONTES, 2012; ABNT, 2013).

É necessário que exista uma proteção técnica para este ambiente considerando:

- a) Controle de software operacional;
- b) Gestão de vulnerabilidades técnicas;
- c) Auditoria de sistemas de informação;
- d) Controles de redes.



SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

Ferramentas, equipamentos e serviços utilizados como recursos no ambiente de tecnologia também devem ser considerados nesta dimensão.

Recursos de Tecnologia da Informação é uma Dimensão do Programa Organizacional de Segurança da Informação e considera os controles relacionados à informação ou aos recursos de informação (FONTES, 2008). A figura 4 apresenta essas dimensões:

Figura 8.1 – Dimensões da Segurança da Informação

Fonte: Livro “Praticando a Segurança da Informação” (FONTES, 2008, p. 48).

8.2 – Proteção Técnica

O ambiente técnico da informação precisa ser protegido. É necessário que exista controles que garantam que as vulnerabilidades técnicas estão sendo eliminadas ou minimizadas.

A Norma ABNT NBR ISO/IEC 27002 – Tecnologia de segurança –

Técnicas de segurança – Código de prática controles de segurança da informação

135

*Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com*

**SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes)** (ABNT, 2013) indica a necessidade do controle de recursos de tecnologia da informação considerando a proteção do ambiente técnico, destacando:

a) Controle de software operacional;

- b) Gestão de vulnerabilidades técnicas;
- c) Auditoria de sistemas de informação;
- d) Controles de redes.

8.2.1 – Controle Software Operacional

O objetivo de controle de software operacional é “assegurar a integridade dos sistemas operacionais” (ABNT, 2013, p.57). É conveniente que

“procedimentos para controlar a instalação de software em sistemas operacionais sejam implementados” (ABNT, 2013, p.57).

Para atender o controle de software operacional deve-se considerar as regras quando da necessidade de mudanças:

Convém que as atualizações do software operacional, aplicativos e bibliotecas de programas sejam executados por administradores treinados e com autorização gerencial apropriada.

Convém que os sistemas operacionais somente contenham código executável e aprovado, e não contenham códigos em desenvolvimento ou compiladores (ABNT, 2013, p.57).

Convém que sistemas operacionais e aplicativos somente sejam implementados após testes extensivos e bem-sucedidos; é

recomendável que os testes incluam testes sobre uso, segurança, efeitos sobre outros sistemas, como também sobre o uso amigável, e sejam realizados em sistemas separados; convém que seja assegurado que todas as bibliotecas de código-fonte dos programas

correspondentes tenham sido atualizadas (ABNT, 2013, p.57).

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

Convém que um sistema de controle de configuração seja utilizado para manter o controle da implementação de software, assim como da documentação do sistema (ABNT, 2013, p.57).

Convém que uma estratégia de retorno às condições anteriores seja disponibilizada antes que mudanças sejam implementadas no sistema (ABNT, 2013, p.57).

Convém que um registro de auditoria seja mantido para todas as atualizações das bibliotecas dos programas operacionais (ABNT, 2013, p.57).

Convém que versões de anteriores de software aplicativos sejam mantidos como medida de contingencia (ABNT, 2013, p.57).

Convém que versões antigas do software sejam arquivadas com todas as informações e parâmetros requeridos, procedimentos, detalhes de configurações e software de suporte durante um prazo igual ao prazo de retenção de dados (ABNT, 2013, p.57).

É recomendável que software adquirido de fornecedores e utilizado em sistemas operacionais seja mantido em um nível apoiado pelo fornecedor (ABNT, 2013, p.57).

A implementação dos controles acima descritos dará maior garantia para o ambiente do sistema operacional que é um recurso crítico como recurso de tecnologia da informação.

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA **(Edison Fontes)**

8.2.2 – Gestão de Vulnerabilidades Técnicas

Para atender o controle de Gestão de Vulnerabilidades Técnicas deve-se considerar as seguintes regras:

Convém que informações sobre vulnerabilidades técnicas dos sistemas de informação em uso sejam obtidas em tempo hábil; convém que a exposição da organização a estas vulnerabilidades seja avaliada e que sejam tomadas medidas apropriadas para lidar com riscos associados (ABNT, 2013, p.58).

Um inventário completo e atualizado dos ativos de informação é um pré-requisito para uma gestão efetiva de vulnerabilidade técnica (ABNT, 2013, p.58).

Convém que a organização defina e estabeleça as funções e responsabilidades associadas à gestão de vulnerabilidade técnicas (ABNT, 2013, p.58).

Convém que os recursos de informação a serem usados para identificar vulnerabilidades técnicas relevantes e manter a conscientização sobre eles sejam identificados, para softwares e outras tecnologias (ABNT, 2013, p.58).

Convém que seja definido um prazo para a reação a notificações de potenciais vulnerabilidades técnicas relevantes (ABNT, 2013, p.58).

Uma vez que uma vulnerabilidade técnica tenha sido identificada, convém que a organização avalie os riscos associados e as ações a serem tomadas (ABNT, 2013, p.58).

(Edison Fontes) *Dependendo da urgência exigida para tratar uma vulnerabilidade técnica, convém que a ação a ser tomada esteja de acordo com os controles de gestão de mudanças (ABNT, 2013, p.58).*

Se uma correção for disponibilizada, convém que sejam avaliados os riscos associados à sua instalação (ABNT, 2013, p.58).

Convém que as emendas (patches) sejam testadas e avaliadas antes de serem instaladas, para assegurar a efetividade, e que não tragam efeitos que não possam ser tolerados (ABNT, 2013, p.58).

A implementação dos controles acima descritos minimizará existência das vulnerabilidades técnicas. É necessário estar atento na gestão destes controles porque este ambiente técnico possui a necessidade de atualização muito frequente.

Nos normativos da organização deve estar definida responsabilidade pelo desenvolvimento, implantação, manutenção e gestão dos controles de proteção técnica. É uma gestão contínua que pode ser feita diretamente pela Organização ou por um prestador de serviço especializado. Mas seja qual for a solução é fundamental que a Área de Tecnologia da Informação e a Área Gestora da Segurança da Informação recebam relatórios gerenciais sobre o andamento da efetividade dos controles de segurança para o ambiente técnico.

8.2.3 – Auditoria de sistemas de informação

O controle de auditoria de sistemas de informação tem como objetivo

“minimizar o impacto das atividades de auditoria nos sistemas operacionais”

(ABNT, 2013, p.60). Para atender este objetivo, deve-se considerar as seguintes regras:

Edison Fontes, edison@pobox.com

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA

(Edison Fontes) *Convém que as atividades e requisitos de auditoria envolvendo a verificação nos sistemas operacionais sejam cuidadosamente*

planejados e acordados para minimizar a interrupção dos processos de negócio.

Convém que os requisitos de auditoria para acesso aos sistemas e dados sejam acordados com o nível apropriado da gerência.

Convém que o escopo dos testes técnicos da auditoria seja acordado e controlado.

Convém que os testes de auditoria sejam limitados somente a leitura de software e dados.

Convém que os outros acessos diferentes de apenas leitura sejam permitidos somente através de cópias isoladas dos arquivos de sistema, as quais recomenda-se que sejam apagadas ao final da auditoria, ou dada proteção apropriada quando existir uma obrigação para guardar tais arquivos como requisitos da documentação da auditoria.

Convém que os requisitos para processamento adicional ou especial sejam identificados e acordados.

Convém que os testes de auditoria que possam afetar a disponibilidade do sistema sejam realizados fora do horário de trabalho.

Convém que todo o acesso seja monitorado e registrado de forma a produzir uma trilha de referência (ABNT, 2013, p.60).

A implementação dos controles acima descritos permitirá a existência de controles que atendam à auditoria de sistemas. A não implantação destes controles implicará em pontos de auditoria que serão relatados para a alta direção da organização ou para o Conselho de Administração.

Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA **(Edison Fontes)**

8.2.4 – Controles de Redes

O controle de rede tem o intuito de “assegurar a proteção das informações em redes e dos recursos de processamento de informações que as apoiam”

(ABNT, 2013, p.61). Para atender este objetivo, deve-se considerar as seguintes regras:

Convém que controles sejam implementados para garantir a segurança da informação nestas redes, e a proteção dos serviços a elas conectados, contra acesso não autorizado (ABNT, 2013, p.61).

Convém que responsabilidades e procedimentos sobre o gerenciamento de equipamentos de rede sejam estabelecidos (ABNT, 2013, p.61).

Convém que a responsabilidade operacional pelas redes seja separada da operação dos recursos computacionais, onde apropriado (ABNT, 2013, p.61).

Convém que controles especiais sejam estabelecidos para a proteção da confidencialidade e integridade dos dados que trafegam sobre redes públicas ou sobre redes sem fio e que sejam protegidos sistemas e aplicações a elas conectadas (ABNT, 2013, p.61).

Convém que sejam aplicados mecanismos apropriados de registro e monitoração para habilitar a gravação e detecção de ações que possam afetar, ou ser relevante para a segurança da informação (ABNT, 2013, p.61).

Convém que as atividades de gerenciamento sejam coordenadas para

otimizar os serviços para a organização e assegurar que os controles estejam aplicados de forma consistente sobre toda a infraestrutura de processamento da informação (ABNT, 2013, p.61).

Convém que os sistemas de rede sejam autenticados (ABNT, 2013, p.61).

Convém que a conexão de sistemas de rede seja restrita (ABNT, 2013, p.61).

141

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) A implementação dos controles acima descritos permitirá uma segurança adequada no ambiente de rede. Este ambiente de rede é a camada mais externa de proteção do ambiente da informação, daí a sua importância em estar protegido.

8.3 – Equipamentos

Esta dimensão contempla o controle de segurança da informação em relação aos equipamentos utilizados pela organização. Normalmente se apresenta mais ênfase em relação aos equipamentos que são de contato direto com o usuário.

Devem existir políticas e normas sobre o uso de equipamentos. A

organização precisa declarar quais os equipamentos que podem ser utilizados no ambiente corporativo e como os usuários devem se comportar ao utilizarem os mesmos. Devem ser definidas regras de uso e responsabilidades.

142

Segurança da Informação: Gestão e Governança - Copyright © 2020

Edison Fontes, edison@pobox.com



SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes)

9. DIMENSÃO FLEXIBILIDADE

OPERACIONAL

Foto: Edison Fontes. Hamar, Noruega.

O objetivo principal da Dimensão Flexibilidade Operacional é possibilitar que a organização suporte situações adversas sem gerar ruptura na operação do negócio no que se refere aos recursos de informação. Isto significa que a organização que possui bem implementada esta dimensão, trata de maneira estruturada, preventiva e profissionalmente as ocorrências do seu dia a dia buscando desta maneira identificar e gerenciar situações que se não controladas adequadamente poderão gerar indisponibilidade de informação ou de recursos de informação.

A Flexibilidade Operacional é uma Dimensão do Programa Organizacional de Segurança da Informação e considera controles que garantem uma resiliência do processo de segurança. A figura abaixo apresenta as dimensões que compõem o Programa Organizacional da segurança da informação.



SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

Figura 9.1 – Dimensões da Segurança da Informação

Fonte: Livro “Praticando a Segurança da Informação” (FONTES, 2008, p. 48).

A Norma NBR ISO/IEC 27002 (ABNT, 2013) orienta a existência de dois elementos que devem ser considerados: Gestão de Mudança e Gestão de Capacidade.

Devem existir controles quando de situações de mudanças na organização, nos processos de negócio, nos recursos de informação e nos sistemas que afetem a segurança da informação. Em relação ao uso de recursos deve haver um monitoramento para garantir o uso ajustado e devem ser realizadas projeções para identificar necessidades de capacidade futura para garantir o desempenho necessário e exigido pelo sistema, que deve representar a necessidade de negócio da organização.

No aspecto de capacidade dos recursos de informação, a área de negócio deve ser envolvida para identificar os requisitos de capacidade necessários para

144

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

**SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes)** atender a criticidade do negócio da organização suportada pelos sistemas que estão sendo analisados.

Estes elementos devem garantir a disponibilidade e a eficiência necessária dos recursos de informação que suportam o negócio da organização. Devem ser implantados controles do tipo detecção para identificar os problemas em tempo hábil para minimizar ou evitar problemas de indisponibilidade.

Quando da consideração da capacidade dos recursos de informação devem ser considerados os requisitos de novos sistemas e demais recursos de informação considerando as tendências atuais e projetadas para atendimento ao uso da informação e dos recursos de informação da organização.

9.1. Gestão de Mudanças

A Gestão de Mudanças deve considerar os seguintes aspectos:

a. Identificação, registro, classificação e gerenciamento das mudanças a serem

implementadas no ambiente de informação.

Todas as mudanças que acontecem no ambiente de informação que está considerado no escopo do Programa Organizacional de Segurança da Informação deve ser gerenciada.

Uma dúvida surge quando estamos considerando “todas” as mudanças.

Realmente é preciso controlar todas? Sim, é a resposta simples e direta. O

que deve acontecer é que podemos ter um padrão de classificação de mudanças.

Mudanças simples devem ter controles simples compatíveis com as suas características. Uma mudança complexa ou que pode acarretar um grande impacto caso aconteça falhas, devem ser cuidadas e gerenciadas com muito maior grau de controle, aprovações e existência de uma avaliação de riscos.

145

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

b. Planejamento das mudanças.

Todo processo de mudança deve ser planejado, estruturado e aprovado por pessoas com competência e poder para tal. Normalmente as organizações possuem uma reunião semanal de mudança, para concentrar todas as mudanças. Uma mudança somente deve ser implementada se formalmente as pessoas

envolvidas aprovam e explicitam o que fazer caso esta mudança

c. Avaliação de impactos potenciais, incluindo impactos de segurança da informação de tais mudanças.

Os impactos potenciais gerados pela realização de uma mudança devem

ser avaliados antes do início do processo de mudança. Esta avaliação permitirá que a mudança seja realizada ou não realizada, considerando o risco e os potenciais impactos de uma falha na mudança.

d. Procedimento formal de aprovação das mudanças propostas.

Deve existir um procedimento ou um fluxo para o registro dos aprovadores

ou dos riscos que eventualmente a organização queira assumir.

e. Verificação de que os requisitos de segurança da informação foram atendidos.

Um processo de mudança é um mini sistema de informação e portanto deve ter controles para o uso dessa informação: controle de acesso, cópias de segurança, registro do acesso e similares.

146

*Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com*

**SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes) f. Comunicação dos detalhes das mudanças para todas as pessoas relevantes.**

A comunicação é um fator crítico de sucesso para uma efetiva Gestão de Mudanças. Todos os envolvidos com a autorização e aqueles que serão impactados devem ser comunicados de cada etapa da Gestão de Mudanças.

g. Procedimentos de recuperação, incluindo procedimentos e responsabilidades para interrupção e recuperação de mudanças em caso de insucesso ou na ocorrência de eventos inesperados.

Na avaliação de implantação de uma mudança deve ser considerada a possibilidade de retorno para a situação antes da mudança. Problemas podem acontecer e podem inviabilizar a concretização da mudança ou a concretização em tempo hábil da mudança. Estabelecer um ponto de avaliação onde será definido se a mudança continua ou se será suspensa, é fundamental para qualidade da Gestão de Mudanças.

h. Provisão de um processo emergencial de mudança para permitir uma

implementação rápida e controlada de mudanças, necessárias para resolver um incidente.

Todas as mudanças devem ser controladas, porém alguns tipos de mudança podem ter uma priorização diferente. Uma mudança necessária para solucionar um problema que parou a organização, tem que ser rápida, coerente com a necessidade da área de negócio.

147

*Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com*

**SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes) i. Convém que sejam estabelecidos procedimentos e responsabilidades de gestão formais para garantir que haja um controle satisfatório de todas as mudanças.**

A definição de responsabilidades é fundamental para uma boa Gestão de Mudanças. Estas responsabilidades devem estar claras e os responsáveis devem estar cientes das suas responsabilidades

9.2. Gestão de Capacidade (Gestão de Recursos)

A Gestão de Recursos tem por objetivo garantir que no futuro de curto, médio ou longo prazo, os recursos existentes para o Ambiente de Informação são suficientes ou existem procedimentos de planejamento que garantirão a existência dos recursos necessários.

Considerando a Gestão de Capacidade devem ser considerados e definidos os seguintes controles:

a. Elementos que serão considerados para a Gestão de Capacidade.

É necessário definir e explicitar o escopo que será considerado para a Gestão de Capacidade.

b. Métricas e limites que serão utilizados e que serão os referenciais para

este monitoramento.

A Gestão de Capacidade vai analisar o comportamento dos recursos de informação e definir pontos de referência para gerar ações de ajustes.

148

*Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com*

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) c. Responsabilidade das áreas e relatórios periódicos de controles.

As áreas envolvidas devem receber informações periódicas e ter suas responsabilidades explicitadas para que a mesma possa tomar decisões adequadas.

d. Autoridade para o início do processo de aquisição de novos recursos ou de aceitação do risco de manutenção dos recursos.

A Gestão de Capacidade vai gerar necessidade de compra de novos recursos de informação. É recomendável que esta área tenha a autoridade suficiente para a decisão de compras ou pelo menos, participar da comissão que trata do assunto.

e. Total de recursos de informação da Organização.

A Gestão de Capacidade deve ter como objetivo considerar todos os recursos da organização. Evidentemente a atendimento a este objetivo pode ser feito por etapas.

f. Características consideradas em cada avaliação de Gestão de Capacidade.

Devem ser considerados pelo menos os seguintes elementos:

- Crescimento natural.

- Crescimento em função de picos ou situações sazonais.
- Facilidade de monitoramento.
- Credibilidade das fontes de informação para o monitoramento.
- Necessidades lógicas, de equipamentos e de ambiente físico.

g. Histórico das avaliações de Gestão de Capacidade.

Devem ser registradas todas as avaliações realizadas pela Gestão de Capacidade. Preferencialmente estas informações não devem nunca ser descartadas. Recomendamos que no mínimo estas informações sejam guardadas pelo período de cinco ano.



SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

10. DIMENSÃO AMBIENTE

FÍSICO

Foto: Edison Fontes. Bonecos Mestre Vitalino, Brasil.

Neste capítulo apresentaremos a Dimensão Ambiente Físico considerando a participação dela no Programa Organizacional de Segurança da Informação.

Após a definição do conjunto de regulamentos que formam a Política de Segurança da Informação é necessário a implementação dos controles das dimensões da segurança da informação. A Dimensão Ambiente Físico é uma destas dimensões

A Norma ABNT NBR ISO/IEC 27002 – Tecnologia de segurança –

Técnicas de segurança – código de prática dos controles de segurança da informação indica a necessidade de controles no ambiente físico: “Convém que perímetros de segurança sejam definidos e usados para proteger tanto as instalações de processamento a informação como as áreas que contenham informações críticas ou sensíveis” (ABNT, 2013, p.38).

150

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes) Este capítulo apresenta os objetivos da Dimensão Ambiente Físico, em seguida descreve os principais conceitos, definições e identificação dos elementos que compõem esta Dimensão.

10.1 – OBJETIVO DIMENSÃO AMBIENTE FÍSICO

O principal objetivo da Dimensão Ambiente Físico é “prevenir o acesso físico não autorizado, danos e interferências com os recursos de processamento das informações e nas informações da organização” (ABNT, 2013, p. 38).

Esta proteção acontece com a implementação de controles do tipo proteção de perímetro de segurança física, controles de entrada física, segurança em escritórios, salas e instalações; proteção contra ameaças externas e do meio ambiente; trabalhando em área segura; áreas de entrega e carregamento;

localização e proteção de equipamentos; combate a incêndio; proteção das instalações físicas; material utilizado e outros controles semelhantes (ABNT, 2013; FONTES, 2000).

Ambiente Físico é uma Dimensão do Programa Organizacional de Segurança da Informação e considera os controles relacionados à informação ou aos recursos de informação. A Figura abaixo apresenta as dimensões que compõem o Programa Organizacional da segurança da informação.

151

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***



SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

Figura 10.1 – Dimensões da Segurança da Informação

Fonte: Livro “Praticando a Segurança da Informação” (FONTES, 2008,

p. 48).

10.2 – Requisitos de segurança para o ambiente físico

O ambiente físico da informação precisa ser protegido. É necessário que exista controles que garantam que as ameaças que podem afetá-la, e que possuam contramedidas (controles) que minimizam o risco até elas se concretizarem (ABNT, 2013; FONTES, 2012; PELTIER, 2005).

Descrevemos abaixo os principais e prioritários elementos de proteção para o ambiente físico. A rigidez da implementação dos controles que atenderão a estes elementos dependerá do tipo da organização (negócio, porte, cultura, estrutura, recursos disponíveis) e da decisão de como ela deseja ter a segurança no seu ambiente físico.

152

*Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com*

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) Independente da rigidez da implementação é fundamental que estes elementos sejam considerados e formalmente definidos os seus controles.

Recomendamos que sejam considerados (pelo menos) os seguintes controles para a Dimensão Ambiente Físico:

a) Acesso Físico de entrada e saída

O acesso físico do ambiente que possui recursos de informação deve ser restrito às pessoas que trabalham e utilizam esse ambiente. Devem ser utilizados crachás de identificação individual, filmagem do ambiente, catracas e portas que restrinjam o acesso físico, além de vigilância presencial ou outros controles equivalentes.

a.1) Controle de pessoas – identificação

Deve-se definir como as pessoas serão identificadas. Normalmente o uso de crachá é suficiente para uma identificação individual. É necessário considerar todos os tipos de usuários que circularão no ambiente físico: funcionários, prestadores contínuos de serviço, prestadores eventuais de serviço, visitantes, conselheiros, funcionários do Grupo Corporativo que a organização pertence (nacional e internacional).

Recomendamos que este registro de acesso seja armazenado por um período mínimo de um ano.

a.2) Acesso aos ambientes

Sempre é necessária a existência de áreas restritas. Isto é, somente um sub grupo de usuário pode acessar este ambiente físico. Neste caso

153

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes) podemos ter a autorização de acesso apenas pela identificação ou pela identificação mais uma autenticação do usuário.

Quando exigimos apenas uma identificação é o caso quando apenas o uso do crachá, que estará previamente autorizado será suficiente.

Quando exigimos a identificação e a autenticação, além do uso do crachá o usuário terá que ser autenticado por uma senha ou por um método de biometria.

Para a decisão do nível de rigidez do controle de acesso de usuário, o Gestor da Segurança da Informação deverá validar com o Gestor do Ambiente Físico em questão. Salvo situações extremas, recomendamos que o Gestor do Ambiente Físico defina a rigidez do controle. Esta definição deve ser formal

e deve conter os riscos que não são minimizados pelos controles escolhidos. Por exemplo, a escolha do controle de acesso apenas pela identificação (uso de crachá) não impedirá o acesso caso um outro usuário esteja utilizando o crachá de determinado usuário, seja por permissão do verdadeiro dono do crachá, seja por má fé, em uma situação de erro.

b) Combate a incêndio

Devem existir sistemas de detecção e combate a incêndios. A organização deve avaliar o nível de automação destes controles, sempre priorizando a vida humana.

Um relatório semestral deve registrar a situação deste controle.

c) Qualidade e manutenção das instalações elétricas

As instalações elétricas devem ser mantidas em excelente padrão de qualidade de maneira a evitar situações que possam impedir o

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes) funcionamento da utilidade energia elétrica ou de funcionamento do ambiente.

d) Monitoramento da vizinhança

A organização precisa cuidar do seu ambiente e monitorar o

ambiente ao seu redor. Muitas vezes, o maior risco está em uma empresa vizinha que não tem proteção física adequada e pode gerar um incêndio de grandes proporções de maneira que afete a organização.

Deve ser gerado um relatório semestral sobre o ambiente da

vizinhança.

e) Material utilizado

O material utilizado no ambiente físico deve ser do tipo de difícil combustão; isto é, material que demora para pegar fogo, aumentando a possibilidade de um combate inicial em uma situação de incêndio.

f) Treinamento de pessoas

As pessoas que utilizam o ambiente físico precisam ser treinadas para saber o que devem fazer diante de uma situação de incêndio para abandono de local, ou mesmo diante de um problema elétrico.

Muitas vezes este treinamento sobre o ambiente físico e combate a

incêndio está sob responsabilidade da Área Administrativa ou Segurança do Trabalho. Sem problemas. Porém, independente onde esteja esta responsabilidade, o Gestor de Segurança da Informação deve exigir a existência do treinamento. Recomendamos que semestralmente as pessoas sejam treinadas em abandono de local, combate a incêndio e outras situações similares. Muitas vezes a organização se baseia apenas na

155

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) legislação e faz o mínimo obrigatório. Como Gestor da Segurança da Informação devemos minimizar ao máximo os riscos que podem interferir na disponibilidade da informação para a realização do negócio e para o atendimento aos objetivos corporativos.

g) Perímetro de segurança física

A proteção do ambiente físico deve ter várias camadas de controle

de proteção física. As camadas mais externas vão realizando uma proteção

inicial. A existência destas camadas facilita o controle da proteção física do ambiente.

h) Movimentação de ativos

do ambiente físico deve continuar com a mesma rigidez. Como exemplo, podemos citar que em muitas organizações quando ocorre uma mudança física de vários elementos simultaneamente, os controles de acesso físico são desligados ou não são considerados.

i) Filmagem do ambiente

O ambiente físico deve ter registrado as imagens do que acontece no mesmo. As imagens devem contemplar as entradas e saídas (pessoas e material), corredores e uma visão geral do ambiente. As imagens não devem focar no trabalho dos usuários. Seu objetivo é registrar para facilitar o que acontece ou aconteceu no ambiente físico da organização. A qualidade da gravação deve ser boa de maneira a podermos identificar pessoas que circulam no ambiente.

**SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes)** A gravação de imagens é um elemento esclarecedor e muitas vezes

definitivo para explicar situações que o ambiente lógico da informação não consegue explicar.

Recomendamos que as imagens do ambiente sejam armazenadas por um período de um ano.

j) Gestor do Ambiente Físico

Todo ambiente físico deve ter o seu gestor formalizado. Este gestor deve ser indicado pela Presidência da organização ou por um órgão de poder executivo da organização. Deve existir um regulamento assinado pela Presidência formalizando estes gestores.

Os controles que realizam a proteção do ambiente físico podem ter níveis de rigidez para cada uma das áreas físicas. Por exemplo, um controle de pessoas na portaria do ambiente de escritório pode ter uma menor rigidez do que o controle de acesso à sala dos servidores do ambiente computacional.



(Edison Fontes)

11. DIMENSÃO

INFRAESTRUTURA

Foto: Edison Fontes. Pont des Arts. Paris, França.

Neste capítulo apresentaremos a Dimensão Infraestrutura considerando a participação dela no Programa Organizacional de Segurança da Informação.

Após a definição do conjunto de regulamentos que formam a Política de Segurança da Informação é necessário a implementação dos controles das dimensões da segurança da informação. A Dimensão Infraestrutura é uma destas dimensões

A Norma ABNT NBR ISO/IEC 27002 – Tecnologia de segurança –

Técnicas de segurança – código de prática dos controles de segurança da informação indica a necessidade de controles na infraestrutura: “Convém que os equipamentos sejam protegidos contra a falta de energia elétrica e outras interrupções causadas por falhas das utilidades” (ABNT, 2013, p.42).

158

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

**SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes)** Este capítulo apresenta os objetivos da Dimensão Infraestrutura, em seguida descreve os principais conceitos, definições e identificação dos elementos que compõem esta Dimensão.

11.1 – Objetivo da Dimensão Infraestrutura

O objetivo principal da Dimensão infraestrutura é proteger o ambiente contra falhas de serviços de facilidades (ABNT, 2013; FONTES, 2000).

Esta proteção acontece com a implementação de vários tipos de controles relacionados aos serviços de facilidades que o ambiente da informação

utiliza.

Algumas vezes incluímos estes controles como proteção do ambiente físico, mas eles devem ser tratados de maneira separada, considerando principalmente que para eles, normalmente, a organização depende de fornecedores externos.

Infraestrutura é uma Dimensão do Programa Organizacional de Segurança da Informação e considera os controles relacionados à informação ou aos recursos de informação. A Figura abaixo apresentada anteriormente trata da Dimensão infraestrutura junto com a Dimensão ambiente físico.

159

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***



**SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes)**

Figura 11.1 – Dimensões da Segurança da Informação

Fonte: Livro “Praticando a Segurança da Informação” (FONTES, 2008, p. 48).

11.2 – Requisitos de segurança para a infraestrutura

A Dimensão infraestrutura é formada por elementos que possibilitam que o ambiente de informação da organização realize os demais controles necessários à segurança da informação.

Descrevemos abaixo os principais e prioritários elementos da infraestrutura que possibilitam a organização estabelecer a segurança da informação. A rigidez da implementação dos controles que atenderão a estes elementos dependerá do tipo da organização (negócio, porte, cultura, estrutura, recursos disponíveis) e da decisão de como ela deseja ter a segurança no seu ambiente físico.

Independente da rigidez da implementação é fundamental que estes elementos sejam considerados e formalmente definidos os seus controles.

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) Consideramos os seguintes elementos para a Dimensão Infraestrutura (ABNT, 2013; FONTES, 2000; PELTIER, 2005):

- **Fornecimento de Energia Elétrica**

A energia elétrica é fundamental para o funcionamento da organização e, conseqüentemente, no uso da informação pela organização. A organização pode ter fontes alternativas temporárias de energia elétrica, mas normalmente, é fundamental que a empresa prestadora de energia elétrica forneça este recurso de maneira adequada.

• Fornecimento de Água

A água é um recurso que permite o funcionamento da organização.

Alguns equipamentos precisam de água para o seu funcionamento; porém, não podemos esquecer que a água é um elemento fundamental

para o ser humano, seja para o consumo, seja para manter o ambiente

em condições de higiene adequado. Uma organização pode entrar em

situação de contingência por falta de água. No passado, quase não era lembrado este recurso, pela sua aparente abundante disponibilidade.

Infelizmente, recentemente, temos aprendido que a água é um recurso

limitado e que para tudo funcionar é necessário o recurso água.

• Fornecimento de Gás

Inicialmente, pode parecer que o gás é uma facilidade que não tem a

ver com o recurso informação. Verifique em sua organização. Talvez

algum equipamento que suporte um ambiente seja mantido a gás. A Norma da ABNT cita explicitamente este elemento (ABNT, 2013).

• Fornecimento de Ar-Condicionado e/ou Calefação

O ambiente para as pessoas e para os equipamentos precisam estar em

condições adequadas e dentro dos padrões estabelecidos. O

monitoramento dos fornecedores que proporcionam uma temperatura adequada é fundamental para que pessoas e equipamentos

desempenhem suas funções de maneira adequada.

Sobre estes elementos da Dimensão infraestrutura, a ABNT resume os controles que a organização deve ter:

Convém que todas as utilidades (como suprimento de energia elétrica, telecomunicações,

suprimento

de

água,

gás,

esgoto,

calefação/ventilação) e ar condicionado):

a) estejam em conformidade com as especificações do fabricante do equipamento e com os requisitos legais da localidade;

b) sejam avaliadas regularmente quanto a sua capacidade de atender ao crescimento do negócio e às interações com outras utilidades;

d) sejam alarmadas para detectar mau funcionamento quando necessário;

e) tenham múltiplas alimentações com rotas físicas diferentes (ABNT, 2013, p.42).

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) Esta Dimensão exige uma gestão contínua dos elementos que a compõe, sob o risco de parada do ambiente da informação ou do ambiente de recursos de informação.

Recomendamos que semestralmente seja emitido um relatório formal avaliando as condições dos elementos que possibilitam uma adequada infraestrutura para o Programa Organizacional da Segurança da Informação.



SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA

(Edison Fontes)

12. DIMENSÃO

DESENVOLVIMENTO E MANUTENÇÃO DE SISTEMAS

APLICATIVOS

Foto: Edison Fontes. Arte de Mateus e Sofia. Brasil

Neste capítulo apresentaremos a Dimensão Desenvolvimento e

Manutenção de Sistemas Aplicativos considerando a participação dela no Programa Organizacional de Segurança da Informação.

Após a definição do conjunto de regulamentos que formam a Política de Segurança da Informação é necessário a implementação dos controles das dimensões da segurança da informação. A Dimensão Desenvolvimento e Manutenção de Sistemas Aplicativos.

164

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes) Este capítulo apresenta os objetivos da Dimensão Desenvolvimento e Manutenção de Sistemas Aplicativos, em seguida descreve os principais conceitos, definições e identificação dos elementos que compõem esta Dimensão.

12.1 – Objetivo da Dimensão Desenvolvimento e manutenção de

sistemas aplicativos

O objetivo principal da Dimensão Desenvolvimento e Manutenção de Sistemas Aplicativos é “garantir que a segurança da informação seja parte integrante de todo o ciclo de vida dos sistemas de informação” (ABNT, 2013, p.

67). Fontes (2012) complementa que esta Dimensão deve “definir os requisitos e os controles de segurança que devem ser considerados quando do desenvolvimento ou manutenção de sistemas desenvolvidos pela Organização ou desenvolvidos para a Organização (p.169).

Os controles desta Dimensão não dizem como desenvolver ou como realizar a manutenção dos sistemas aplicativos. Eles indicam aspectos de segurança da informação que devem ser considerados quando do desenvolvimento ou manutenção de sistemas aplicativos.

Desenvolvimento e manutenção de sistemas aplicativos é uma Dimensão do Programa Organizacional de Segurança da Informação e considera os controles relacionados à informação ou aos recursos de informação. A Figura 2

apresenta as Dimensões que compõem o Programa Organizacional da Segurança da Informação.



SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

Figura 12.1 – Dimensões da Segurança da Informação

Fonte: Livro “Praticando a Segurança da Informação” (FONTES, 2008, p. 48).

12.2 – Requisitos de segurança para o desenvolvimento e manutenção de sistemas aplicativos

Quando do desenvolvimento ou manutenção de sistemas aplicativos deve-se considerar alguns controles de segurança. A implementação ou não destes controles, ou a rigidez de um controle que será aplicado, varia para cada organização. O importante é que estes controles sejam considerados e que a organização, utilizando seus profissionais de segurança e os profissionais relacionados ao negócio, definam como será esta implementação (ABNT, 2013; FONTES, 2012).

Consideramos os seguintes elementos para a Dimensão Desenvolvimento e

*Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com*

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) a) Continuidade do serviço – Limite de indisponibilidade

Indica o tempo mínimo de indisponibilidade exigido pela área de negócio ou pela área responsável pelo serviço que este sistema possibilita ser executado.

b) Criptografia de informação

Deve-se definir se o sistema tratará com informações que necessitam ser criptografadas. Caso necessário é preciso definir como será esta criptografia, a guarda das chaves, e aonde estas informações serão armazenadas, além da existência de procedimentos formais para este tratamento criptográfico.

c) Acesso à informação – Identificação do usuário

Indica como será a identificação para cada um dos tipos de usuários que acessarão o sistema aplicativo.

d) Acesso à informação – Autenticação do usuário

Indica como o usuário será autenticado. Dependendo da rigidez deste controle, esta definição terá impacto no projeto do sistema aplicativo e também impactará nos custos do projeto, como por exemplo quando do uso de sistema de token com números aleatórios.

e) Acesso à informação – Grupos de Usuários ou Perfil de Usuário É necessário definir se o acesso do usuário será realizado de maneira discreta

(cada pessoa) ou pela utilização de grupos ou de perfil de usuário.

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

**SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes)** Deve-se lembrar que uma decisão por Perfil do Usuário deve estar

coerente com o grau de maturidade da Organização em perfil do usuário junto aos sistemas de Recursos Humanos. Bem como à cultura da Organização. Uma Organização que não deseja ter (por motivos que somente cabem à ela julgar) um sistema verdadeiro de perfis de usuário na gestão de pessoas, não poderá utilizar a opção de Perfil de Usuário como identificação de usuário. Uma alternativa é o uso de grupos.

f) Acesso à Informação – Autorização

É necessário indicar como será feita a autorização para o acesso à informação. Recomendamos o uso do controle Gestor da Informação.

g) Gestor da Informação

É necessário que cada informação ou grupo de informação tenha explicitamente o seu gestor. O Gestor da Informação é a pessoa que tem o poder de autorizar ou negar o acesso à informação pelo usuário. Este gestor também tem outras responsabilidades em relação à informação.

h) Acesso à Informação - Registro (log) dos acessos.

É necessário definir as situações que devem ser registradas quando do acesso à informação (leitura, alteração, remoção, gravação, similar) pelo usuário.

i) Acesso à informação - Guarda dos registros (log)

- É necessário definir o tempo de guarda/armazenamento dos registros referente aos acessos à informação.

168

*Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com*

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

-Deve-se considerar a guarda em arquivos que permitem uma consulta imediata (online) e a guarda de arquivos que necessitam de um tempo maior de recuperação (offline).

- Ciclo e periodicidade dessa informação armazenada on-line ou off-line.

j) Cópias de segurança

Deve-se definir como serão as cópias de segurança e durante quanto

tempo elas devem ser guardadas. É necessário considerar os aspectos legais, históricos e de auditoria, para definição deste tempo.

k) Segurança do ambiente de desenvolvimento

O ambiente de desenvolvimento de sistemas deve ter os mesmos tipos de controle utilizados para o ambiente de produção. Questões como confidencialidade, privacidade e disponibilidade para a realização de funções são equivalentes ao ambiente de produção. Os controles do ambiente de desenvolvimento devem estar explícitos e documentados.

l) Testes do sistema

Deve-se identificar como serão realizados os testes, incluindo os testes de aceitação. É necessário a existência de planos de testes, de maneira a permitir que erros nos sistemas sejam identificados antes do sistema tratar com o ambiente de produção.

Esta documentação de testes deve ser suficiente para a geração de evidências de maneira a mostrar que os testes buscam garantir a melhor efetividade dos sistemas aplicativos.

169

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) m) Desenvolvedores

Independente do desenvolvimento ser interno ou externo (prestadores de serviço) é necessária uma avaliação de segurança para indicar como a Organização está dependente deste grupo de profissionais.

Os controles que realizam a proteção da Dimensão Desenvolvimento e Manutenção de Sistemas Aplicativos permitem a realização de uma segurança proativa. Em muitas organizações, a preocupação com os controles descritos nesta aula só acontece quando o sistema aplicativo está funcionando em produção. E neste caso é bem mais trabalhoso tratar adequadamente destes controles de segurança da informação.

Entendemos que o Controle de Código Seguro é uma responsabilidade do desenvolvedor. O Gestor da Segurança da Informação deve validar se o desenvolvedor segue na prática os princípios e recomendações de código seguro.

Elaborar um código adequado e seguro é função do desenvolvedor de sistemas aplicativos.

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***



**SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes)**

13. DIMENSÃO MODELO

OPERATIVO DA SEGURANÇA DA INFORMAÇÃO

Foto: Edison Fontes. Av. Brasil. São Paulo, Brasil.

Neste capítulo apresentamos a Dimensão Modelo Operativo da Segurança da Informação considerando a participação dela no Programa Organizacional de Segurança da Informação.

Após a definição do conjunto de regulamentos que formam a política de segurança da informação é necessário a implementação dos controles das dimensões da segurança da informação. A Dimensão Modelo Operativo da Segurança da Informação é uma destas dimensões.

A Norma ABNT NBR ISO/IEC 27002 – Tecnologia de segurança –

Técnicas de segurança – Código de prática de controles de segurança da

171

*Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com*

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) informação indica a necessidade da existência de modelo operativo da segurança da informação: “Convém que todas as responsabilidades pela segurança da informação sejam definidas e atribuídas” (ABNT, 2013, p.04).

13.1 – Objetivo da Dimensão Modelo Operativo da Segurança da

Informação

O principal objetivo da Dimensão Modelo Operativo de Segurança da Informação é “estabelecer uma estrutura de gerenciamento para iniciar e controlar a implementação e operação da segurança da informação dentro da organização” (ABNT, 2013, p. 04). Esta mesma norma explicita o objetivo da organização interna da segurança da informação:

6. Organização da segurança da informação

6.1 – Organização interna

Objetivo: Estabelecer uma estrutura de gerenciamento para iniciar e controlar a implementação e operação da segurança da informação dentro da organização (ABNT, 2013, p.04).

O objetivo do modelo operativo da segurança da informação ou da área organizacional da segurança da informação é a “definição do escopo e atuação, definição da estrutura de pessoas e recursos, identificação das áreas gestoras de informação, identificação das áreas que utilizam a informação, identificação dos processos necessários para a gestão da segurança da informação, definição da posição organizacional”.

Esta proteção acontece com a implementação de controles que possibilitem que a organização tenha uma estrutura formal de como o processo de segurança da informação deve funcionar e como está definida o conjunto de responsabilidades para que este processo aconteça. São controles, como



SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

responsabilidades e papéis, níveis de autorização, entidade responsável pelo processo de segurança da informação e gerenciamento da coordenação geral.

Alguns itens que devem ser considerados na estrutura de implementação da segurança da informação: “A forma de atuação, a quantidade de pessoas, o nível hierárquico e os recursos envolvidos variam de empresa para empresa” e complementa que a organização deve definir se esta gestão da segurança da informação será centralizada ou descentralizada (FONTES, 2000).

O modelo operativo da segurança da informação é uma Dimensão do Programa Organizacional de Segurança da Informação e considera os controles relacionados à informação ou aos recursos de informação. A Figura 1 apresenta as Dimensões que compõem o Programa Organizacional da Segurança da Informação.

Figura 13.1 – Dimensões. Fonte: Livro “Praticando a Segurança da Informação” (FONTES, 2008, p. 48).

*Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com*

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) 13.2 – Requisitos de segurança para o modelo operativo da

segurança da informação.

O modelo operativo da segurança da informação precisa ser considerado no Programa Organizacional de segurança da informação considerando que ele definirá o a área organizacional responsável para que a segurança da informação aconteça na organização. É necessário que existam controles que garantam que as ameaças que podem afetar o modelo operativo, possuem contramedidas (controles) que minimizam o risco delas se concretizarem (ABNT, 2013; FONTES, 2012; PELTIER, 2005).

Descrevemos abaixo os principais e prioritários elementos de estruturação para o modelo operativo de segurança da informação. A rigidez da implementação dos controles que atenderão a estes elementos dependerá do tipo da organização (negócio, porte, cultura, estrutura, recursos disponíveis) e da decisão de como ela deseja ter para o seu modelo operativo.

Independente da maneira de como estes controles serão implementados é fundamental que estes elementos sejam considerados, formalmente definidos e de conhecimento de todos os usuários da organização.

Consideramos os seguintes elementos para a Dimensão modelo operativo de segurança da informação (ABNT, 2013; FONTES, 2000; PELTIER, 2005):

a) Definição dos recursos humanos e de responsabilidades e papéis É necessário definir como será o conjunto de pessoas que formarão a

área de segurança da informação, a quantidade de pessoas, as áreas de atuação, equipe interna e externa e atendimento às questões técnicas são os principais pontos que devem ser definidos. Os papéis e as responsabilidades

da área de segurança da informação e das pessoas que compõem esta área precisam estar explícitas e formalizadas para toda a organização.

174

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) b) Definição da forma de atuação

Uma área de segurança da informação pode atuar de maneira centralizada, descentralizada, mista ou de qualquer outra forma que a organização entenda. O fundamental é que esta definição de atuação esteja alinhada com o que a organização necessita e esteja formalizada para toda a organização.

c) Definição da estrutura organizacional

A área de segurança da informação precisa estar inserida

formalmente na estrutura hierárquica e estrutural da organização. Cada organização precisa definir o nível hierárquico e o poder de atuação.

Uma questão é certa: quanto mais independente for a área de segurança da informação, mais chances de sucesso ela terá.

d) Definição da arquitetura para o Programa Organizacional de segurança da informação

É necessário que seja definida qual a arquitetura que a área de segurança da informação seguirá. Esta arquitetura pode ser formada por várias estruturas. São exemplos de estruturas: Norma ISO/IEC

27002, Conjunto de Normas da Família 27000, Legislação,

Requerimentos do Banco Central e similar.

175

*Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com*

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) e) Consideração com o recurso humano que será afetado pelo processo de segurança

O modelo operativo da segurança da informação deve considerar o público que receberá diretamente a operacionalização dos controles.

Considerando os diversos tipos de usuários que serão impactados pelo Programa Organizacional de segurança da informação, a condução deste processo deverá tratar cada um destes grupos da maneira mais adequada às suas características.

f) Garantia da segregação de funções

As pessoas que participam da área de segurança da informação não podem atuar em outras funções na organização que entre em conflito com a função no processo de segurança da informação. Mesmo internamente na área de segurança da informação, a segregação de função deve ocorrer.

g) Garantia de contato com autoridades e grupos específicos

As pessoas que fazem parte da área de segurança da informação devem manter contato

periódico com autoridades e com grupos de

trabalho que tratem do assunto ou de situações que impactem a segurança da informação. Não é no momento da ocorrência de um problema que devemos procurar autoridades ou outros profissionais.

Devemos manter um contato permanente pois quando houver a necessidade, esta comunicação será facilitada.

176

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) h) Participação no Gerenciamento de Projetos

A área de segurança da informação deve ser sempre considerada no

gerenciamento de projetos, com o objetivo de identificar aspectos deste projeto que necessitarão da definição de controles. Esta participação é uma medida preventiva e permitirá que futuras vulnerabilidades de proteção de segurança da informação sejam minimizadas ou eliminadas

com a implantação de controles no

início dos projetos.

i) Auditabilidade das ações da área de segurança da informação

Todas as ações da área de segurança da informação devem ser passíveis de rastreabilidade. Esta é uma maneira de controlar eventuais dúvidas ou investigações que se façam necessárias sobre a atuação dos profissionais de segurança da informação.

A forma de implementação do Modelo Operativo da Segurança da Informação depende exclusivamente da organização e de suas características

(porte da organização e tipo de negócio).

**RESPONSABILIDADE:
UMA ESPECIALIDADE
DO BOM
PROFISSIONAL.**

- SÓ ACESSE AMBIENTES E FUNÇÕES AOS QUAIS ESTÁ AUTORIZADO. TENTAR ACESSAR OUTRAS FUNÇÕES, ALÉM DE SOBRECARREGAR O SISTEMA, É AUDITÁVEL!
- VOCÊ É O RESPONSÁVEL PELO USO E SIGILO DAS INFORMAÇÕES ACESSADAS COM A SUA IDENTIFICAÇÃO/SENHA, QUE SÓ DEVEM SER UTILIZADAS PARA O DESEMPENHO DO SEU TRABALHO.
- CONHEÇA A FUNDO OS SEUS DIREITOS E DEVERES. PROCURE O SEU MONITOR DE USUÁRIO.

Banorte
Banco privado com rede eletrônica nacional.
Um amigo na praça

**CAMPANHA
DE
SEGURANÇA**

SEGURANÇA É FATOR DE CRESCIMENTO.

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

14. DIMENSÃO

CONSCIENTIZAÇÃO E

TREINAMENTO

Foto: Edison Fontes. Campanha Segurança Informação BANORTE, Recife, Brasil.

14.1 – Objetivo da Dimensão Conscientização e Treinamento de

Usuários

O objetivo principal da Dimensão Conscientização e Treinamento de Usuário é capacitar os usuários para entender e seguir os controles de segurança da informação (ABNT, 2013; FONTES, 2000; PELTIER, 2005). Esta Dimensão acontece com a implementação de controles que definem que os usuários precisam ser treinados e devem conhecer as suas responsabilidades no Programa Organizacional de Segurança da Informação.

178

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes) A organização deve orientar a todos os funcionários e partes externas que pratiquem a segurança da informação de acordo com o estabelecido nas políticas e procedimentos da organização, assegurando que eles:

- a) estejam adequadamente instruídos sobre as suas responsabilidades e papéis pela segurança da informação, antes de terem acesso às informações sensíveis ou aos sistemas de informação;*
- b) recebam diretrizes que definam quais as expectativas sobre segurança da informação de suas atividades dentro da organização;*
- c) sejam motivados para cumprir com as políticas de segurança da informação da organização;*

d) atinjam um nível de conscientização sobre segurança da informação que seja relevante para os seus papéis e responsabilidades dentro da organização;

e) cumpram com os termos e condições de trabalho que incluam a política de segurança da informação da organização e métodos apropriados de trabalho;

f) tenham as habilidades e qualificações apropriadas e sejam treinados regularmente;

g) tenham disponível um canal de notificação, de forma anônima, para reportar violações nas políticas e procedimentos de segurança da informação.

É recomendável que a direção demonstre seu apoio às políticas, procedimentos e controles, e aja como tal, de forma exemplar (ABNT, 2013, p.13).



SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

A conscientização e treinamento de usuário é uma Dimensão do Programa Organizacional de Segurança da Informação e considera os controles relacionados à formação das pessoas no entendimento da proteção da informação. A Figura abaixo apresenta as dimensões que compõem o Programa Organizacional da segurança da informação.

Figura 27 – Dimensões da Segurança da Informação

Fonte: Livro “Praticando a Segurança da Informação” (FONTES, 2008, p. 48).

(Edison Fontes) 14.2 – Requisitos de segurança para a Dimensão Conscientização e

Treinamento de Usuários

A Dimensão Conscientização e Treinamento de Usuário é formada por elementos que possibilitam que as pessoas envolvidas com a informação da organização exerçam os demais controles necessários à segurança da informação.

Descrevemos abaixo os principais e prioritários elementos para que a conscientização e treinamento de usuário aconteça na organização. A rigidez da implementação dos controles que atenderão a estes elementos dependerá do tipo da organização (negócio, porte, cultura, estrutura, recursos disponíveis) e da decisão de como ela deseja ter a conscientização dos usuários em segurança da informação.

Independente da rigidez da implementação é fundamental que estes elementos sejam considerados e formalmente definidos os seus controles.

Os seguintes elementos da Dimensão conscientização e treinamento e usuário devem ser desenvolvidos e implantados (ABNT, 2013; FONTES, 2000; PELTIER, 2005):

- **Considerar todos os tipos de usuários**

A Dimensão Conscientização e Treinamento em Segurança da Informação

deve ser aplicada a todos os tipos de usuários: funcionários, prestadores de serviço, estagiários, menor aprendiz, conselheiro ou qualquer outro tipo de usuário que exista na organização. O cliente também é um tipo de usuário e deve ser considerado. Evidentemente o tipo de treinamento e de comunicação sobre segurança da informação será específica para este tipo de usuário. O conjunto de características da organização também deve ser

Edison Fontes, edison@pobox.com

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA

(Edison Fontes) considerado: tipo de organização, tipo de informação, porte da organização e tipo do negócio da organização.

- **Planejar as ações de conscientização e treinamento**

A conscientização e o treinamento do usuário em segurança da informação precisa ser bem planejada e estruturada. As ações devem ser concatenadas e devem considerar os usuários

antigos e os usuários novos. Este

treinamento deve considerar a maneira de comunicação para os diversos tipos de usuários, bem como deve aproveitar da melhor maneira possível as diversas mídias e meios de comunicação possíveis de serem utilizadas pela organização.

- **Contar com o apoio explícito da direção nos treinamentos**

A direção da organização e seus demais executivos precisam apoiar explicitamente as ações de treinamento e conscientização de usuários em segurança da informação. O treinamento de novos funcionários deve ter sua abertura realizada por um gestor executivo da organização. Os treinamentos periódicos devem também de maneira criativa, mas contundente, deixar evidente que a direção da organização apoia estas iniciativas de

treinamento porque quer que todos saibam o que deve

fazer com a informação da organização e o que não pode ser feito.

- **Definir processo disciplinar**

A organização já deve ter um processo disciplinar. Neste caso, a segurança da informação será mais um elemento da organização que utilizará este processo disciplinar.

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA **(Edison Fontes)**

- **Dar continuidade ao processo**

A Dimensão Conscientização e Treinamento em Segurança da Informação

nunca se encerra. Esta Dimensão precisa desenvolver atividades que devem existir, enquanto a organização existe. Serão desenvolvidos projetos com início, meio e fim. Porém sempre devem existir processos que garantirão que os usuários são treinados e se mantêm conscientes das responsabilidades em relação à segurança da informação.

- **Criar uma cultura de segurança**

Para que a conscientização e a internalização dos controles de segurança da informação aconteçam de maneira efetiva é necessário criar e manter uma cultura de segurança da informação. Vale lembrar que para criar essa cultura, é preciso a existência de um forte processo de segurança da informação, e do apoio da direção da organização e de profissionalismo com os controles de segurança.

Esta Dimensão exige uma gestão contínua dos elementos que a compõe, sob o risco de enfraquecimento do Programa Organizacional de Segurança da Informação, porque o elemento que faz acontecer esta proteção é o conjunto de pessoas. Se as pessoas não internalizarem como devem proceder em relação à informação, o processo de segurança estará comprometido ao não sucesso.

Edison Fontes, edison@pobox.com



SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

15. DIMENSÃO CONTINUIDADE DE NEGÓCIO

Foto: Edison Fontes. Vigeland Park Oslo, Noruega.

Neste capítulo apresentamos a Dimensão Continuidade de Negócio, considerando a participação dela no Programa Organizacional de Segurança da Informação.

Após a definição do conjunto de regulamentos que formam a política de segurança da informação é necessário a implementação dos controles das dimensões da segurança da informação. A Dimensão Continuidade de Negócio é uma destas dimensões (FONTES, 2012).

A Norma ABNT NBR ISO/IEC 27002 – Tecnologia de segurança –

Técnicas de segurança – Código de prática de controles de segurança da informação indica a necessidade da existência da continuidade de negócio:

184

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

“Convém que a continuidade da segurança da informação seja contemplada nos sistemas de gestão de continuidade de negócio da organização” (ABNT, 2013, p.

88).

A Norma ABNT NBR ISO/IEC 27031 – Tecnologia de segurança –

Técnicas de segurança – Diretrizes para a prontidão para a continuidade dos negócios da tecnologia da informação e comunicação orienta que as ações para a continuidade de negócio devem ser integradas às atividades da organização:

“Para ser efetivo, é recomendado que o Programa de Continuidade de Negócio seja um processo totalmente integrado com as atividades gerenciais, direcionadas do topo da cadeia hierárquica da organização, endossadas e promovidas pela alta direção” (ABNT, 2015, p. 9).

Este capítulo apresentará os objetivos da Dimensão Continuidade de Negócio, descrevendo os principais conceitos e definições e, em seguida,

identificará os elementos que compõem esta Dimensão.

15.1 – Objetivo da Dimensão Continuidade de Negócio

O principal objetivo da Dimensão continuidade de negócio, de acordo com Fontes (2006, p. 59), é garantir que:

[...] cada organização deve estar preparada para enfrentar situações de contingência e de desastre que tornem indisponíveis recursos que possibilitam seu uso. Ele deve garantir que os processos que permitem a realização do negócio vão continuar acontecendo, dentro de padrões previamente estabelecidos, apesar da ocorrência de uma situação de contingência.

185

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) Fontes (2008, p. 73) complementa que a Dimensão continuidade de negócio deve garantir que o “plano de continuidade de negócio deve ser efetivo e deve possibilitar que a organização funcione em um nível aceitável para a sua sobrevivência e absorva possíveis impactos financeiros, operacionais e de imagem”.

Para o desenvolvimento e implantação da Dimensão Continuidade de Negócio, Fontes (2008) estabelece as seguintes diretrizes:

A organização deve estar preparada para enfrentar situações de contingência que indisponibilizem recursos de informação.

A definição do plano de continuidade de negócio deve ser específica para cada organização, pois deve ser baseado em uma análise de impacto no negócio caso ocorra uma indisponibilidade dos recursos de informação.

A alta administração e os acionistas da organização devem conhecer a

cobertura (cenário, escopo, ameaças contempladas, impacto aceito, soluções, tempo de recuperação e limitações do plano. Deve também conhecer e aprovar as ameaças e riscos que estão fora de cada versão do plano.

O plano de continuidade de negócio deve ser eficiente e eficaz, deve ser mantido atualizado e deve ser testado periodicamente contando com a participação de todos os envolvidos (FONTES, 2008, p.73).

Os executivos, como representantes dos acionistas, devem conhecer a situação do nível de proteção quando da ocorrência de desastres no ambiente da informação (FONTES, 2008, p. 77).

186

**Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com**



**SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes)**

Cuidar da continuidade de negócio ao longo do tempo, exige garantir a disponibilidade da informação para a realização deste negócio, é uma responsabilidade da direção executiva (FONTES, 2008, p. 99).

A Continuidade de Negócio é uma Dimensão do Programa Organizacional de Segurança da Informação e considera os controles relacionados à informação ou aos recursos de informação. A Figura 28 apresenta as Dimensões que compõem o Programa Organizacional de Segurança da Informação.

Figura 15.1 – Dimensões da Segurança da Informação

Fonte: Livro “Praticando a Segurança da Informação” (FONTES, 2008, p. 48).

15.2 – Etapas de um Plano de Continuidade de Negócio

A continuidade do negócio precisa ser considerada no Programa Organizacional de segurança da informação levando-se em conta que a organização necessita continuar operando, mesmo que em um ritmo menor,

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) quando há ocorrência de uma indisponibilidade da informação. É necessário que existam controles que garantam que as ameaças que podem afetar a efetividade de um plano de continuidade do negócio, possuam contramedidas que minimizem o risco do plano não se concretizar (ABNT, 2013; FONTES, 2012; PELTIER, 2005).

Descrevemos abaixo as etapas para a estruturação do plano de continuidade de negócio. O porte do plano a ser implementado dependerá do tipo da organização (negócio, porte, cultura, estrutura, recursos disponíveis) e da decisão de como ela deseja ter tempo de indisponibilidade da informação,

impactando o negócio.

Independente da maneira como estes controles serão implementados é fundamental que os mesmos sejam considerados, formalmente definidos e de conhecimento de todos os usuários da organização.

Consideramos os seguintes elementos para o Plano de Continuidade de Negócio (ABNT, 2013; FONTES, 2012; PELTIER, 2005):

15.2.1 – Definição do Escopo

É necessário definir a área de atuação do Plano de Continuidade de Negócio. Evidentemente desejamos que a organização possua um plano que contemple tudo: toda a organização, todas as ameaças e todos os recursos.

Porém, este objetivo deve ser alcançado por etapas. Uma organização que não possui algum Plano de Continuidade de Negócio deve começar com um plano considerando um escopo limitado. Esta limitação de escopo servirá para que o projeto do plano tenha início, meio e fim possíveis de serem realizados e alcançados.

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) Devemos considerar alguns elementos que ajudarão a definir este escopo:

- Serviços, produtos, atividades e parcerias da organização.
- Objetivos da organização.
- Fatores internos e externos que criam incerteza e que dão origem ao risco de indisponibilidade da informação.

- Appetite de risco dos executivos da organização..
- Natureza, tamanho e complexidade da organização
- Requisitos legais ou contratuais exigidos para a organização, incluindo legislação externa ao Brasil mas que afeta à matriz da corporação.

O Escopo consiste na definição do cenário e da abrangência para o plano de continuidade de negócio.

A abrangência significa que áreas organizacionais, recursos de informação, pessoas, sistemas aplicativos, processos, ferramentas e ambiente físico serão considerados para o plano. É importante que essas informações sejam explicitadas e formalizadas. Isto não quer dizer que a organização não considera importante o que está fora desta abrangência. Significa que nesse momento, para este plano específico estes outros elementos não estão considerados neste plano.

Serão considerados futuramente neste plano ou em outros planos complementares de continuidade de negócio.

O Cenário indica para qual situação o plano em questão foi escrito. Isto significa definir para a situação de contingência:

- Horário da ocorrência.
- Contingência total ou contingência parcial.
- Pessoas envolvidas e nível de disponibilidade destas pessoas.
- Complexidade da contingência. Isto significa a consideração de vários problemas ao mesmo tempo.

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) 15.2.2 – Análise de riscos

A organização deve desenvolver, implementar e manter um processo de análise de riscos que continuamente avalie os riscos que podem causar uma interrupção de disponibilidade dos recursos de informação. Para tanto, deve-se:

- identificar os riscos de ameaças se concretizarem e interromper as atividades da organização que dependem da informação;
- analisar estes riscos;
- avaliar quais destes riscos podem ser tratados;
- identificar qual o melhor tratamento para as ameaças e riscos que serão considerados.

Nesta etapa deve-se explicitar e formalizar as ameaças e os riscos que não foram considerados neste plano de continuidade de negócio. Esta informação deve ser coerente com o escopo descrito acima. A existência desta declaração do que não foi considerado facilita o entendimento posterior por profissionais de segurança da informação que não participaram da elaboração deste plano e ficariam com dúvidas para o adequado entendimento deste plano..

15.2.3 – Análise de impacto no negócio

O principal objetivo de uma análise de impacto no Negócio (BIA –

Business Impact Analysis) é identificar qual o tempo máximo, e seu respectivo impacto, que uma determinada área organizacional ou um Programa Organizacional, pode ficar sem informação. Para tanto, é realizado um levantamento junto às áreas dos usuários, normalmente com o executivo responsável, para identificar este tempo e os impactos financeiros, de imagem e operacional.

Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes) A Norma NBR ISO/NBR 22301 – Segurança da sociedade - Sistema de gestão de continuidade de negócios – Requisitos detalha muito bem a exigência para existência desta etapa:

A organização deve definir, implementar e manter um processo formal e documentado para a análise de impacto nos negócios que:

- a) estabeleça o contexto da avaliação, definindo critérios e avaliando o impacto de uma interrupção;*
- b) considere requisitos legais entre outros aos quais a organização deva atender;*
- c) determine uma análise sistemática, com priorização de tratamento de riscos e seus respectivos custos;*
- d) especifique os critérios para que estas informações sejam confidenciais e mantenham-se atualizadas.*

A organização deve estabelecer, implementar e manter um processo de avaliação formal e documentado para determinar prioridades de continuidade e recuperação, com objetivos e metas. Este processo de incluir a avaliação dos impactos de interrupção que suportam os produtos e serviços da organização.

A análise de impacto nos negócios, deve:

- a) identificar as atividades que suportam o fornecimento de produtos e serviços;*

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA

(Edison Fontes) *b) avaliar os impactos, ao longo de tempo, de não realizar estas atividades;*

c) fixar prazos de forma priorizada para a retomada destas atividades, em um nível mínimo de execução tolerável, levando em consideração o tempo dentro do qual os impactos desta interrupção tornem-se inaceitável; e

d) identificar dependências e recursos que suportam estas atividades, incluindo fornecedores, terceiros e demais partes interessadas relevantes (ABNT, 2013, p. 18).

A análise de impacto nos negócios exige uma forte participação das áreas de negócio da organização, pois os executivos delas é quem tem a responsabilidade de indicar o tempo máximo de indisponibilidade de cada uma.

Para identificação do tempo máximo de indisponibilidade da informação, podemos tomar por base duas abordagens: por processo ou por área organizacional.

Historicamente a abordagem por processo é a mais famosa e a mais defendida. Rigorosamente quando avaliamos tomando por base processos, estamos utilizando a alma da organização. Ótimo. Porém, esta opção têm algumas características que somente os profissionais que realmente já desenvolveram trabalhos práticos neste tema, enfrentaram estas questões: **a. Nem todas as organizações possuem boa documentação de processos.**

Algumas organizações nem têm a formalização de processos. Outras possuem, mas estão totalmente desatualizadas. E neste caso, não poderíamos fazer uma Análise de Impacto no Negócio?

*Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com*

**SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes) b. Identificação de impacto nos processos**

Ao identificarmos impacto nos processos, precisamos estar atentos para verificar se os valores indicados por uma área inclui ou não os impactos das áreas anteriores no processo.

c. Dono do processo

Normalmente não é fácil a explicitação e a responsabilização como dono do processo.

Analisando por área organizacional temos algumas vantagens,

considerando que cada área organizacional tem claramente um responsável, é mais fácil identificar o impacto de uma indisponibilidade de informação.

Não existe a solução certa ou errada. Existe a solução que é mais adequada para a organização naquele momento. Evidentemente a opção utilizada deve valer para todo o plano de continuidade, inclusive para as futuras atualizações.

15.2.4 – Definição das estratégias possíveis de serem implementadas

Primeiramente, deve-se identificar quais são as estratégias possíveis de serem implementadas e, em seguida, definir qual estratégia será utilizada para este plano de continuidade de negócio.

Antes da escolha da estratégia a ser utilizada, deve-se identificar quais os recursos que devem ser considerados, como: pessoas; informações; ambiente de trabalho; instalações, equipamentos e recursos consumíveis; sistemas de informação e de telecomunicação; transporte; finanças; e fornecedores e parceiros.

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA

(Edison Fontes) Após serem identificadas as possíveis estratégias, é necessário escolher uma delas. Esta escolha deve ficar documentada para eventual questionamento sobre o processo de escolha da estratégia mais adequada, naquele momento, para ser implementada na organização.

15.2.5 – Elaboração do plano

O Plano de Continuidade de Negócio estabelece os procedimentos e ações que devem ser seguidos por todos os usuários da organização, quando da ocorrência de uma situação de indisponibilidade da informação para a realização do negócio da organização.

Este plano deve conter:

- os papéis e as responsabilidades de cada usuário;
- o processo estruturado para o acionamento do plano e a execução das demais atividades descritas no plano;
- os procedimentos para a comunicação interna e externa sobre a ocorrência desta situação de indisponibilidade;
- recursos necessários para a execução do plano.

Cada usuário da informação da organização precisa ter conhecimento apenas da parte do plano de continuidade de negócio, que lhe diz respeito. Esta definição acontece por dois motivos: confidencialidade da informação e facilidade de aprendizagem.

1. Confidencialidade da informação: nem todas as pessoas precisam saber todas as informações sobre o plano. Desta maneira minimiza-se o risco de vazamento de informação para pessoas não autorizadas.

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) **2. Facilidade de aprendizagem:** normalmente, um plano de continuidade de negócio é volumoso e possui uma grande quantidade de informação. Desta maneira, é recomendável que o usuário tenha acesso apenas ao conjunto essencial de informações que são de sua

responsabilidade.

15.2.6 – Teste e manutenção

Cada plano de continuidade de negócio precisa ser testado e mantido atualizado. O teste busca garantir que as atividades definidas para o plano são suficientes e efetivas para garantir o restabelecimento da utilização da informação após a ocorrência de uma situação de indisponibilidade. Para tanto, um teste deve:

- ser consistente com o escopo e objetivos definidos para o plano;
- ser baseado em cenários de teste coerentes com o cenário definido para o plano;
- considerar os acordos com prestadores de serviços e parceiros;
- produzir uma documentação do que foi realizado durante o teste, permitindo a elaboração de um relatório de avaliação do teste, e gerando a possibilidade de que o próximo teste será melhor do que este teste; e
- existam periodicamente e sejam comunicados a sua realização e os seus resultados, à alta direção da organização.

A manutenção tem como objetivo garantir que as informações existentes no plano de continuidade de negócio estão atualizadas.

O plano de continuidade de negócio deve ser revisto periodicamente.

Normalmente, se pensa nesta revisão em relação ao aspecto de estar atualizado.

Isto é importante, porém é visto no item de manutenção. O que se chama atenção aqui é que o plano deve ser revisitado e deve sofrer uma crítica se o mesmo não pode ser melhorado em alguns dos seus aspectos. Algumas vezes, uma pequena mudança economiza tempo e recursos para a execução das atividades previstas para o plano.

Para esta melhoria contínua é necessário que o monitoramento deste plano.

Cuidar da continuidade de negócio ao longo do tempo, exige garantir a disponibilidade da informação para a realização deste negócio

15.3 – Continuidade do negócio e continuidade de TI

O plano de continuidade de negócio deve contemplar tanto o ambiente de tecnologia da informação como o ambiente das áreas de negócio. Isto significa que este plano terá ações técnicas como terá um conjunto de ações para a área de escritório da organização.

Para não haver dúvidas é necessário que esteja claro para todos o escopo deste plano, detalhado anteriormente.

Senso assim, a organização deve ter um plano ou planos que contemplem a necessidade de tecnologia da informação e a necessidade das áreas de negócio.

15.4 – Plano de Cópias de Segurança da Informação

A existência de cópias de segurança da informação pode ser tomado como uma dimensão isolada ou considerada dentro da continuidade de negócio. O importante é que este aspecto seja considerado.

Edison Fontes, edison@pobox.com

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA

(Edison Fontes) Na abordagem deste livro estamos considerando as cópias de segurança da informação como parte da Dimensão Continuidade de Negócio.

15.4.1. Tipos de Cópias de Segurança

A necessidade de recuperação de informações não necessariamente significa situação de contingência gerando uma grande indisponibilidade. A Organização deve ter cópias de segurança de informação motivadas por quatro situações:

a. Recuperação Técnica

É necessária quando acontece algum problema de indisponibilidade na cópia original da informação motivada por um problema técnico. Simples: “o disco deu problema!” Quem nunca ouviu esta expressão? Atualmente existe uma sofisticação técnica que problemas simples no passado já não acontecem mais.

Porém, é uma situação que precisa ser considerada.

b. Guarda de Informação por questões legais.

Todas as organizações precisam armazenar informações por exigências legais durante vários anos. Atualmente a facilidade de armazenamento permite que o ambiente principal acumule muitas informações, porém por maior que seja esta capacidade de armazenamento, em um momento, será necessário existir cópias de segurança.

c. Guarda de dados históricos

Muitas organizações desejam guardar informações durante um certo tempo, ou até sempre, mesmo que não exista existência legal. São dados históricos que têm importância para a organização.

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) d. Guarda de dados por exigência de auditoria

Normalmente a auditoria (interna ou externa) se baseia sua exigência de guarda de dados em função das exigências legais. Mas é importante considerar esta exigência da auditoria de uma maneira independente, pois a auditoria pode exigir outros padrões de guarda de informação, e a organização deve seguir estas orientações.

15.4.2. Responsabilidade pela definição dos tempos de guarda

O Gestor da Informação tem a responsabilidade de definir o tempo de guarda das cópias de segurança da informação para os aspectos: legal e histórico.

Para o aspecto de auditoria, deve-se seguir as exigências das auditorias internas ou externas.

A Área de Tecnologia da Informação têm a responsabilidade de definir a guarda de dados para a necessidade de recuperação técnica.

15.4.3. Formalização

É obrigatório que as definições de cópias de segurança da informação dadas pelas diversas áreas, sejam formalizadas e assinadas pelos respectivos gestores. Considerando a informação no ambiente digital, é de responsabilidade da Área de Tecnologia da Informação a garantia da execução e integridade das cópias de segurança definidas.



SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes)

16. GOVERNANÇA DE SEGURANÇA DA INFORMAÇÃO

Brasão da Cidade de São Paulo/SP – Brasil.

“Conduzo. Não sou conduzido”

16.1. INTRODUÇÃO

Governança, em todos os seus aspectos, é um tema de responsabilidade da Alta Administração (Corpo Diretivo e Gerência Executiva) da Organização. A Governança tem por objetivo decidir em relação à organização:

- os elementos para o seu funcionamento,
- a exigência para o seu desempenho,
- o nível de disponibilidade do negócio, e
- outros aspectos necessários para o seu funcionamento.

199

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) Todas estas decisões ou definições são tomadas sempre com a perspectiva de geração de valor e de sustentabilidade organizacional. Isto é, a Alta Administração é responsável pela definição dos objetivos corporativos, pela definição de ações que possibilitem o atendimento destes objetivos, pela geração de valor e pela adequada administração deste valor que deve permitir a sustentabilidade da organização.

Neste capítulo vamos utilizar os conceitos: Alta Direção, Corpo Diretivo e Gerência Executiva. Eles são definidos e utilizados na Norma NBR ISO/IEC

27014 - Governança de Segurança da Informação. Seguem abaixo estas definições.

Alta Direção

É o conjunto de gestores responsáveis pelo direcionamento e pela operacionalização das atividades da organização. A Alta Direção é formada pelo Corpo Diretivo e pela Gerência Executiva.

Corpo Diretivo

É o conjunto de gestores responsável pelas decisões da organização e pelo seu desempenho. Considerando o aspecto da segurança da informação, o Corpo Diretivo tem a responsabilidade de garantir que a abordagem para a segurança da informação seja:

- Eficiente.
- Eficaz.
- Aceitável.
- Alinhada com as estratégias de negócio e com os objetivos corporativos no que dependem da informação.

200

*Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com*

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) Gerência Executiva

É o conjunto de gestores delegado pelo Corpo Diretivo da organização que tem o objetivo de implementar as estratégias e as políticas para alcançar o propósito da organização em relação aos negócios e aos objetivos corporativos.

16.2. GOVERNANÇA CORPORATIVA

Definimos Governança Corporativa como o conjunto de definições

transformadas em diretivas, limites, controles, forma de atuação, objetivos corporativos, orientação ética, orientação de gestão, criação de cultura

organizacional e indicação de tipos de métricas que definem como as organizações devem funcionar e devem ser gerenciadas.

Atualmente a Governança Corporativa é obrigatória para alguns tipos de organizações. Porém, independente da organização se situar na obrigação legal de possuir governança, cada vez mais as organizações seguem este modelo de controle organizacional. No Brasil existe o Instituto Brasileiro de Governança Corporativa, uma organização sem fins lucrativos que é atualmente a principal referência do Brasil para o desenvolvimento das melhores práticas de Governança Corporativa. O IBGC promove palestras, fóruns, conferências, treinamentos e relacionamento entre profissionais, além de produzir publicações e pesquisas.

O IBGC define: “Governança Corporativa é o sistema pelo qual as empresas e demais organizações são dirigidas, monitoradas e incentivadas, envolvendo os relacionamentos entre sócios, conselho de administração, diretoria, órgãos de fiscalização e controle e demais partes interessadas”. (IBGC, 2015, p.20).

**SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes)** Uma definição mais geral é dada pela Wikipédia:
“Governança

Corporativa é o conjunto de processos, costumes, políticas, leis, regulamentos e instituições que regulam a maneira como uma empresa é dirigida, administrada ou controlada.” (Wikipédia, acessada em 2016).

A Governança Corporativa possui formalmente quatro princípios que devem ser seguidos quando da sua implementação. Estes princípios são

diretrizes da natureza da Governança Corporativa e devem ser seguidos por qualquer organização independente do seu porte e tipo de negócio. O que será diferente para cada organização é: como cada um destes princípios será implementado?

Neste caso, esta implementação e continuidade dos Princípios da Governança Corporativa serão diferentes em cada organização.

16.2.1. PRINCIPIOS DA GOVERNANÇA CORPORATIVA

a. Transparência

Consiste no desejo de disponibilizar para as partes interessadas as informações que sejam de seu interesse e não apenas aquelas impostas por disposições de leis ou regulamentos. Não deve restringir-se ao desempenho econômico-financeiro, contemplando também os demais fatores (Inclusive intangíveis) que norteiam a ação gerencial e que conduzem à preservação e à otimização do valor da organização. (IBGC, 2015, p.20).

b. Equidade

Caracteriza-se pelo tratamento justo e isonômico de todos os sócios e demais partes interessadas (*Stakeholders*), levando em consideração seus direitos, deveres, necessidades, interesses e expectativas. (IBGC, 2015, p.21).

202

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) c. Prestação de Contas (*Accountability*) -

Responsabilização Os agentes de governança devem prestar contas de sua atuação de modo claro, conciso, compreensível e tempestivo, assumindo integralmente as consequências de seus atos e omissões e atuando com diligência e

responsabilidade no âmbito dos seus papéis. (IBGC, 2015, p.21).

Existe uma responsabilização dos gestores da governança e os gestores operacionais da organização. Qualquer ato ou omissão de ato tem associado um gestor que é responsável e responde por este fato. Nada pode ficar sem uma responsabilização.

d. Responsabilidade Corporativa

Os agentes de governança devem zelar pela viabilidade econômico-

financeira das organizações, reduzir as externalidades negativas de seus negócios e suas operações e aumentar as positivas, levando em consideração, no seu modelo de negócios, os diversos capitais (financeiro, manufaturado, Intelectual, humano, social, ambiental, reputacional etc.) no curto, médio e longo prazos.

(IBGC, 2015, p.21).

16.3. GOVERNANÇA DA SEGURANÇA DA INFORMAÇÃO

A informação é um elemento chave para qualquer organização. Para

atender os objetivos corporativos a organização utiliza a informação: algumas de maneira indireta outras de maneira direta. Mas todas as organizações dependem da informação. Desta maneira é responsabilidade do Corpo Diretivo da

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) organização garantir que as iniciativas de controles de segurança da informação estão contribuindo positivamente para o atendimento aos objetivos corporativos.

O Corpo Diretivo da organização é o responsável pelas decisões de uma organização e pelo seu desempenho, portanto, deve definir as diretrizes do Programa Organizacional de Segurança da Informação e deve governar as iniciativas de segurança da informação. Governar a segurança da informação significa garantir que a abordagem de segurança da informação definida e adotada para a organização é eficiente, eficaz, possível de ser implementada e

alinhada com as estratégias e objetivos corporativos.

Segundo a Norma NBR ISO/IEC 27014 a Governança de Segurança da

Informação “fornece a ordem essencial para direcionar as iniciativas de segurança da informação por toda a organização” (ABNT, 2013, p.V). Mas à frente ela complementa “Governança de Segurança da Informação é o sistema pelo qual as atividades de segurança da informação de uma organização são dirigidas e controladas.

A Governança de Segurança da Informação acontece pelas ações acima

descritas para o Corpo Diretivo e pela sua implementação pelo Gestor de Segurança da Informação que desenvolverá ações para a materialização desta governança na organização.

A Norma NBR ISO/IEC 27014 define para a Governança de Segurança da Informação (p.2) seus objetivos, resultados esperados e seu relacionamento.

204

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) 16.3.1. Objetivos, Resultados e Relacionamento

São Objetivos da Governança da Segurança da Informação:

- * Alinhar os objetivos e estratégia da segurança da informação com os objetivos e estratégia do negócio (alinhamento estratégico).
- * Agregar valor para o corpo diretivo e para as partes interessadas (entrega de valor).

* Garantir que os riscos da informação estão sendo adequadamente endereçados (responsabilidade).

A Governança da Segurança da Informação tem como Resultados Desejados:

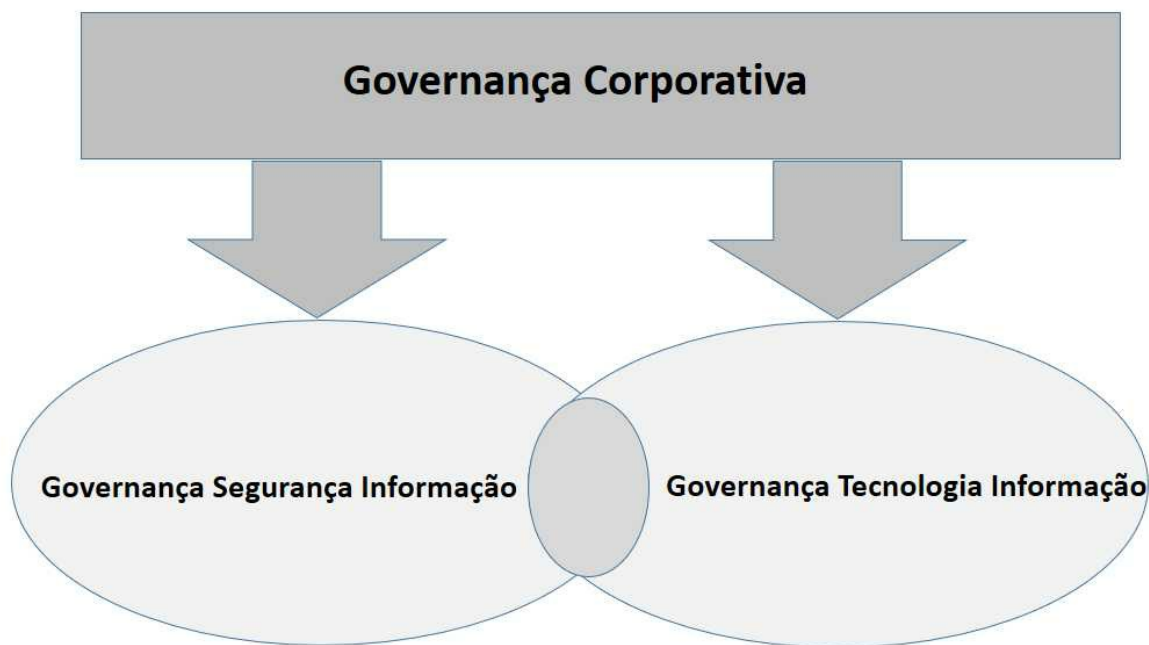
* Dar visibilidade ao Corpo Diretivo sobre a situação da segurança da informação.

* Permitir uma abordagem ágil para a tomada de decisões sobre os riscos de informações.

* Possibilitar investimentos eficientes e eficazes em segurança da informação.

* Garantir Conformidade com requisitos externos (legais, regulamentares e contratuais).

Em relação ao Relacionamento, existem vários modelos de áreas de governança em uma organização. Cada modelo de governança é um componente da governança da organização, que enfatiza a importância do alinhamento com os objetivos de negócio. Estes modelos de governança algumas vezes se sobrepõem,



SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

como por exemplo a Governança de Segurança da Informação e a Governança de Tecnologia da Informação, conforme ilustra a figura abaixo.

Figura 16.1– Relacionamento áreas de governança. Fonte: ABNT

Neste exemplo podemos destacar que a Governança de Tecnologia da

Informação busca garantir recursos necessários para adquirir, processar e armazenar informação de maneira a atender os objetivos corporativos. A Governança de Segurança da Informação tem por objetivo garantir a

confidencialidade, a integridade, a disponibilidade, a legalidade, a autenticidade e a auditabilidade da informação de maneira a permitir que a organização atinja seus objetivos corporativos naquilo que depende de informação.

16.3.2. Princípios da Governança da Segurança da Informação

Princípios de Governança da Segurança da Informação são diretrizes para a conduta e para a implementação da governança. A Norma NBR ISO/IEC 27014

206

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes) define cinco princípios para a Governança da Segurança da Informação (p.3).

Estes princípios são válidos para qualquer tipo de organização. A organização deve:

a. Estabelecer a segurança da informação em toda a organização.

A informação utilizada na organização deve ser protegida independente em que ambiente ela se encontra: ambiente digital ou ambiente convencional. Esta proteção deve envolver todas as áreas organizacionais e todos os tipos de usuários que tem contato com a informação da organização ou sob

responsabilidade da organização.

A responsabilidade por cada ação de segurança da informação deve estar explicitamente definida e deve ser de conhecimento de cada usuário. Todas as ações de segurança da informação devem estar rigorosamente coordenadas e devem participar de um Programa Organizacional .

b. Adotar uma abordagem baseada em riscos.

As decisões para as ações de segurança da informação devem ser baseadas na gestão de riscos de segurança da informação. A decisão da rigidez dos controles de segurança da informação deve ser baseada no apetite de risco da organização, considerando a perda de vantagem competitiva, conformidade com a legislação e regulamentação, indisponibilidade da informação, danos à

reputação e aos impactos financeiros ou possíveis impactos financeiros.

*Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com*

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) c. Estabelecer a direção de decisões de investimento

A Governança de Segurança da Informação deve estabelecer a estratégia de investimentos para os recursos necessários para a implantação da segurança da informação, com base em resultados de negócio alcançados, resultando na harmonia entre os requisitos de negócio e a rigidez dos controles de segurança da informação.

O Corpo Diretivo deve garantir que a segurança da informação seja

integrada com os processos da organização em relação aos gastos (investimentos e despesas), conformidade legal e de regulamentos, para considerar na avaliação dos riscos.

d. Assegurar a conformidade com os requisitos internos e externos A Governança de Segurança da Informação deve assegurar que as

políticas, demais regulamentos e práticas de segurança da informação atendem à legislação e regulamentos obrigatórios, assim como aos requisitos de negócio e outros requisitos internos ou externos.

Para garantir esta conformidade e ter certeza que os controles de segurança da informação estão sendo cumpridos satisfatoriamente, o Corpo Diretivo da organização deve autorizar a realização de auditorias independentes para a segurança da informação.

e. Analisar criticamente o desempenho em relação aos resultados de negócios.

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) A Governança de Segurança da Informação deve garantir que a abordagem utilizada para proteger a informação está adequada à sua finalidade de suporte à organização, proporcionando níveis coerentes de segurança da informação. O

desempenho e a rigidez dos controles de segurança da informação devem estar em um nível suficiente para atender aos requisitos de negócio atuais e futuros da organização.

16.3.3. Processos da Governança da Segurança da Informação

Processos da Governança da Segurança da Informação definem uma série de tarefas que viabilizam a implementação dos princípios de Governança de Segurança da Informação e garantem sustentabilidade da governança.

A Norma NBR ISO/IEC 27014 define os seguintes processos para a

Governança de Segurança da Informação (p.5), que devem ser executados pelo Corpo Diretivo:

a. Avaliação

Este processo considera o atendimento atual e futuro dos objetivos de segurança da informação nos processos atuais e nas mudanças planejadas. Ele também considera os ajustes necessários no momento ou no futuro de maneira a possibilitar o atendimento aos objetivos corporativos.

A Alta Direção (Corpo Diretivo e Gerência Executiva) deve garantir que:

- As iniciativas de negócio consideram os controles de segurança da informação definidos nas políticas e nos regulamentos.

*Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com*

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

- Avaliar os resultados da segurança da informação, definindo e redefinindo as prioridades e as novas iniciativas de segurança da informação.
- A segurança da informação protege adequadamente a informação de maneira coerente com os objetivos de negócio.
- Avaliar os novos projetos da organização e suas necessidades de segurança da informação.

b. Direção

Neste processo o Corpo Diretivo fornece o direcionamento ou valida o direcionamento da estratégia e dos objetivos da segurança da informação.

A Alta Direção (Corpo Diretivo e Gerência Executiva) deve:

- Determinar o apetite de risco da organização.
- Aprovar a política de segurança da informação.
- Autorizar a alocação de recursos e investimentos para a implantação dos controles de segurança da informação.
- Desenvolver e implementar a estratégia da segurança da informação.

- Alinhar os objetivos de segurança da informação com os objetivos corporativos.
- Garantir a existência de uma cultura de segurança da informação.

210

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) c. Monitoração

Neste processo o Corpo Diretivo avalia ao atendimento dos objetivos de segurança da informação.

A Alta Direção (Corpo Diretivo e Gerência Executiva) deve:

- Avaliar a efetividade da gestão da segurança da informação.
- Garantir a conformidade da segurança da informação com os requisitos internos e externos.
- Avaliar periodicamente e constantemente as alterações no ambiente externo à organização que afetem à informação e o seu potencial impacto sobre a organização.
- Selecionar métricas para a gestão da segurança da informação.
- Fornecer resultados de retorno sobre o desempenho da segurança da informação.
- Identificar os novos desenvolvimentos que afetam os riscos de

informação e de segurança da informação, tomando as medidas necessárias para minimizar estes riscos.

d. Comunicação

Este processo da Governança de Segurança da Informação, permite que o Corpo Diretivo e as demais partes da organização troquem informações sobre a segurança da informação, considerando as necessidades específicas de cada área.

A Alta Direção (Corpo Diretivo e Gerência Executiva) deve:

211

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

- Comunicar externamente e internamente que a organização possui um nível de segurança da informação compatível com os eu negócio, com seu porte e com os objetivos corporativos.
- Notificar às partes envolvidas o resultado de auditorias externas e eventuais questões de segurança da informação que precisam ser corrigidas ou aprimoradas.
- Considerar as obrigações regulatórias, as expectativas de partes interessadas e as necessidades de negócios em relação aos controles e à rigidez dos controles de segurança da informação.

- Orientar as partes envolvidas sobre atividades que serão realizadas para garantir o direcionamento, a implantação e a sustentabilidade da segurança da informação.

e. Garantia

Neste processo o Corpo Diretivo autoriza a realização de auditorias, análises ou avaliações independentes. Tudo isto com o objetivo de validar os objetivos e ações relacionadas com a execução da Governança de Segurança da Informação e com a condução das atividades para se atingir o nível desejado de segurança da informação.

Estas auditorias podem ser internas ou externas. Um fato importante que o Gestor da Segurança da Informação vai conviver e deve compartilhar com o corpo Diretivo é a criticidade (avaliação de riscos) dos pontos adotados. Muitas vezes o ponto de auditoria apontado não deve ter uma alta prioridade, considerando os demais controles de segurança da informação. Porém, por ser um ponto de auditoria que caso não seja atendido conforme a auditoria deseja,

212

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes) pode ter o nome do presidente da empresas reportado para (por exemplo) a Alta Administração do Conglomerado organizacional.

Desta maneira um controle de auditoria pode ser de baixa prioridade, porém torna-se de alta prioridade, apenas porque está sendo apontado como ponto de Auditoria.

Evidentemente este “problema” depende para acontecer da organização e do seu ambiente interno ou externo. Desta maneira, chamo atenção do Gestor da Segurança da Informação para que esteja atento a situações deste tipo.

16.4. PRATICANDO OS PRINCÍPIOS DA GOVERNANÇA DA SEGURANÇA DA INFORMAÇÃO

Descrevo abaixo como atendemos na prática a Governança de Segurança da Informação. As ações relacionadas abaixo indicam ações que atendem aos elementos da governança Porém, registro que estas ações descritas formam um conjunto de exemplos. Existem outras atividades que também referendam os conceitos de Governança de Segurança da Informação. Segue abaixo os princípios e o seu atendimento prático.

a. Estabelecer a segurança da informação em toda a organização.

Na Arquitetura do Programa Organizacional de Segurança da Informação, existe a Dimensão Política Segurança da Informação que define os regulamentos para a efetiva existência dos controles de proteção da informação. Nos regulamentos gerados, considerando o tipo de negócio, as características de negócio e os objetivos corporativos, deve estar definido a abrangência do programa de segurança e as responsabilidades de cada pessoa. Desta maneira é

213

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) possível garantir que a segurança da informação será estabelecida em toda a organização e para todos os usuários da informação da organização ou que está sob sua responsabilidade.

A Dimensão Conscientização e Treinamento do Usuário garantirá que todos os usuários serão treinados em segurança da informação, assinarão termos de compromisso com o uso da informação e possibilitará a sustentabilidade de entendimento do assunto e das responsabilidades de cada usuário.

b. Adotar uma abordagem baseada em riscos.

Na Arquitetura do Programa Organizacional de Segurança da Informação, existe a Dimensão Gestão de Riscos de Segurança da Informação que garante a base para a utilização da gestão de riscos para a tomada de decisões estratégicas e operacionais.

A avaliação de riscos deve contar com a participação dos gestores para a definição da maturidade atual dos controles e para a definição de quão rígido devem ser estes controles. O Corpo Diretivo deve validar (ou alterar) as recomendações de ações baseada na avaliação de riscos de segurança da informação.

Recomendamos que a avaliação de riscos seja realizada em cada período máximo de seis meses.

c. Estabelecer a direção de decisões de investimento

O Planejamento do Programa Organizacional de Segurança da Informação deve ser precedido da avaliação da Maturidade dos Controles de Segurança da

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) Informação. Com este resultado, o Gestor da Segurança da Informação deve recomendar uma priorização de ações. Esta priorização deve ser validada ou alterada pelo Corpo Diretivo da organização.

Este planejamento de ações, em alinhamento com a Gestão de Riscos de Segurança da Informação, deve ser realizada a cada período de 12 (doze) meses, exigindo a participação do Corpo Diretivo.

Desta maneira estaremos garantindo que as orientações e das diretrizes da Governança da Segurança da Informação estarão sendo seguidas nas ações de segurança da informação da organização.

d. Assegurar a conformidade com os requisitos internos e externos Um dos objetivos do Programa Organizacional de Segurança da

Informação é a legalidade da informação. Isto é, o uso da informação precisa obrigatoriamente está de acordo com as leis existentes, regulamentos e demais elementos que submetem a organização a uma ordem, como contratos e

similares.

Desenvolvendo e implantando o Programa Organizacional de Segurança

da Informação, estaremos assegurando que os requisitos internos e externos serão considerados para o uso da informação pelos usuários para o atendimento aos objetivos corporativos.

Recomendamos a revisão destas ações a cada período de 12 meses.

215

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

**SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes) e. Analisar criticamente o desempenho em relação aos
resultados de negócios.**

Realizando o Planejamento do Programa Organizacional de Segurança da Informação e apresentando o mesmo para o Corpo Diretivo, estaremos

garantindo este princípio pois o planejamento pressupõe uma avaliação (ou acompanhamento) da maturidade dos controles de segurança da informação e a validação (ou ajustes) pelo Corpo Diretivo, das ações planejadas para a segurança da informação. O Corpo Diretivo possui as informações suficientes para avaliar a segurança da informação considerando os resultados e desempenho dos negócios da organização. Recomendamos a revisão destas ações a cada período de 12

meses.

16.5. CONCLUSÃO

O tema governança nas organizações é relativamente novo, considerando outros conceitos de administração em organizações. Porém já existe uma boa literatura sobre o assunto permitindo que os profissionais interessados busquem o conhecimento sobre governança. Entendemos que o entendimento dos conceitos de governança tem acontecido, principalmente se tratando da Governança Corporativa que por existir exigências legais possui orientações diretas, explícitas e que facilitam o seu desenvolvimento, implantação e sustentabilidade.

Em relação à Governança da Segurança da Informação, o tema é mais

recente e não existe nenhuma legislação obrigando a existência desta governança em qualquer tipo de organização. Porém é aconselhável (pelo menos) nas organizações que estão obrigadas a terem a Governança Corporativa, que as mesmas tenha a Governança de Segurança da Informação.

**SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes)** Como o conceito de governança traz a médio e longo prazo benefícios

concretos para a organização, recomendamos que qualquer organização

desenvolva, implante e mantenha a Governança da Segurança da Informação.
E

neste caso a grande dificuldade é: como fazer na minha organização? Sugiro que considere verdadeiramente os elementos descritos neste capítulo e

implemente a Governança da Segurança da Informação. Algumas organizações pensam a Governança em Segurança da Informação como algo muito complexo e

inatingível. Outras, não entendem o conceito e criam uma área para esta governança em um nível hierárquico mais baixo que existe. Estas organizações estão muito longe de terem uma verdadeira Governança de Segurança da Informação.

Se o Corpo Diretivo realmente deseja proteger adequadamente a informação, deve definir um Gestor da Segurança da Informação com experiência suficiente para elaborar, implantar e manter o Programa Organizacional de Segurança da Informação.

217

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***



SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

POSFÁCIO

No Congresso Infovia 1997, um agradabilíssimo evento organizado pela SUCESU/RN na não menos agradabilíssima Natal dos mestres Salu e Cassiano, entrei por engano na sala onde se iniciava a palestra do Edison

Fontes, um especialista em Segurança da Informação que até então eu não conhecia.

Tratava-se de um tema decididamente corporativo e que, portanto, pouco havia de me interessar. Mas como tinha acabado de entrar e os olhares da plateia ainda se cravavam em minha humílima pessoa, seria uma indelicadeza virar as costas e sair.

Decidi permanecer pelo menos até começar a projeção, quando

aproveitaria a penumbra para acobertar meus passos, esgueirando-me

covardemente para fora da sala. O Edison começou a falar, as luzes se apagaram e preparei-me para escafeder-me. Mas só consegui sair no final da palestra, não sem antes cumprimentá-lo pela excelente apresentação.

Porque, por menor que fosse meu interesse pela informática corporativa, segurança de dados revelou-se um tema fascinante.

B.Piropo, Jornalista.

Publicado no Caderno de Informática do Jornal O GLOBO, Rio de Janeiro, em 09/03/1998.

Obrigado Mestre Piropo!

BIBLIOGRAFIA

Foto: Edison Fontes, São Paulo, Brasil.

ABNT, NBR 15999-1 – Gestão de continuidade de negócios – Parte 1: Código de prática. Rio de Janeiro: Associação Brasileira de Normas Técnicas, 2008.

_____, **NBR 15999-2 – Gestão de continuidade de negócios – Parte 2: Requisitos.** Rio de Janeiro: Associação Brasileira de Normas Técnicas, 2008.

_____, **NBR 16167 – Segurança da Informação — Diretrizes para classificação, rotulação e tratamento da informação.** Rio de Janeiro: Associação Brasileira de Normas

219

*Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com*

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) _____, NBR ISO/IEC 22301 – Segurança da Sociedade – Sistema de gestão de continuidade de negócios - Requisitos. Rio de Janeiro: Associação Brasileira de Normas Técnicas, 2013.

_____, **NBR ISO/IEC 24762 – Tecnologia da informação – Técnicas de segurança**

– **Diretrizes para os serviço de recuperação após um desastre na tecnologia da informação e Comunicação.** Rio de Janeiro: Associação Brasileira de Normas Técnicas, 2009.

_____, **NBR ISO/IEC 27001 - Tecnologia da informação – Técnicas de segurança**

– **Sistema de Gestão de segurança da informação – Requisitos.** Rio de

Janeiro: Associação Brasileira de Normas Técnicas, 2013.

_____, **NBR ISO/IEC 27002 - Tecnologia da informação – Técnicas de segurança**

- **Código de prática para a gestão da segurança da informação.** Rio de Janeiro: Associação Brasileira de Normas Técnicas, 2013.

_____, **NBR ISO/IEC 27003 – Tecnologia da informação – Técnicas de segurança**

– **Diretrizes para implantação de um sistema de gestão da segurança da informação.** Rio de Janeiro: Associação Brasileira de Normas Técnicas, 2011.

_____, **NBR ISO/IEC 27004 – Tecnologia da informação — Técnicas de segurança - Gestão da segurança da informação — Medição.** Rio de Janeiro: Associação Brasileira de Normas Técnicas, 2010.

_____, **NBR ISO/IEC 27005 – Tecnologia da informação – Técnicas de segurança**

– **Gestão de riscos de segurança da informação.** Rio de Janeiro: Associação Brasileira de Normas Técnicas, 2008.

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes) _____, **NBR ISO/IEC 27007 – Diretrizes para auditoria de sistemas de gestão da segurança da informação.** Rio de Janeiro: Associação Brasileira de Normas Técnicas, 2012.

_____, **NBR ISO/IEC 27011 – Tecnologia da informação - Técnicas de segurança**

- Diretrizes para gestão da segurança da informação para organizações de telecomunicações baseadas na ABNT NBR ISO/IEC 27002. Rio de Janeiro: Associação Brasileira de Normas Técnicas, 2009.

_____, **NBR ISO/IEC 27014 – Tecnologia da Informação — Técnicas de Segurança — Governança de segurança da informação.** Rio de Janeiro: Associação Brasileira de Normas Técnicas, 2013.

_____, **NBR ISO/IEC 27031 – Tecnologia da informação — Técnicas de segurança — Diretrizes para a prontidão para a continuidade dos negócios da tecnologia da informação e comunicação.** Rio de Janeiro: Associação Brasileira de Normas Técnicas, 2015.

_____, **NBR ISO/IEC 27037 – Tecnologia da informação — Técnicas de segurança — Diretrizes para identificação, coleta, aquisição e preservação de evidência digital.** Rio de Janeiro: Associação Brasileira de Normas Técnicas, 2013.

_____, **NBR ISO/IEC 27701 –Técnicas de segurança — Extensão da ABNT NBR**

ISO/IEC 27001 e ABNT NBR ISO/IEC 27002 para gestão da privacidade da informação — Requisitos e diretrizes. Rio de Janeiro: Associação Brasileira de Normas Técnicas, 2020.

_____, **NBR ISO/IEC 29100 – Tecnologia da informação – Técnicas de segurança**

– **Estrutura de privacidade.** Rio de Janeiro: Associação Brasileira de Normas Técnicas, 2020.

_____, **NBR ISO/IEC 38500 – Tecnologia da informação – Governança da TI para a organização.** Rio de Janeiro: Associação Brasileira de Normas Técnicas, 2018.

Técnicas, 2013.

_____, **NBR ISO 31000 – Gestão de riscos - Diretrizes.** Rio de Janeiro: Associação Brasileira de Normas Técnicas, 2018.

_____, **NBR ISO/TR 31004 – Gestão de riscos – Guia para implementação da NBR ISO 31000.** Rio de Janeiro: Associação Brasileira de Normas Técnicas, 2018.

_____, **NBR ISO/IEC 31010 – Gestão de riscos – Técnicas para o processo de avaliação de riscos.** Rio de Janeiro: Associação Brasileira de Normas Técnicas, 2012.

_____, **NBR ISO/IEC Guia 73 – Gestão de riscos – Vocabulário –**

Recomendações para uso em normas. Rio de Janeiro: Associação Brasileira de Normas Técnicas, 2005.

ALBERTIN, Alberto Luiz; PINOCHET, Luis Hernan Contreras. **Política de Segurança de Informações**. Rio de Janeiro: Elsevier Editora, 2010.

ALBERTIN, Alberto Luiz; MOURA, Rosa Maria (Organizadores). **Tecnologia de Informação**. São Paulo: Editora Atlas, 2004.

ASSI, Marcos. **Governança, Riscos e Compliance: Mudando a Conduta nos Negócios**. São Paulo: Saint Paul Editora, 2017.

BACIK, Sandy. **Building na Effective Information Security Policy Architecture**.

Boca Raton: CRC Press, 2008.

BARMAN, Scott. **Writing Information Security Polices**. Indianapolis: New Riders, 2002.

BISHOP, Matt. **Introduction to Computer Security**. Boston: Addison-Wesley, 2006.

BROTBY, Krag. **Information Security Governance**. New Jersey: Wiley, 2009.

CALDER, Alan; WATKINS, Steve **IT Governance – A Managers Guide to Data Security and BS17799**. London: Editora Kogan Page, 2005.

DOMENEGHETTI, Daniel; MEIR, Roberto. **Ativos Intangíveis**. Rio de Janeiro: Elsevier Editora, 2009.

DEY M. **Information security management – a practical approach**. In: Africon 2007 – 8th IEEE Africon Conference 2007. p. 1-6.

FONTES, Edison. **Políticas e normas para a segurança da informação**. Rio de Janeiro. Editora Brasport. 2012.

_____. **Política de segurança da informação: uma contribuição para o estabelecimento de um padrão mínimo**. São Paulo: Centro Estadual de Educação Tecnológica Paula Souza, Dissertação de Mestrado, Programa de Pós Graduação em Tecnologia, 2011.

_____. **Clicando com segurança**. Rio de Janeiro: Editora Brasport, 2011.

_____. **Praticando a segurança da informação**. Rio de Janeiro: Editora Brasport, 2008.

_____. **Segurança da informação: o usuário faz a diferença**. São Paulo: Editora Saraiva, 2006.

224

*Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com*

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) _____. **Vivendo a segurança da informação**. São Paulo: Editora Sicurezza, 2000.

_____. **Segurança da Informação: orientações práticas**. São Paulo.

Amazon. 2016

HANSCHKE, Susan; BERTI, John; HARE, Chris. **Official Guide to CISSP**

Exam. USA: Auerbach, 2004.

HEROLD, Rebecca. **Managing Information Security and Privacy**. USA: Auerbach, 2005.

IBGC, **Código das melhores práticas de governança corporativa**. São Paulo: Instituto Brasileiro de Governança Corporativa, 5a ed. 2015.

_____, Papéis e responsabilidades do Conselho na Gestão de Riscos Cibernéticos.

São Paulo: Instituto Brasileiro de Governança Corporativa, 2019.

ISACA, **Information System Audit and Control Association**,
<http://www.isaca.org/>,

acesso em 27/04/2020.

ITGI, **COBIT – Control Objectives for Information and related Technology**, 4th edition, Rolling Meadows, Illinois – USA: Information Technology Governance Institute, 2007.

225

Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes) _____, Information Security Governance: Guidance for Board Directors and Executive Management, 2nd Edition, Rolling Meadows, Illinois – USA: Information Technology Governance Institute, 2006.

_____, **Information Security Governance: Guidance for Information Security Managers**, 2nd Edition, Rolling Meadows, Illinois – USA: Information Technology Governance Institute, 2008.

_____, **COBIT for Information Security**, Rolling Meadows, Illinois –

USA: Information Technology Governance Institute, 2012.

KARABACAK B., SOGUKPINAR I. Isram: **Information risk security analysis method**. J Comput Secur. 2005.

LANDOLL, Douglas. **The Security Risk Assessment Handbook**. USA: Auerbach, 2006.

MALDONADO, Viviane Nóbrega; BLUM, Renato Opice (Organizadores). **LGPD Lei Geral de Proteção de Dados**. São Paulo. Thomson Reuters Brasil. 2019.

OCG, ITIL - **Information Technology Infrastructure Library – Service Design**, 3rd edition, London: OCGE, 2007.

OLIVEIRA Jr., Renato Salatiel. **Utilizando a norma ISO 27002 para atender os requisitos da SOX que exigem proteção da informação no ambiente de TI**. São Paulo: Faculdade de Informática e Administração Paulista, Pós-Graduação em Gestão de Segurança da Informação, 2010.

226

*Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com*

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) PAGE, Stephane. **Establishing a System of Policy and Procedures**. Westerville: Process Improvement Publishing, 2002.

PCI Security Standards Council. **Padrão de Segurança de Dados**. Brasil.2013.

PELTIER, Thomas. **Information Security Fundamentals**. USA: Auerbach, 2005.

_____. **Information Security Policies and Procedures**. USA: Auerbach, 2004.

_____. **Information Security Risk Analysis**. USA: Auerbach, 2001.

SHERWOOD, John; CLARK, Andrew; LYNAS, David. **Enterprise Security Architecture**. USA: CMP Books, 2005.

SHOSTACK, Adam; STEWART, Andrew. **A Nova Escola da Segurança da Informação**. Rio de Janeiro: Alta Books, 2008.

SMALLWOOD, Robert F. **Information Governance**. New Jersey: WILEY, 2020.

UNESCO – Organização das Nações Unidas para a Educação, a Ciência e a Cultura.

Declaração Universal dos Direitos Humanos. Brasília. Representação da Unesco no Brasil. 1998.

227

*Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com*

**SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes) ANEXO 1 - Os controles da**

segurança da informação – Norma

ISO/IEC 27002

228

*Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com*

**SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes)**

Capítulo 5 – Políticas de segurança da informação

(1) Controle: Políticas para a segurança da informação.

5.1.1 - Convém que um conjunto de políticas de segurança da informação seja definido, aprovado pela direção, publicado e comunicado para todos os funcionários e partes externas relevantes.

(ABNT, NBR 27002, 2013, p.2)

(2) Controle: Análise crítica das políticas de segurança da informação.

5.1.2 - Convém que as políticas de segurança da informação sejam analisadas criticamente a intervalos planejados ou quando mudanças significativas ocorrerem, para assegurar a sua continua pertinência, adequação e eficácia. (ABNT, NBR 27002, 2013, p.4)

Capítulo 6 – Organização da segurança da informação

(3) Controle: Responsabilidades e papéis pela segurança da informação.

6.1.1 – Convém que todas as responsabilidades pela segurança da informação sejam definidas e atribuídas. (ABNT, NBR 27002, 2013, p.4)

(4) Controle: Segregação de funções.

6.1.2 - Convém que funções conflitantes e áreas de responsabilidades sejam segregadas para reduzir as oportunidades de modificação não autorizada ou não intencional, ou uso indevido dos ativos da organização. (ABNT, NBR 27002, 2013, p.5)

6.1.3 - *Convém que contatos apropriados com autoridades relevantes sejam mantidos. (ABNT, NBR 27002, 2013, p.6)*

(6) Controle: Contato com grupos especiais

6.1.4 – *Convém que contatos apropriados com grupos especiais, associações profissionais ou outros fóruns especializados em segurança da informação sejam mantidos. (ABNT, NBR 27002, 2013, p.6)*

(7) Controle: Segurança da informação no gerenciamento de projetos.

6.1.5 - *Convém que a segurança da informação seja considerada no gerenciamento de projetos, independentemente do tipo do projeto.*

(ABNT, NBR 27002, 2013, p.7)

(8) Controle: Política para uso de dispositivo móvel.

6.2.1 - *Convém que uma política e medidas que apoiam a segurança da informação sejam adotadas para gerenciar os riscos decorrentes do uso de dispositivos móveis. (ABNT, NBR 27002, 2013, p.8)*

(9) Controle: Trabalho remoto

6.2.2 - *Convém que uma política e medidas que apoiam a segurança da informação sejam implementadas para proteger as informações acessadas, processadas ou armazenadas em locais de trabalho remoto.*

(ABNT, NBR 27002, 2013, p.9)

Capítulo 7 – Segurança em recursos humanos

(10) Controle: Recursos Humanos - Seleção.

7.1.1 - Convém que verificações do histórico sejam realizadas para todos os candidatos a empregos, de acordo com a ética, regulamentações e leis relevantes, e seja proporcional aos requisitos de negócio, aos riscos percebidos e à classificação das informações a serem acessadas. (ABNT, NBR 27002, 2013, p.11)

(11) Controle: Recursos Humanos – Termos e condições de contratação.

7.1.2 - Convém que as obrigações contratuais com funcionários e partes externas declarem a sua responsabilidade e as da organização para a segurança da informação. (ABNT, NBR 27002, 2013, p.12)

(12) Controle: Recursos Humanos – Responsabilidade da Direção.

7.2.1 - Convém que a Direção solicite a todos os funcionários e partes externas que pratiquem a segurança da informação de acordo com o estabelecido nas políticas e procedimentos da organização. (ABNT, NBR 27002, 2013, p.13)

(13) Controle: Recursos Humanos – Conscientização, educação e treinamento.

7.2.2 - Convém que todos os funcionários da organização e, onde pertinente, partes externas, recebam treinamento, educação e conscientização apropriados, e as atualizações regulares das políticas e procedimentos organizacionais relevantes para as suas funções. (ABNT, NBR 27002, 2013, p.13)

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA

(Edison Fontes)

(14) Controle: Recursos Humanos – Processo disciplinar.

7.2.3 - Convém que exista um processo disciplinar formal, implantado e comunicado, para tomar ações contra funcionários que tenham cometido uma violação da segurança da informação. (ABNT, NBR

27002, 2013, p.15)

(15) Controle: Recursos Humanos – Encerramento ou mudança de contratação.

7.3.1 - Convém que as responsabilidades e obrigações pela segurança da informação que permaneçam válidas após um encerramento ou mudança da contratação sejam definidas, comunicadas aos

funcionários ou partes externas e cumpridas. (ABNT, NBR 27002, 2013, p.16)

Capítulo 8 – Gestão de ativos

(16) Controle: Inventário dos ativos.

8.1.1 – Convém que os ativos associados à informação e aos recursos de processamento da informação sejam identificados, e um inventário destes ativos seja estruturado e mantido. (ABNT, NBR 27002, 2013, p.16)

(17) Controle: Proprietário dos ativos.

8.1.2 - Convém que os ativos mantidos no inventário tenham um proprietário. (ABNT, NBR 27002, 2013, p.17)

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes) (18) Controle: Uso aceitável dos ativos.

8.1.3 - Convém que regras para o uso aceitável das informações, dos ativos associados com a informação e dos recursos de processamento da informação sejam identificadas, documentadas e implementadas.

(ABNT, NBR 27002, 2013, p.18)

(19) Controle: Devolução de ativos.

8.1.4 - Convém que todos os funcionários e partes externas devolvam todos os ativos da organização que estejam em sua posse, após o encerramento de suas atividades, do contrato ou do acordo. (ABNT, NBR 27002, 2013, p.18)

(20) Controle: Classificação da informação.

8.2.1 - Convém que a informação seja classificada em termos do seu valor, requisitos legais, sensibilidade e criticidade para evitar modificação ou divulgação não autorizada. (ABNT, NBR 27002, 2013, p.18)

(21) Controle: Rótulos e tratamento da informação.

8.2.2- Convém que um conjunto apropriado de procedimentos para rotular e tratar a informação seja desenvolvido e implementado de acordo com o esquema de classificação adotado pela organização.

(ABNT, NBR 27002, 2013, p.20)

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes) (22) Controle: Tratamento dos ativos

8.2.3 - Convém que procedimentos para o tratamento dos ativos sejam

desenvolvidos e implementados de acordo com o esquema de classificação da informação adotado pela organização. (ABNT, NBR

27002, 2013, p.20)

(23) Controle: Gerenciamento de mídias removíveis.

8.3.1- Convém que existam procedimentos implementados para o gerenciamento de mídias removíveis, de acordo com o esquema de classificação adotado pela organização. (ABNT, NBR 27002, 2013, p.21)

(24) Controle: Descarte de mídias

8.3.2 - Convém que as mídias sejam descartadas de forma segura, quando não forem mais necessárias, por meio de procedimentos formais. (ABNT, NBR 27002, 2013, p.22)

(25) Controle: Transferência física de mídias.

8.3.3 – Convém que mídias contendo informações sejam protegidas contra acesso não autorizado, uso impróprio ou corrupção durante o transporte. (ABNT, NBR 27002, 2013, p.22)

(26) Controle: Política de controle de acesso.

9.1.1 - Convém que uma política de controle de acesso seja estabelecida, documentada e analisada criticamente, baseada nos requisitos de segurança da informação e dos negócios. (ABNT, NBR

27002, 2013, p.23)

(27) Controle: Acesso às redes e aos serviços de rede.

9.1.2 - Convém que os usuários somente recebam acesso às redes e aos serviços de rede que tenham sido especificamente autorizados para utilizar. (ABNT, NBR 27002, 2013, p.25)

(28) Controle: Registro e cancelamento de usuário

9.2.1 - Convém que um processo formal de registro e cancelamento de usuário seja implementado para permitir atribuição dos direitos de acesso. (ABNT, NBR 27002, 2013, p.25)

(29) Controle: Provisionamento para acesso de usuário.

9.2.2 - Convém que um processo formal de provisionamento de acesso do usuário seja implementado para conceder ou revogar os direitos de acesso do usuário para todos os tipos de usuários em todos os tipos de sistemas e serviços. (ABNT, NBR 27002, 2013, p.26)

235

**Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com**

**SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes) (30) Controle: Gerenciamento de direitos de acesso privilegiados.**

9.2.3 - Convém que a concessão e o uso de direitos de acesso privilegiado sejam restritos e controlados. (ABNT, NBR 27002, 2013, p.27)

(31) Controle: Gerenciamento da informação de autenticação secreta de usuários 9.2.4 - Convém que a concessão de informação de autenticação secreta seja controlada por meio de um processo de gerenciamento formal.

(ABNT, NBR 27002, 2013, p.28)

(32) Controle: Análise crítica dos direitos de acesso de usuário.

9.2.5 - *Convém que os proprietários de ativos analisem criticamente os direitos de acesso dos usuários a intervalos regulares. (ABNT, NBR*

27002, 2013, p.28)

(33) Controle: Retirada ou ajuste dos direitos de acesso.

9.2.6 - *Convém que os direitos de acesso de todos os funcionários e partes externas às informações e aos recursos de processamento da informação sejam retirados logo após o encerramento de suas atividades, contratos ou acordos, ou ajustados após a mudança desta atividade. (ABNT, NBR 27002, 2013, p.29)*

236

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

**SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes)** *(34) Controle: Uso da informação de autenticação secreta.*

9.3.1 - *Convém que os usuários sejam orientados a seguir as práticas da organização quanto ao uso da informação de autenticação secreta.*

(ABNT, NBR 27002, 2013, p.30)

(35) Controle: Restrição de acesso à informação

9.4.1 – *Convém que o acesso à informação e às funções dos sistemas de aplicações seja restrito, de acordo com a política de controle de acesso.*

(ABNT, NBR 27002, 2013, p.31)

(36) Controle: Procedimentos seguros de entrada no sistema (log-on) 9.4.2 - Convém que, onde aplicável pela política de controle de acesso, o acesso aos sistemas e aplicações, sejam controlados por um procedimento seguro de entrada no sistema (log-on). (ABNT, NBR

27002, 2013, p.31)

(37) Controle: Sistemas de gerenciamento de senha

9.4.3 - Convém que sistemas para gerenciamento de senhas sejam interativos e assegurem senhas de qualidade. (ABNT, NBR 27002, 2013, p.33)

(38) Controle: Uso de programas utilitários privilegiados.

9.4.4 - Convém que o uso de programas utilitários que podem ser capazes de sobrepor os controles dos sistemas e aplicações seja restrito e estritamente controlado. (ABNT, NBR 27002, 2013, p.33)

237

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

***SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes)***

(39) Controle: Controle de acesso ao código fonte de programas.

9.4.5 - Convém que o acesso ao código fonte de programas seja restrito.

(ABNT, NBR 27002, 2013, p.34)

Capítulo 10 – Criptografia

(40) Controle: Política para uso de controles criptográficos

10.1.1 - Convém que seja desenvolvida e implementada uma política sobre o uso de controles criptográficos para a proteção da informação.

(ABNT, NBR 27002, 2013, p.35)

(41) Controle: Gerenciamento de chaves.

10.1.2 - Convém que uma política sobre o uso, proteção e tempo de vida das chaves criptográficas seja desenvolvida e implementada ao longo de todo o seu ciclo de vida. (ABNT, NBR 27002, 2013, p.36)

Capítulo 11 – Segurança física e do ambiente

(42) Controle: Perímetro de segurança física.

11.1.1 - Convém que perímetros de segurança sejam definidos e usados para proteger tanto as instalações de processamento da informação como as áreas que contenham informações críticas ou sensíveis. (ABNT, NBR 27002, 2013, p.38)

238

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

**SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes) (43) Controle: Controles de entrada física.**

11.1.2 - Convém que as áreas seguras sejam protegidas por controles apropriados de entrada para assegurar que somente pessoas autorizadas tenham acesso permitido. (ABNT, NBR 27002, 2013, p.39) (44) Controle: Segurança em escritórios, salas e instalações.

11.1.3 - Convém que seja projetada e aplicada segurança física para escritórios, salas e instalações. (ABNT, NBR 27002, 2013, p.40)

(45) Controle: Proteção contra ameaças externas e do meio ambiente.

11.1.4 - Convém que seja projetada e aplicada proteção física contra desastres naturais, ataques maliciosos ou acidentes. (ABNT, NBR 27002, 2013, p.40)

(46) Controle: Trabalhando em áreas seguras.

11.1.5 - Convém que sejam projetados e aplicados procedimentos para o trabalho em áreas seguras (ABNT, NBR 27002, 2013, p.40)

(47) Controle: Áreas de entrega e de carregamento.

11.1.6 - Convém que pontos de acesso como áreas de entrega e de carregamento e outros pontos em que pessoas não autorizadas possam entrar nas instalações, sejam controlados e, se possível, isolados das instalações de processamento de informação, para evitar o acesso não autorizado. (ABNT, NBR 27002, 2013, p.41)

239

**Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com**

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

(48) Controle: Localização e proteção do equipamento.

11.2.1 - Convém que os equipamentos sejam protegidos e colocados em locais para reduzir os riscos de ameaças e perigos do meio ambiente, bem como as oportunidades de acesso não autorizado. (ABNT, NBR

27002, 2013, p.41)

(49) Controle: Utilidades.

11.2.2 - Convém que os equipamentos sejam protegidos contra a falta de energia elétrica e outras interrupções causadas por falhas das utilidades. (ABNT, NBR 27002, 2013, p.42)

(50) Controle: Segurança do cabeamento.

11.2.3 - Convém que o cabeamento de energia e de telecomunicações que transporta dado ou dá suporte aos serviços de informações seja protegido contra interceptação, interferência ou danos. (ABNT, NBR

27002, 2013, p.43)

(51) Controle: Manutenção dos equipamentos.

11.2.4 – Convém que os equipamentos tenham uma manutenção correta para assegurar a sua contínua integridade e disponibilidade.

(ABNT, NBR 27002, 2013, p.43)

240

Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes) (52) Controle: Remoção de ativos.

11.2.5 - Convém que equipamentos, informações ou software não sejam retirados do local sem autorização prévia. (ABNT, NBR 27002, 2013, p.44)

(53) Controle: Segurança de equipamentos e ativos fora das dependências da organização.

11.2.6 - Convém que sejam tomadas medidas de segurança para ativos que operem fora do local, levando em conta os diferentes riscos decorrentes do fato de se trabalhar fora das dependências da organização. (ABNT, NBR 27002, 2013, p.45)

(54) Controle: Reutilização ou descarte seguro de equipamentos.

11.2.7 - Convém que todos os equipamentos que contenham mídias de armazenamento de dados sejam examinados antes da reutilização, para assegurar que todos os dados sensíveis e software licenciados tenham sido removidos ou sobre gravados com segurança. (ABNT, NBR

27002, 2013, p.46)

(55) Controle: Equipamento de usuário sem monitoração.

11.2.8 - Convém que os usuários assegurem que os equipamentos não monitorados tenham proteção adequada. (ABNT, NBR 27002, 2013, p.46)

241

Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes) (56) Controle: Política de mesa limpa e tela limpa.

11.2.9 - Convém que sejam adotadas uma política de mesa limpa para papéis e mídias de armazenamento removíveis e uma política de tela limpa para os recursos de processamento de informação. (ABNT, NBR

27002, 2013, p.47)

Capítulo 12 – Segurança nas operações

(57) Controle: Documentação dos procedimentos de operação.

12.1.1 - Convém que os procedimentos de operação sejam

documentados e disponibilizados para todos os usuários que necessitem deles. (ABNT, NBR 27002, 2013, p.48)

(58) Controle: Gestão de mudanças.

12.1.2 - Convém que mudanças na organização, nos processos de negócio, nos recursos de processamento da informação e nos sistemas que afetam a segurança da informação, sejam controladas. (ABNT, NBR

27002, 2013, p.49)

(59) Controle: Gestão de capacidade.

12.1.3 - Convém que a utilização dos recursos seja monitorada e ajustada, e que as projeções sejam feitas para necessidades de capacidade futura para

garantir o desempenho requerido do sistema (ABNT, NBR 27002, 2013, p.49)

(60) Controle: Separação dos ambientes de desenvolvimento, teste e produção.

242

Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA

(Edison Fontes) 12.1.4 - *Convém que ambientes de desenvolvimento, teste e produção sejam separados para reduzir os riscos de acessos ou modificações não autorizadas no ambiente de produção. (ABNT, NBR 27002, 2013, p.50)*

(61) Controle: Controles contra malware

12.2.1 - *Convém que sejam implementados controles de detecção, prevenção e recuperação para proteger contra malware, combinados com um adequado programa de conscientização do usuário. (ABNT, NBR 27002, 2013, p.51)*

(62) Controle: Cópias de segurança das informações.

12.3.1 - *Convém que cópias de segurança das informações, dos software e das imagens do sistema sejam efetuadas e testadas regularmente conforme a política de geração de cópias de segurança definida. (ABNT, NBR 27002, 2013, p.53)*

(63) Controle: Registro de eventos.

12.4.1 - *Convém que registros (log) de eventos das atividades do usuário, exceções, falhas e eventos de segurança da informação sejam produzidos, mantidos e analisados criticamente, a intervalos regulares.*

(ABNT, NBR 27002, 2013, p.54)

243

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes)

(64) Controle: Proteção das informações dos registros de eventos (log).

12.4.2 - Convém que as informações dos registros de eventos (log) e os seus recursos sejam protegidos contra acesso não autorizado e adulteração. (ABNT, NBR 27002, 2013, p.55)

(65) Controle: Registro de eventos (log) de administrador e operador 12.4.3 - Convém que as atividades dos administradores e operadores do sistema sejam registradas e os registros (log) protegidos e analisados criticamente, a intervalos regulares. (ABNT, NBR 27002, 2013, p.56) (66) Controle: Sincronização dos relógios

12.4.4 - Convém que os relógios de todos os sistemas de processamento de informações relevantes, dentro da organização ou do domínio de segurança, sejam sincronizados com uma única fonte de tempo precisa.

(ABNT, NBR 27002, 2013, p.56)

(67) Controle: Instalação de software nos sistemas operacionais.

12.5.1 - Convém que procedimentos para controlar a instalação de software em sistemas operacionais sejam implementados. (ABNT, NBR 27002, 2013, p.57)

(Edison Fontes) (68) *Controle: Gestão de vulnerabilidades técnicas.*

12.6.1 - *Convém que informações sobre vulnerabilidades técnicas dos sistemas de informação em uso sejam obtidas em tempo hábil; convém que a exposição da organização a estas vulnerabilidades seja avaliada e que sejam tomadas as medidas apropriadas para lidar com os riscos associados. (ABNT, NBR 27002, 2013, p.58)*

(69) *Controle: Restrição quanto à instalação de software.*

12.6.2 - *Convém que sejam estabelecidas e implementadas regras definindo critérios para a instalação de software pelos usuários. (ABNT, NBR 27002, 2013, p.59)*

(70) *Controle: Controles de auditoria de sistemas de informação.*

12.7.1 - *Convém que as atividades e requisitos de auditoria envolvendo a verificação nos sistemas operacionais sejam cuidadosamente planejados e acordados para minimizar interrupção dos processos do negócio. (ABNT, NBR 27002, 2013, p.60)*

Capítulo 13 – Segurança nas comunicações

(71) *Controle: Controles de redes*

13.1.1 - *Convém que as redes sejam gerenciadas e controladas para proteger as informações nos sistemas e aplicações. (ABNT, NBR 27002, 2013, p.61)*

13.1.2 - *Convém que mecanismos de segurança, níveis de serviço e requisitos de gerenciamento de todos os serviços de rede sejam identificados e*

incluídos em qualquer acordo de serviços de rede, tanto para serviços de rede providos internamente como para terceirizados.

(ABNT, NBR 27002, 2013, p.61)

(73) Controle: Segregação de redes

13.1.3 - Convém que grupos de serviços de informação, usuários e sistemas de informação, sejam segregados em redes. (ABNT, NBR

27002, 2013, p.62)

(74) Controle: Políticas e procedimentos para transferência de informações
13.2.1 - Convém que políticas, procedimentos e controles de transferências formais sejam estabelecidos para proteger a transferência de informações, por meio de uso de todos os tipos de recursos de comunicação. (ABNT, NBR 27002, 2013, p.63)

(75) Controle: Acordos para transferência de informações.

13.2.2 - Convém que sejam estabelecidos acordos para transferência segura de informações do negócio entre a organização e as partes externas. (ABNT, NBR 27002, 2013, p.64)

13.2.3 - Convém que as informações que trafegam em mensagens eletrônicas sejam adequadamente protegidas. (ABNT, NBR 27002, 2013, p.65)

(77) Controle: Acordos de confidencialidade e não divulgação.

13.2.4 - Convém que os requisitos para a confidencialidade ou acordos de

não divulgação que reflitam as necessidades da organização para a proteção da informação sejam identificados, analisados criticamente e documentados. (ABNT, NBR 27002, 2013, p.668)

Capítulo 14 – Aquisição, desenvolvimento e manutenção de sistemas (78)

Controle: Análise e especificação dos requisitos de segurança da informação

14.1.1 - Convém que os requisitos relacionados à segurança da informação sejam incluídos nos requisitos para novos sistemas de informação ou melhorias dos sistemas de informação existentes. (ABNT, NBR 27002, 2013, p.67)

(79) Controle: Serviços de aplicação seguros em redes públicas.

14.1.2 - Convém que as informações envolvidas nos serviços de aplicação que transitam sobre as redes públicas sejam protegidas de atividades fraudulentas, disputas contratuais e divulgação e modificações não autorizadas. (ABNT, NBR 27002, 2013, p.68)

247

Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA

(Edison Fontes) (80) Controle: Protegendo as transações nos aplicativos de

serviços 14.1.3 - Convém que informações envolvidas em transações nos aplicativos de serviços sejam protegidas para prevenir transmissões incompletas, erros de roteamento, alteração não autorizada da mensagem, divulgação não autorizada, duplicação ou reapresentação da mensagem não autorizada. (ABNT, NBR 27002, 2013, p.70)

(81) Controle: Política de desenvolvimento seguro.

14.2.1 - Convém que regras para o desenvolvimento de sistemas e software sejam estabelecidas e aplicadas aos desenvolvimentos realizados dentro da organização. (ABNT, NBR 27002, 2013, p.70)

(82) Controle: Procedimentos para controle de mudança de sistemas 14.2.2 - Convém que as mudanças em sistemas no ciclo de vida de desenvolvimento sejam controladas utilizando procedimentos formais de controle de mudanças. (ABNT, NBR 27002, 2013, p.71)

(83) Controle: Análise crítica técnica das aplicações após mudanças nas plataformas operacionais.

14.2.3 – Quando plataformas operacionais forem modificadas, convém que as aplicações críticas de negócio sejam analisadas criticamente e testadas para garantir que não haverá qualquer impacto adverso na operação da organização ou na segurança. (ABNT, NBR 27002, 2013, p.73)

248

Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes) *(84) Controle: Restrições sobre mudanças em pacotes de software*

14.2.4 - Convém que modificações em pacotes de software sejam desencorajadas e estejam limitadas às mudanças necessárias, e todas as mudanças sejam estritamente controladas. (ABNT, NBR 27002, 2013, p.73)

(85) Controle: Princípios para projetar sistemas seguros

14.2.5 - Convém que princípios para projetar sistemas seguros sejam estabelecidos, documentados, mantidos e aplicados para qualquer implementação de sistemas de informação. (ABNT, NBR 27002, 2013, p.74)

(86) Controle: Ambiente seguro para desenvolvimento

14.2.6 – Convém que as organizações estabeleçam e protejam adequadamente ambientes seguros de desenvolvimento, para os esforços de integração e desenvolvimento de sistemas, que cubram todo o ciclo de vida

de desenvolvimento de sistema. (ABNT, NBR 27002, 2013, p.74)

(87) Controle: Desenvolvimento terceirizado.

14.2.7 - Convém que a organização supervisione e monitore as atividades de desenvolvimento de sistemas terceirizado. (ABNT, NBR

27002, 2013, p.75)

249

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

***SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes) (88) Controle: Testes de segurança do sistema***

14.2.8 - Convém que os testes das funcionalidades de segurança sejam realizados durante o desenvolvimento e sistemas. (ABNT, NBR 27002, 2013, p.76)

(89) Controle: Teste de aceitação de sistemas

14.2.9 - Convém que testes de aceitação e critérios relacionados sejam estabelecidos para novos sistemas de informação, atualizações e novas versões. (ABNT, NBR 27002, 2013, p.76)

(90) Controle: Proteção dos dados para testes

*14.3.1 - Convém que os dados de testes sejam selecionados com cuidado, protegidos e controlados. (ABNT, NBR 27002, 2013, p.76) Capítulo 15 –
Relacionamento na cadeia de suprimento*

(91) Controle: Política de segurança da informação no relacionamento com os fornecedores.

15.1.1 - Convém que os requisitos de segurança da informação para mitigar os riscos associados com o acesso dos fornecedores aos ativos da

organização sejam acordados com o fornecedor e documentados.

(ABNT, NBR 27002, 2013, p.77)

250

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA

(Edison Fontes) (92) *Controle: Identificando segurança da informação nos acordos com fornecedores 15.1.2 - Convém que todos os requisitos de segurança da informação relevantes sejam estabelecidos e acordados com cada fornecedor que possa acessar, processar, armazenar, comunicar ou prover*

componentes de infraestrutura de TI para as informações da organização, (ABNT, NBR 27002, 2013, p.78)

(93) *Controle: Cadeia de suprimento na tecnologia da informação e comunicação 15.1.3 - Convém que acordos com fornecedores incluam requisitos para contemplar os riscos de segurança da informação associados à cadeia de suprimento de produtos e serviços de tecnologia da informação e comunicação. (ABNT, NBR 27002, 2013, p.80)*

(94) *Controle: Monitoramento e análise crítica de serviços com fornecedores 15.2.1 - Convém que as organizações monitorem, analisem criticamente e auditem, a intervalos regulares, a entrega dos serviços executados pelos fornecedores. (ABNT, NBR 27002, 2013, p.81)*

(95) *Controle: Gerenciamento de mudanças para serviços com fornecedores 15.2.2 - Convém que mudanças no provisionamento dos serviços pelos fornecedores, incluindo manutenção e melhoria das políticas de segurança da informação, dos procedimentos e controles existentes, sejam gerenciadas, levando-se em conta a criticidade das informações do negócio, dos sistemas e processos envolvidos, e a reavaliação de riscos. (ABNT, NBR 27002, 2013, p.82)*

Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA **(Edison Fontes)**

Capítulo 16 – Gestão de incidentes de segurança da informação

(96) Controle: Responsabilidades e procedimentos

16.1.1 - Convém que responsabilidades e procedimentos de gestão sejam estabelecidos para assegurar respostas rápidas, efetivas e ordenadas aos incidentes de segurança da informação. (ABNT, NBR

27002, 2013, p.83)

(97) Controle: Notificação de eventos de segurança da informação.

16.1.2 - Convém que os eventos de segurança da informação sejam relatados por meio de canais de gestão, o mais rapidamente possível.

(ABNT, NBR 27002, 2013, p.84)

(98) Controle: Notificando fragilidades de segurança da informação.

16.1.3 - Convém que os funcionários e partes externas que usam os sistemas e serviços de informação da organização sejam instruídos a notificar e registrar quaisquer fragilidades de segurança da informação, observada ou suspeita, nos sistemas ou serviços. (ABNT, NBR 27002, 2013, p.85)

(99) Controle: Avaliação e decisão dos eventos de segurança da informação.

16.1.4 - Convém que os eventos de segurança da informação sejam avaliados e seja decidido se eles são classificados como incidentes de segurança da informação. (ABNT, NBR 27002, 2013, p.86)

Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA

(Edison Fontes) (100) *Controle: Resposta aos incidentes de segurança da informação 16.1.5 - Convém que incidentes de segurança da informação sejam reportados de acordo com procedimentos documentados. (ABNT, NBR 27002, 2013, p.86)*

(101) Controle: Aprendendo com os incidentes de segurança da informação.

16.1.6 - Convém que os conhecimentos obtidos da análise e resolução dos incidentes de segurança da informação sejam usados para reduzir a probabilidade ou o impacto de incidentes futuros. (ABNT, NBR 27002, 2013, p.87)

(102) Controle: Coleta de evidências

16.1.7 - Convém que a organização defina e aplique procedimentos para identificação, coleta, aquisição e preservação dos informações, as quais podem servir como evidências. (ABNT, NBR 27002, 2013, p.87)

Capítulo 17 – Aspectos de segurança da informação na gestão de continuidade do negócio (103) *Controle: Planejando a continuidade da segurança da informação 17.1.1 - Convém que a organização determine seus requisitos para a segurança da informação e continuidade da gestão da segurança da informação em situações diversas, por exemplo, durante uma crise ou desastre. (ABNT, NBR 27002, 2013, p.88)*

Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes) (104) *Controle: Implementando a continuidade da segurança da informação.*

17.1.2 - Convém que a organização estabeleça, documente, implemente e mantenha processos, procedimentos e controles para assegurar o nível requerido de continuidade para a segurança da informação, durante uma situação adversa. (ABNT, NBR 27002, 2013, p.89)

(105) Controle: Verificação, análise crítica e avaliação da continuidade da segurança da informação.

17.1.3 - Convém que a organização verifique os controles de continuidade da segurança da informação, estabelecidos e

implementados, a intervalos regulares, para garantir que eles sejam válidos e eficazes em situações adversas. (ABNT, NBR 27002, 2013, p.90)

(106) Controle: Disponibilidade dos recursos de processamento da informação.

17.2.1- Convém que os recursos de processamento da informação sejam implementados com redundância suficiente para atender aos requisitos de disponibilidade. (ABNT, NBR 27002, 2013, p.91)

Capítulo 18 – Conformidade

(107) Controle: Identificação da legislação aplicável e de requisitos contratuais 18.1.1 - Convém que todos os requisitos legislativos estatutários, regulamentares e contratuais pertinentes e o enfoque da organização para atender a esses requisitos sejam explicitamente identificados, documentados e mantidos atualizados para cada sistema de

informação da organização. (ABNT, NBR 27002, 2013, p.91)

Edison Fontes, edison@pobox.com

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

(108) Controle: Direitos de propriedade intelectual.

18.1.2 - Convém que procedimentos apropriados sejam implementados para garantir a conformidade com os requisitos legislativos, regulamentares e contratuais relacionados aos direitos de propriedade intelectual, e sobre o uso de produtos de software proprietários. (ABNT, NBR 27002, 2013, p.93)

(109) Controle: Proteção de registros

18.1.3 - Convém que registros sejam protegidos contra perda, destruição, falsificação, acesso não autorizado e liberação não autorizada, de acordo com os requisitos regulamentares, estatutários, contratuais e do negócio. (ABNT, NBR 27002, 2013, p.93)

(110) Controle: Proteção e privacidade de informações de identificação pessoal 18.1.4 - Convém que a privacidade e a proteção das informações de identificação pessoal sejam asseguradas conforme requerido por legislação e regulamentação pertinente, quando aplicável (ABNT, NBR

27002, 2013, p.94)

(111) Controle: Regulamentação de controles de criptografia

18.1.5 - Convém que controles de criptografia sejam usados em conformidade com todas as leis, acordos, legislação e regulamentação pertinentes (ABNT, NBR 27002, 2013, p.94)

(Edison Fontes) (112) *Controle: Análise crítica independente da segurança da informação* 18.2.1- *Convém que o enfoque da organização para gerenciar a segurança da informação e a sua implementação (por exemplo, objetivo dos controles, controles, políticas, processos e procedimentos para a segurança da informação) seja analisado criticamente, de forma independente, a intervalos planejados, ou quando ocorrerem mudanças significativas. (ABNT, NBR 27002, 2013, p.95)*

(113) *Controle: Conformidade com as políticas e procedimentos de segurança da informação.*

18.2.2 - *Convém que os gestores analisem criticamente, a intervalos regulares, a conformidade dos procedimentos e do processamento da informação, dentro das suas áreas de responsabilidades, com as normas e políticas de segurança e quaisquer outros requisitos de segurança da informação. (ABNT, NBR 27002, 2013, p.96)*

(114) *Controle: Análise crítica da conformidade técnica*

18.2.3 - *Convém que os sistemas de informação sejam analisados criticamente, a intervalos regulares, para verificar a conformidade com as normas e políticas de segurança da informação da organização.*

(ABNT, NBR 27002, 2013, p.

Documentos e Estruturas de Apoio

257

*Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com*

**SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes) Documento Programa Organizacional Segurança da
Informação**

1. OBJETIVO DESTE DOCUMENTO

Apresentar o Programa Organizacional de Segurança de Informação da Organização.

2. PROGRAMA ORGANIZACIONAL SEGURANÇA DA INFORMAÇÃO

O Programa Organizacional de Segurança da Informação é o conjunto de ações estruturadas que possibilitam que a Organização alcance os seus objetivos corporativos no que depende da informação e/ou dos recursos de informação.

O Programa Organizacional de Segurança da Informação possui os seguintes Elementos Estruturais:

2.1 – DIRECIONADORES DO PROCESSO DE SEGURANÇA

=> Definem os controles que devem ser implementados considerando referências: externas, legais e de exigência de mercado.

2.2 – DIMENSÕES DA SEGURANÇA DA INFORMAÇÃO.

=> Definem o escopo, a abrangência, as limitações e os temas a serem considerados pelo Programa Organizacional de Segurança da Informação.



SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

2.3 – GOVERNANÇA DA SEGURANÇA DA INFORMAÇÃO

=> Define as diretrizes que garantirão o alinhamento do Programa Organizacional de Segurança da Informação com a Governança Corporativa da Organização.

2.4 – GESTÃO DA SEGURANÇA DA INFORMAÇÃO

=> Define como os controles são desenvolvidos, implantados e gerenciados, possibilitando desta maneira a existência de um Programa Organizacional de Segurança da Informação efetivo (eficaz e eficiente ao longo do tempo).

2.5 - O Planejamento das Ações de Segurança da Informação

=> Define o Plano de Ação para as atividades e para os projetos de Segurança da Informação, possibilitando uma gestão efetiva do Programa

Organizacional de Segurança da Informação e o alinhamento com a Governança Corporativa.

A figura abaixo representativa dos Elementos Estruturais do Programa Organizacional de Segurança da Informação da Organização.

Elementos Estruturais do Programa Organizacional de Segurança da Informação.

Fonte: Edison Fontes, 2016

259

*Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com*

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) 3. DIRECIONADORES DO PROGRAMA ORGANIZACIONAL

3.1 – DIRECIONADORES OBRIGATÓRIOS

Direcionadores Obrigatórios são os controles que devem ser implantados por se tratarem de legislação nacional ou internacional, requisitos de mercado, requisitos de clientes ou requisito de fornecedores.

Citamos abaixo os Direcionadores Obrigatórios relacionados à Segurança da Informação que a Organização deve atender, sob pena de não estar cumprindo a legislação em vigor. Alguns destes direcionadores estão relacionados ao negócio de pagamentos e outros estão relacionados ao funcionamento como organização.

3.1.1 – Legislação Brasileira

Neste item deve ser relacionada a legislação que afeta a organização. Dependendo do tipo de negócio existem legislações específicas. Para todas as organizações existe a legislação mais geral. Neste exemplo de documento, deixo apenas a legislação mais geral.

a) Lei 12.737/2012 – Crimes Eletrônicos

=> Exige que mecanismos de segurança sejam implantados na Organização para que a mesma possa reclamar de eventuais Crimes Eletrônicos contra ela.

b) Lei No. 12.965/2014 - Marco Civil Internet

=> Exige a proteção e sigilo para os dados pessoais.

260

*Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com*

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) 3.1.2 – Requerimentos de mercado

Existem requerimentos de Mercado, como o PCI (The Payment Card Industry), padrão exigido pelas bandeiras de cartão, que não é uma legislação, mas é operacional que tem como objetivo proteger o processo de uso do cartão.

3.1.3 – Requerimentos dos Acionistas

Exigências e orientações dos acionistas que retratam uma necessidade específica para a Organização que não são contempladas por outros Direcionadores Obrigatórios.

3.2 – DIRECIONADORES DE REFERÊNCIA TEÓRICA (ESTRUTURAIS)

Direcionadores de Referência Teórica são elementos publicados por órgãos nacionais ou internacionais, com credibilidade perante a comunidade

profissional/acadêmica e que apresentam uma estrutura que facilita e padroniza o tratamento para a Gestão e Governança do Programa Organizacional de Segurança da Informação.

A Organização atende aos seguintes direcionadores:

3.2.1 – Gestão de Segurança da Informação

=> Descrevem os elementos que devem compor a Gestão da Segurança da Informação.

a) Norma NBR ISO/IEC 27002:2013 - Tecnologia da informação – Técnicas de segurança - Código de prática para a gestão da segurança da informação. ABNT.

261

*Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com*

**SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes)** b) Norma [NBR ISO/IEC 27001:2013 - Tecnologia da
informação — Técnicas de](#)

[segurança — Sistemas de gestão da segurança da informação — Requisitos.](#)
ABNT.

c) Norma [NBR ISO/IEC 27003:2011 - Tecnologia da informação – Técnicas de](#)

[segurança – Diretrizes para implantação de um sistema de gestão da
segurança da](#)

[informação.](#) ABNT.

3.2.2 – Governança da Segurança da Informação

=> Descrevem os elementos que devem compor a Governança da Segurança da Informação.

a) Norma [NBR ISO/IEC 27014:2013 - Tecnologia da Informação —
Técnicas de](#)

[Segurança — Governança de segurança da informação.](#) ABNT.

b) Information Security Governance: Guidance for Board Directors and Executive Management, ITGI - Information Technology Governance Institute, USA

c) Information Security Governance: Guidance for Information Security Managers, ITGI - Information Technology Governance Institute, USA.

3.2.3 – Classificação da informação

=> Descreve os elementos que devem compor a Classificação da Informação.

a) Norma [NBR 16167:2013 - Segurança da Informação — Diretrizes para classificação, rotulação e tratamento da informação.](#) ABNT.

262

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) 3.2.4 – Gestão de Riscos de Segurança da Informação

=> Descrevem os elementos que devem compor a Gestão de Riscos de Segurança da Informação.

a) Norma [NBR ISO/IEC 27005:2011 - Tecnologia da informação — Técnicas de](#)

[segurança — Gestão de riscos de segurança da informação.](#) ABNT.

b) Norma NBR ISO/IEC 31000:2009 – Gestão de riscos – Princípios e diretrizes.

ABNT.

c) Norma NBR ISO/IEC 31010:2012 – Gestão de riscos – Técnicas para o processo de avaliação de riscos. ABNT.

3.2.5 – Gestão de Continuidade de Negócios

=> Descrevem os elementos que devem compor a Gestão de Continuidade de Negócio.

a) Norma [NBR ISO 22301:2013 - Segurança da sociedade — Sistema de gestão de](#)

[continuidade de negócios — Requisitos.](#) ABNT.

3.2.6 - Demais Normas da Família NBR ISO/IEC 27000.

=> Estas normas descrevem os demais elementos que devem compor a Gestão da Segurança da Informação.

3.2.7 - COBIT

Control Objectives for Information and related Technology, ITGI - Information Technology Governance Institute, ISACA, USA.

263

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

=> O COBIT tem como foco principal a Gestão do Processo de Tecnologia da Informação. Neste contexto o COBIT aborda a Segurança da Informação para o ambiente de Tecnologia e possui um forte alinhamento com os regulamentos da Família 27.000, dedicada à Segurança da Informação.

3.2.8 – ITIL

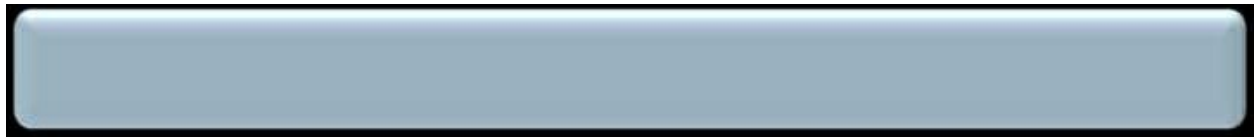
Information Technology Infrastructure Library – Service Design, OCGE, London.

=> O ITIL tem como foco principal a Entrega de Serviços pelo Processo Gestão do Processo de Tecnologia da Informação. Neste contexto o ITIL contempla a Segurança da Informação para possibilitar uma entrega adequada dos serviços de tecnologia da Informação.

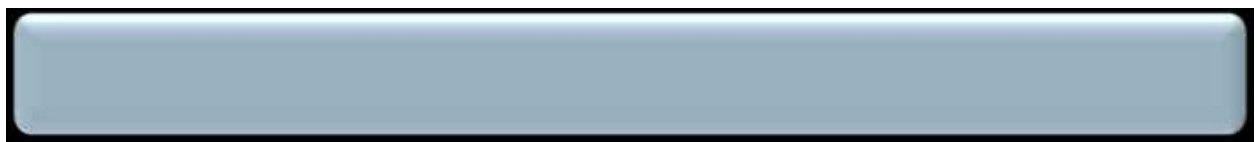
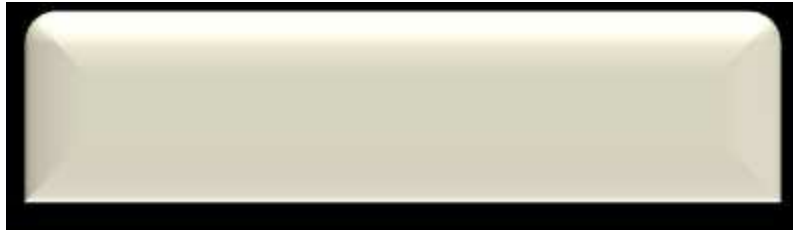
4. DIMENSÕES DA SEGURANÇA DA INFORMAÇÃO

O Programa Organizacional da Segurança da Informação da ORGANIZAÇÃO

considera a existência de controles em todas as Dimensões de Segurança da Informação, tomando por base a Norma NBR ISO/IEC 27002:2013.







SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes)

POLÍTICAS DE SEGURANÇA DA INFORMAÇÃO

o

óci

Acesso à Informação

Classificação da Informação

Proteção técnica

g

Recursos de informação

ne

de

s

s

co

a

s

r

i

g

r

er

Flexibilidade

Desenvolvimento de aplicativos

Conscientização e Treinamento

de

e

Operacional

o

o

ãt

ça

s

a

Ge

ntema

Continuidade do negócio

ul

Tratamento de

Modelo operativo

ge

incidentes de segurança

da SI

R

Ambiente

Cópias de segurança

Físico e infra-estrutura

8

Fonte: Livro Praticando a segurança da informação, Edison Fontes, Editora BRASPORT, 2008. Página 48.

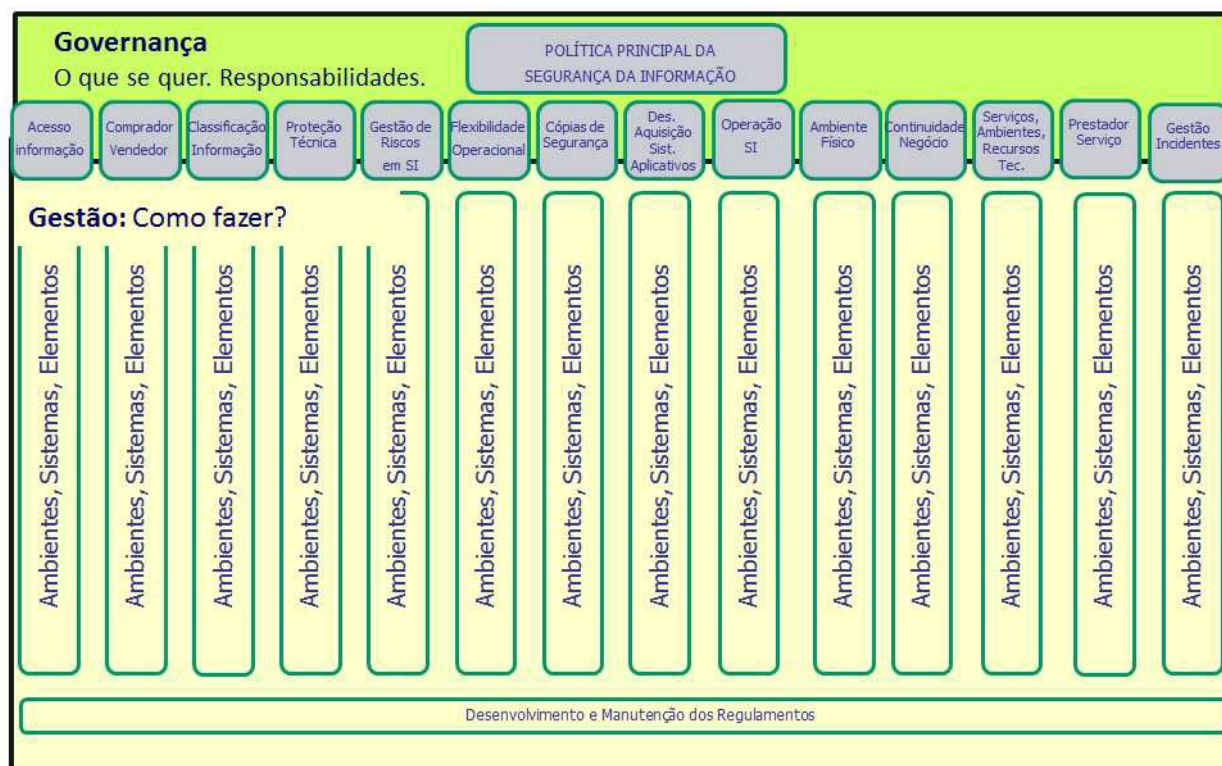
Estrutura baseada na Norma Internacional ISO/IEC 27002.

4.1. DIMENSÃO POLÍTICA DA SEGURANÇA DA INFORMAÇÃO

A Dimensão Política de Segurança da Informação define as regras de como este Programa Organizacional de Segurança da Informação irá funcionar, define as responsabilidades e permite a conexão da Governança da Segurança da Informação com a Gestão do Programa Organizacional . Ela é um elemento estrutural para o Programa Organizacional da Segurança da Informação.

265

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***



SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

A Dimensão Política de Segurança da Informação explicita como a Organização deseja que a informação seja utilizada, controlada e tenha responsabilidades quando do seu uso.

4.1.1 – Arquitetura da Política de Segurança da Informação

A ORGANIZAÇÃO segue a seguinte Arquitetura de Política de Segurança da Informação:

Arquitetura Política Segurança Informação.

Fontes: Livro Normas e Políticas para a Segurança da Informação, Edison Fontes, Editora BRASPORT, 2012.

4.1.2 – Documentos de Regulamentos da Segurança da Informação

Descrevemos abaixo os Documentos que compõem o Conjunto Política de

*Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com*

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) 4.1.2.1 - Documentos Nível 1

a) Política Corporativa de Segurança da Informação.

=> Diretrizes e filosofia da Organização para a Segurança da Informação

4.1.2.2 - Documentos Nível 2

a) Política Dimensão Acesso à Informação.

=> Diretrizes e regras para o acesso lógico do usuário à informação **b) Política Dimensão Ambiente Físico.**

=> Diretrizes e regras para o acesso do usuário ao ambiente físico que possui recursos de informação.

c) Política Dimensão Cópia de Segurança.

=> Diretrizes e regras para a existência de cópias de segurança para a informação da Organização.

d) Política Dimensão Classificação Informação.

=> Diretrizes e regras para a existência de níveis de classificação da informação no que diz respeito ao seu sigilo.

e) Política Dimensão Conscientização e Treinamento de Usuário.

=> Diretrizes e normas para que o usuário seja permanentemente treinado e conscientizado em segurança da informação.

*Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com*

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) f) Política Dimensão de Continuidade de Negócio. (N.2)

=> Diretrizes e regras que definem como a Organização irá garantir que a continuará funcionando em condições mínimas aceitáveis, mesmo quando da ocorrência de uma indisponibilidade da informação. Seja esta indisponibilidade causada por erro, ações de má fé, fenômenos da natureza ou similar.

g) Política Dimensão Desenvolvimento Aplicativo e Aquisição Produtos.

=> Diretrizes e regras para que controles de segurança sejam contemplados (obrigatórios ou desejáveis) quando do desenvolvimento de sistemas aplicativos ou quando da aquisição de programa produto.

h) Política Dimensão Recursos Tecnologia - Correio Eletrônico Corporativo.

=> Diretrizes e regras para o uso adequado pelo usuário do serviço Correio Eletrônico Corporativo, com o objetivo de garantir a proteção da informação.

i) Política Dimensão Recursos Tecnologia - Equipamentos.

=> Diretrizes e regras para o uso adequado pelos usuários dos equipamentos corporativos de Tecnologia da Informação, liberados pela Organização.

j) Política Dimensão Recursos Tecnologia - Uso Internet.

=> Diretrizes e regras para o uso adequado pelos usuários do serviço internet, de maneira a preservar a proteção da informação da Organização.

**SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes) k) Política Dimensão Recursos Tecnologia - Rede
Interna.**

=> Diretrizes e regras para o uso adequado pelos usuários da Rede Interna de Tecnologia da Informação.

l) Política Dimensão Recursos Tecnologia - Redes Sociais.

=> Diretrizes e regras para o uso adequado pelos usuários do ambiente de redes sociais, de maneira que a informação Organização tenha a sua informação protegida.

m) Política Dimensão Gestão de Riscos de Segurança da Informação

=> Diretrizes e as regras para a existência da Gestão de Riscos de Segurança da Informação da Organização.

4.1.2.3 - Documentos Nível 3

Neste item a Organização pode descrever os regulamentos que já possui ou que serão elaborados.

4.1.2.4 – Outros Documentos

a) Termos Utilizados nos regulamentos de Segurança da Informação.

=> Definição dos Termos utilizados nos regulamentos de segurança da informação.

4.2 – DIMENSÃO ACESSO A INFORMAÇÃO

=> Implanta e operacionaliza as regras e os controles necessários para um acesso seguro à informação, tanto no ambiente de tecnologia como no ambiente convencional.

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

**SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes)** São consideradas nesta dimensão:

- Gestão de Identidade,
- Gestão de Autenticidade,
- Gestão de Autorização, e
- Auditabilidade dos acessos à informação.

Nesta dimensão são definidos os conceitos de:

- Gestor de Usuário,
- Gestor da Informação, e
- Custodiante da Informação.

4.3 – DIMENSÃO AMBIENTE FÍSICO

=> Implanta e operacionaliza as regras e os controles necessários para o acesso do usuário no ambiente físico que possui recursos de informação.

Para cada ambiente físico deve existir um Gestor de Recursos (Área Física);

4.4 – DIMENSÃO CÓPIA DE SEGURANÇA

=> Implanta e operacionaliza as regras e os controles para a existência de cópias de segurança para a informação da Organização.

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) São considerados os seguintes motivos para a existência de cópias de segurança:

- Recuperação do ambiente.
- Dados Legais.
- Dados Históricos, e
- Dados para a Auditoria (Interna ou Externa).

4.5 – DIMENSÃO CLASSIFICAÇÃO DA INFORMAÇÃO

=> Implanta e operacionaliza as regras e os controles para a existência de níveis de classificação da informação no que diz respeito ao seu sigilo.

Nesta dimensão são definidos os níveis de sigilo que são utilizados nas informações sob responsabilidade da Organização. Exemplo: público, interno, confidencial.

4.6 – DIMENSÃO CONSCIENTIZAÇÃO E TREINAMENTO DO USUÁRIO.

=> Implanta e operacionaliza as regras e os controles para que o usuário seja permanentemente treinado e conscientizado em segurança da informação.

Esta Dimensão tem uma forte interação com a Área de Treinamento (Recursos Humanos) e com a Área de Marketing Interno. É de responsabilidade da Área de RH

operacionalizar e fazer a gestão deste treinamento em segurança da informação.

A jurisprudência no Brasil tem decidido que é necessário a existência de um processo contínuo de treinamento em relação às regras da organização para a

segurança da informação. É aconselhável que cada usuário participe de um treinamento em cada

271

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) período máximo de doze meses. Sem este treinamento periódico a Organização não pode penalizar ações de usuário por descumprimentos destes controles.

4.7 – DIMENSÃO CONTINUIDADE DE NEGÓCIO

=> Implanta e operacionaliza as regras e os controles para garantir que a Organização continuará funcionando em condições mínimas aceitáveis, mesmo quando da ocorrência de uma indisponibilidade da informação. Seja esta indisponibilidade causada por erros de pessoas, ações de má fé, fenômenos da natureza ou similar.

Para a efetividade desta dimensão é necessário a existência do Gestor da Informação para cada informação da Organização. Este Gestor da Informação é responsável para indicar o tempo (desejado) máximo de indisponibilidade da informação quando da ocorrência de uma indisponibilidade, considerando impactos financeiros, impactos de imagem e impactos operacionais.

4.8 – DIMENSÃO DESENVOLVIMENTO APLICATIVO E AQUISIÇÃO DE

PRODUTO.

=> Implanta e operacionaliza as regras e os controles de segurança (obrigatórios ou desejáveis) quando do desenvolvimento de sistemas aplicativos ou quando da aquisição de programa produto.

São definidos os Requisitos de Segurança da Informação que devem ser formalmente atendidos, após a Especificação do Produto/Sistema e antes da Especificação Técnica.

272

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) Na prática, quando esta dimensão não é contemplada adequadamente, estes requisitos de segurança serão analisados após a implantação do sistema ou produto, gerando um custo e um impacto maior.

4.9 – DIMENSÃO RECURSOS TECNOLOGIA - Correio Eletrônico Corporativo.

=> Implanta e operacionaliza as regras e os controles para o uso adequado pelo usuário do serviço Correio Eletrônico Corporativo, com o objetivo de garantir a proteção da informação da Organização.

4.10 – DIMENSÃO RECURSOS TECNOLOGIA - Equipamentos.

=> Implanta e operacionaliza as regras e os controles para o uso adequado pelos usuários dos equipamentos da Organização e de propriedade do usuário, quando da utilização da Infraestrutura Corporativa de Tecnologia da Informação, liberados pela Organização.

Nesta Dimensão são definidos os Programas Produtos e Ferramentas que são homologados para utilizarem o Ambiente de Tecnologia da Informação da

Organização.

4.11 – DIMENSÃO RECURSOS TECNOLOGIA - Uso Internet.

=> Implanta e operacionaliza as regras e os controles para o uso adequado pelos usuários do serviço internet, de maneira a preservar a proteção da informação da Organização.

4.12 – DIMENSÃO RECURSOS TECNOLOGIA - Rede Interna.

=> Implanta e operacionaliza as regras e os controles para o uso adequado pelos usuários da Rede Interna de Tecnologia da Informação.

273

*Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com*

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

4.13 – DIMENSÃO RECURSOS TECNOLOGIA - Redes Sociais.

=> Implanta e operacionaliza regras e os controles para o uso adequado pelos usuários do ambiente de redes sociais, de maneira que a Organização tenha a sua informação protegida.

Esta Dimensão tem uma forte interação com a Área de Recursos Humanos, considerando que serão definidas regras da organização para serem cumpridas pelo usuário no seu ambiente particular de redes sociais.

4.14 – DIMENSÃO DE RISCO EM SEGURANÇA DA INFORMAÇÃO

=> Implanta e operacionaliza as regras e controles para a existência da Gestão de Riscos de Segurança da Informação da Organização.

Esta dimensão facilita a priorização das ações e a continuidade do Programa Organizacional da Segurança da Informação.

5. GOVERNANÇA DA SEGURANÇA INFORMAÇÃO

274

*Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com*



SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

5.1 – GOVERNANÇA CORPORATIVA

A Governança Corporativa da Organização considera como direcionadores:

- a) Transparência das Informações e Decisões,
- b) Equidade com os envolvidos,
- c) Continuidade da Organização (atendimento aos objetivos corporativos),
- d) Conformidade com a legislação.

A Governança Corporativa da Organização segue os controles exigidos pela legislação e pelas boas práticas de Governança Corporativa.

5.2 – GOVERNANÇA DE SEGURANÇA DA INFORMAÇÃO

A Governança da Segurança da Informação está alinhada com a Governança Corporativa da Organização. Este fato se concretiza com o atendimento aos seguintes direcionadores:

275

*Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com*

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) 5.2.1 – Alinhamento ao negócio

A Gestão do Programa Organizacional da Segurança da Informação está orientada para o atendimento aos objetivos de negócio.

5.2.2 – Políticas e demais regulamentos de Segurança da Informação

Existe uma Arquitetura da Política de Segurança da Informação que estrutura a existência e garante a coerência das políticas, normas e procedimentos. Estes regulamentos definem regras e controles que valem para todos os usuários garantindo um tratamento profissional para a proteção da informação.

O Documento Política Corporativa de Segurança da Informação é o elemento que possibilita a implantação das orientações de Governança Corporativa e faz o relacionamento com a Gestão da Segurança da Informação. Este documento é aprovado pela Presidência da Organização em acordo com o Conselho de Administração.

5.2.3 – Avaliação contínua de riscos de segurança da informação

Existe um processo de avaliação periódica e contínua dos riscos de segurança da informação com o objetivo de garantir:

a) Para as ameaças já consideradas

=> Que o tratamento previsto para os controles está efetivo e em melhoria

contínua.

b) Para novas ameaças

=> Identificar que controles já atuam como contra medidas para estas ameaças e identificar novos controles que devem ser implementados.

276

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

**SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes)** Esta avaliação contínua é insumo para o planejamento de ações e priorização destas ações.

5.2.4 – Priorização das ações

É apresentado para a Direção da Organização o planejamento de ações de segurança da informação, garantindo desta maneira o alinhamento das atividades operacionais de Segurança da Informação, com o planejamento estratégico da Organização.

6. GESTÃO DA SEGURANÇA DA INFORMAÇÃO

O objetivo da Segurança da Informação é garantir que a Organização alcance os seus objetivos corporativos no que depende do recurso informação. Para tanto é necessário a existência do Programa Organizacional da Segurança da Informação.

A Gestão da Segurança da Informação garante a execução eficiente e eficaz das atividades previstas para o Programa Organizacional da Segurança da Informação, considerando a prioridade previamente acertada com a direção da Organização.

A Diretoria de Riscos Corporativos é a responsável pela Área da Gestão da Segurança da Informação.

*Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com*

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) 7. PLANEJAMENTO AÇÕES SEGURANÇA DA INFORMAÇÃO

A Área de Segurança da Informação da Diretoria de Riscos Corporativos elabora o planejamento das atividades para o desenvolvimento, implantação e manutenção do Programa Organizacional de Segurança da Informação.

Este planejamento deve:

- contemplar atividades para os próximos 36 (trinta e seis meses),
- ser revisado a cada 06 (seis) meses pela própria Área de Segurança da Informação, e
- aprovado formalmente pela direção da Organização, no máximo em períodos de 12 (doze) meses.

8. CONCLUSÃO

Este documento deve ser revisto periodicamente para estar sempre atualizado de como a Arquitetura do Processo de Segurança da Informação da Organização está definida e implementada.

*Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com*

**SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes) Documento Base para Avaliação Controles de**

Segurança da

Informação (214 Controles)

1. INTRODUÇÃO

Este Documento Base para Avaliação de Controles ou Macrocontroles de Segurança da Informação, é um dos produtos do Projeto de Aprimoramento do Processo Organizacional de Segurança da Informação da Organização, aprovado e apoiado pelo seu Corpo Diretivo.

Esta etapa consiste na Avaliação da Maturidade dos Controles e Macrocontroles de Segurança da Informação. Ela é composta por dois documentos, descritos na proposta de trabalho e formalizados no contrato assinado:

- *Documento Base para Avaliação de Controles ou Macrocontroles de Segurança da Informação.*

- *Documento Final Avaliação da Maturidade dos Controles ou Macrocontroles de Segurança da Informação.*

Os controles e macrocontroles aqui descritos neste primeiro documento, podem ser agrupados ou mais detalhados quando da ação da avaliação e da geração do trabalho a ser registrado no segundo documento.

Edison Fontes, CISM, CISA, CRISC, Ms.

Consultor Gestão Segurança Informação

edison@pobox.com

(Edison Fontes)

2. OBJETIVO DESTE DOCUMENTO

Apresentar os Controles ou Macrocontroles que, inicialmente, serão considerados na avaliação do nível de Maturidade da Gestão da Segurança da Informação da Organização.

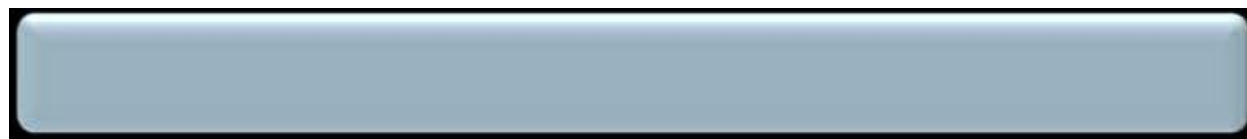
3. ESCOPO

A abrangência dos controles e macrocontroles de segurança da informação identificados e definidos neste documento, toma por base o Documento Arquitetura da Segurança da Informação – Processo Organizacional da Segurança da Informação.

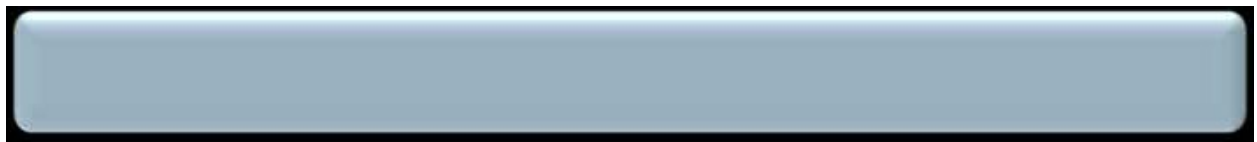
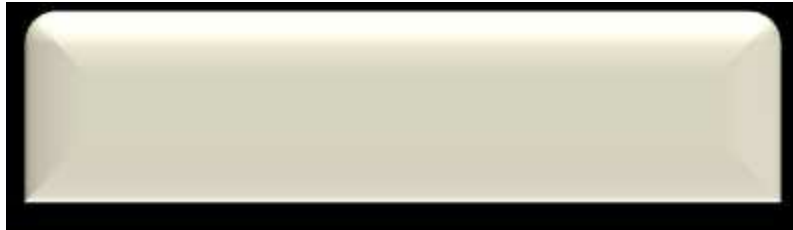
O Processo Organizacional de Segurança da Informação descrito na Arquitetura de Segurança da Informação, considera as seguintes dimensões apresentadas na figura abaixo, que serão a base para os controles e macrocontroles básicos considerados para a avaliação de maturidade.

280

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***







SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes)

POLÍTICAS DE SEGURANÇA DA INFORMAÇÃO

o

óci

Acesso à Informação

Classificação da Informação

Proteção técnica

g

Recursos de informação

ne

de

s

s

co

a

s

r

i

g

r

er

Flexibilidade

Desenvolvimento de aplicativos

Conscientização e Treinamento

de

e

Operacional

o

o

ãt

ça

s

a

Ge

ntema

Continuidade do negócio

ul

Tratamento de

Modelo operativo

ge

incidentes de segurança

da SI

R

Ambiente

Cópias de segurança

Físico e infra-estrutura

8

Fonte: Livro Praticando a segurança da informação, Edison Fontes, Editora BRASPORT, 2008. Página 48.

Estrutura baseada na Norma Internacional ISO/IEC 27002.

4. CONTROLES E MACROCONTROLES INICIAIS

Descrevemos abaixo os Controles e Macrocontroles básicos para a avaliação de maturidade da organização em relação à Gestão da Segurança da Informação.

Chamamos de controles e macrocontroles básicos, porque durante o processo de levantamento de informações para a avaliação do nível de maturidade da Gestão da Segurança da Informação, podemos identificar a necessidade de novos controles, ou detalhamento ou concentração de controles (granularidade dos controles).

Os controles e macrocontroles aqui descritos estão respaldados em regulamentos organização existentes ou previstos, normativos internacionais, direcionadores

281

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) obrigatórios para a organização (legislação, regulamentos setoriais, similar) e experiência do consultor.

Uma avaliação de maturidade considera diversos parâmetros, ambiente da Organização, pessoal envolvido e não exige respostas binárias (sim/não). Um dos seus objetivos é permitir a elaboração de um planejamento de ações. Outro objetivo é apresentar de uma maneira simples para o Corpo Diretivo da organização como se encontra a efetividade da Gestão da Segurança da Informação.

A seguir detalhamos, separando pelas Dimensões da Segurança da Informação, os controles e macrocontroles a serem avaliados.

4.1. Arquitetura da Segurança da Informação.

4.1.1. Existência de uma arquitetura de segurança da informação baseada em estruturas formais.

4.1.2. Identificação e consideração de direcionadores obrigatórios, considerando o tipo e negócio da Organização.

4.1.3. Formalização da arquitetura e dos direcionadores obrigatórios. Apresentação para o primeiro nível hierárquico executivo.

4.1.4. Garantia de que a arquitetura de segurança da informação é seguida e se mantém atualizada. Revisão a cada período de 12 meses.

4.1.5. Responsabilidade definida pela definição da arquitetura de segurança da informação.

4.1.6. Apresentação para o Corpo Diretivo e para as demais áreas relacionadas com controle da informação.

282

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) 4.2. Área de Gestão da Segurança da informação.

4.2.1. Existência de área organizacional formal com a responsabilidade do Processo Organizacional de Segurança da Informação.

4.2.2. Definição formal, aprovada pelo Corpo Diretivo, das funções, responsabilidades, escopo de atuação, estrutura de recursos e poder de controles.

4.2.3. Conhecimento por todos, ou pela grande maioria dos usuários colaboradores da existência da Área de Segurança da Informação.

4.2.4. Área de Segurança da Informação possui autonomia adequada, inclusive não subordinada à Área de Tecnologia da Informação.

4.2.5. Considera formalmente a legislação que direta ou indiretamente afeta o controle da informação. Garantia de atualização em relação à legislação e normativos setoriais.

4.2.6. Existência de um plano de ação para os próximos 36 meses, considerando revisão periódica formal a cada 12 meses.

4.2.7. Plano de ação deve ser validado formalmente pelo Corpo Diretivo.

Normalmente a segurança da informação afeta as demais áreas e é positivo que as demais áreas envolvidas com controle da informação conheçam este plano de maneira gerencial.

4.2.8. Existência de monitoramento do Nível de Maturidade da Gestão da Segurança da Informação. Identificar como acontece.

4.2.9. Nível de Maturidade de Segurança da Informação deve ser apresentado de maneira executiva para o Corpo Diretivo da Organização. Em intervalos máximos de 12 meses.

4.2.10. Revisão periódica do Nível de Maturidade da Gestão da Segurança da Informação. Em intervalos máximos de 12 meses.

4.2.11. Envolvimento da Área de Segurança da Informação quando do planejamento de ações de negócio, tipo no nível tático. Objetivo: antecipar questões de controle da informação.

4.2.12. Executivo da Segurança da Informação participa de comitê (ou equivalente) que analisa os requisitos necessários para a implementação dos futuros produtos e serviços da Organização.

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA

(Edison Fontes) 4.2.13. É garantida a Governança da Segurança da Informação. Acontece com a comunicação para as áreas da Organização e para o Corpo Diretivo: Maturidade em Segurança da Informação, controles existentes, planejamento, ocorrências, fragilidades e similar. Evidentemente considerando o nível de sigilo de cada destinatário da informação.

4.2.14. Existe um profissional Gestor da Segurança da Informação.

4.3. Política e demais regulamentos de Segurança da Informação.

4.3.1. Existência de uma Arquitetura de Regulamentos de Segurança da Informação.

Formal e divulgada.

4.3.2. Existência de uma Política Principal de Segurança da Informação, contendo diretrizes, macrocontroles e principais responsabilidades.

4.3.3. Áreas diretamente afetadas pela Política Principal de Segurança da Informação, participaram de uma revisão/validação da mesma.

4.3.4. Política Principal de Segurança da Informação: aprovada pelo Presidente, Conselho de Administração ou elemento executivo equivalente.

4.3.5. Política Principal de Segurança da Informação é comunicada a todos os usuários corporativos. Ela está de fácil acesso pelos usuários.

4.3.6. Política Principal de Segurança da Informação descreve os objetivos, escopo e responsabilidades pelo Processo Organizacional de Segurança da Informação.

4.3.7. Política Principal de Segurança da Informação possui a amplitude adequada.

Analisar garantia de sustentabilidade.

4.3.8. Existência de regulamentos tipo normas, considerando os principais

assuntos de segurança da informação. Pelo menos:

- *Acesso à Informação.*
- *Ambiente Físico da Informação.*
- *Carta de Não Conformidade.*
- *Cópia de Segurança.*
- *Classificação Informação.*

284

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

**SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes)**

- *Conscientização e Treinamento de Usuário.*
- *Continuidade de Negócio.*
- *Controles básicos de segurança para o desenvolvimento, manutenção, aquisição de aplicativo ou aquisição Programas Produtos.*
- *Correio Eletrônico Corporativo.*
- *Custodiante, Gestor da Informação e Gestor do Usuário.*
- *Dados Pessoais.*
- *Equipamentos.*
- *Flexibilidade Operacional: Gestão de Mudanças, Gestão de Problemas, Gestão de Incidentes, Gestão de Capacidade.*

- *Uso Internet.*
- *Rede Interna de acesso ao ambiente de tecnologia*
- *Redes Sociais Públicas.*
- *Redes Sociais Corporativas.*
- *Riscos de Segurança da Informação.*
- *Termo de Responsabilidade de Uso da Informação.*
- *Termos Utilizados nos regulamentos de Segurança da Informação.*

4.4. Acesso a Informação

4.4.1. Indicação e formalização de Gestor da Informação. Possibilita auditoria.

4.4.2. O Gestor da Informação revisa e valida periodicamente os usuários com autorização de acesso às informações ou recursos de informação, sob responsabilidade do gestor. Participa do processo de aprovação de cada acesso à informação.

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA

(Edison Fontes) 4.4.3. Todas as informações ou recursos de informações estão identificados e mapeados com o seu respectivo gestor. Considerar pastas do ambiente de TI e arquivos no ambiente convencional.

4.4.4. Indicação e formalização de Gestor de Usuário. Possibilita auditoria.

4.4.5. O Gestor do Usuário revisa e valida periodicamente os usuários sob sua

responsabilidade, garantindo que eles estão válidos para a Organização.

4.4.6. Todos os processos de autorização e validação do Gestor da Informação ou Gestor do Usuário são registrados, geram evidências e permitem auditoria.

4.4.7. Indicação e formalização de Custodiante da Informação. Possibilita auditoria.

4.4.8. Identificação de usuário individual é intransferível.

4.4.9. Identificações coletivas estão identificadas e gerenciadas.

4.4.10. Identificações de elementos tecnológicos automáticos, tipo programas produto, estão identificadas e possuem um responsável para monitorar.

4.4.11. A cadeia de caracteres que formam a identificação do usuário possibilita fazer a ligação com os dados complementares e descritivos do usuário.

4.4.12. Quando a autenticação é feita através de senha, essa senha é secreta e de conhecimento exclusivamente do usuário. Verificar processo de entrega de senha.

4.4.13. Usuário tipo prestador de serviço ou equivalente possui identificação com tempo de validade. Se sim, avaliar tempo e responsabilidades para a gestão. Verificar efetividade do processo.

4.4.14. Possibilidade de consulta ou listagem dos usuários atuais dos ambientes de informação. Tempo imediato.

4.4.15. Declaração nos regulamentos (ou equivalente) que o usuário é responsável pelo acesso realizado com a sua identificação e autenticação.

4.4.16. Todo acesso realizado ou tentativa de acesso ao/no ambiente computacional é gravado e guardado durante um tempo previamente definido.

4.4.17. O tempo de guarda do registro de acesso a informação foi validado

e/ou aprovado pela área de negócio, jurídico, TI e segurança.

4.4.18. O processo de liberação de acesso da informação para o usuário é formalizado e registrado permitindo auditoria.

286

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

**SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes)**

4.4.19. Quando o usuário muda de função ou de área organizacional, existe um processo formal para as devidas alterações de acesso à informação. Corte dos antigos acessos e inclusão de novos acessos. Existe SLA acordado com áreas envolvidas. Tempo de SLA compatível com o negócio: criticidade e sigilo.

4.4.20. Quando o usuário deixa de ter relacionamento profissional com a Organização seus acessos ao ambiente ou recursos de informação são bloqueados.

Analisar o tempo em que isto acontece. Podemos garantir com razoável grau de certeza que os usuários atuais estão corretos.

4.4.21. As definições de regras de identificação de usuário são cumpridas em todas as plataformas e ambientes de informação.

4.4.22. As regras mínimas de senha são cumpridas em todas as plataformas e ambientes de tecnologia da informação. Existe definido regras mínimas para uso senha.

4.4.23. As regras mínimas de uso de senha definem tamanho mínimo, composição dos caracteres, bloqueio por tentativas incorretas, outros tipos de bloqueio, procedimentos para pedido de nova senha.

4.4.24. A rigidez da autenticação (senha, biometria outros) é definido ou validado com as áreas de negócio, jurídico, riscos corporativos, TI, segurança

da informação ou equivalentes.

4.4.25. Quando do uso de senhas, o arquivo de senhas é criptografado. A transmissão de senhas também é criptografada.

4.4.26. Existe uma política para a definição de uso (ou não) de criptografia quando do armazenamento, apresentação e transmissão de dados.

4.4.27. Quando do uso de criptografia foi considerado a situação de perda de chaves e o impacto dessa situação.

4.4.28. Quando do uso de criptografia no ambiente computacional principal da Organização foi definido a forma de guarda das chaves.

4.4.29. Quando existe tratamento de dados da Organização por parte de prestadores de serviço é garantido que esses terceiros possuem o mesmo nível de proteção da Organização. Validar como é feita esta garantia.

4.4.30. Existência de inteligência para a análise de uso da informação. Existência de padrões comuns de acesso, permitindo identificação de comportamento fora da curva pelos usuários.

**SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes)** 4.4.31. Existe normativo específico para acesso a informação.

4.4.32. É considerada a questão da segregação de função e está garantido que este controle está implementado.

4.5. Ambiente Físico da Informação ou Recursos de Informação.

4.5.1. Existe regulamento específico para controles no Ambiente Físico da Informação ou Recursos de Informação.

- 4.5.2. Os usuários são identificados individualmente.
- 4.5.3. Os crachás temporários (curto ou médio prazo), permitem identificar os acessos aos ambientes físicos.
- 4.5.4. Existe formalizado o Gestor do Recurso Informação Ambiente Físico. Todos os ambientes físicos possuem identificados os seus gestores.
- 4.5.5. Existe revisão periódica pelo Gestor de Ambiente, dos usuários autorizados a acessar o ambiente físico.
- 4.5.6. O monitoramento de imagem e registro de catracas ou equivalente são guardados pelo menos por seis meses.
- 4.5.7. Existe um processo formalizado para a inclusão e exclusão de usuários no ambiente físico. Processo que gera evidências e permite auditoria.
- 4.5.8. Existência de regra para o uso do crachá em local visível.
- 4.5.9. Usuário colaborador quando deixa de ter relacionamento profissional com a Organização tem seu acesso bloqueado. Existe SLA acordado entre as áreas envolvidas. SLA está compatível com o tipo de negócio da Organização: sigilo e criticidade.
- 4.5.10. Apenas pessoas autorizadas tem acesso ao ambiente físico da informação.
- 4.5.11. Existe interação com a segurança patrimonial do prédio para a efetividade dos controles de ambiente físico.
- 4.5.12. Facilidade para consulta ou emissão de listagem das pessoas autorizadas a acessar os diversos ambientes físico.

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

4.5.13. Existe formalizado os ambientes físicos que possuem maior grau de rigidez de controle. Esta classificação foi validada pelos gestores de informação ou recursos de informação e com o Custodiante da Informação.

4.5.14. O registro de acesso físico e a gravação de imagens possuem rígido controle de acesso às mesmas. Considera a proteção de dados pessoais.

4.5.15. O controle de acesso aos ambientes físico de informação gera evidências e guardam registros que possibilitam uma auditoria, tanto em relação ao acesso físico quanto em relação à gestão do acesso físico.

4.5.16. Os Visitantes são registrados mesmo de maneira macro (edifício). Este controle pode ser auditado. É guardado por um tempo mínimo de seis meses.

4.5.17. As pessoas são avisadas que as imagens dos ambientes são gravadas.

4.5.18. As pessoas são treinadas em simulações de abandono de ambiente físico.

4.5.19. São considerados os ambientes físicos dos prestadores de serviço que possuem áreas que podem ser acessadas por usuários colaboradores da

Organização.

4.5.20. Existem procedimentos formalizados detalhando as regras para acesso a cada ambiente físico.

4.6. Cópias de Segurança.

4.6.1. Existe regulamento específico para cópias de segurança da informação.

Contempla ambiente de tecnologia e ambiente convencional.

4.6.2. As cópias de segurança são validadas em relação à periodicidade, ciclo e granularidade pelo Gestor da Informação. A Área Jurídica é envolvida no processo, seja pelo Gestor da Informação ou pela Área de Segurança da

Informação.

4.6.3. Foram considerados os aspectos que geram necessidade de cópias de segurança: recuperação do ambiente, dados históricos, aspectos legais e questões de auditoria.

4.6.4. Existe a garantia, com realização de testes ou procedimentos equivalentes, de que as cópias de segurança da informação estão integras, disponíveis e correspondem ao ciclo/periodicidade/granularidade.

289

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA

(Edison Fontes) 4.6.5. Existem cópias em poder de prestadores de serviços e esta responsabilidade de validação item anterior está adequadamente garantida.

4.6.6. O ambiente físico das cópias de segurança é adequado em relação à sua proteção. Cada ambiente tem a proteção adequada.

4.6.7. Está identificado para todos os ambientes de tecnologia e para os ambientes convencional a existência de cópias de segurança ou, se não, existe a garantia de que a não existência está definida pelo Gestor da Informação ou por alguma outra maneira.

4.6.8. Ambiente de usuário. Se o usuário necessita realizar algo para a existência de cópias de segurança, ele está ciente e é treinado para tal. Existem evidências desse treinamento ou orientação. Possibilita auditoria.

4.7. Classificação da Informação

4.7.1. Existe um regulamento específico para a classificação da informação.

4.7.2. A Informação pode ser classificada em relação ao sigilo, criticidade e dado pessoal.

4.7.3. Está definido que o Gestor da Informação é responsável pela classificação da informação, com apoio da Área de Segurança da Informação.

4.7.4. Quando da classificação por sigilo está definido como deve ser o tratamento do recurso informação quando em papel ou no ambiente de tecnologia. São considerados o tratamento: armazenamento, destruição, transmissão, posse com prestador de serviço, uso de criptografia, e outras situações.

4.7.5. Está considerada a informação estruturada e informação não estruturada.

4.7.6. Existe a obrigatoriedade para a classificação da informação quando do desenvolvimento ou aquisição de sistemas de informação.

4.7.7. Existe um plano de ação para a classificação das informações dos sistemas legados.

4.7.8. A Classificação da Informação é um item do treinamento de usuários. Está claro para os usuários, principalmente em relação à classificação por sigilo, os níveis de classificação.

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) 4.8. Conscientização e Treinamento

4.8.1. Existe um regulamento específico sobre conscientização e treinamento em segurança da informação.

4.8.2. Todos os usuários tipo colaborador são treinados em segurança da informação periodicamente, a cada período máximo de 12 meses.

4.8.3. A Segurança da Informação é um dos assuntos do processo de ingresso

do usuário no seu relacionamento profissional com a Organização.

4.8.4. Existe um planejamento das ações de treinamento e conscientização em segurança da informação. Planejamento para 36 meses. Garantia de continuidade e sustentabilidade.

4.8.5. São enviadas mensagens, ou equivalentes, para a conscientização e lembrança dos principais controles de segurança da informação. Tipo semanal ou mensal. São guardadas as evidências destas ações. Permite auditoria.

4.8.6. Todo tipo de usuário tem o seu treinamento em segurança da informação, mesmo com formatos diferentes. Adequado ao tipo de usuário.

4.8.7. Existe nos contratos com os usuários referência a cláusulas de confidencialidade da informação.

4.8.8. Todos os usuários colaboradores assinam um Termo de Responsabilidade de Uso da Informação.

4.8.9. A Área de Recursos Humanos é responsável pela operacionalização do treinamento e conscientização em segurança da informação, coordenada pela Área de Segurança da Informação. Verificar este relacionamento e responsabilidades.

4.8.10. Os treinamentos e conscientização em segurança da informação geram evidências permitindo a auditoria deste processo. Também permite garantir de que o usuário está ciente das suas obrigações. Em questões levadas à justiça.

4.8.11. Os assuntos considerados no treinamento e conscientização de segurança da informação, cobrem ao longo do tempo, os principais controles relacionados aos usuários. Tipo: dado pessoal e uso de recursos da Organização.

4.8.12. Existe documentação tipo cartilha, folhetos que facilitam a consulta dos usuários em relação aos controles de segurança da informação tratados no dia a dia.

*Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com*

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) 4.9. Continuidade de Negócio

- 4.9.1. Existe regulamento específico sobre Continuidade de Negócio.
- 4.9.2. Existe um plano ou planos de continuidade de negócio para a continuidade da operação da Organização quando da indisponibilidade da informação.
- 4.9.3. Existe um mapeamento dos ambientes de informação para a existência de planos de continuidade de negócio para cada um desses ambientes.
- 4.9.4. Os Gestores da Informação foram considerados para a definição do tempo máximo de indisponibilidade.
- 4.9.5. O tempo máximo de indisponibilidade foi definido pelos gestores da informação, contratos ou legislação. Esta opção foi validada com o Corpo Diretivo da Organização. Existe esta formalização.
- 4.9.6. O levantamento para a identificação dos tempos máximos de indisponibilidade dos ambientes está formalizado e permite auditoria.
- 4.9.7. A Gestão de Riscos de Segurança da Informação considera ameaças que podem impedir utilização da informação. O combate à estas ameaças são consideradas no planejamento da Organização pela Área de Segurança da Informação.
- 4.9.8. A solução adotada para cada plano de continuidade de negócio foi validada pelo Corpo Diretivo da Organização. Formalizado e possibilita auditoria. Ou controle equivalente..
- 4.9.9. O Escopo e Cenário de cada Plano de Continuidade estão definidos.

4.9.10. Existe o planejamento de aprimoramento (aumento da dificuldade) do Escopo e Cenário, para as situações de indisponibilidade e consequentemente para os planos de continuidade de negócio. Próximos 36 meses.

4.9.11. Para cada Plano de Continuidade de Negócio existe um manual atualizado que define os procedimentos a serem feitos quando da ocorrência de uma situação de contingência. Teste de mesa, teste real ou simulação.

4.9.12. Existe a garantia de que cada Manual de Plano de Continuidade de Negócio está atualizado. Seja pela revisão periódica a cada 12 meses, seja quando atualizações pontuais.

4.9.13. As pessoas envolvidas em cada Plano de Continuidade de Negócio foram treinadas ou realizaram simulações. Formalizado e gera evidências.

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA

(Edison Fontes) 4.9.14. O treino ou simulação mais recente para cada Plano de Continuidade de Negócio aconteceu nos recentes doze meses.

4.9.15. Existe um Plano de Teste formalizado para cada teste ou simulação de ativação de cada Plano de Continuidade de Negócio. Cada teste é planejado adequadamente e contém no mínimo descrito o objetivo, o escopo, os participantes, a responsabilidade dos participantes, o planejamento das ações, o tempo previsto das ações, o tempo real das ações ao longo do teste e registro das ocorrências do teste.

4.9.16. O Corpo Diretivo da Organização autoriza formalmente a realização de cada teste ou simulação.

4.9.17. Existe um planejamento de teste de planos de continuidade de negócio para os próximos 36 meses.

4.9.18. Os teste e simulações são realizados dentro do planejado.

4.9.19. Após cada teste é emitido pela Área de Segurança da Informação um Documento de Registro de Teste/Simulação contendo o que aconteceu certo, com problema, lições aprendidas e ações de correção.

4.9.20. Os testes realizados contam com um observador, mesmo interno da Organização, que apenas assiste ao que está acontecendo. Uma visão mais independente.

4.9.21. O Corpo Diretivo da Organização está ciente dos ambientes e situações cobertas por Planos de Continuidade de Negócio. Este registro está formalizado, permitindo auditoria ou resposta a qualquer outro questionamento.

4.9.22. O Corpo Diretivo da Organização recebe periodicamente, a cada período máximo de 12 meses, um relatório executivo sobre a efetividade dos planos existentes, considerando os testes, seus resultados e o escopo considerado. Bem como, cenários.

4.10. Desenvolvimento, manutenção, aquisição aplicativo ou aquisição de programa produto.

4.10.1. Existe um regulamento específico sobre este tema.

4.10.2. Existe uma metodologia de desenvolvimento de sistemas e essa metodologia é de conhecimento de todos os desenvolvedores (funcionários e terceiros) envolvidos com o tema.

da informação antes do desenho lógico da solução.

4.10.4. A Área de Segurança da Informação participa de alguma fase quando do desenvolvimento ou aquisição de aplicativo, ou aquisição de programa produto relacionado ao uso da informação.

4.10.5. A documentação exigida pela metodologia de desenvolvimento de sistemas é suficiente para que outro profissional com mesmo conhecimento técnico possa substituir um desenvolvedor de sistemas.

4.10.6. Cada desenvolvedor de sistemas tem acesso apenas aos programas e outros elementos que são necessários para o desempenho das suas funções profissionais na Organização. Verificar acesso de prestadores de serviço.

4.10.7. Cada novo desenvolvedor que começar a trabalhar para a Organização, seja como funcionário ou seja como prestador de serviço, recebe treinamento sobre os padrões e forma de trabalhar da Organização.

4.10.8. Existe um efetivo controle de versão para os programas e outros elementos construídos pelos desenvolvedores garantindo a integridade e o versionamento correto dos mesmos durante o processo de desenvolvimento.

4.10.9. Existem pelo menos três ambientes computacionais: de desenvolvimento, de teste e de produção. Ambientes são segregados. Verificar rigidez da garantia de segregação de ambiente.

4.10.10. O ambiente de produção não é acessado pelos usuários desenvolvedores para realizar atividades de desenvolvimento, teste ou similar. Situações de exceção são registradas e aprovadas pelo diretor da área.

4.10.11. Quando da correção de sistemas aplicativos, sempre se faz a alteração e teste no ambiente não produção e somente após essa etapa é passada a nova versão para o ambiente de produção. Exceto emergência que é documentada e registrada. Possível de auditoria.

4.10.12. Quando em situações de exceção for necessário a alteração diretamente no ambiente de produção, existe um processo que exige uma autorização específica e possibilita a realização de auditoria.

4.10.13. Os dados para a realização de testes são realizados com dados criados para o teste ou com dados mascarados do ambiente de produção. Verificar participação e validação do gestor da Informação.

294

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

**SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes)**

4.10.14. Existe controle de acesso ao ambiente de desenvolvimento. Os acessos são registrados e guardados por tempo definido previamente.

4.10.15. Apenas usuários validos estão cadastrados. Quando um usuário encerra as atividades profissionais é bloqueado. Existe SLA. SLA compatível com a criticidade e sigilo do ambiente e sistemas.

4.10.16. Os controles básicos de segurança da informação são considerados quando do desenvolvimento/manutenção de sistemas ou aquisição de programas produto.

4.10.17. Existem cópias de segurança suficientes para recuperação do ambiente de desenvolvimento de sistemas. Validado pelo Gestor da Informação.

4.10.18. Existe definido e acordado o nível de disponibilidade do ambiente computacional de desenvolvimento de sistemas. Internamente e com prestadores de serviço em desenvolvimento. Verificar como acontece o trabalho destes desenvolvedores.

4.10.19. Existe a função interna ou externa de testes de sistemas ou produtos. Esta função elabora plano de testes e controles necessários para a adequada garantia dos testes.

4.10.20. O resultado destes testes é considerado no processo de gestão de Mudanças, quando da implantação de elementos no ambiente de produção.

4.11. Gestão de Mudanças

4.11.1. Existe formalizado o Processo de Gestão de Mudanças.

4.11.2. Existe regulamento específico sobre Gestão de Mudanças.

4.11.3. A Área de Segurança da Informação participa das reuniões de Gestão de Mudanças com o objetivo de garantir que os aspectos de segurança da informação foram considerados.

4.11.4. São emitidos relatórios gerenciais sobre o andamento das mudanças acontecidas no ambiente de informação.

4.11.5. Existem prazos e regras para mudanças e situações de emergência e os respectivos níveis de autorização.

4.11.6. Existem requisitos obrigatórios para que aconteça uma mudança no ambiente de informação, inclusive: risco, opção de retorno, ok nos testes realizados e similar.

295

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes) Não atendimento destes requisitos pode impedir a implantação no ambiente de informação. Existe a autonomia dos atores da Gestão de Mudança.

4.11.7. As mudanças são acompanhadas até 15 dias após a sua implantação para garantir que houve sucesso, insucesso ou sucesso parcial.

14.11.8. Mudanças com insucesso geram novas mudanças com nível de risco maior.

14.11.9. Existem relatórios periódicos, gerenciais, consolidando os resultados das mudanças (normais, emergenciais, sucesso, falhas, outras situações) para

o ambiente de produção.

14.11.10. Para mudanças emergenciais existe uma autorização de executivo da área.

4.12. Gestão de Incidentes de Informação

4.12.1. Existe formalizado o Processo de Gestão de Incidentes.

4.12.2. Existe regulamento específico sobre Gestão de Incidentes.

4.12.3. A Área de Segurança da Informação recebe informações sobre incidentes relacionados à informação: indisponibilidade, vazamento, perda de integridade, roubo, acesso indevido, tentativa de acesso indevido, perda da informação e situações similares.

4.12.4. Existe um Sistema Produto que controla e facilita a Gestão de Incidentes.

4.12.5. Existem relatórios gerenciais e executivos para posicionar o Corpo Diretivo sobre os impactos no negócio em função de incidentes no ambiente de informação.

4.12.6. Para cada incidente existe a avaliação se o mesmo é uma situação pontual ou vai gerar um elemento na Gestão de Problemas que, normalmente, exige um estudo mais aprofundado e uma solução mais estruturada.

4.12.7. A Gestão de Incidentes já contempla incidentes com Dados Pessoais, que pode exigir a comunicação com o mercado, clientes e com a Autoridade Nacional de Proteção de Dados Pessoais.

4.12.8. A Gestão de Incidentes contempla o ambiente de tecnologia e o ambiente convencional.

4.12.9. Utilizando canal de comunicação, o usuário colaborador pode reportar um incidente de segurança. Verificar comunicação anônima. Ver relacionamento com área de conformidade e combate à fraude.

**SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes)**

4.12.10. A Área de Segurança da Informação considera os incidentes de informação para subsídio para o seu planejamento de ações para os próximos 36 meses.

4.12.11. Existe uma integração da gestão de incidentes de segurança da informação com o processo de gestão de problemas.

4.12.12. Existe definida a responsabilidade pelo tratamento de incidentes de tecnologia, de informação convencional, de pessoas e outros tipos.

4.13. Gestão de Problemas de informação

4.13.1. Existe formalizado o Processo de Gestão de Problemas.

4.13.2. Existe regulamento específico sobre Gestão de Problemas.

4.13.3. A Área de Segurança da Informação recebe informações sobre problemas relacionados à informação. Podem ser originados de incidentes ou não.

4.13.4. Existe um Sistema Produto que controla e facilita a Gestão de Problemas.

4.13.5. Existem relatórios gerenciais e executivos para posicionar o Corpo Diretivo sobre os impactos no negócio em função de problemas no ambiente de informação.

4.13.6. Existe uma integração da gestão de incidentes de segurança da informação com o processo de gestão de problemas?

4.14. Gestão de Riscos de Segurança da Informação.

4.14.1. Existe um regulamento específico para este assunto.

4.14.2. Existe um processo de gestão de Riscos de Segurança da Informação que faz parte do Processo organizacional de Segurança da Informação.

4.14.3. A avaliação de ameaças e riscos para a segurança da informação é realizada a cada período máximo de 12 meses.

4.14.4. É emitido um relatório completo da avaliação de riscos de S.I.

4.14.5. É elaborado um documento executivo para o Corpo Diretivo da Organização, posicionando o mesmo sobre a Maturidade em Segurança da Informação,

considerando a avaliação de riscos realizada.

297

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

**SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes)** 4.14.6. As avaliações de riscos de segurança da informação são base para o planejamento de ações para definição e implantação de controles de segurança da informação.

4.14.7. Para cada avaliação de risco, são contextualizados:

- Escopo => recursos que serão considerados.
- Objetivo => objetivo da análise e avaliação.
- Critérios básicos => tabelas ou valores a serem considerados.
- Ameaças identificadas e ameaças tratadas.

4.14.8. Para cada resultado de avaliação de riscos deve ser explicitado o tratamento do risco:

=> Minimizar (novos controles)

=> Aceitar

=> Evitar

=> Transferir

4.14.9. A Gestão de Riscos de Segurança da Informação está em conformidade com os pontos apresentados pela Gestão de Riscos Corporativos.

4.4.10. A Área de Segurança da Informação é responsável pelo processo de Gestão de Riscos de Segurança da Informação.

4.15. Recursos Tecnologia

4.15.1. Existem normativos específicos para Correio Eletrônico Corporativo, Equipamentos, Uso Internet, Controles para acesso rede interna, Uso de Redes Sociais Públicas.

4.15.2. As regras e controles definidos nos normativos acima descritos são cumpridos e tem garantida a sua continuidade.

298

*Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com*

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) 4.15.3. Os controles relacionados aos equipamentos de uso direto pelos usuários definem controles de uso de periféricos, responsabilidades pelo uso de equipamentos, registro de ações que permitem auditoria.

4.15.4. A entrega de equipamentos para uso pelos usuários colaboradores é formalizada por documento.

4.15.5. Os usuários são treinados e conscientizados nestes controles que afetam mais diretamente os mesmos.

4.15.6. O uso destes recursos ou serviços de tecnologia permitem o registro de uso e possibilitam que as ações dos usuários sejam auditadas.

4.15.7. O uso destes recursos ou serviços são monitorados pela Organização com o objetivo de identificar se os usuários estão em conformidade com os controles estabelecidos.

4.15.8. Para situações não previstas o usuário colaborador possui um canal de comunicação para apresentar as mesmas.

4.15.9. A Área de Segurança da Informação está atenta para as novas tecnologias ou novos serviços, que devem ser sempre contemplados para a definição de controles de segurança da informação a serem seguidos pelos usuários.

4.15.10. Existem regras sobre a utilização de recursos particulares do usuário colaborador, acessando serviços de tecnologia.

4.16. Situações de Não Conformidade

4.16.1. Existe regulamento considerando situações de não conformidade e que o Corpo Diretivo aprovará.

4.16.2. Em situações de Não Conformidade será gerada uma Carta de Não Conformidade que é aprovada pelo nível hierárquico definido no Regulamento de Não Conformidade.

4.16.3 Uma situação de não conformidade pode durar no máximo durante 12 meses.

Após este período é obrigatório a renovação da Não Conformidade.

4.16.4. A Área de Segurança da Informação é responsável pela Gestão de Não Conformidades. Todas as Cartas de Não Conformidade são validadas pela Área de Segurança da Informação que emitirá seu parecer sobre os riscos. Depois ela será aprovada ou não pelo Corpo Diretivo.

4.17.1. Existe um regulamento sobre dados pessoais em conformidade com a Lei Brasileira de Proteção de Dados Pessoais.

4.17.2. A coleta dos dados pessoais é autorizada por cada pessoa natural proprietária dos seus dados pessoais ou está autorizado pelas situações específicas descritas na lei.

4.17.3. OS dados pessoais são utilizados exclusivamente para o seu objeto de contrato entre a Organização e a pessoa natural. Finalidade específica. Qualquer necessidade de outra utilização, será solicitada a autorização do usuário.

4.17.4. Após o encerramento de relação contratual ou relação de informação, os dados pessoais da pessoa natural serão apagados. Respeitando eventual outra legislação, tipo registros fiscais ou de órgãos setoriais.

4.17.5. Existe o Encarregado de Dados Pessoais da Organização, conforme exigido pela lei.

4.17.6. Quando da ocorrência de incidentes com dados pessoais, a Organização comunicará à Agência Nacional de Proteção de Dados. Dependendo do tipo de incidente, também comunicará ao mercado e aos clientes.

4.17.7. A Organização sempre responderá a pessoa natural que questionar quais são dados a Organização possui sobre esta pessoa. Livre acesso da pessoa natural às suas informações.

4.17.8. Sempre que possível a Organização realizará a anonimização de dados pessoais.

4.17.9. A Organização manterá criptografados os dados pessoais quando armazenados ou transmitidos, com o objetivo de minimizar o risco da ameaça de vazamento destes dados.

14.17.10. A Organização coleta apenas e exclusivamente os dados pessoais necessários para o seu relacionamento de prestação de serviço com a pessoa natural.

14.17.11. A Organização é responsável pela confidencialidade dos dados pessoais sob sua responsabilidade, mesmo que repasse os mesmos para

parceiros que realizam a prestação de serviços da Organização.

300

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

**SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes)** 14.17.12. A Organização não disponibiliza os dados pessoais sob sua

responsabilidade para outras organizações que não estejam na cadeia de prestação de serviços que a Organização presta para a pessoa natural.

5. PARÂMETROS PARA A AVALIAÇÃO

A avaliação de maturidade tem o propósito de auxiliar o planejamento de ações e apresentar para o Corpo Diretivo da Organização uma visão executiva e objetiva de como está a efetividade da Gestão da Segurança da Informação.

Os controles e macrocontroles apresentados acima deverão sofrer junções ou detalhamento dependendo da situação da Organização. Por exemplo: se a Organização não tiver um determinado controle, de nada adianta o detalhamento acima. Porém, também entendemos que na medida que vamos explorando os controles reais existentes (formais ou não formais), podemos caminhar por novos questionamentos ou questionamentos de maior granularidade. Um possível tipo de avaliação da maturidade dos controles, pode ser:

- Inadequados. Necessário implementação total/quase total. O que existe não atende.
- Parcialmente adequados. Necessário melhorias. Não compatível com a Organização.
- Adequados. Necessário garantir a manutenção do controle. Avaliar

melhorias.

Também poderemos apresentar uma avaliação em escala decimal, ou as duas formas de apresentação.

O importante é que o Nível de Maturidade seja entendido e utilizado.

301

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) 6. CONCLUSÃO

Recomendamos que este documento seja revisto a cada período máximo de 12

(doze) meses ou quando de novos controles ou adaptação de controles. Ele deve estar sempre atualizado para garantir um eficiente Processo Organizacional de Segurança da Informação da organização.

Sugestões e observações podem e devem ser feitas.

Edison Fontes, CISM, CISA, CRISC, Ms.

Consultor Gestão da Segurança da Informação

edison@pobox.com

302

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA

(Edison Fontes) Documento Base para Planejamento Inicial Segurança da

Informação

1. INTRODUÇÃO

Este Documento Base para Levantamento para o Planejamento Inicial do Processo Organizacional de Segurança da Informação, é uma das etapas do Projeto de Aprimoramento do Processo Organizacional de Segurança da Informação da Organização.

Esta etapa consiste na Priorização e Planejamento de Atividades para o Processo Organizacional de Segurança da Informação. Ela é composta por dois documentos, descritos na proposta de trabalho e formalizados no contrato assinado:

- *Documento Base para Levantamento para Planejamento Inicial do processo Organizacional de Segurança da Informação. Este documento.*
- *Documento Final do Planejamento Inicial do Processo Organizacional de Segurança da Informação. A realizar.*

Os elementos base para a priorização descritos neste documento, podem ser agrupados ou mais detalhados quando da ação de planejamento dos controles ou macrocontroles e da geração do trabalho a ser registrado no segundo documento.

Sugestões e observações podem e devem nos ser encaminhadas

Edison Fontes, CISM, CISA, CRISC, Ms.

Consultor Gestão Segurança Informação

edison@pobox.com

*Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com*

**SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes) 2. OBJETIVO DESTE DOCUMENTO**

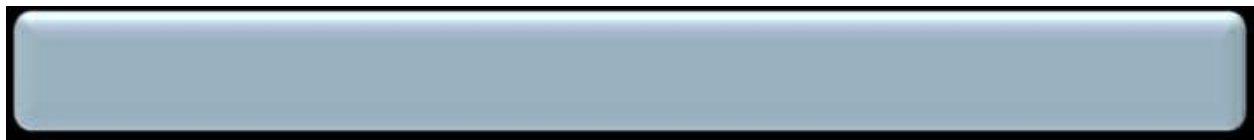
Apresentar os elementos base que serão considerados para a priorização e planejamento dos controles ou macrocontroles do Processo Organizacional de Segurança da Informação da Organização.

3. ESCOPO

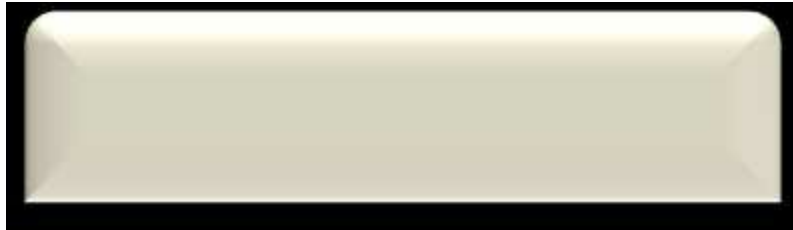
Os elementos aqui considerados são definidos, para possibilitar de uma maneira estruturada e documentada, a priorização e o planejamento de atividades para a melhoria da efetividade dos controles. Eles sempre consideram o escopo e características do projeto. Estes elementos foram definidos com o objetivo de explicitar o porquê da prioridade recomendada, sempre considerando as características da organização, seus objetivos corporativos e necessidades de negócio.

O Documento Arquitetura da Segurança da Informação – Processo Organizacional da Segurança da Informação é o grande orientador para ações de todas as etapas do projeto, bem como todas as ações relacionadas à Gestão da Segurança da Informação.

Outro elemento importante é o conjunto das dimensões definidas no Processo Organizacional de Segurança da Informação descrito na Arquitetura de Segurança da Informação, apresentadas na figura abaixo:







SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes)

POLÍTICAS DE SEGURANÇA DA INFORMAÇÃO

o

óci

Acesso à Informação

Classificação da Informação

Proteção técnica

g

Recursos de informação

ne

de

s

s

co

a

s

r

i

g

r

er

Flexibilidade

Desenvolvimento de aplicativos

Conscientização e Treinamento

de

e

Operacional

o

o

ãt

ça

s

a

Ge

ntema

Continuidade do negócio

ul

Tratamento de

Modelo operativo

ge

incidentes de segurança

da SI

R

Ambiente

Cópias de segurança

Físico e infra-estrutura

8

Fonte: Livro Praticando a segurança da informação, Edison Fontes, Editora BRASPORT, 2008. Página 48.

Estrutura baseada na Norma Internacional ISO/IEC 27002.

4. ELEMENTOS CONSIDERADOS PARA A PRIORIZAÇÃO E PLANEJAMENTO

DE ATIVIDADES

Descrevemos abaixo os elementos básicos para a definição da priorização e planejamento de ações que tem o objetivo de melhorar a efetividade dos controles ou macrocontroles existentes nos ambientes de informação da organização.

Uma das dificuldades que todas as organizações têm quando da Gestão da Segurança da Informação é: o que priorizar? Podemos afirmar que praticamente todos os controles ou macrocontroles de segurança da informação são importantes e

305

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) protegem a organização contra ameaças que podem impactar negativamente a organização, seja financeiramente, operacionalmente, na sua reputação, na conformidade com leis, contratos e regulamentos de agências governamentais.

Então, eles devem ser implementados. Porém, por mais rica que seja, qualquer organização não possui à sua disposição, todos os recursos, como: financeiro, tempo, pessoas e similar. Existem limitações.

Desta maneira a grande questão é: para a nossa organização específica, considerando as características do negócio e objetivos corporativos, que ações são mais prioritárias que outras? A resposta desta questão deve ser dada considerando os elementos que facilitem a priorização de ações, com a utilização de critérios explícitos, de fácil compreensão e que possam ser acompanhados ao longo do tempo.

A quantidade de elementos que podem ser considerados é infinita. Teoricamente, quanto mais elementos forem considerados e suas

interrelações, mais rigorosamente o resultado para a priorização estaria mais exato, seria mais correto. Porém, quanto mais elementos, mais esforço será exigido para obtermos o resultado: priorização das ações de segurança da informação.

Novamente temos que ser inteligentes e considerar os elementos básicos, que permitam uma priorização estruturada, considerando um esforço adequado. Temos que considerar o custo (tempo, complexidade) x benefícios (plano de ação) Entendemos que os elementos aqui considerados são adequados para a definição da prioridade e do plano de ação para a organização, considerando a sua maturidade em Gestão da Segurança da Informação, identificada no documento Diagnóstico da Maturidade dos Controles ou Macrocontroles de Segurança da Informação.

306

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) Estes elementos e a abordagem aqui considerados podem e devem ser sempre revisados para as futuras avaliações de maturidade e definição do plano de ação.

Esta continuidade de avaliação é obrigatória e definida na Política de Segurança da Informação:

A cada período de 12 (doze) meses a equipe de Segurança da Informação e Continuidade de Negócios deve disponibilizar para a Alta Direção um relatório descrevendo a maturidade da organização em relação aos controles de segurança da informação e ao planejamento das próximas ações.

4.1. Controles ou macrocontroles considerados para o planejamento
Serão considerados os controles ou macrocontroles avaliados como Inadequados ou Parcialmente Adequados.

Os controles Adequados não serão considerados para a priorização das atividades.

Evidentemente estes controles, com este nível de maturidade, devem receber esforços para a manutenção desta sua efetividade.

4.2. Avaliação da Maturidade dos Controles ou Macrocontroles

Será considerado mesmo critério utilizado no Documento Diagnóstico da Maturidade dos Controles ou Macrocontroles de Segurança da Informação. São dez níveis de maturidade/efetividade dos controles, que podem ser agrupados em três grupos: **Nível da Avaliação, de 1 a 4: Controle está inadequados.**

Necessário implementação total ou quase total do controle.

Com certeza será Ponto de Auditoria. O que existe não atende.

Nível da Avaliação, de 5 a 7: Controle está parcialmente adequado.

Necessário melhorias para o controle. Esta efetividade de controle não compatível com a organização. Possível Ponto de Auditoria.

Nível da Avaliação, 8 a 10: Controle está adequado.

Necessário garantir a manutenção do controle. Avaliar melhorias.

Não será Ponto de Auditoria.

Se for auditado: será Ponto de Auditoria.

Precisa ser implantado.

- 1. Não é considerado.**
- 2. Em planejamento inicial. Sem compromisso formal.**
- 3. Está planejado. Com data, responsáveis e aprovação (quase) formal.**
- 4. Início de implantação. Não atende aos requisitos básicos. Muito frágil.**

Maturidade 5 a 7 – CONTROLE EXISTE COM LIMITAÇÕES/PRECARIEDADES

Se for auditado: podem ser encontrados algumas situações não adequadas.

Em funcionamento com requisitos mínimos

- 5. Atende minimamente aos requisitos básicos.**
- 6. Identificadas melhorias necessárias e já planejadas.**
- 7. Quase totalmente implementado. Com pendência: documentação,**

outra.

Maturidade 8 a 10 – CONTROLE EXISTE DE MANEIRA ADEQUADA.

Se for auditado: não será Ponto de Auditoria. Exceto se falha em atividades por erro, ação de

má fé ou outras situações não contempladas no processo.

Em funcionamento com atendimento adequado

8. Está funcionando bem. Pode ter melhorias.

9. Totalmente implementado. Atende adequadamente à organização.

10. É ou pode ser considerado: referência de mercado. (Melhor da Classe)

308

*Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com*

**SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes)** Para a abordagem de priorização de ações e elaboração de plano de ação, vamos considerar a seguinte pontuação:

Controles está Adequado: 1.

Controle Parcialmente Adequado: 2

Controle está Inadequado: 3.

Quanto mais baixa a efetividade do controle, mas alta a vulnerabilidade. E

consequentemente, quanto mais efetivo for o controle mais baixa será a vulnerabilidade.

4.3. Impactos considerados

Impacto significa a consequência caso o controle, macrocontrole ou conjunto de controles não impeçam a ocorrência da ameaça.

Consideramos os seguintes tipos de impactos:

- Continuidade operacional
- Financeiro
- Reputação (imagem)
- Legal
- Combate à fraude
- Prevenção de vazamento de informação
- Auditoria – Pontos de Auditoria.

Alto

Gera ou tem alto potencial de gerar situações que a Organização não quer e não aceita que ocorra. Este tipo de ocorrência impede ou tem grande potencial de impedir o atendimento aos objetivos corporativos.

Médio

Gera ou tem alto potencial de gerar situações não desejadas pela Organização, mas que caso ocorram podem ser absorvidas em tempo médio pelas atividades.

Baixo

Gera ou tem alto potencial de gerar situações não desejadas pela Organização, mas que caso ocorram são facilmente absorvidas pelas atividades operacionais.

Descrevemos abaixo, a descrição dos níveis para cada tipo de impacto,

4.3.1. Continuidade Operacional

Alto

Impede o funcionamento normal do negócio.

Impacta fortemente todos os clientes.

Médio

Impacta a realização do negócio, mas suportável.

Pouco impacto para todos os clientes. Afeta grupo de clientes.

310

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) Baixo

Pequeno impacto no funcionamento do negócio.

Maioria dos clientes não serão impactados.

4.3.2. Financeiro

Alto

Forte prejuízo financeiro.

Necessário justificativa perante o Corpo Diretivo ou Matriz da organização.

Médio

Prejuízo financeiro suportável.

Possível de ser aceitável pela organização.

Baixo

Prejuízo financeiro possível de ser assumido pela própria área.

Pouco impacto organizacional.

4.3.3. Reputação (imagem)

Alto

Forte impacto na imagem comprometendo a reputação da organização.

Tem que se justificar perante a mídia, público, mercado ou agentes reguladores.

Médio

Impacto de imagem e reputação da organização não é percebido pela maioria dos clientes.

Impacto específico em grupo de clientes.

311

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) Baixo

Pequeno impacto de imagem ou reputação.

Impacto pouco perceptível pelos clientes.

4.3.4. Legal

Alto

Impacto legal.

Não atende a legislação ou normativos de órgãos reguladores.

Médio

Não cumpre controle definido em regulamento interno da organização.

Está em conformidade com a legislação ou normativos de órgãos reguladores.

Baixo

Não está em conformidade com as boas práticas.

Está em conformidade com a legislação ou normativos de órgãos reguladores.

4.3.5. Combate à Fraude

Alto

Facilita a ocorrência de fraude.

Impede a identificação do usuário.

A organização pode ser acusada de não implementar controles para evitar ilícitos.

Impede a rastreabilidade.

312

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

**SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes) Médio**

Pequena possibilidade de ocorrência de fraude.

Rastreabilidade mínima e tempo mínimo.

Baixo

Gera ou pode gerar maior vulnerabilidade no futuro.

Possibilidade de ocorrência de fraude se combinado com outras vulnerabilidade em controles.

4.3.6. Prevenção de vazamento de informação

Alto

Facilita o vazamento de dados: clientes, negócios, pessoal.

Médio

Facilita o vazamento de dados em geral.

Baixo

Gera ou pode gerar maior vulnerabilidade no futuro em relação à vazamento de informação.

4.3.7. Auditoria – Pontos de Auditoria

Alto

Ponto severo em relatório de auditoria. Exigirá solução em curto prazo.

313

*Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com*

**SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes) Médio**

Ponto comum em relatório de auditoria. Possível ter planejamento adequado.

Baixo

Ponto de atenção em relatório de auditoria.

Para este trabalho de planejamento inicial, quando da avaliação do impacto, consideraremos o impacto resultante sem especificar cada tipo de impacto.

4.4. Risco

Para definir a priorização de ações para uma efetiva Gestão de Segurança da Informação, é necessário identificar o risco associado a ameaças.

Considerando a Norma NBR ISO/IEC 27005 – Tecnologia da informação – Técnicas de segurança – Gestão de riscos de segurança da informação, temos a seguinte definição de riscos de segurança da informação:

3.2. Riscos de segurança da informação

Possibilidade de uma determinada ameaça explorar vulnerabilidades de um ativo ou de um conjunto de ativos, desta maneira prejudicando a organização.

É medido em função da combinação da probabilidade de um evento e o seu impacto.

4.4.1. Abordagem

Seguiremos a abordagem Qualitativa, respaldada teoricamente pela Norma BR

ISO/IEC 27005, com a seguinte parametrização para a probabilidade da ocorrência de um evento

314

*Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com*

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) Risco Alto

Grande probabilidade de acontecer.

Acontece com certa periodicidade

Se não aconteceu ainda, foi “sorte”

Risco Médio

Em condições normais não acontece.

Não tem acontecido.

Risco Baixo

Nunca aconteceu.

Muito raramente acontece.

Para ocorrer necessita de muitas coincidências.

4.5. Relação Impacto x Probabilidade do Evento

Para a identificação da priorização de implementação de controles ou macrocontroles de segurança da informação, vamos considerar a Matriz de Impacto x Probabilidade do Evento.

Esta matriz nos ajudará a melhor identificar de maneira estruturada os grupos de risco, e provável prioridade.

A priorização fruto dessa matriz, terá considerado: maturidade do controle, impacto no caso de falha do controle, probabilidade do evento de falha do controle acontecer.

E como resultante, um posicionamento para a priorização de implementação ou melhoria do controle.

O conteúdo deste documento atende ao previsto como produto a ser entregue, conforme descrito na proposta e contrato.

Recomendamos que este documento seja revisto a cada período máximo de

(doze) meses ou quando de novas situações que devam ser consideradas na priorização dos controles, isto é, novos elementos devam ser considerados para a priorização de atividades.

Este documento deve estar sempre atualizado para garantir um eficiente Processo Organizacional de Segurança da Informação da organização.

Sugestões e observações podem e devem ser feitas.

Edison Fontes, CISM, CISA, CRISC, Ms.

Consultor Gestão da Segurança da Informação

edison@pobox.com

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) Documento Gerenciamento de Risco de Segurança da Informação

O exemplo abaixo descreve uma situação específica, como toda situação de uma organização. A análise de um exemplo vale pela riqueza de tomarmos conhecimento de uma implementação de conceitos estudados. Porém, temos que ter sabedoria para saber que atividade prática apresentada é válida para uma organização em um determinado momento. Somente a experiência com a realização de ações de gestão e de gerenciamento de riscos vai permitir a melhor compreensão do assunto.

Mesmo sabendo destas limitações entendo que um exemplo sempre é muito enriquecedor.

CONTEXTUALIZAÇÃO

a. Gestão de Riscos de Segurança da Informação

A Gestão de Riscos de Segurança da Informação é uma atividade contínua com revisão periódica realizada a cada doze meses e que na medida em que aumente a maturidade da organização em gestão de riscos, aumente a sua abrangência, sejam considerados os demais recursos de informação e sejam consideradas outras ameaças.

b. Escopo

Recursos de informação do Ambiente Corporativo Centralizado de Tecnologia da Organização.

c. Objetivo

Garantir a minimização dos riscos realizando o monitoramento constante das ameaças que podem se concretizar e impactar negativamente a Organização.

317

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

Probabilidade da ocorrência - Ameaça		Ameaça Baixa				Ameaça Média				Ameaça Alta		
Facilidade de exploração - Fragilidade do controle	Baixa	Média	Alta	Não existe	Baixa	Média	Alta	Não existe	Baixa	Média	Alta	Não existe
	1	2	3	4	2	3	4	5	3	4	5	6

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

d. Métodos considerados

- Análise de riscos com o objetivo de determinar o nível de risco e posteriormente o nível de proteção.
- Definir as ameaças que serão consideradas.
- Identificar os controles existentes que minimizam a ocorrência da ameaça.
- Identificar a efetividade de cada controle, isto é, o quão eficiente (na prática) este controle bloqueia a ameaça.
- Calcular o nível de risco tomando por base a planilha definida.
- Indicar o tratamento (minimizar, assumir, evitar ou transferir) para o risco residual.

e. Tabela para a Análise de Risco

Figura – Critérios de Análise de Riscos

Fonte: *Tabela Completa E.1 (a), Norma NBR ISO/IEC 27005:2008, p. 49.*

318

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes) A Organização tem como objetivo nesta fase inicial da Gestão de Riscos de Segurança da Informação até o Nível 3 para qualquer um dos tipos de ameaça; baixa, média ou alta.

f. Personalização para o a Organização

A tabela acima é baseada em uma tabela mais completa exemplificada na Norma NBR ISO/IEC 27005:2008. Para a avaliação pela Organização, consideramos apenas um tipo de valor de ativo (uma linha). A norma considera ativos com valores diferentes.

Para ameaças onde não existam controles, vamos considerar o valor da facilidade de exploração em Alta + 1. Desta forma manteremos uma escala de criticidade mais coerente.

g. Definições para o nível de Probabilidade

Probabilidade Alta Grande probabilidade de acontecer

Já aconteceu. Se não aconteceu, foi

“sorte”

Muito provável de acontecer.

Média Em condições normais pode acontecer

Acontece com baixa frequência, mas

acontece

Provável de acontecer

Baixa Nunca aconteceu

Muito raramente acontece

Pouco provável de acontecer

Se ocorrer, aconteceram muitas

coincidências

Figura – Definições para o Nível de Prioridade - Fonte: Autor.

319

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

**SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes) h. Definições para o nível de Fragilidade dos Controles
(Vulnerabilidade) Muito Alta : Não existe um controle.**

Alta : O controle existente é fraco, pouco eficiente.

Média : Existe um controle que não garante completamente a concretização da ameaça ou na utilização da vulnerabilidade.

Baixa : Existe um controle que impede/impedirá da ameaça se concretizar ou da vulnerabilidade ser utilizada.

i. Avaliação do Risco

Objetivo:

Identificar a magnitude do risco considerando o impacto/consequência.

Possibilita definir a prioridade de cada risco em relação aos demais.

Etapas:

a) Identificar os riscos estimados, Isto é, identificar o nível de risco de cada ameaça, considerando os controles existentes. (Entrada) .

b) Avaliar a consequência de impactos do tipo operacional, financeiro, imagem, cumprimento de prazo ou atendimento a requisitos legais.

Definimos impacto como sendo as consequências negativas ou danos que podem alterar a operação das atividades da Organização no que depende dos recursos de informação.

320

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

**SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes)** c) Construir a saída que será composta dos riscos avaliados considerando o impacto e consequentemente possibilitando uma priorização para a sua resolução.

j. Tabela para Avaliação de Risco – Considerando o Impacto

Acontece em uma (ou mais) das situações descritas ou equivalentes.

5 – Muito gravemente

- Impede totalmente funcionamento da Organização.

- Graves consequências de imagem para a Organização. Exigirá grande esforço para reparar imagem da Organização.

- Graves consequências legais para a Organização. Exigirá ações jurídicas complexas para a defesa da Organização.

- Gera impacto financeiro de valor muito alto.

4 – Gravemente

- Impede parcialmente o funcionamento da Organização.
- Forte consequências de imagem para a Organização. Exigirá algum esforço para reparar imagem da Organização.
- Forte consequências legais para a Organização. Exigirá algumas ações jurídicas para defesa da Organização.
- Gera impacto financeiro de valor alto.

3 – Medianamente

- Impede durante um período de tempo algumas funções operacionais.

Acarreta impacto.

- Prejudica a imagem da organização. Exige esforço médio para reparar a imagem da Organização. Será visto como uma situação que pode acontecer com as organizações.
- Gera necessidade de ações legais. Solução em médio prazo.
- Causa impacto financeiro médio

- Impede algumas funções operacionais durante um curto período de

tempo. Pequeno impacto apenas em áreas específicas.

- Imagem da Organização poderá ser impactada, mas é uma situação aceitável.
- Necessário acompanhamento jurídico, mas gera pouca ação.
- Pequeno impacto financeiro.

1 – Muito levemente

- Impede poucas funções operacionais durante um período curto.
- Pouco impacto na imagem da Organização. Situação considerada tipo erro.
- Não necessita acompanhamento jurídico.
- Muito pequeno impacto financeiro. A própria área tem condições de absorver pelo próprio orçamento previsto.

k. Comunicação dos riscos

Objetivo: dar conhecimento da situação dos riscos à todos os envolvidos no assunto e nos objetivos da organização.

A Área de Segurança da Informação deverá providenciar a comunicação dos resultados da Gestão de Riscos de Segurança da Informação à diretoria executiva com o objetivo desenvolver ações para que a Organização tenha um nível de risco adequado aos seus objetivos de negócio.

l. Avaliação de Riscos – Planilha Parcial

AMEAÇAS / VULNERABILIDADES (Ambiente Corporativo de Tecnologia)	Controle	Responsável pelo Controle	Probabilidade da Ameaça	Fragilidade do Controle	Nível de Risco	Impacto (negativo)	Prioridade para tratamento do risco
DISPONIBILIDADE							
1. Falta de energia elétrica menor que 2 horas	Nobreak 2 horas + Revisão periódica	Área Tecnologia	Alta	Baixo	3	1	3
2. Falta de energia elétrica maior que 2 horas	Não tem	Área Tecnologia	Média	Alta+	5	4	20
3. Parada CPD Principal - Necessidade uso CPD Alternativo	CPD Alternativo não está funcionando	Área Tecnologia	Baixa	Alta+	4	4	16
4. Desastre ambiente físico (prédios CPDs) Organização	CPD Alternativo Externo não existe	Área Tecnologia	Baixa	Alta+	4	5	20
5. Dependência de prestadores de serviço de SW	Regras de SI para Desenvolvedores, Contratação	Área Tecnologia	Alta	Média	4	3	12
6. Indisponibilidade por problemas repetidos ou por falta de controle nas implantações	Gestão de Problemas e Gestão de Mudanças	Área Tecnologia	Alta	Alta	5	3	15
7. Parada do CPD Principal por problemas no ar condicionado	Duas máquinas e ronda periódica	Área Tecnologia	Baixa	Média	2	4	8
8. Incêndio no CPD Principal	Deteção Incêndio: Não existe. Existem servidores em outra sala	Área Tecnologia	Baixa	Alta	3	5	15
INTEGRIDADE							
9. Necessidade de uso de cópias de segurança	Existem processos para a execução da cópia	Área Tecnologia	Alta	Baixa	3	3	9
10. Destruição/Indisponibilidade cópias de segurança existentes na instalação principal da Organização	Não existe cópia externa	Área Tecnologia	Baixa	Alta+	4	3	12

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

Figura 17 – Resultado da Análise e Avaliação de Riscos

Fonte: *Autor*.

m. Priorização para o tratamento de Riscos

Considerando a Planilha Parcial apresentada acima, temos como priorização:
Pontuação

Ameaça ou

(Maior Prioridade)

Vulnerabilidades

20

2. Falta de energia elétrica maior que 2 horas

4. Desastre ambiente físico CPD Organização

16

3. Parada CPD Principal - Necessidade CPD Alternativo

15

6. Indisponibilidade por problemas repetidos ou por falta de controle nas implantações.

8. Incêndio no CPD Principal

12

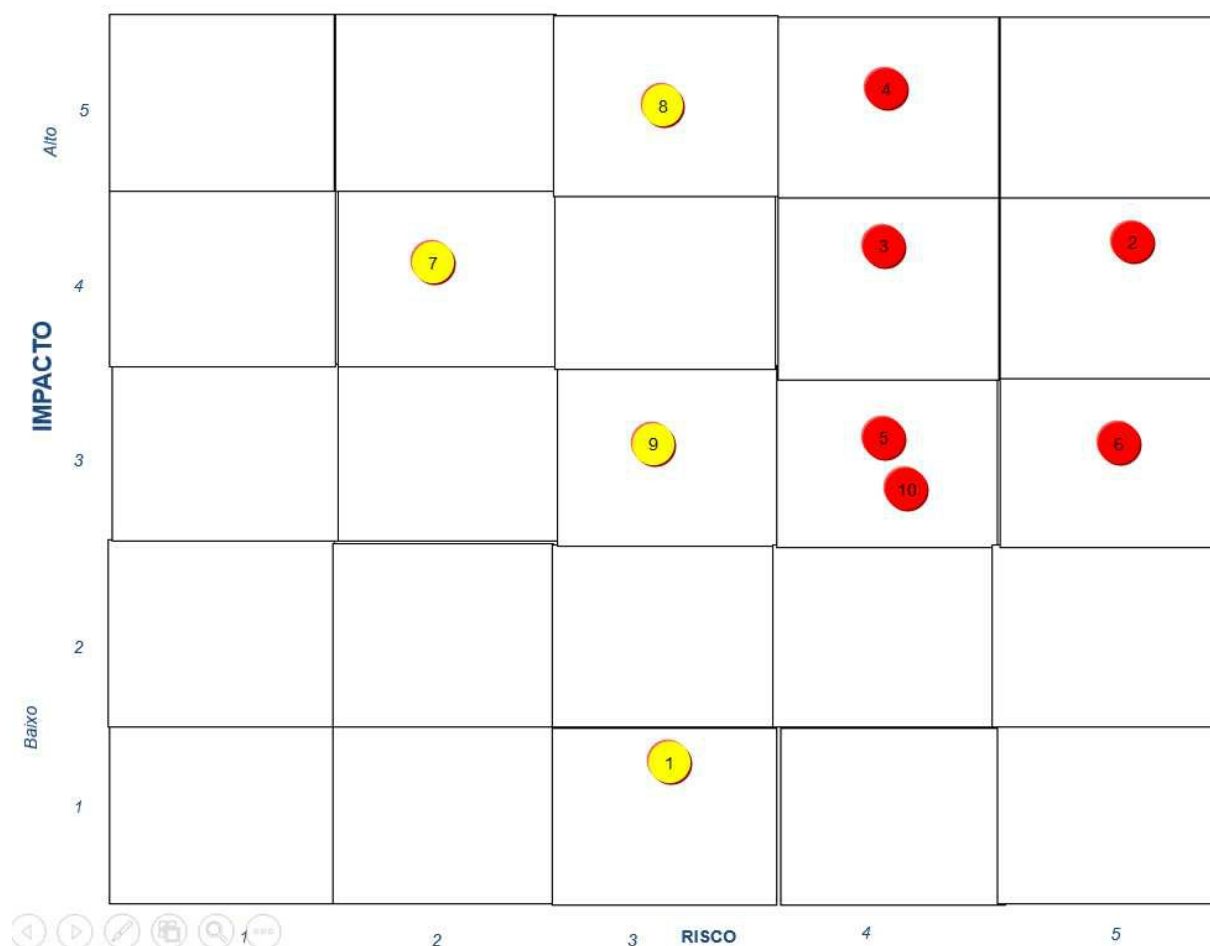
5. Dependência de prestadores de serviço de SW.

12

10.Destruição/Indisponibilidade cópias de segurança existentes na instalação principal da Organização.

323

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***



**SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes)**

09

9. Necessidade de uso de cópias de segurança.

08

7. Parada do CPD Principal por problemas no ar condicionado.

1. Falta de energia elétrica menor que 2 horas

Figura 18 – Representação para a Prioridade de Ações. Fonte: Autor.

Os quadrantes mais à direita e mais altos possuem as ameaças que devem prioritariamente ser tratados.

**SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes) Documento Termo de Uso de Informação**

1. Pelo presente Termo declaro que entendi e aceito que:

- i. As regras de uso da informação de propriedade ou sob responsabilidade da organização estão descritas nas políticas, diretrizes gerenciais e demais regulamentos de Segurança da Informação, disponíveis para minha leitura no ambiente centralizado de tecnologia da informação.
- ii. É minha obrigação profissional e/ou contratual cumprir os regulamentos de Segurança da Informação da organização.
- iii. Os regulamentos de Segurança da Informação poderão ser alterados ou novos regulamentos poderão ser criados pela ORGANIZAÇÃO. Nestes casos, eu serei comunicado por meio do correio eletrônico; e
- iv. Após o recebimento desta comunicação de alteração ou criação de regulamentos, é minha obrigação acessar, ler, entender e cumprir as regras neles estabelecidas.

2. Também declaro que fui informado, estou ciente e tenho total

entendimento que:

- i. Minhas ações e atividades de uso de informação ou recursos de informação, decorrentes das funções desempenhadas para a organização, inclusive a utilização de correio eletrônico corporativo, acesso à internet e/ou uso de equipamentos fornecidos pela organização, podem ser monitorados de acordo com os regulamentos de Segurança da Informação da organização e a legislação aplicável.
- ii. Os sistemas ou os demais recursos da organização que eu utilizo poderão ser auditados a qualquer tempo pela mesma ou por empresa indicada por ela.
- iii. O endereço de correio eletrônico corporativo disponibilizado pela organização para o desempenho das minhas atividades profissionais e/ou contratuais é de propriedade da mesma.

325

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA

(Edison Fontes) iv. Não é permitido compartilhar com outras pessoas, a identificação de usuário disponibilizada pela organização e o recurso (senha, *token*, biometria, outro) que utilizo para autenticação. É minha responsabilidade qualquer acesso feito com esta identificação, advinda da respectiva autenticação.

v. É proibido revelar para pessoas não autorizadas, informações que eu tenha acesso em função das minhas atribuições profissionais e/ou contratuais para a organização.

vi. Eu sou responsável por qualquer impacto consequente do meu descumprimento dos regulamentos de Segurança da Informação da organização.

vii. Eu recebo autorização para acessar as informações ou recursos de

informação de propriedade ou sob responsabilidade da organização para desempenhar minhas atividades profissionais, e que este acesso não me garante o direito sobre estas informações.

viii. Constitui infração profissional e/ou contratual realizar ou facilitar ações não autorizadas pelos regulamentos de segurança, relacionadas a informações ou recursos de informação de propriedade ou sob responsabilidade da organização.

Local, __ de _____ de 20____.

Nome: _____ Assinatura:

RG: _____ CPF:

326

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

**SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes) Documento Carta de Risco em Segurança da informação**

(Necessário existência de Política de Aceitação de Risco)

Introdução

Este Documento de Aceitação de Risco em Segurança da Informação ou também chamado de Carta de Risco em Segurança da Informação, obrigatoriamente deve ser elaborado e devidamente assinado pelos gestores adequados, quando por qualquer razão um determinado controle definido em regulamentos de segurança da informação não poderá ser cumprido pela Organização.

É mandatório a existência de um Regulamento de Segurança da Informação (Política ou Norma) definindo os controles para a existência deste

documento. Neste regulamento é obrigatório que esteja descrito o grau de autoridade do gestor para a aceitação do risco. Cada Organização precisa fazer esta definição. Algumas organizações poderão descentralizar esta autorização por tema, outras poderão deixar de maneira centralizada com a presidência. Evidentemente que esta definição depende do porte e negócio da Organização. Pessoalmente defendo, à princípio para a maioria das informações, que qualquer aceitação de risco deve ser em última instância ser aprovado pelo Presidente ou gestor Executivo da Organização no local.

Por um motivo simples: existe um controle que não será cumprido. É uma responsabilidade deste gestor garantir perante os acionistas e perante o mercado que os controles de segurança da informação serão cumpridos.

Todo documento deste tipo deve ter os seguintes itens descritivos e de aprovação.

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) 1. Controle Existente

Indicar o controle existente que não será cumprido. Nome do Regulamento, item e descrição do texto do controle

Rigorosamente somente se faz uma Carta de Risco ou Documento de Aceitação de Risco, para situações em que existe um controle (regra ou diretriz) que não será cumprido.

No caso de não existir o controle formalmente, mas existir a intenção de se ter o controle e, portanto, já estamos elaborando este documento assumindo uma existência informal do controle, é necessário preencher um outro Documento de Aceitação de Risco registrando a não existência do regulamento, mas a intenção de ter o mesmo em um prazo estabelecido. Durante este período informal de controle o Documento de aceitação de

Risco cobrirá a situação.

2. Possíveis Impactos

Descrever neste item os possíveis impactos financeiros, de imagem, de reputação, operacionais, de não cumprimento de legislação e outros similares.

3. Possíveis Controles Compensatórios.

Neste item devem ser descritos possíveis controles compensatórios, que são controles que não têm a mesma eficácia do controle original, mas podem gerar uma situação de controle parcial. Exemplo: é para se ter um controle automatizado. Por alguma razão não será possível dentro do tempo estabelecido. Pode-se ter um controle manual que não será tão eficaz como o controle previsto, porém oferece um nível de controle que atende parcialmente.

328

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) 4. Tempo de aceitação do risco

O regulamento sobre a existência deste documento deve definir um tempo máximo de aceitação de risco. Ultrapassando este tempo uma novo Documento de Aceitação de Risco de Segurança da Informação deverá ser assinado.

5. Parecer de Áreas Envolvidas

Neste item devem ser explicitadas a opinião de algumas áreas específicas. Exemplo:

- Área de Segurança da Informação.
- Área de Tecnologia da Informação.

- Área Jurídica.

- Área de Negócio afetada pelo controle que não será cumprido.

6. Parecer do Autorizador

Neste item o gestor que tem poder de autorizar a aceitação de risco, deve descrever a sua opinião, considerando a sua opinião e considerando as explicações das Áreas Envolvidas.

7. Assinatura do Autorizador

Neste item o Autorizador deve assinar e datar.

329

*Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com*

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

Documento Planejamento para Teste de Continuidade de Negócio

1 – OBJETIVO (S) DO TESTE

- Descrever o objetivo ou objetivos do teste a ser realizado.
- Este objetivo ou objetivos, será/serão o direcionador para a avaliação do teste. Isto é, após a realização do teste poderemos identificar se o teste atendeu aos objetivos propostos.

2 – FORMA DE REALIZAÇÃO DO TESTE

- Indicar como o teste será realizado, quais etapas, que ambientes o teste vai envolver.

3 – CONSIDERAÇÃO SOBRE O TESTE

Descrever o porquê da realização do teste e outras informações importantes para o registro do teste.

4 – LIMITAÇÕES DO TESTE

4.1 - Escopo

Descrever os elementos, os sistemas, os serviços ou outras informações que definam o que o teste está contemplando.

4.1.1 – Sistemas de Tecnologia da Informação

=> Indicar todos os sistemas que serão contemplados no teste.

330

*Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com*

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) 4.1.2 – Ambiente Considerado

4.1.2.1 – Ambiente de Tecnologia da Informação

=> Indicar quais são os ambientes de tecnologia considerados.

=> Ambiente Principal, Ambiente Alternativo.

4.1.2.2 – Ambiente de Escritório

=> Indicar quais são os ambientes de escritório considerados.

=> Ambiente Principal, Ambiente Alternativo.

4.2 - Cenário

- Descrever o cenário considerado para este teste.

- Exemplo: indisponibilidade total do Ambiente Principal de TI com a ocorrência da indisponibilidade ocorrendo às 08:00hs. De um dia útil de trabalho normal.

5 – DESCRIÇÃO MACRO ATIVIDADES DO TESTE

- Descrever as Macro Atividades que serão executadas no teste.

- Exemplo:

* Indisponibilidade do Ambiente Principal.

* Comunicação com as áreas da Organização

* Comunicação com o Ambiente Alternativo.

331

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

ATIVIDADE	ATIVIDADE	EQUIPE

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

* Migração para o Ambiente Alternativo.

* Confirmação de que o Ambiente Alternativo está OK.

* Liberação do Ambiente Alternativo como Ambiente Principal.

- Indicar se será necessário a realização de alguma atividade Pré Teste.

6 – CRONOGRAMA DAS ATIVIDADES PARA ANTES DA

REALIZAÇÃO DO

TESTE

7 – CRITÉRIOS PARA A VALIDAÇÃO DO TESTE

Descrever quais os critérios que serão considerados para a validação do teste. Por exemplo, em um determinado teste pode ser que não seja considerado o desempenho do Data Center Alternativo, porque já se sabe que o ambiente alternativo está com o problema que vai impedir o desempenho esperado, porém outros elementos podem ser testados.

332

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***

NOME	EQUIPE	Local	Função Específica

**SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes)**

8 – CONDUÇÃO DO TESTE

Estarão participando do teste:

9 – REGISTRO DO TESTE

- Deve-se Indicar que pessoa ou pessoas farão o registro do teste.
- Todas as atividades realizadas durante o teste serão registradas (início, fim, problemas, observações).
- Também todos os problemas e situações que causaram impacto na execução do plano durante o teste, devem ser registrados.

10 – OBSERVADORES

Indicar a pessoa ou pessoas que farão o papel de Observador

Este Observador fará um relatório separado do Relatório de Avaliação do Teste.

333

*Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com*

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) 11 – AVALIAÇÃO DO TESTE

Após a realização do teste deve ser feita uma avaliação da eficácia e eficiência do plano testado e de todos os elementos que permitiram a realização do teste.

Será gerado um relatório sobre o teste e um resumo gerencial deve ser enviado à Presidência da Organização.

Deve-se indicar quem será responsável pela condução da avaliação e quem vai elaborar o relatório.

12 – DOCUMENTAÇÃO DAS ALTERAÇÕES DO TESTE

As alterações que forem necessárias para a correção ou aprimoramento do plano devem ser documentadas e, se possível, alteradas de imediato no plano.

Definir quem é o responsável por esta atividade

13 – RISCO PELA REALIZAÇÃO DO TESTE

Indicar o risco de impacto negativo para o Ambiente Principal de Tecnologia ou para o Ambiente Principal de Escritório, que ficará funcionando, quando da realização deste teste.

334

*Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com*

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes) 14 – ELABORAÇÃO DESTE DOCUMENTO

Indicar quem elaborou este documento de planejamento de teste

Nome e Cargo/Função

Nome e Cargo/Função

15 – APROVAÇÃO DESTE DOCUMENTO E AUTORIZAÇÃO PARA A

REALIZAÇÃO DO TESTE ESPECIFICADO

Assinatura do Presidente, Diretor ou Executivo com Poder de Decisão

335

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA **(Edison Fontes) Estruturas de Apoio**

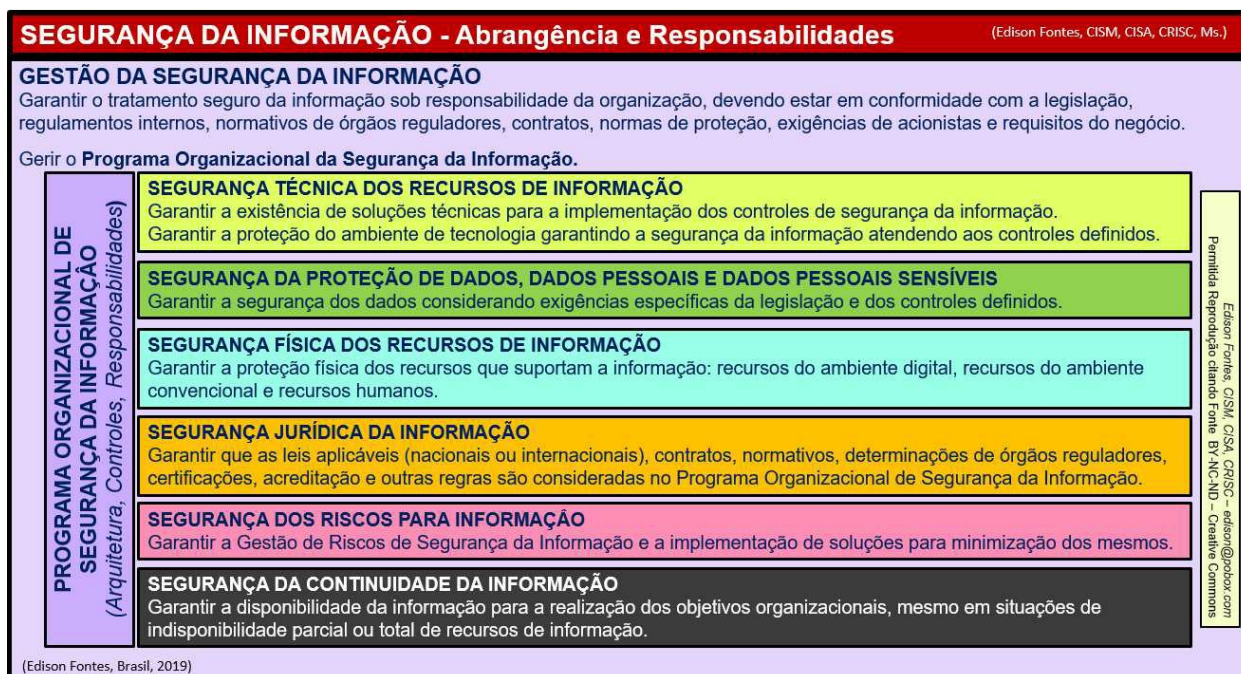
As Estruturas de Apoio apresentadas nas próximas páginas resumem, cada uma delas, pontos apresentados no corpo deste livro.

Tenho utilizado as figuras adiante para facilitar o entendimento e comunicar de uma maneira estruturada e com lógica, os conceitos e controles apresentados.

Você pode utilizar estas estruturas desde que apresente as mesmas da maneira que estão neste livro e cite a fonte.

Espero que elas sejam proveitosas para você, como tem sido na minha vida profissional.

Edison Fontes.



Estrutura Segurança da Informação Abrangência e Responsabilidades



SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

Estrutura Risco Corporativo

338

Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com

GOVERNANÇA – PRINCÍPIOS (Edison Fontes, CISM, CIAS, CRISC, MS, 2019)	
GOVERNANÇA CORPORATIVA TRANSPARÊNCIA: Informar e disponibilizar informação corretamente. EQUIDADE: Tratamento justo, não discriminatório. PRESTAÇÃO DE CONTAS: Agentes de governança prestam contas de sua atuação, assumindo as consequências de seus atos e omissões. RESPONSABILIDADE CORPORATIVA: Sustentabilidade da organização	Edison Fontes, CISM, CIAS, CRISC, MS, 2019, Brasil) Permitida Reprodução BY-NC-ND - Creative Commons
GOVERNANÇA DA TECNOLOGIA DA INFORMAÇÃO RESPONSABILIDADE: Respeitar ao fornecimento e demanda de TI. ESTRATÉGIA: Satisfazer as demandas atuais e futuras da estratégia de negócio da organização. AQUISIÇÃO: Equilíbrio apropriado entre benefícios, oportunidades, custos e riscos. DESEMPENHO: Serviços, níveis de serviços e qualidade necessários para atender requisitos do negócio. CONFORMIDADE: Cumprir e legislação e os regulamentos obrigatórios. COMPORTAMENTO HUMANO: Respeito às necessidades atuais e futuras de todas as pessoas no processo.	
GOVERNANÇA DA SEGURANÇA DA INFORMAÇÃO ENFOQUE ORGANIZACIONAL: Estabelecer a Segurança da Informação em toda a organização. ABORDAGEM DE GESTÃO DE RISCOS: Adotar uma abordagem baseada em riscos. DIRECIONAMENTO DOS INVESTIMENTOS DE SEGURANÇA: Estabelecer a direção de decisões de investimentos. CONFORMIDADE LEGAL E NORMATIVA: Assegurar a conformidade com os requisitos internos e externos referente informação. AMBIENTE DE SEGURANÇA: Promover um ambiente positivo de segurança COERÊNCIA COM A ORGANIZAÇÃO: Garantir que abordagem adotada esteja adequada a sua finalidade de apoio a organização	
GOVERNANÇA DE DADOS QUALIDADE DOS DADOS: Avaliação, gestão, monitoramento e melhoria do uso dos dados. PLANEJAMENTO DA GESTÃO DE DADOS: Entender as necessidades de informações da empresa e definir modelo de dados corporativos. CONTROLE DA GESTÃO DE DADOS: Controlar o funcionamento da estrutura de dados definida.	

Fonte: Autor, IBGC, ABNT NBR ISO/IEC 27014, ABNT NBR ISO/IEC 38500 e DMBOK.

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

Estrutura Governança – Princípios

339

Segurança da Informação: Gestão e Governança - Copyright © 2020

GOVERNANÇA, GESTÃO E CONTROLES DE PROTEÇÃO E SEGURANÇA DE DADOS

*Edison Fontes, CISM, CISA, CRISC, Ms.
2019*

GOVERNANÇA DE PROTEÇÃO E SEGURANÇA DE DADOS

Garantia de que o tratamento da informação está em conformidade com os direcionadores obrigatórios e garantindo o atendimento aos os objetivos corporativos.

=> *Corpo Diretivo.*

GESTÃO DE PROTEÇÃO E SEGURANÇA DE DADOS

Garantia da confidencialidade, da integridade, da disponibilidade e da auditabilidade dos dados, de maneira alinhada à Governança de Proteção e Segurança de Dados.

=> *Programa Organizacional de Segurança da Informação.*

CONTROLES DE PROTEÇÃO E SEGURANÇA DE DADOS

São regras, atividades, processos, mapeamento ou tratamento com o objetivo de garantir a operacionalização, efetividade e sustentabilidade da Gestão de Proteção e Segurança de Dados.

=> *Áreas organizacionais.*

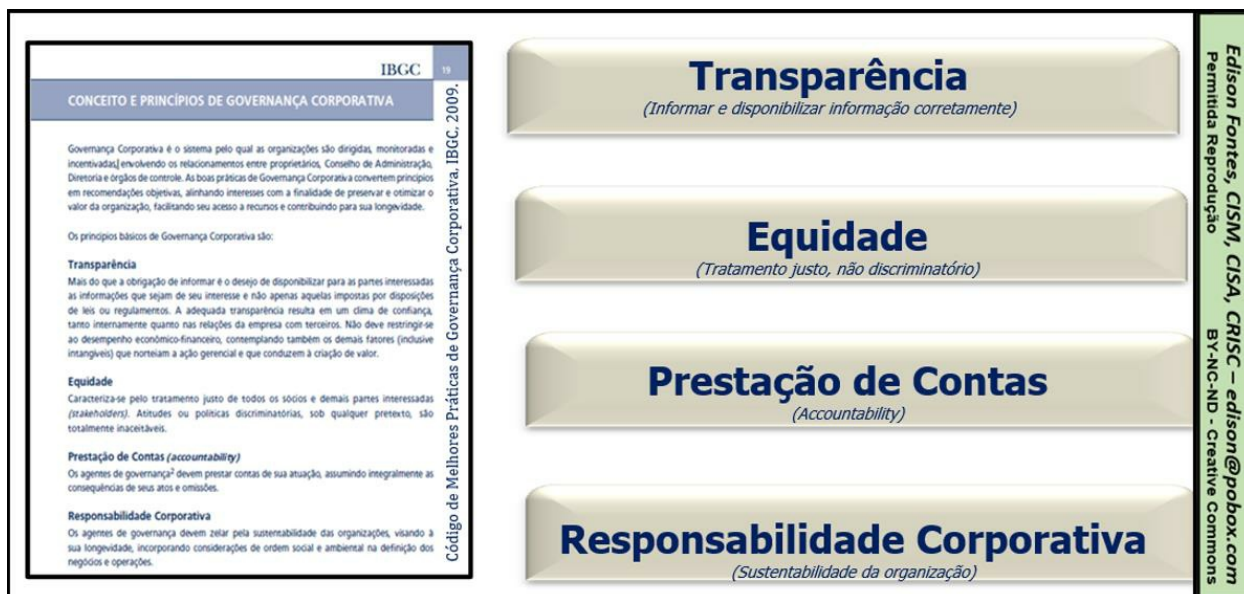
Definições Baseadas em:

- Normas ISO/IEC: 27001, 27002, 27014, 38500.
- Data Governance Board
- ISACA

Edison Fontes, CISM, CISA, CRISC – edison@pobox.com
BY-NC-ND - Creative Commons
Autorizado Compartilhamento

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

Estrutura Governança, Gestão, Controles de Proteção e Segurança

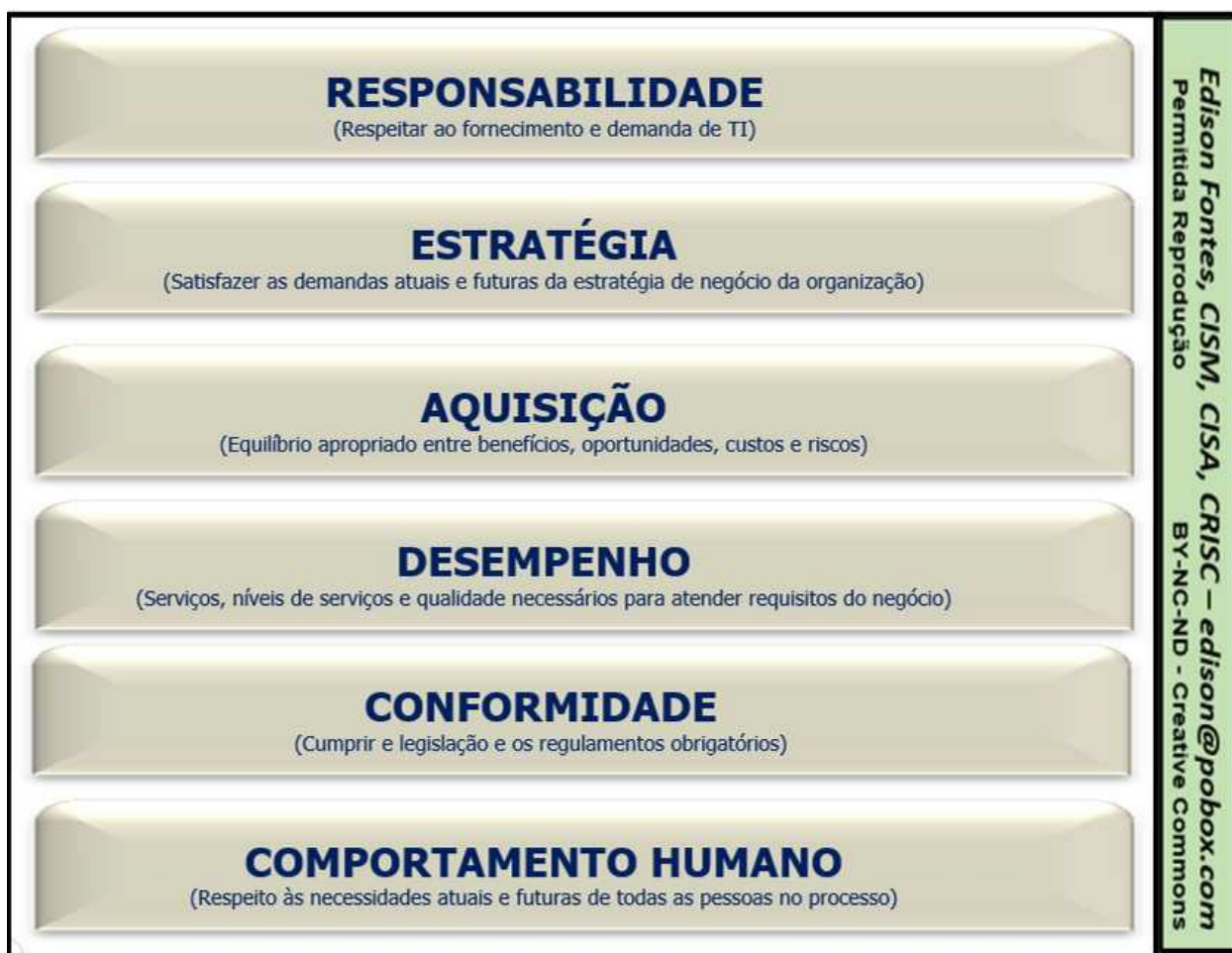


SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

Estrutura Governança Corporativa – Princípios

341

*Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com*

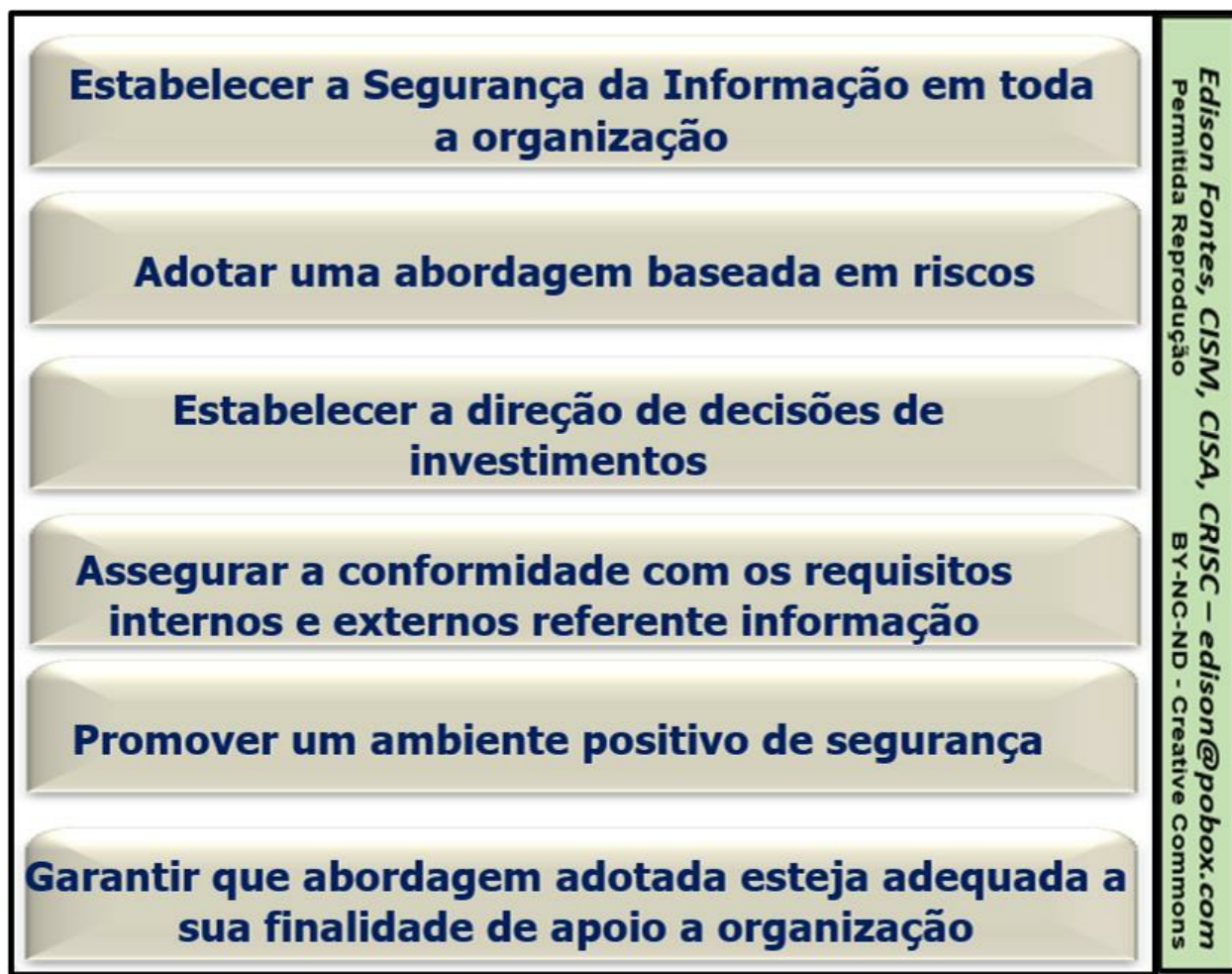


SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

Estrutura Governança da Tecnologia da Informação – Princípios

342

*Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com*



SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

Estrutura Governança da Segurança da Informação – Princípios

343

Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com



SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

Estrutura Governança da Segurança da Informação – Prática

LGPD - GESTÃO DE INCIDENTES – ELEMENTOS BÁSICOS NECESSÁRIOS PARA A EFETIVIDADE

Edison Fontes, CISM, CISA, CRIS, Ms, 2020, Brasil

ESCOPO

Indica qual a abrangência é considerada para a Gestão de Incidentes.

PRIORIDADE

Indica os níveis de urgência para o tratamento do incidente.

(Edison Fontes, CISM, CISA, CRISC, Ms., 2020, Brasil)

IMPACTO NO NEGÓCIO

Indica os níveis de impacto negativo para a organização em função da ocorrência de um incidente.

EXTENSÃO

Ambientes (interno, externo, mercado, outras empresas do grupo) que serão considerados na análise do impacto do mesmo.

TIPO

Indica o mérito, o motivador da ocorrência: erro, negligência, fraude interna, fraude externa, falha na manutenção do controle.

AMBIENTES

Ambiente original: indica onde ocorreu o incidente. Ambientes afetados: indica quais (ou qual) ambientes foram afetados.

RELACIONAMENTO COM GESTÃO PROBLEMAS

Identifica se o incidente registrado deve ser considerado pela Gestão de Problemas.

RESPONSABILIDADES

É necessário definir as responsabilidades em relação às atividades para a existência de uma boa Gestão de Incidentes.

COMUNICAÇÃO

Necessidade de comunicação com órgãos reguladores, mercado, clientes, matriz corporação e/ou acionistas.

REGULAMENTO

Política ou norma de Gestão de Incidentes aprovada pelo Corpo Diretivo.

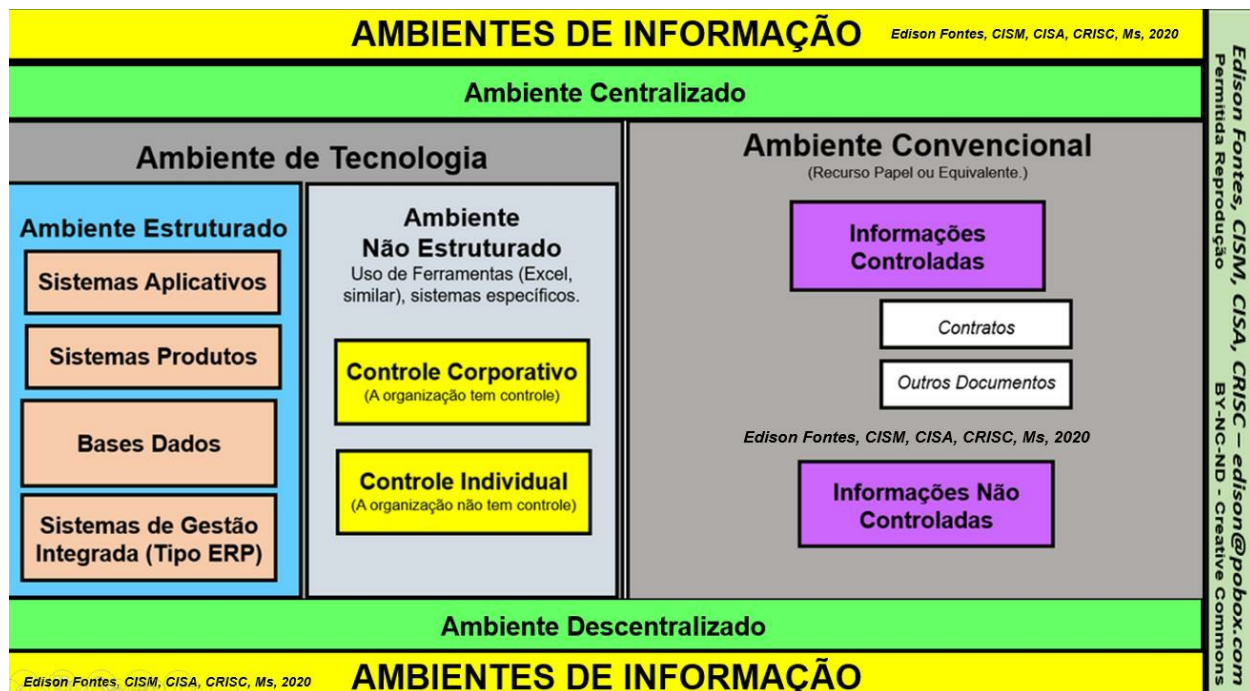
Edison Fontes, CISM, CISA, CRISC – edison@pobox.com
Permitida Reprodução
BY-NC-ND - Creative Commons

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA **(Edison Fontes)**

Estrutura Gestão de Incidentes – Elementos Básicos

345

Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com



SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

Estrutura Ambiente de Informação

347

*Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com*



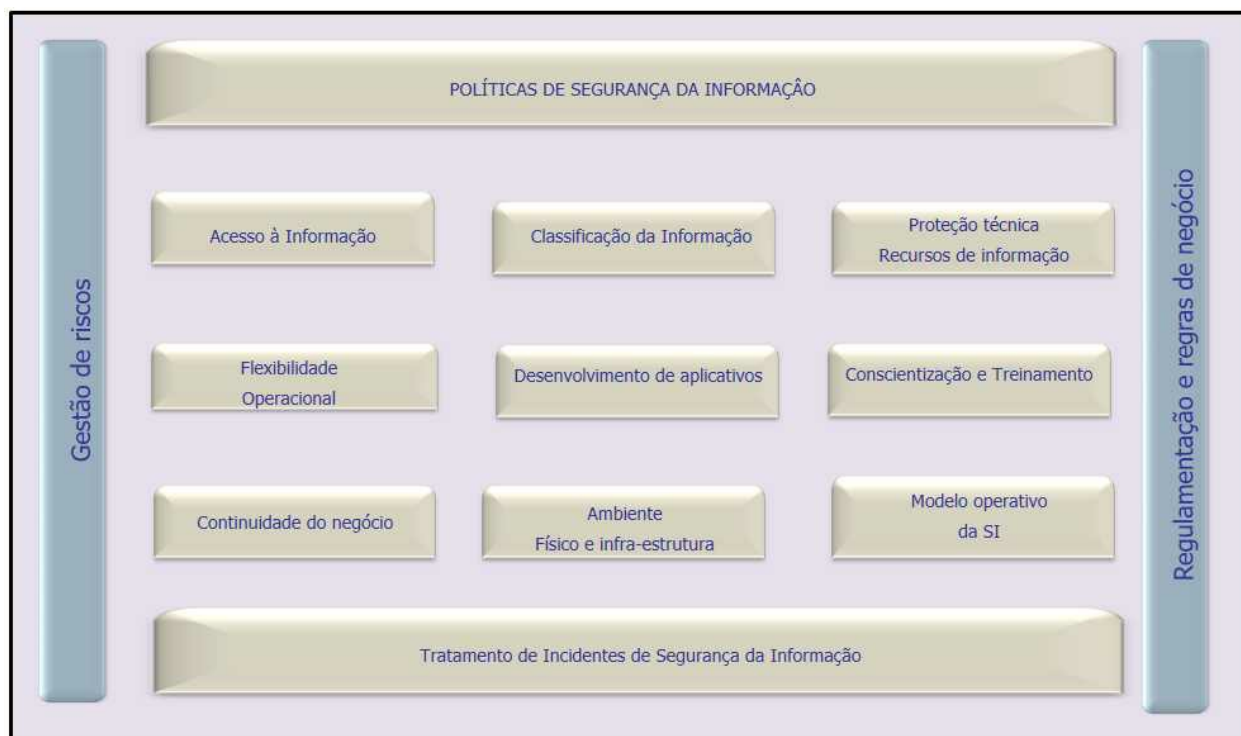
SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

Estrutura Segurança da Informação – Dados sob responsabilidade da organização



SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

Estrutura Acesso à Informação – Estrutura Básica



SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

Estrutura Programa Organizacional de Segurança da Informação

350

*Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com*



Edison Fontes, CISM, CISA, CRISC – edison@pobox.com
 BY-NC-ND - Creative Commons

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

Estrutura Controles Corporativos

351

Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com

CLASSIFICAÇÃO DA INFORMAÇÃO - ABORDAGENS

Estas abordagens conversam entre si, mas são independentes.

Edison Fontes, CISM, CISA, CRISC, Maio-2018

1. SIGILO DA INFORMAÇÃO

Considera o valor do segredo da informação para a organização. É a mais utilizada.

2. CRITICIDADE DE USO DA INFORMAÇÃO

Considera a dependência operacional que a organização possui da informação.

3. TRATAMENTO DADOS PESSOAIS

Considera a informação relativa à uma pessoa singular identificada ou identificável.

Comentários:

Uma informação pode ser crítica, mas pode não ter alto grau de sigilo.

Classificação da Informação ajuda, mas não faz controle de acesso de usuário individual.

Todas estas abordagens devem estar ligadas à realidade da organização, à maturidade em segurança da informação e à legislação que a organização está submetida.

Base: NBR 27002:2013, NBR 16167:2013, Regulamento GDPR (EU), Autor.

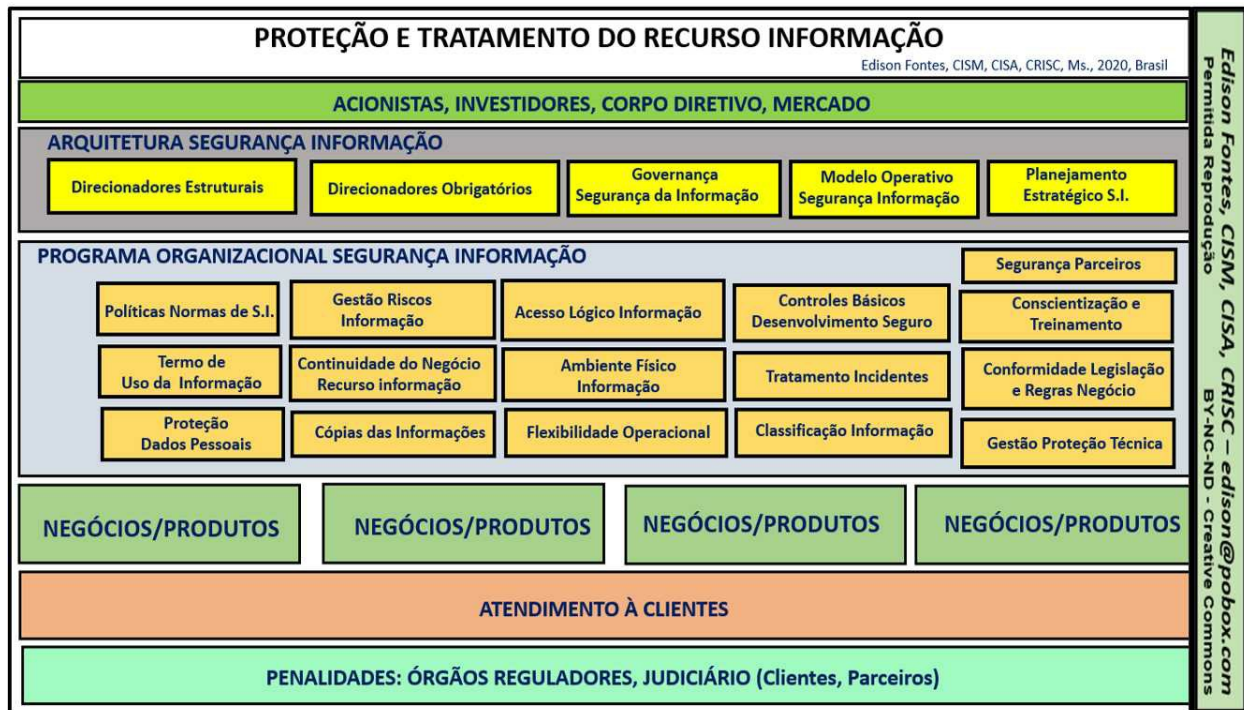
Este quadro pode ser compartilhado e divulgado de maneira não comercial e sem alterações.

BY-NC-ND - Creative Commons

SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA **(Edison Fontes)**

Estrutura Classificação da Informação – Abordagens

352



SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

Estrutura Proteção e Tratamento do Recurso Informação

353



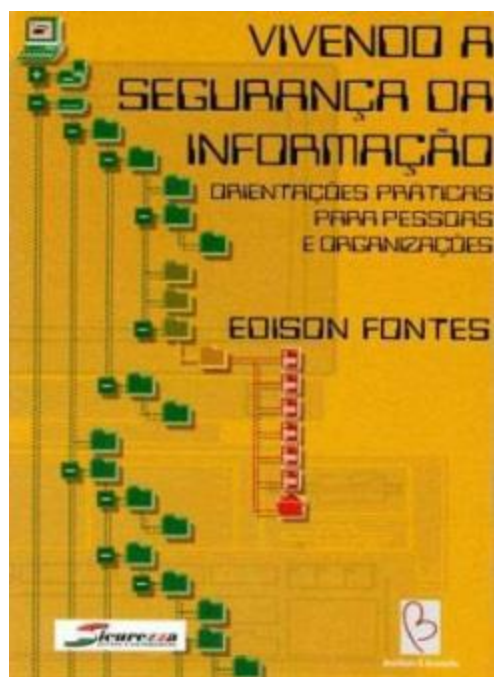
SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA (Edison Fontes)

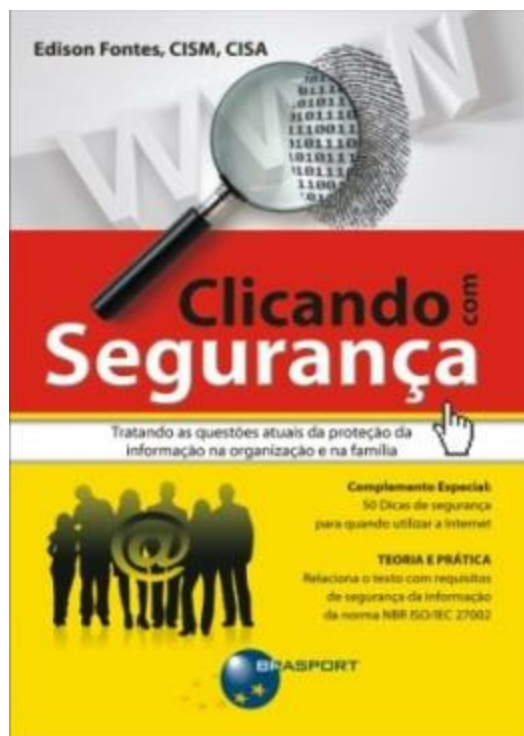
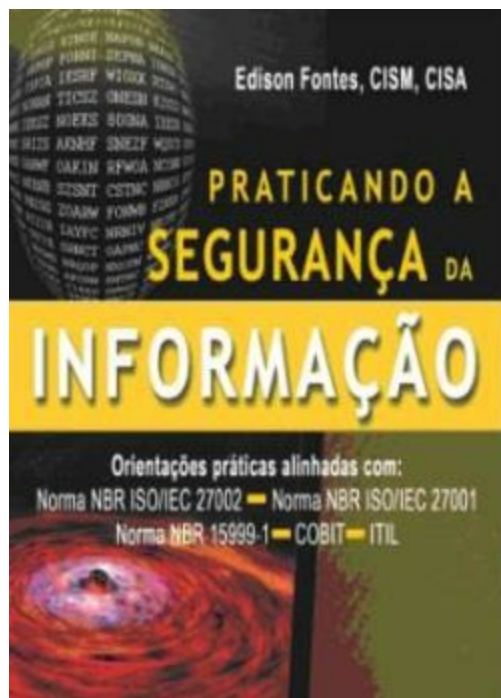
Estrutura Segurança da Informação e Controles LGPD

354

*Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com*









Escola
Superior
de Redes
RNP

Políticas de Segurança da Informação

Edison Luiz Gonçalves Fontes

COMO PROTEGER A INFORMAÇÃO?



SEGURANÇA DA INFORMAÇÃO

ORIENTAÇÕES PRÁTICAS

EDISON FONTES

PROF., MS, CISM, CISA, CRISC



ALINHADO COM NORMAS ISO/IEC 27000,
ITIL, COBIT, GOVERNANÇA

LIVROS PUBLICADOS PELO AUTOR



SEGURANÇA DA INFORMAÇÃO: GESTÃO E GOVERNANÇA
(Edison Fontes)

Edison Fontes

<https://www.linkedin.com/in/edison-fontes-897261/>

FIM DESTE LIVRO

356

***Segurança da Informação: Gestão e Governança - Copyright © 2020
Edison Fontes, edison@pobox.com***